LECTRA

Deliverable 1 - Parts A-F

REVIEW DRAFT / NOT READY FOR SUBMISSION

Theme 10: Review, Feedback, and Survey System. Context: feedback after individual lectures. Course: CPE334 Software Engineering.

67070501022 - Thanawat Suntarawattana

67070501060 - Songwit Rueangsawat

Repository: https://github.com/Maibokdaimhai/LECTRA

Working increment PR: https://github.com/Maibokdaimhai/LECTRA/pull/36

Observed candidate source: 1f7ae02083438fba066185e3823a68f77bde3aa0

Assessed main release/tag: **NOT AVAILABLE**. This draft contains complete embedded planning sources and selected actual candidate checks. It does not replace required human review, integrated release verification or final contributions. Source/code and separate report revisions are distinguished.

Known open boundaries: PR #35 integration; working increment teammate review/integration; complete STS dispositions; teammate setup reproduction; assessed main release and release-linked checks; final contribution confirmation.

Reading notes: wide Markdown tables are expanded into labelled records to preserve all cells legibly. Mermaid source is retained verbatim as code, with architectural/domain descriptions in the SDS. Unsupported non-BMP fixture characters are displayed as explicit Unicode escapes. No secrets, passwords, session cookies or real feedback are embedded.

Contents and page navigation

Part A - SRS and product scope 3

docs/srs.md . . . 4

docs/decisions.md . . . 16

docs/baseline-review.md . . . 23

Part B - Feature inventory and traceability 30

docs/features.md . . . 31

docs/traceability.md . . . 36

Part C - System-Level SDS 44

docs/system-sds.md . . . 45

docs/sprints/sprint-1/database-foundation.md . . . 70

Part D - Three-sprint plan and team workflow 73

docs/sprints/plan.md . . . 74

docs/sprints/sprint-1/workflow.md . . . 82

docs/sprints/sprint-1/tracker.md . . . 88

Part E - Feature contracts, AC, STS and Product DoD 95

docs/sprints/sprint-1/README.md . . . 96

docs/sprints/sprint-1/shared-contract.md . . . 100

docs/sprints/sprint-1/product-dod.md . . . 108

docs/sprints/sprint-1/f-01-authentication.md . . . 112

docs/sprints/sprint-1/f-01-authentication-sts.md . . . 125

docs/sprints/sprint-1/f-02-context-discovery.md . . . 136

docs/sprints/sprint-1/f-02-context-discovery-sts.md . . . 148

docs/sprints/sprint-1/f-03-survey-authoring.md . . . 157

docs/sprints/sprint-1/f-03-survey-authoring-sts.md . . . 173

docs/sprints/sprint-1/f-04-responses.md . . . 184

docs/sprints/sprint-1/f-04-responses-sts.md . . . 192

docs/sprints/sprint-1/f-05-results.md . . . 199

docs/sprints/sprint-1/f-05-results-sts.md . . . 212

Part F - Actual candidate evidence and remaining gates 221

docs/sprints/sprint-1/implementation-evidence.md . . . 222

README.md . . . 225

Part A - SRS and product scope

docs/srs.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - Software Requirements Specification

Version: 0.4 (2026-11-06). Status: consolidated planning draft with source-qualified review recommendations; not an approved or implemented baseline. Related issue: #1 (https://github.com/Maibokdaimhai/LECTRA/issues/1).

1. Sources and requirement authority

`group_work_specs_v1.pdf`**, Sections 5-8, Theme 10 on page 9**

Authority and use: Instructor requirements for the full-stack product, identity/access, survey domain, engineering process, and three sprints. The supplied master PDF is marked as a draft.

`project_deliverable_1_v1.pdf`**, Sections 2-4**

Authority and use: Instructor requirements for the Sprint 1 release, Parts A-F, and assessable evidence.

Project owner's instructions, including 2026-11-06 clarification

Authority and use: Team of two; LECTRA; lecture-feedback context selected under delegated scope discretion; React/Vite/TypeScript, Vitest, PostgreSQL, Prisma ORM, Playwright; permitted additions documented in the SDS.

Partner's proposal in `message-3.txt`

Authority and use: Input for discussion, not an instructor requirement or automatic authorization to expand scope.

Owner-supplied `LECTRA - Product Direction and Documentation Improvements`

Authority and use: Direction for this revision: explicit Course → Section → Lecture context, Sprint 2 Starter Questionnaire, and Sprint 3 Teaching Improvement Notes. Requested evaluation does not constitute teammate approval of every implementation detail.

Owner-supplied `Final Product Baseline Revision & PR Approval Preparation` **and subsequent clarification**

Authority and use: Confirmed PD-01 anonymous raw-text non-exposure, PD-02 simplified private notes, PD-03 single-dimension starter wording. Keep workload planning proportionate. Its earlier "four Suggestions" label/temporary deferral is superseded by the source correction below. The team manages all Git/PR operations itself.

Owner's later correction of review provenance

Authority and use: Section 8 Innovation Opportunities P10/P05/P14/P15 are attributed to the teammate's Comprehensive Review `Pasted text(20261106-090722).txt` in their ChatGPT conversation. The separate Initial Review has formal suggestion REV-08. The owner's supplied descriptions are available; complete original reports are not directly accessible or confirmed repository files. These recommendations are not instructor requirements.

IDs below describe LECTRA's proposed requirements. `I` means an instructor requirement or theme expectation; `T` means a team-specific design decision selected under the project owner's authorization. An `I + T` entry combines a required outcome with a team-selected realization. The exact thresholds, screens, stack, and feature count are not mandated by the instructor. Team review is still required before implementation contracts are accepted.

2. Problem, vision, and actors

LECTRA means **Lecture Evaluation, Classroom Thoughts, Reviews & Analytics**. Students need a structured way to report understanding, pacing, and unresolved questions after a lecture. Instructors need feedback soon enough to adjust the next lecture.

The primary unit is a **lecture within a section/offering of a course**, not a university-wide instructor-ranking or end-of-term evaluation program. Questions cover Course Content, Teaching Methods, Classroom Experience and General Suggestions without adding separate evaluation products. The instructor can record how they plan to act on feedback,

closing the loop between collection and teaching improvement.

The canonical relationship is `Course` → `Section` → `Lecture` → `Survey` → `Results`, with one optional Teaching Improvement Note attached to a Closed survey in Sprint 3. Results are derived from valid stored answers, not an independently editable evaluation record. Cross-lecture results describe feedback on compatible questions; they do not establish an instructor's overall quality or a causal measure of teaching effectiveness.

Course-level and instructor-level feedback evaluation remains in scope through authorized, compatible per-metric summaries across lectures in the instructor's own Sections. Show the contributing lecture/question counts, weighting, context and limitations. This is different from a universal instructor score or cross-owner ranking; lecture focus does not remove meaningful broader feedback analysis.

Survey Owner (instructor)

Responsibility: Own sections, create/publish/close their lecture surveys, inspect authorized results, use a starter questionnaire, and maintain their private improvement notes.

Respondent (student)

Responsibility: Access eligible surveys, submit a valid response, and inspect their own participation status.

One account has one role. Each section has one instructor owner; a Course is academic context, not a permission boundary. Two instructors can own different sections of the same Course without gaining access to each other's surveys. Each lecture has at most one survey in the baseline. No staff administrator role or ownership delegation is included. Seed operators are setup responsibilities, not an application role with privileged answer access.

Domain glossary

Course

Definition and boundary: Stable academic context such as course code/title; can have multiple offerings. Not a survey or permission grant.

Section / offering

Definition and boundary: A Course taught in a specific term and section code, with one owner and enrolled members. `Classroom` in earlier drafts meant this entity; no separate physical-room model is introduced.

Lecture

Definition and boundary: A dated teaching session in a Section; the unit evaluated by one survey. A room/location is not required.

Survey Owner

Definition and boundary: Application role for the instructor responsible for a Section and its surveys; no access inherited merely by sharing a Course.

Eligibility

Definition and boundary: Permission to answer one survey, snapshotted from a selected set of enrolled respondents at publication.

Participation

Definition and boundary: Whether an eligible account has submitted; distinct from answer content, particularly in anonymous mode.

Response bundle

Definition and boundary: One atomic set of answers to a survey. Identified bundles link to their student; anonymous bundles do not.

Starter Questionnaire

Definition and boundary: Versioned, seeded set of question definitions copied into a new Draft; not a live link to historical survey questions.

Question lineage / metric definition

Definition and boundary: Source/version provenance and an exact measurement definition used to decide whether two rating questions are comparable. A matching category/title alone is insufficient.

Teaching Improvement Note

Definition and boundary: One owner-private issue/action record per accessible Closed survey, with a simple Planned/Applied status; no reflection field, detailed workflow, public response or proof of effectiveness.

3. Scope and exclusions

Whole-product scope

Authentication; seeded Courses, Sections, lectures and memberships; survey lifecycle; configurable questions; eligibility; one submission per eligible student; identified and anonymous modes; participation status; aggregate analysis; owner-visible text feedback under the stated policy; versioned Starter Questionnaire and independent survey copies; aggregate CSV export; owned lecture history/compatible trends; owner-private Teaching Improvement Notes; delivery, UAT and maintenance responsibilities.

Sprint 1 scope

Identified surveys; rating and text questions; manual publication and closing; eligibility snapshot from seeded Section membership; immutable published structure; one immutable submission per student; own identified response retrieval; aggregate count/mean/distribution and text feedback visible to the owner after closing. Courses/Sections/lectures are seeded read-only context, not administration screens. No template or note workflow is required in Sprint 1. See features (features.md) for allocation.

Explicit exclusions

Attendance, grades, homework, LMS workflows, university integrations, registration/recovery/verification flows, SSO, co-teaching, delegated staff access, instructor rankings, cross-instructor dashboards, notifications, scheduled opening/closing, AI text analysis, PDF data export, discussions, template-authoring administration and student-visible improvement notes. Product demonstration data is synthetic. CSV export, anonymous mode, the Starter Questionnaire and private improvement notes remain in scope. Shared notes are a deferred proposal requiring explicit scope/privacy agreement, not an implemented toggle.

4. Functional requirements

FR-01

Requirement: Users can log in, retrieve their current identity and role, and log out using a documented server-side session lifecycle.

Origin: I

FR-02

Requirement: Instructors can navigate seeded Course → owned Section → Lecture contexts; students can discover only Published or Closed surveys in their eligibility snapshot. Sharing a Course grants no access to another Section.

Origin: I + T

FR-03

Requirement: An instructor can create and edit a Draft survey and its ordered rating/text questions for an owned lecture.

Origin: I + T

FR-04

Requirement: The owner can publish a valid Draft and close a Published survey. The UI shows the resulting persisted state.

Origin: I + T

FR-05

Requirement: An eligible student can submit a complete validated response to a Published survey and receive a persisted confirmation.

Origin: I

FR-06

Requirement: A student can retrieve their own submission status, including after logout/login. For identified surveys, they can reopen their own submitted answers. Anonymous surveys expose status only.

Origin: I + T

FR-07

Requirement: A survey owner can view response count and authorized per-question quantitative results. Individual text responses without respondent labels are available only for identified surveys after closure; anonymous raw text is never exposed to owners through any result surface. Owners cannot retrieve respondent-linked answers.

Origin: I + T

FR-08

Requirement: The owner can select identified or anonymous mode before publication. Anonymous submission separates participation identity from stored answers, suppresses raw text and applies question-level quantitative privacy controls under a documented/tested design. Anonymous text collection/storage is an explicit pre-F-06 decision, not implicitly enabled.

Origin: I + T

FR-09

Requirement: The owner can add single-choice questions, duplicate an owned survey into a new Draft for another owned lecture without a survey, and select an eligible subset of Section members before publication.

Origin: T

FR-10

Requirement: The owner can export authorized aggregate results as CSV, observing the same privacy and visibility rules as result APIs.

Origin: I + T

FR-11

Requirement: The owner can filter history by Course, Section, lecture date and state, inspect compatible Closed-lecture trends, and evaluate Course/own-instructor feedback through labelled per-metric summaries of visible questions. No cross-owner access, pooling of hidden data or universal instructor ranking is allowed.

Origin: T

FR-12

Requirement: Setup can reproduce synthetic accounts, Courses, Sections, membership and lectures, and initialize/version the database without real secrets. Later seeds also reproduce the versioned Starter Questionnaire and note/trend test contexts.

Origin: I + T

FR-13

Requirement: In Sprint 2, an owner can preview a published Starter Questionnaire version and copy it into a new Draft for an owned lecture, then edit/add/remove/reorder questions and required flags before publication without changing the source or other surveys.

Origin: T

FR-14

Requirement: In Sprint 3, the owner can create, retrieve and edit one private Teaching Improvement Note per Closed survey with available results, recording interpreted issues, planned actions and Planned/Applied status. Students and other owners cannot access it.

Origin: T

5. Business rules

BR-01

Observable rule: Protected operations require an authenticated server-resolved identity; client-supplied role/owner/student IDs never grant permission.

Origin: I

BR-02

Observable rule: Respondents cannot manage surveys or inspect another student's answers. Owners cannot access/manage another owner's surveys/results.

Origin: I

BR-03

Observable rule: A student's eligibility is frozen from the selected Section-member set at publication. Later membership changes do not silently modify that survey's eligibility.

Origin: I + T

BR-04

Observable rule: Valid transitions are Draft → Published → Closed. No reopening is supported. Respondents cannot discover Draft content.

Origin: I + T

BR-05

Observable rule: Only Published surveys accept responses. Publication requires 1-10 valid questions including at least one rating or single-choice question, a nonblank title, and at least one eligible student.

Origin: I + T

BR-06

Observable rule: Each eligible student can submit at most once per survey, including concurrent requests. A rejected duplicate creates no second response.

Origin: I + T

BR-07

Observable rule: Required answers must be present; required text must contain non-whitespace content. Ratings are integers 1-5. Text is at most 2,000 Unicode code points. Unknown, duplicate or wrong-survey question IDs and wrong-type answers are rejected. A submission must contain at least one nonempty valid answer even if all questions are optional.

Origin: I + T

BR-08

Observable rule: A response is atomic: either participation and all valid answers commit, or no part is retained.

Origin: T

BR-09

Observable rule: Question structure/order, required flags, eligibility and privacy mode are immutable after publication. A new evaluation requires a new survey for another lecture or an explicit future approved scope change.

Origin: T

BR-10

Observable rule: Submitted answers cannot be edited, withdrawn or resubmitted in the baseline. Drafts may be deleted; Published/Closed surveys and submitted responses are not hard-deleted through the application.

Origin: T

BR-11

Observable rule: Closing and submitting have a database-defined order. If closing acquires the survey transaction lock and commits first, the submission is rejected; if a submission commits first, it is included in the closed survey.

Origin: T

BR-12

Observable rule: The mean uses answered ratings for that question only, excludes missing optional answers, and displays two decimal places. No answers produces a null mean and an explicit no-data state, not zero. Distribution includes counts for each score 1-5.

Origin: T

BR-13

Observable rule: While Published, the owner sees only the survey response count. After closure, identified results have no minimum-count suppression. For anonymous data, raw text is never owner-visible and each quantitative question independently requires at least five valid nonempty answers; a proposed sparse-distribution guard additionally requires every nonzero rating/option bin to contain at least three answers. Otherwise suppress that question's entire numeric result, including its mean, distribution and answered count, across UI/API/export/analytics. A survey-level count of five does not release a sparsely answered question or guarantee anonymity.

Origin: T

BR-14

Observable rule: Before answering, students see the privacy mode and a truthful disclosure. Identified answers remain linked to the account in storage even though the owner UI/API omits the link. Anonymous mode must not be advertised or enabled until its design and verification are accepted.

Origin: I + T

BR-15

Observable rule: Anonymous participation records cannot store an answer-bundle ID, and answer records cannot store user/eligibility/session IDs or precise per-submission timestamps. Logs and exports must not reintroduce an application-visible join. Remaining infrastructure/backup risks are disclosed.

Origin: I + T

BR-16

Observable rule: Aggregate CSV excludes names, account IDs, participation lists, individual answers, text comments and private notes. Text feedback is readable only for identified surveys in the authorized results view. Anonymous raw text is omitted from every owner API, UI, CSV and analytics path regardless of response count. Single-choice summaries report option counts, not a numeric mean, subject to BR-13.

Origin: T

BR-17

Observable rule: Applying a starter or copying a survey creates new Survey/Question/Option IDs in one transaction from one consistent source version/revision, copying definitions only with provenance. A concurrent change to an expected mutable source revision causes a conflict rather than a mixed copy. No eligibility snapshot, participation, response, result or note is copied; source changes never update copies.

Origin: T

BR-18

Observable rule: Cross-lecture rating comparisons require the same immutable metric-definition version, question meaning/type, 1-5 anchors and interpretation. Editing the measured wording/type/anchors clears inherited comparability. Shared category, template origin or owner-entered title alone is insufficient.

Origin: T

BR-19

Observable rule: Trends/summaries include only owned, compatible Closed-survey question results already releasable under BR-13. Show per-lecture counts where permitted. Course/own-instructor summaries are per metric and response mode, with answer-weighted sum/count, contributing-lecture count and context labels; repeated students across lectures are answer observations, not unique people. Never pool hidden questions, infer anonymous text or compute an unlabelled mean of means.

Origin: T

BR-20

Observable rule: Notes may be created only for an owned Closed survey with accessible results; an anonymous survey requires at least one releasable quantitative question. Enforce one private note per survey under concurrent creates. No respondent, other owner, CSV export or analytics payload receives note content.

Origin: T

BR-21

Observable rule: A note has required issue summary and planned improvement, each 1-2,000 Unicode code points after trimming, and Planned/Applied status. Default to Planned; either valid status can be selected on edit without reflection, reversal reason or workflow prerequisites. Keep createdAt, updatedAt and current appliedAt only; Applied is the instructor's recorded status, not proof of effectiveness.

Origin: T

BR-22

Observable rule: Note updates use an integer revision precondition; stale edits conflict rather than overwrite. Update note/status/timestamps and revision atomically. No detailed status-history entity, transition audit or automatic raw-feedback copy is included. Survey data/results remain unchanged.

Origin: T

BR-23

Observable rule: A survey must belong to a lecture in the owner's Section; one survey per lecture is enforced even under concurrent creation/copy requests. Starter availability and note completion never gate the core Sprint 1 publish/answer workflow.

Origin: T

Optional blank text is normalized to no answer; omitted optional questions are excluded from that question's answered denominator. Omit unanswered optional fields rather than submitting a fabricated score or empty typed value. The response count counts submitted students, not answer rows. Draft titles are limited to 120 and question prompts to 500 Unicode code points. Single-choice has 2-6 nonblank, distinct option labels of up to 120 code points and exactly one selected option when answered. A survey requires at least one rating or single-choice question to support a numeric/count summary. Survey limits and privacy thresholds are team choices, not instructor-specified values.

F-04 request sizing must accommodate bounded escaped JSON as well as UTF-8: at most ten answers, 2,000 Unicode code points per text answer and a proposed 256 KiB encoded-body ceiling. Ten texts encoded as surrogate-pair escapes require up to 240,000 bytes before a bounded envelope. Enforce decoded answer/count limits independently and reject oversized bodies before persistence. Arbitrarily padded or unusually escaped JSON can still exceed the transport limit; the baseline does not promise to accept every serialization of the same values. Issue #5 finalizes the exact envelope, parser settings and boundary cases (BASE-03).

State and workflow boundaries

Draft

Owner operations: Read/edit/delete; publish after validation; choose starter only when creating a new Draft.

Respondent operations: Cannot discover/read/answer.

Results / notes: No results or notes.

Published

Owner operations: Read frozen structure; close manually.

Respondent operations: Eligible: read, submit once, inspect own status/identified answers.

Results / notes: Owner count only; no text/rating results, exports or notes.

Closed

Owner operations: Read; no reopen, edit-structure or delete.

Respondent operations: Eligible: read frozen questionnaire, own status/identified answers; cannot submit.

Results / notes: Owner results subject to privacy threshold; export S2; private note S3 when results visible.

Normal paths must persist through UI → API → PostgreSQL; role rejection, invalid transitions and concurrency failures leave authoritative data unchanged. A successful browser message alone is not proof of completion.

Starter Questionnaire working content (Sprint 2)

One seeded starter, `lecture-feedback`, version `1`, is sufficient. It is an application-provided starting point, not a university-validated psychometric instrument or mandatory survey. Owners may create a blank Draft instead.

Course Content

Initial question: How clear was the content presented in this lecture?

Type / required: Rating / required

Scale meaning: 1 Not clear → 5 Very clear; clarity of lecture content only.

Teaching Methods

Initial question: How effective were the instructor's explanations?

Type / required: Rating / required

Scale meaning: 1 Not effective → 5 Very effective; effectiveness of explanations only.

Classroom Experience

Initial question: How suitable was the learning environment for this lecture?

Type / required: Rating / optional

Scale meaning: 1 Not suitable → 5 Very suitable; learning environment only.

General Suggestions

Initial question: What is one thing that could be improved in a future lecture?

Type / required: Text / optional in identified surveys

Scale meaning: No numeric score. Anonymous collection remains OPEN-04.

This content is a team design starting point. Required-flag changes are permitted before publication but affect response completeness and must be shown with trend denominators. A pacing question, if authored, must explain whether 1/5 mean slow/fast or unsuitable/suitable; higher is not automatically better.

6. Non-functional requirements and verification targets

Targets below are selected for this project and remain unverified until execution evidence exists.

NFR-01

Target: Every protected operation rejects unauthenticated requests and unauthorized role/ownership access without private data; no plaintext passwords in storage or logs.

Verification and sprint: API/database access matrix tests and credential-storage inspection, Sprint 1; extend/regress each sprint.

NFR-02

Target: No committed survey/answer is lost across application restart. Concurrent duplicate submissions produce exactly one stored response; close/submit follows BR-11.

Verification and sprint: Real PostgreSQL integration tests and restart retrieval, Sprint 1; redeployment persistence in Lab 5.

NFR-03

Target: A fresh checkout with documented prerequisites can migrate, seed, build and run using documented commands and example configuration; no real secret is committed.

Verification and sprint: Teammate reproduction on a clean database and secret/configuration review, Sprint 1; Docker/CI/GCP reproduction in Lab 5.

NFR-04

Target: For 30 concurrent synthetic users with 10-question surveys and 1,000 stored responses, summary reads and submissions have p95 ≤ 1 second excluding network transit and password hashing, with no unexpected server errors.

Verification and sprint: Repeatable load run recording hardware, dataset and command, Sprint 3. This is a planning target, not a measured claim.

NFR-05

Target: Every Sprint 1 AC maps to a planned test/check and actual result; important logic has unit tests, persistence/access has real integration tests, and critical journeys have selected E2E tests.

Verification and sprint: Contract/traceability audit plus recorded release test runs, Sprint 1 onward. No invented coverage percentage.

NFR-06

Target: Anonymous owner-facing UI/API/CSV/analytics expose no raw text, identity-answer join or suppressed question statistics. Independently verify question-answer threshold, optional/sparse responses and distribution/complement risks; survey count is not sufficient.

Verification and sprint: Privacy design review, schema/log/projection/export tests and adversarial small-group cases, Sprint 2; regression in Sprint 3. No anonymity guarantee against infrastructure observation or external knowledge.

NFR-07

Target: Core login, create/publish, respond and summary journeys work using keyboard navigation at 360px and 1280px viewport widths, with associated field labels and visible validation/error states.

Verification and sprint: Selected UI/E2E plus documented manual checks, Sprint 1 basic journeys; regression Sprint 3.

NFR-08

Target: Release evidence identifies the tested commit, command, pass/fail/skip counts and relevant test names; accepted releases follow teammate-reviewed staging and main PRs.

Verification and sprint: Evidence audit Sprint 1; required CI quality gates, Docker and repeatable GCP release delivery in Lab 5 and maintained afterward.

NFR-09

Target: A template revision or customization of one Draft cannot change another survey's persisted questions/options/answers. Owners may still customize that Draft before publication; published snapshots remain immutable. Note writes do not alter survey/results, and concurrent note edits cannot silently overwrite.

Verification and sprint: Real DB copy-isolation and note revision/uniqueness/transaction tests, Sprint 2 and Sprint 3 respectively.

7. Privacy policy for this baseline

Sprint 1 is identified. Students may reopen their own answers; owners receive no identity-linked response endpoint or list of who submitted. Owners can read individual text responses after closure without names, IDs or submission timestamps. Text can still identify its author through its contents, and a small class can make aggregate feedback identifiable. The disclosure must explain this; omitting names is not anonymous mode.

Anonymous mode protects against Survey Owners and ordinary application users. The current planned boundary does not claim resistance to a database/infrastructure operator observing transactions, request timing or backups. Authentication still controls eligibility and participation without attaching identity to the answer bundle. Detailed linkability controls and residual risks are a blocking design gate before F-06 implementation. No per-user receipt identifier is a join to an anonymous answer bundle; own status must not recover the answers.

Text feedback is untrusted plain text. Owners must not paste identifying student details or verbatim sensitive feedback into improvement notes. The initial note feature is private; it does not publish student feedback or communicate with students. Shared visibility is a proposal, not a confirmed requirement. Adding it would require redaction rules, audience/eligibility policy, independent student-visible content and tests, and an explicit scope decision. Notes can be entered manually; no AI analysis or automatic quote transfer is included.

PD-01 is confirmed: anonymous raw text is never disclosed to Survey Owners, even at high counts. This applies to direct responses, comments lists, CSV, analytics, previews and indirect note prefill. The exact collection/storage policy is still open:

Disable text in anonymous MVP

Value / trade-off: Recommended simpler option: avoids collecting data the owner cannot use and reduces sensitive storage. The four-category starter must warn about its text question; require explicit removal/conversion before anonymous publication, never silently drop required content.

Required agreement before F-06: Team explicitly accepts text prohibition, author/respondent messages and backend rejection tests.

Collect but never expose text to owners

Value / trade-off: Preserves a potential future use but adds storage/retention/access obligations without current owner value. No raw text in any owner payload or log; inaccessible does not mean deleted or anonymous by itself.

Required agreement before F-06: Team defines a purpose, retention/deletion policy, storage access boundary and tests; no hidden administrator viewer is added by assumption.

Neither option is silently selected by this document. Anonymous publication/collection must remain disabled until OPEN-04 resolves the choice explicitly. Identified text remains in Sprint 1 unchanged. Quantitative privacy controls remain necessary whichever text policy is selected.

For each anonymous rating or choice question, the working threshold is **five valid answered responses**, independently of survey participation. Additionally propose a **minimum nonzero bin count of three**; if it fails, hide the entire question's numeric projection rather than exposing complementary cells or the mean. Return only question metadata and a generic suppression label for hidden questions, not its exact answered count. Finalize/validate this practical guard in the F-06 contract; it is a project choice, not an instructor mandate or mathematical anonymity guarantee. Do not offer response-subgroup filtering, arbitrary participant slices or cross-question joins.

Result counts are not grade/attendance measures. Broader Course/own-instructor feedback uses visible compatible per-metric observations, never another owner's Section or suppressed data. External knowledge, unanimous responses and repeated observations can still enable inference; explain these limits rather than promising anonymity based on one threshold.

Synthetic data only will be used for course demonstrations. No real student deployment is authorized by this document. Automated retention/deletion, account erasure and backup purging are not promised by the baseline; a real-data rollout would require an approved policy and implemented verification first.

8. Assumptions, decisions, and change control

See decision log (decisions.md) for rationale and open decisions. Both students must review this draft and record actual review evidence. Later changes must update affected requirements, features, contracts and tests rather than silently shrinking scope.

No implementation, passing test, deployment, teammate approval or completion of Issue #1 is claimed by this document.

9. Use cases, limitations and implementation readiness

Owner creates and publishes lecture survey

Expected boundary: Select owned Course/Section/Lecture; validate Draft; publication freezes definitions and eligible members.

Features: F-01-03

Student answers and returns later

Expected boundary: Resolve identity on server; eligibility/state/answer validation; commit once; persisted own record is retrievable in identified mode.

Features: F-01-04

Owner reviews a Closed survey

Expected boundary: Correct aggregate denominators and privacy; no respondent-linked records; no access to another Section owner.

Features: F-05

Owner starts from questionnaire

Expected boundary: Preview version; copy definitions to a new owned Draft; customize without modifying source or historical surveys.

Features: F-07

Owner reviews compatible lectures

Expected boundary: Closed visible own surveys only; comparable metrics and denominators; no ranking or pooling hidden results.

Features: F-09

Owner records improvement

Expected boundary: Accessible Closed results; one private issue/action note, simple status/essential timestamps and optimistic edits; no student disclosure/history workflow.

Features: F-10

Unverified assumptions: synthetic demonstration only, stable seeded membership/account set, one owner per Section, one survey per lecture, no owner transfer or grading policy, and sufficient time for the bounded roadmap. Operational database-admin access is outside ordinary application roles and the anonymous threat boundary. Resolve changing course notices and resource access with instructor/TA when applicable.

Before implementation: review this product baseline, assign real student responsibilities, version the relevant feature design/UI/API/data contract and AC/STS/DoD, then implement meaningful rules with TDD. Later-sprint contract details may remain open until their implementation gate; missing runtime evidence must remain explicit. See baseline review (baseline-review.md) for the documentation audit and remaining gates.

Review recommendations are individually dispositioned without automatically becoming new requirements: Keep P10 categorized starter and P05 consistent-question series within existing F-07/F-09; Simplify P14 to private F-10 and defer optional sharing; Incorporate P15 as bounded usability evaluation in SYS-04/S3 supporting existing user goals. No new product feature, quantitative NFR or instructor obligation is created. REV-08 is a separate process recommendation to make decisions/rationale/gates explicit before contracts. Full original-report verification remains OPEN-11; no claim of directly

reading the teammate's report is made.

docs/decisions.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - Decision Log

Version: 0.5 (2026-11-06). Status: consolidated planning draft with corrected review provenance; actual teammate review is pending. The owner explicitly authorized commit/push of this revision to the existing PR branch.

`Owner direction` is explicitly requested product intent. `Selected` is a working design selected under the owner's delegation and still requiring substantive team review. `Deferred proposal` is not in the implementation baseline. `Open gate` requires a named resolution before its dependent work. None of these means a teammate approved the PR or an implementation was verified. Instructor mandates are distinguished in the SRS source/origin tables; the decisions below are project choices.

DEC-01

Status: Owner direction

Decision and rationale: Focus on feedback after each lecture; reaffirmed in the product-direction attachment. Content/teaching/classroom/general-suggestion questions are categories, not separate evaluation products. Individual lecture results are not complete instructor evaluations.

DEC-02

Status: Selected

Decision and rationale: Instructor and student roles; one owner per Section; no delegated staff access or multi-role accounts. Course is shared academic context and grants no cross-Section owner permissions. Use seeded contexts/accounts to avoid administration scope.

DEC-03

Status: Selected

Decision and rationale: Keep React, Vite, TypeScript, Vitest, PostgreSQL, Prisma ORM and Playwright from the team's stated experience. Add Node.js/Express, express-session/connect-pg-simple, Argon2, Zod and Supertest for missing backend responsibilities. Exact compatible versions are selected and locked during authorized setup.

DEC-04

Status: Selected

Decision and rationale: Modular monolith with one API and one PostgreSQL database; same-origin browser/API delivery. Microservices and separate staging infrastructure are unnecessary for this scope.

DEC-05

Status: Selected

Decision and rationale: Draft → Published → Closed; manual close, no reopen; freeze structure/mode/eligibility after publication; no submitted-answer editing.

DEC-06

Status: Selected

Decision and rationale: Sprint 1 uses identified rating/text surveys. Owners see count during collection and results after closure, including text without identity labels. Students can reopen only their own identified answers. This remains identified data in storage.

DEC-07

Status: Selected

Decision and rationale: Freeze eligibility at publication from Section members. Enforce unique participation and atomic response writes in PostgreSQL; serialize Draft mutations, publication, closing and submission on the survey row where applicable.

DEC-08

Status: Superseded in part by PD-01 / DEC-19

Decision and rationale: Anonymous mode remains S2 with identity/answer separation and owner/application-user threat boundary. Replace the old survey-level five-response release rule and anonymous text visibility with per-question privacy and an unconditional raw-text prohibition. No infrastructure anonymity guarantee.

DEC-09

Status: Selected

Decision and rationale: CSV aggregate export only; no raw-answer/text export. Single-choice, duplicate-to-Draft and eligible-subset controls are bounded Sprint 2 expansion. No instructor ranking, scheduling or AI insights.

DEC-10

Status: Selected

Decision and rationale: Survey limit 1-10 questions; ratings integer 1-5; text ≤ 2,000 code points; title ≤ 120 and prompt ≤ 500. Required text rejects whitespace-only input. These limits keep validation and tests finite.

DEC-11

Status: Scoped renewed owner authorization

Decision and rationale: Git/PR management defaults to the team under the final revision request. The owner's later explicit instruction authorizes the assistant to commit/push this consolidated revision on `docs/1-4-product-baseline` for PR #7. This does not authorize merge, human review impersonation or unrelated Git/PR actions.

DEC-12

Status: Owner direction

Decision and rationale: Model Course → Section/offering → Lecture → Survey → derived Results explicitly. Replace the ambiguous Classroom entity in planning only; no production migration is claimed. F-02 remains seeded/read-only context in S1.

DEC-13

Status: Owner direction / selected realization

Decision and rationale: Add the Starter Questionnaire in F-07/Sprint 2 with four content categories. Realization: one seeded immutable versioned catalog, independent question/option copies into new Drafts, no template administration UI or live propagation.

DEC-14

Status: Owner direction; simplified by PD-02

Decision and rationale: F-10 remains S3, private and one-per-survey. Retain issue/action, Planned/Applied, essential timestamps and revision protection. Remove reflection prerequisites, reversal reasons and detailed history. No S1 expansion.

DEC-15

Status: Deferred proposal

Decision and rationale: Shared improvement notes are not included initially. A shared view would need a separately reviewable public summary, eligible audience, redaction/publication/retraction and tests. Private notes do not yet communicate improvements to students.

DEC-16

Status: Selected

Decision and rationale: Compatible-rating trends use immutable matching metric meaning/type/anchors; provenance alone is insufficient. Permit labelled per-metric Course/own-instructor summaries from visible observations, weighted by answer count and separated by mode/context. No hidden inputs, unlabelled mean-of-means or universal ranking.

DEC-17

Status: Selected

Decision and rationale: Reuse existing Draft editor, results/privacy policy and Closed-results page for starter/notes to limit complexity. No AI, notification, discussion, additional role or external integration is introduced.

DEC-18

Status: Selected

Decision and rationale: Append FR-13-14, BR-17-23 and NFR-09; preserve all previous requirement IDs and F-01-09. Review new source/copy/concurrency/privacy cases rather than silently replacing old requirements.

DEC-19 / PD-01

Status: Confirmed team direction

Decision and rationale: Raw anonymous text is never exposed to Survey Owners via UI/API/CSV/analytics/notes. Text collection versus prohibition remains explicitly undecided until team agreement before F-06. Recommend disable-text for simplicity; do not implement that recommendation as confirmed.

DEC-20 / PD-02

Status: Confirmed team direction

Decision and rationale: Simplify F-10 as described in DEC-14. Planned/Applied is an editable status, not a separate audited workflow. Keep unique survey note and optimistic revision checks.

DEC-21 / PD-03

Status: Confirmed team direction; wording is selected draft

Decision and rationale: Four-category starter in F-07/S2; each rating measures one dimension. Working prompts address content clarity, explanation effectiveness and environment suitability separately; one optional identified-text suggestion. Preserve editable independent versioned copies.

DEC-22

Status: Selected working policy, to validate in F-06

Decision and rationale: Anonymous quantitative release requires at least five answered responses per question; propose minimum nonzero bin count three and suppress the whole numeric projection on failure. Survey count alone is insufficient; these values are project policy, not anonymity guarantees.

DEC-23

Status: Selected contract direction

Decision and rationale: Replace 128 KiB with proposed 256 KiB for F-04 to accommodate bounded surrogate-escaped JSON plus an envelope. Issue #5 must finalize byte/decoded/count/parser/compression limits and test the encoding variants before code.

DEC-24

Status: Owner clarification; review-item deferral superseded by DEC-25

Decision and rationale: Keep BASE-01 planning proportionate without private schedules; capacity/ownership remains unconfirmed until Issue #5. The earlier deferral of four unidentified items is superseded by the owner's P-ID/source clarification; do not retain the incorrect "four formal Suggestions" classification.

DEC-25

Status: Owner-supplied source clarification

Decision and rationale: The four items are Section 8 Innovation Opportunities P10/P05/P14/P15 from the teammate's Comprehensive Review, attributed to `Pasted text(20261106-090722).txt` in the teammate's ChatGPT conversation, not a confirmed repository file. The separate Initial Documentation Review has formal suggestion REV-08 only. Full reports have not been directly accessed; cite the owner's descriptions without inventing additional text.

DEC-26

Status: Selected dispositions for review

Decision and rationale: Keep P10 in F-07/S2 and P05 in F-07/F-09; Simplify P14 to private F-10/S3 and Defer sharing; Incorporate P15 as small SYS-04/S3 usability evaluation, not a new feature. Incorporate separate REV-08 through explicit pre-contract decision/rationale/gate records. None is an instructor mandate or implementation-complete claim.

Open items and gates

OPEN-01

Owner: Both students

Required resolution: Review selected scope/rules/privacy and record substantive feedback. Names/IDs are needed for the assessed handoff, not a reason to invent personal information now.

Gate: Human approval of baseline/contracts; team identity before submission.

OPEN-02

Owner: Feature implementer + teammate

Required resolution: Pin mutually compatible Node, package and PostgreSQL versions; verify Prisma generation/migration/transaction API and Argon2 runtime support. Do not copy version-dependent APIs from an unrelated version.

Gate: Before dependency installation and F-01/F-02 implementation.

OPEN-03

Owner: Both students, instructor/TA if needed

Required resolution: Confirm no later course notice supersedes the supplied draft specification or deadlines.

Gate: Before assessed submission.

OPEN-04

Owner: Both students

Required resolution: Explicitly choose disable-text or collect-but-owner-inaccessible, then define storage/retention where applicable; finalize per-question/sparse quantitative guards, metadata/log controls and identity/answer separation tests.

Gate: Before F-06 implementation/enabling; baseline already fixes unconditional owner raw-text non-exposure.

OPEN-05

Owner: Team with Lab 5 guidance

Required resolution: Confirm actual GCP resources/permissions and secret handoff. Proposed Cloud Run/Cloud SQL components are architecture choices, not provisioned infrastructure.

Gate: Before cloud deployment.

OPEN-06

Owner: Both students + instructor/TA

Required resolution: Agree the maintenance change for Lab 7 against already implemented behavior. Do not invent approval or treat planned baseline expansion as the approved change.

Gate: Before Lab 7 change implementation.

OPEN-07

Owner: Both students

Required resolution: Review starter wording, 1/5 anchors, optional/required defaults and immutable metric meaning. The supplied questionnaire is a working starting point, not a validated university instrument.

Gate: Before F-07 contract acceptance; wording versions cannot change past surveys.

OPEN-08

Owner: Both students

Required resolution: Elaborate the confirmed simplified private note contract: two fields, simple statuses, timestamps/revision; no detailed history, reversal reason or reflection workflow. Sharing requires a separate future decision.

Gate: Before F-10/S3 code; no need to reopen the selected simplification.

OPEN-09

Owner: Export implementer + teammate

Required resolution: Choose/document spreadsheet compatibility, BOM/formula-safe text policy and verify with target reader; CSV quoting alone is insufficient.

Gate: Before F-08 implementation.

OPEN-10

Owner: Both students

Required resolution: Write complete Sprint 1 feature contracts, AC, STS and Product DoD, preserving their actual preimplementation versions.

Gate: Before each S1 feature's code; no claim that this Parts A-D PR replaces Issue #5.

OPEN-11

Owner: Team/teammate when full reports are shared

Required resolution: Verify the full Section 8 source and separate Initial Review against the owner-supplied P10/P05/P14/P15/REV-08 descriptions. IDs and selected dispositions are now recorded; direct access to the teammate's conversation is unavailable.

Gate: Source verification follow-up; revise only if material original wording differs. No false claim that the reports were read or exist in the repository.

OPEN-12

Owner: Both students in Issue #5

Required resolution: Confirm actual bounded task ownership/reviewer, available work capacity and revised estimates before finalizing S1 implementation commitments. Coarse estimates/buffer exist; no actual availability is claimed.

Gate: Before calling the Sprint 1 implementation schedule final; no personal calendar collection required.

Product-direction proposal disposition

Lecture-focused vision and explicit Course/Section context

Disposition: Incorporated.

Rationale / consequences: Fits Theme 10 and the existing vision; data/navigation/access now explicitly follow Section ownership. Seed-only S1 avoids administration expansion.

Starter Questionnaire in Sprint 2

Disposition: Incorporated in existing F-07.

Rationale / consequences: Independent versioned copies preserve historical definitions; no unnecessary feature-ID renumbering or template-manager role.

Teaching Improvement Notes in Sprint 3

Disposition: Incorporated as simplified F-10, private only.

Rationale / consequences: Record issues/actions/status without a new workflow system. Student communication remains deferred.

Course/instructor-wide feedback understanding

Disposition: Included as authorized per-metric summaries and lecture trends.

Rationale / consequences: Meaningful answer-weighted aggregation is possible while preserving mode/context/scale and question privacy. No universal instructor rating or cross-owner dashboard.

Private and shared note visibility

Disposition: Private selected; shared deferred.

Rationale / consequences: Shared publication adds audience/redaction/retraction rules and privacy tests; do not add it blindly to the two-person baseline.

Preserve IDs and mandatory theme scope

Disposition: Preserved and extended.

Rationale / consequences: F-01-09 unchanged in identity; F-10 appended. Anonymous/export stay S2 and S1 remains F-01-05.

Final finding follow-up ownership

BASE-01 uses lightweight estimates/critical path/buffer now and actual task/capacity confirmation in Issue #5. BASE-02 fixes product privacy now; collection and detailed protection contracts gate F-06/S2. BASE-03/04/06 hand off precise S1 payload/context/scale contracts to Issue #5. BASE-05/07 copy snapshot/starter verification precedes F-07/S2. BASE-08 simplified scope is fixed now; detailed F-10 contract remains S3. The review register (baseline-review.md) individually evaluates the four Section 8 P-ID opportunities and separates REV-08. For identification of those proposals, direct full-report verification remains open; their stage-specific contracts and all other listed gates still apply. The proposals are no longer unidentified or blanket-deferred.

Impact and change-control procedure

Any later accepted change records its source, rationale, affected FR/BR/NFR, feature/sprint, SDS entities/endpoints, AC/tests and release implications. Append IDs for genuinely new requirements; preserve prior definitions in Git history. Versioned template content/metric changes cannot silently rewrite historical comparisons.

Implementation start requires the relevant contract to be recorded before code; a spec-only commit is useful, but no arbitrary commit-count quota is imposed. A student's review must be their own substantive check/question/finding/reason for approval. AI consistency review and proposed work assignments are never substituted for actual teammate review or contribution evidence.

Revision record

2026-11-06

Version: 0.1

Change: Initial planning draft for Issues #1-#4 using the two supplied PDFs and owner's delegated scope/stack instruction; authorized for commit, push and PR submission.

Evidence status: Planning documents only; teammate review pending; no implementation or test execution claimed.

2026-11-06

Version: 0.2

Change: Product-direction revision: explicit Course/Section, starter copy/version rules, F-10 private notes, comparable trends and fuller engineering review.

Evidence status: Working documentation revision. Earlier commits `fe6324f` and `76de388` are real planning/theme history; no human approval or runtime evidence inferred.

2026-11-06

Version: 0.3

Change: Consolidate BASE-01-08/PD-01-03, question-level anonymous protection, simple notes, escaped-body direction, source revision snapshots and single-dimension wording. Owner deferred unknown Suggestions and reserved Git/PR management to the team.

Evidence status: Local documentation revision; no assistant Git publication, application tests or human approval claimed.

2026-11-06

Version: 0.4

Change: Owner clarified the teammate's report provenance and Section 8 P10/P05/P14/P15 versus separate Initial Review REV-08. Replace blanket deferral with individual selected dispositions and bounded P15 QA planning.

Evidence status: Attribution uses owner-provided descriptions; full original reports unavailable; no Git operation, session result or human approval claimed.

2026-11-06

Version: 0.5

Change: Owner explicitly renewed commit/push permission for this documentation revision on the existing PR branch.

Evidence status: Publication authorization only; no teammate approval, merge, software test or new source verification implied.

docs/baseline-review.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - Final Product Baseline Review and Approval Preparation

Date: 2026-11-06. Scope: documentation for Issues #1-#4 in PR #7 (https://github.com/Maibokdaimhai/LECTRA/pull/7). Type: AI-assisted review, not human teammate approval or software testing. After the documentation-only review, the owner explicitly authorized commit/push of this revision to the existing branch. No merge or review impersonation is authorized.

1. Source authority and inspection limits

The two supplied instructor PDFs remain the authority for assignment outcomes: `group_work_specs_v1.pdf` (Theme 10, common requirements, process and Labs 5-7) and `project_deliverable_1_v1.pdf` (Parts A-F and evidence). Team PD-01-PD-03 and the cool-color theme are product decisions, not new instructor mandates.

The owner supplied the final revision request listing 0 Critical, 2 Major and 6 Minor; BASE-01-BASE-08 are available in that request. A later clarification corrects the earlier label "four Suggestions": these are **Section 8: Innovation Opportunities** in the Comprehensive Product & Engineering Review, attributed to `Pasted text(20261106-090722).txt` shared in a teammate's previous ChatGPT conversation. The owner supplied the four exact proposal IDs/titles and short descriptions. The report is not confirmed to exist in the repository, and the assistant cannot access the teammate's conversation or independently verify the full original text. Evaluations below use the owner's supplied descriptions with that provenance; do not claim the original report was read or fabricate its additional wording.

The separate **Initial Documentation Review** contains one formal suggestion, **REV-08 - Record Explicit Pre-contract Dispositions**, according to the owner. It is not part of Section 8, not a fifth innovation proposal and not interchangeable with any P-ID. Earlier deferral of four unidentified items is superseded by this clarification; verification of the full source remains pending, not evaluation of four invented replacements.

Earlier public GitHub API inspection observed PR #7 open/unmerged at head `6fa1a14`, with no reviews, inline comments or conversation comments. This is historical inspection context, not a current-head or review guarantee. No Git command or PR mutation was performed during the documentation-only audit; the owner subsequently renewed scoped commit/push permission.

2. Consolidated product changes

- Keep Course → Section/offering → Lecture → Survey → derived Results, with Section ownership and lecture as the primary unit.

- Preserve useful Course/own-instructor evaluation through compatible per-metric summaries across owned lectures; label context, mode, weighting, observations and limitations. No universal instructor score or cross-owner ranking.

- PD-01: never expose anonymous raw text to owners on any surface. Keep collection/storage as an explicit pre-F-06 decision. Quantitative privacy operates per question, not merely per survey.

- PD-02: one private note, issue/action, Planned/Applied, essential timestamps and revision protection; remove detailed history, reversal reasons and reflection prerequisites.

- PD-03: one concise four-category starter with single-dimension rating prompts, independent editable copies and immutable source/version meaning.

- Keep F-01-F-10 and all 46 FR/BR/NFR IDs. S1 F-01-05, S2 F-06-08 and S3 F-09-10 remain unchanged in allocation.

- Preserve architecture, cool-color UI theme, real identity/access, persistence, test/TDD/review expectations and historical-data protection.

3. Major / Minor finding resolution matrix

Status definitions: **Baseline addressed** means an actual product/design correction is present, not merely a mention. **Contract follow-up** means detailed preparation is safely gated before its dependent implementation. **Unverified** is not a completed result. No finding is declared runtime-verified.

BASE-01 - Major: Sprint Workload Feasibility

Final documentation status: Planning structure addressed; actual capacity unverified.

Resolution and supporting evidence: Sprint plan §5 has complexity/illustrative effort, non-equal proposed responsibilities, critical path, shared checks/review/PDF work and 20% buffer. Owner asked for proportionate treatment; no private calendars or invented availability.

Affected documents: `sprints/plan.md` §2/5/9/10; `decisions.md` DEC-24, OPEN-12.

Remaining work and safe gate: Issue #5 confirms actual implementer/reviewer and feasible bounded work before S1 implementation schedule is called final. Coarse estimates are not available hours.

BASE-02 - Major: Anonymous Survey Privacy

Final documentation status: Confirmed product policy addressed; collection choice and detailed protection contract open.

Resolution and supporting evidence: FR-07/08, BR-13/15/16/19 and NFR-06 forbid raw anonymous text on UI/API/CSV/analytics. Proposed question threshold five plus nonzero-bin guard three is separate from total survey count. Hidden means/distributions/answered counts cannot leak through consumers.

Affected documents: `srs.md` §4/5/7; `system-sds.md` §7/13/15; `features.md` F-06/08/09; `decisions.md` PD-01/DEC-22, OPEN-04.

Remaining work and safe gate: Team explicitly chooses text-disabled or collect-but-owner-inaccessible and finalizes privacy tests before F-06/S2; anonymous collection/publication is not enabled until then.

BASE-03 - Minor: Request Size Limit

Final documentation status: Baseline direction corrected; F-04 contract follow-up.

Resolution and supporting evidence: Replace 128 KiB with proposed 256 KiB; account for 12-byte surrogate-pair escapes, 240,000-byte text bound, bounded envelope and independent decoded/count limits. Over-limit requests fail before persistence.

Affected documents: `srs.md` §5; `system-sds.md` §6.2; `traceability.md` BR-07; `decisions.md` DEC-23.

Remaining work and safe gate: Issue #5 fixes envelope/parser/compression/resource limits and exact UTF-8/escaped/boundary cases before F-04 code. Not a tested server setting yet.

BASE-04 - Minor: Context Selection vs Historical Filtering

Final documentation status: Responsibility split corrected; detailed S1 contracts remain.

Resolution and supporting evidence: F-02 is owned context/current-work discovery in S1; F-09 adds historical Course/Section/date/state search in S3. Reuse list/context views/APIs; analytics endpoint has a separate aggregate purpose.

Affected documents: `features.md` F-02/F-09; `system-sds.md` §6.1.7/6.2; `sprints/plan.md` §2/10; `traceability.md` FR-02/11.

Remaining work and safe gate: Issue #5 finalizes F-02 request/screen boundaries; F-09 adds later filters in S3 without duplicating context endpoints.

BASE-05 - Minor: Concurrent Template Copy

Final documentation status: Snapshot/version direction addressed; F-07 contract follow-up.

Resolution and supporting evidence: Exact immutable TemplateVersion, source Draft definitionRevision, lock/recheck/read/copy in one transaction, 409 on changed expected revision, fresh target IDs and no mixed source.

Affected documents: `srs.md` BR-17; `system-sds.md` §2/3/10; `traceability.md` BR-17; `features.md` F-07.

Remaining work and safe gate: F-07/S2 contract specifies source mutation/retirement lock order and concurrent tests before implementation. No new template-management feature.

BASE-06 - Minor: Scale Interpretation

Final documentation status: S1 storage/readback direction addressed; F-03/F-05 contract follow-up.

Resolution and supporting evidence: Question stores range, endpoint labels and scaleInterpretation with the frozen definition in S1. Answering/results use the same metadata; numeric range alone cannot certify comparability.

Affected documents: `system-sds.md` §2/11; `srs.md` BR-09/18 and starter scale meanings; `traceability.md` FR-07/BR-18.

Remaining work and safe gate: Issue #5 specifies fields/payloads/validation and freeze/readback tests before F-03/F-05 code; later metric provenance is S2.

BASE-07 - Minor: Starter Questionnaire Wording

Final documentation status: Single-dimension draft corrected; content/contract review scheduled.

Resolution and supporting evidence: Separate content clarity, explanation effectiveness and environment suitability; one optional suggestion prompt. Retain editable independent copies, required flags, versioning and historical consistency.

Affected documents: `srs.md` §5 starter table; `decisions.md` PD-03, OPEN-07; `features.md` F-07.

Remaining work and safe gate: Human content review and F-07/S2 verification before the versioned starter is released. No claim of psychometric validation.

BASE-08 - Minor: Teaching Improvement Notes Complexity

Final documentation status: Scope simplified now; F-10 contract follow-up.

Resolution and supporting evidence: FR-14/BR-20-22 and SDS remove NoteStatusChange, reflection, reversal reasons and complex transitions; retain two fields, two statuses, essential timestamps, unique survey note and revision checks.

Affected documents: `srs.md`; `features.md` F-10; `system-sds.md` §2/3/12; `traceability.md`; `sprints/plan.md`; `decisions.md` PD-02.

Remaining work and safe gate: Detailed private-note contract/tests before F-10/S3. No additional history or sharing work implied.

The matrix distinguishes actual baseline edits from future work. BASE-01 is not labelled capacity-confirmed, and BASE-02 is not labelled anonymous-mode verified. Every deferred implementation item has a preimplementation owner/gate rather than silently disappearing.

4. Comprehensive Review - Section 8: Innovation Opportunities

Source attribution: teammate's Comprehensive Product & Engineering Review, `Pasted text(20261106-090722).txt`, Section 8, **as identified and summarized by the owner**. These are recommendations, not instructor requirements. Decisions below are selected baseline dispositions for human review, not implementation completion or proof that the original report has been independently checked.

P10 - Categorized Starter Questions

Disposition: Keep the existing bounded incorporation.

User / engineering value: Reduces repeated authoring and gives a consistent starting point across content/teaching/environment/suggestions.

Complexity and trade-off: Moderate copy/version work is already scoped; keep one seeded editable starter, not template administration or automatic propagation.

Baseline mapping / next gate: F-07/S2; FR-13, BR-17/18, NFR-09; SRS starter table and SDS §10. Review wording/anonymous text handling before F-07.

P05 - Consistent Question Series

Disposition: Keep the existing compatible-series design.

User / engineering value: Makes comparisons across lectures interpretable and preserves historical measurement meaning.

Complexity and trade-off: Requires scale/version metadata and comparability tests; matching numeric ranges/titles alone are insufficient. Custom edits may lose comparison eligibility.

Baseline mapping / next gate: F-07 metric provenance/S2 and F-09/S3; FR-11, BR-18/19; SDS §11. No new feature ID or ranking.

P14 - "What I Will Change" Note

Disposition: Simplify to the selected private MVP; **Defer** optional sharing.

User / engineering value: Records an instructor's interpretation and intended action after Closed feedback without becoming a workflow system.

Complexity and trade-off: Low-to-moderate single-note work; sharing adds audience/redaction/publication rules and privacy risk. Keep two fields, status/timestamps/revision; no history/discussion/AI.

Baseline mapping / next gate: F-10/S3; FR-14, BR-20-22, PD-02; SDS §12. Sharing is excluded until a separate accepted privacy/scope decision.

P15 - Measure the Feedback Cycle

Disposition: Incorporate a bounded usability evaluation into existing QA, not a product feature.

User / engineering value: Checks whether results support a useful teaching action and whether students understand participation/privacy, beyond merely completing buttons.

Complexity and trade-off: Small facilitated sessions and analysis require recruitment/time; avoid a new research platform, statistical claims or a dashboard. Reuse synthetic data and existing UAT/QA materials where suitable.

Baseline mapping / next gate: SYS-04/S3 supporting NFR-07 and existing user goals; plan §11 and SDS §15. Record actual participants/outcomes only when run; exploratory success is not a new release threshold.

All four have been considered individually; keeping an existing bounded implementation plan is different from automatically adding every recommendation. No additional F-ID, new FR/BR/NFR or Sprint 1 scope is introduced. Original full-text verification remains OPEN-11 because the report is in the teammate's conversation; if its wording materially differs, review these dispositions instead of retroactively claiming an exact source match.

Separate report: Initial Documentation Review

REV-08 - Record Explicit Pre-contract Dispositions

Disposition: Incorporate as an explicit documentation/process practice.

Value / scope: Records Keep/Incorporate/Simplify/Defer, rationale, affected feature/sprint and contract gate before implementation; no application feature added.

Evidence and remaining boundary: This table, the BASE register, decision log and Issue #5 handoffs make dispositions explicit. Attribution/title is owner-supplied; the complete Initial Review has not been independently retrieved. This is not teammate approval or proof of contract completion.

5. Product decisions and exact locations

PD-01

Confirmed boundary: No anonymous raw text to owners on any surface; identity/answer separation and separate quantitative privacy required.

Selected detail / remaining decision: Text-disabled is recommended, not confirmed; collect-but-inaccessible remains alternative until explicit agreement. Working quantitative minimum is five answered per question; sparse-bin guard three needs F-06 validation.

Locations: SRS FR-07/08, BR-13/15/16/19, NFR-06, §7; SDS §7/13; DEC-19/22; OPEN-04.

PD-02

Confirmed boundary: Private one-note F-10/S3, issue/action, Planned/Applied, essential timestamps and revision.

Selected detail / remaining decision: Default Planned and current-state appliedAt semantics are selected design details; detailed history/reversal/reflection/sharing removed.

Locations: SRS FR-14/BR-20-22; SDS §2/12; F-10 inventory; DEC-20; OPEN-08.

PD-03

Confirmed boundary: One starter F-07/S2, four categories, single-dimension ratings and independent versioned customization.

Selected detail / remaining decision: Working wording/anchors are in SRS; anonymous text treatment remains tied to OPEN-04, not a silent template mutation.

Locations: SRS starter table/BR-17/18; SDS §10/11; F-07; DEC-21; OPEN-07.

6. Assignment coverage and current PR scope

A

Current coverage: Vision/actors/scope, glossary, 14 FR, 23 BR, 9 NFR, privacy and decision gates.

Remaining assessed work: Real teammate review and accepted decisions; no score or approval is inferred.

B

Current coverage: Ten features/four system responsibilities; all 46 requirements allocated to sprints and planned verification.

Remaining assessed work: Actual AC/test IDs/files/results/versions added after contracts/execution.

C

Current coverage: System architecture, data, ownership, sessions, UI/theme/API direction, version/copy/scale/privacy/notes and delivery design.

Remaining assessed work: Compatible versions and feature contracts; later actual delivery evidence.

D

Current coverage: Same three-sprint allocation, dependencies/critical path, coarse effort/buffer, lab overlap and proposed shared responsibilities.

Remaining assessed work: Issue #5 actual capacity/tasks before final S1 implementation commitments.

E

Current coverage: Contract handoff areas and gates only; not complete in this PR.

Remaining assessed work: Issue #5: S1 feature design, API/database/UI specs, AC, STS, security/validation tests, Product DoD and detailed allocation before code.

F

Current coverage: Evidence obligations acknowledged; no application evidence supplied.

Remaining assessed work: Working UI/API/PostgreSQL increment, real build/tests/TDD/demo, substantive human review/integration, accepted main release, contribution and complete self-contained PDF.

Instructor theme requirements remain: identified S1 plus later documented/tested anonymous mode, eligibility, question/lifecycle/duplicate rules, aggregate analysis/export, real auth/access, persistence and engineering evidence. Course/own-instructor summaries are meaningful contextual feedback evaluation, not a complete instructor-quality claim or ranking. No AI/discussion/integration/template-admin scope is introduced.

7. Cross-document verification of this revision

Observed local checks on 2026-11-06:

English text, relative links, whitespace, code fences and table structure

Observed documentation result: Passed across all eight Markdown files.

Limit: Source checks only, not rendered UI or human review.

Requirement/feature traceability

Observed documentation result: Passed: 14 FR, 23 BR, 9 NFR defined/mapped once; 10 features and four system responsibilities resolve; all requirement rows have sprint/verification allocation.

Limit: Planned coverage, not 46 executed tests.

Cross-document consolidation

Observed documentation result: Passed checks for BASE-01-08/PD-01-03, stable requirements/features, retained theme, four individual P10/P05/P14/P15 rows and separate REV-08. The proposal mappings and bounded P15 QA plan are consistent across affected documents.

Limit: Source attribution uses the owner's descriptions; no direct access to the teammate's complete reports is claimed.

Markdown parser

Observed documentation result: Passed: eight Markdown files, 51 structurally consistent tables and two Mermaid source blocks.

Limit: Diagram rendering not performed.

Request-size arithmetic

Observed documentation result: Ten 2,000-emoji answers serialized to 80,663 UTF-8 bytes or 240,663 ASCII-escaped bytes; proposed 256 KiB ceiling is 262,144 bytes, with the conservative envelope budget separately bounded.

Limit: Serialization sanity calculation, not an HTTP acceptance test or proof of final parser configuration.

Checks read the local files and parse Markdown; no Git command, commit, branch, push, PR update or review submission is involved. The initial source-level/encoding checks are observations, not application build/test evidence.

No runtime/unit/API/database/E2E/privacy/load/migration test has run because no application exists. Documentation checks are not software verification. Mermaid source is present; rendered diagram layout remains unverified because the bundled runtime lacks a Mermaid renderer.

8. Open decisions, deferral safety and target stage

Real bounded task/reviewer allocation and capacity confirmation

Owner / target: Both students, Issue #5 before final S1 implementation commitments.

Why safe to defer from this baseline: Model is explicitly provisional; no fictitious availability or final feasibility claim.

Detailed payload/parser/encoding/resource and F-02 context / rating-scale contracts

Owner / target: S1 feature owners + teammate, Issue #5 before F-02-05 code.

Why safe to defer from this baseline: Required direction is fixed here; no implementation starts without the detailed contract.

Anonymous text collection/storage choice and privacy adversarial tests

Owner / target: Both students, before F-06/S2 code/enabling.

Why safe to defer from this baseline: Raw-text non-exposure is fixed; anonymous collection/publication remains gated until the choice and controls are agreed.

Copy source revision/retirement concurrency and starter content verification

Owner / target: F-07 owner + teammate, S2 before implementation.

Why safe to defer from this baseline: Independent immutable/versioned snapshot direction is fixed; no starter workflow is represented as live.

Simple note payload/status/timestamp/revision tests

Owner / target: F-10 owner + teammate, S3 before implementation.

Why safe to defer from this baseline: Two-field/private scope is fixed; removed history/workflow is not carried as hidden work.

Original Comprehensive / Initial Review full-text verification

Owner / target: Team/teammate when source is shared; OPEN-11.

Why safe to defer from this baseline: Proposal IDs/descriptions and separate REV-08 are owner-supplied and individually dispositioned; full-source verification is not falsely claimed. No instructor requirement depends on an invented source.

P15 small usability sessions

Owner / target: Both students, existing SYS-04/S3 QA.

Why safe to defer from this baseline: No new S1 feature or infrastructure; protocol/participants and actual observations are recorded only when available. See plan §11.

Human review, version pinning, GCP guidance and Lab 7 approved change

Owner / target: Appropriate owners/gates in OPEN-01-12.

Why safe to defer from this baseline: Review remains real; resources/approval not invented; timing matches relevant implementation/lab.

9. Final readiness assessment

Revised local baseline: Ready for Approval with Explicitly Documented Deferred Work. This is an AI recommendation for human planning review, not the team's actual approval. BASE-01 remains capacity-unverified and the anonymous collection choice remains open at its explicit S2 gate; those limits must be accepted as documented, not silently marked resolved.

The owner authorized publishing this final revision on the existing PR branch after the earlier `6fa1a14` inspection. The team must inspect the resulting diff, provide substantive teammate review and accept the listed deferrals before approval. Publication does not imply merge, human approval or runtime verification. No further full rewrite is recommended; proceed through that review and the named stage-specific follow-ups, then Issue #5.

Part B - Feature inventory and traceability

docs/features.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - Feature Inventory

Version: 0.4 (2026-11-06). Status: consolidated planning draft with individually dispositioned review recommendations. Related issue: #2 (https://github.com/Maibokdaimhai/LECTRA/issues/2). Source requirements: SRS (srs.md). All features are planned, not implemented or verified.

F-01

Feature / outcome: Authentication and access foundation: login/logout/me, database-backed sessions, backend role/record guards.

Requirement links: FR-01; BR-01-02; NFR-01

Dependencies: Seeded identity and database setup under SYS-01

Sprint: 1

F-02

Feature / outcome: Seeded Course/Section/Lecture selection and role-appropriate current-work/eligible survey lists; no historical date/state search. Shared Course never implies shared owner access.

Requirement links: FR-02, FR-12; BR-02-04, BR-23

Dependencies: SYS-01 supplies identities/context first; F-01 supplies authenticated discovery

Sprint: 1

F-03

Feature / outcome: Survey authoring/lifecycle: rating/text Draft creation/edit/delete, validation, publish with eligibility snapshot, manual close and structural locking.

Requirement links: FR-03-04; BR-02-05, BR-07, BR-09-11, BR-14, BR-23

Dependencies: F-01, F-02

Sprint: 1

F-04

Feature / outcome: Identified response submission and retrieval: atomic validated submission, duplicate prevention, confirmation/status and own-answer retrieval.

Requirement links: FR-05-06; BR-01-08, BR-10-11, BR-14

Dependencies: F-01, F-02, F-03

Sprint: 1

F-05

Feature / outcome: Identified owner results: count, frozen scale interpretation, rating mean/distribution, no-data states and identified text after closure without identity labels.

Requirement links: FR-07; BR-02, BR-12-14, BR-16

Dependencies: F-03, F-04

Sprint: 1

F-06

Feature / outcome: Anonymous mode: identity/answer separation, no owner-visible raw text on any result surface, question-level quantitative release, status-only self-service and truthful disclosure. Text collection/storage is a blocking pre-F-06 team decision.

Requirement links: FR-08; FR-06 (anonymous); BR-03, BR-06, BR-08, BR-13-16; NFR-06

Dependencies: F-01-05 and accepted privacy/collection contract

Sprint: 2

F-07

Feature / outcome: Starter Questionnaire and bounded survey expansion: preview/copy a seeded version into an independent Draft, customize before publication, single-choice questions, duplicate-to-Draft for another owned lecture and eligible-member subset.

Requirement links: FR-09, FR-13; BR-03, BR-07, BR-09, BR-16-18, BR-23; NFR-09

Dependencies: F-02-05; shared lifecycle/validation; integration with F-06 before S2 release

Sprint: 2

F-08

Feature / outcome: Authorized aggregate CSV export following result visibility and anonymous suppression rules.

Requirement links: FR-10; BR-02, BR-12-13, BR-16

Dependencies: F-05, F-06, F-07

Sprint: 2

F-09

Feature / outcome: Historical Course/Section/date/state filtering, compatible lecture trends and labelled per-metric Course/own-instructor summaries, excluding hidden questions and rankings.

Requirement links: FR-11; BR-02, BR-12-13, BR-18-19

Dependencies: F-02 context APIs, F-05 results, F-06 question release and F-07 metric provenance; F-08 is not a prerequisite for history reads

Sprint: 3; working progress by 29 Nov

F-10

Feature / outcome: One private issue/action note per owned Closed survey with accessible results; simple Planned/Applied status, essential timestamps and revision-safe editing. No detailed workflow/history.

Requirement links: FR-14; BR-02, BR-13, BR-20-22; NFR-09

Dependencies: F-03, F-05 and F-06 per-question privacy; may be built alongside F-09

Sprint: 3; bounded progress by 29 Nov

Named system responsibilities

These are engineering responsibilities, not extra user-facing features or a mandatory feature-count quota.

SYS-01

Responsibility: Database migrations, reproducible synthetic seed, configuration and setup/build instructions; additive template/note schema changes preserve historical records.

Requirements: FR-12; NFR-02-03, NFR-09

Establish / verify: Sprint 1; Docker/redeployment in Lab 5; template seed S2 and notes S3.

SYS-02

Responsibility: Release engineering: contracts before implementation, Issues/board, feature branches from staging, teammate reviews, integrated release and evidence tied to commit.

Requirements: NFR-05, NFR-08

Establish / verify: Sprint 1; CI quality gates and GCP pipeline in Lab 5; maintained afterward.

SYS-03

Responsibility: Privacy/security across schema, sessions, APIs, UI, logging, exports, comparison results and private notes.

Requirements: BR-01-02, BR-13-16, BR-19-22; NFR-01, NFR-06

Establish / verify: Basic access/disclosure S1; anonymous S2; note/analysis regression S3.

SYS-04

Responsibility: Integration, usable UI states, performance verification, cross-team UAT, approved maintenance and regression/defect closure; bounded P15 feedback-cycle usability sessions, not a new feature.

Requirements: NFR-02, NFR-04-05, NFR-07-08; FR-07/FR-14 user goals

Establish / verify: Basic integration/UI S1; Labs 6-7; P15 evaluation/final verification S3.

Scope control

Course-administration UI, staff delegation, multiple-choice with multiple selections, scheduling, PDF data export, cross-instructor comparisons, AI feedback insights, template administration and shared improvement notes are excluded. Shared notes remain a proposal requiring agreement. Anonymous and aggregate export are instructor-theme baseline work; Starter Questionnaire and private notes are owner-requested product extensions. None expands Sprint 1.

Detailed AC/test coordination uses the #5 register (sprints/sprint-1/README.md), shared conventions (sprints/sprint-1/shared-contract.md) and Product DoD (sprints/sprint-1/product-dod.md). F-01/F-02/F-03/F-05 document packages merged via PR #29/#31/#32/#33; actual interface/schema agreements and feature implementation remain separate. F-04 now has a local contract (sprints/sprint-1/f-04-responses.md) and STS (sprints/sprint-1/f-04-responses-sts.md), pending human review. #15 tooling checks are not feature acceptance tests. Each feature waits for its own reviewed contract/dependencies, not closure of the whole umbrella; no planned case is presented as executed.

Feature boundaries and completion outcomes

These are planning-level outcomes, not substitutes for feature contracts or execution evidence.

F-01

Included outcome: Real credential checking, current identity, fixed-lifetime revocable session, CSRF enforcement and negative access tests.

Boundary / deliberate omission: No signup/recovery/SSO or role selector granting backend identity.

F-02

Included outcome: Section-scoped navigation, immutable seeded context IDs and role-appropriate survey discovery.

Boundary / deliberate omission: No Course/Section/member/lecture CRUD UI; SYS-01 seed is independent of the login UI.

F-03

Included outcome: Entire Draft definition saved atomically; publish snapshot; close; invalid transition and wrong-owner rejection.

Boundary / deliberate omission: No reopen or published question changes; one survey per lecture.

F-04

Included outcome: Whole response persists once; student can reopen their identified response/status; duplicate/close races are tested.

Boundary / deliberate omission: No partial autosaved answer draft, post-submit editing or cross-student lookup.

F-05

Included outcome: Identified count, frozen scale-labelled mean/distribution, optional-answer denominator and identified plain-text comments after closure.

Boundary / deliberate omission: No raw identity list/public summary/overall instructor score; S2 anonymous extension never exposes raw text.

F-06

Included outcome: No anonymous raw-text exposure, separate question-answer threshold/sparse-bin release, reviewed identity/answer separation and a resolved collection policy before enabling.

Boundary / deliberate omission: No reliance on survey total alone, owner raw-text viewer, subgroup filtering, infrastructure anonymity guarantee or checkbox-only anonymity.

F-07

Included outcome: One seeded versioned starter with single-dimension ratings; consistent immutable-version or mutable-revision copy snapshots, independent definitions and customizability.

Boundary / deliberate omission: No live propagation, mixed-version source copy, template-builder role, answer copy or arbitrary template editing/deletion.

F-08

Included outcome: UTF-8 aggregate CSV with safe escaping, owner scoping and consistent privacy filtering.

Boundary / deliberate omission: No identities, raw comments, notes, individual answers or PDF export.

F-09

Included outcome: Course/Section/date/state history filters and compatible per-lecture/per-metric summaries, visible observations/counts and answer-weighted aggregation with labels.

Boundary / deliberate omission: No cross-owner join, category-only comparability, hidden-data pooling, anonymous text inference or universal instructor score/ranking.

F-10

Included outcome: One owner-private issue/action note, Planned/Applied choice, essential timestamps and optimistic edit conflicts.

Boundary / deliberate omission: No detailed history, reversal reason, mandatory reflection, discussion, publishing, notifications or claim that Applied caused better outcomes.

Dependency and integration policy

SYS-01 creates the minimum identity/context schema and seed before F-01/F-02 runtime verification; F-01 must not depend on a feature that in turn requires successful login to be seeded. Database setup is therefore a shared foundation rather than a cyclic feature dependency.

F-06 and F-07 can be specified and developed in bounded parallel work after F-03-05, but must pass a combined anonymous/starter/choice/subset regression before S2 release. F-08 consumes the same results authorization/projection service as F-05. F-09 and F-10 consume closed results independently; neither must wait for the other's UI. The later lab responsibilities apply to the evolving application regardless of feature allocation.

Changes from version 0.1

- Preserve F-01-F-09 and SYS-01-SYS-04 IDs; append F-10 only.

- Replace ambiguous Classroom with explicit Course/Section/Lecture context in F-02.

- Expand F-07 with FR-13 starter-copy/version isolation; keep it in Sprint 2.

- Add FR-14 private improvement notes in F-10/Sprint 3 and comparability/suppression rules for F-09.

- No feature is claimed complete and no mandatory anonymous/export work is removed.

Final consolidation (version 0.3)

PD-01 changes F-06 projections and F-08/F-09 consumption without adding IDs or moving sprints. PD-02 removes unnecessary F-10 history/workflow complexity. PD-03 revises F-07 starter content, not historical implemented questions. BASE-03/04/06 provide product direction now and detailed S1 contracts in Issue #5; BASE-02/05/07 detailed preparation remains before the relevant S2 feature. BASE-08 detailed note contracts remain S3. See the finding register (baseline-review.md) for status, evidence locations and safe deferral gates.

Review recommendation disposition, without scope inflation

The owner's clarification attributes P10/P05/P14/P15 to Section 8 Innovation Opportunities of the teammate's Comprehensive Review, not instructor mandates. Keep P10 in F-07 and P05 in F-07/F-09; Simplify P14 to private F-10 and Defer optional sharing; Incorporate P15 into SYS-04/S3 QA. No new feature/requirement ID is added. The separate Initial Review REV-08 concerns explicit pre-contract dispositions, not another innovation feature. See the source-qualified evaluation (baseline-review.md) for value/complexity/trade-offs and the full-report access limitation.

docs/traceability.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - Requirements Traceability

Version: 0.3 (2026-11-06). Status: consolidated planned coverage, not execution evidence. Related issue: #2 (https://github.com/Maibokdaimhai/LECTRA/issues/2).

Requirements are defined in SRS (srs.md); features/responsibilities in inventory (features.md). Verification descriptions below are plans. Actual AC/test IDs, files, commands, versions and results will be linked when contracts and implementation exist. All current execution statuses are **Not run**.

FR-01

Feature / responsibility: F-01

Establish / verify: S1

Planned verification: Valid/invalid login, current identity, session expiry and logout-replay API tests; login/logout E2E.

FR-02

Feature / responsibility: F-02, F-03, F-04

Establish / verify: S1

Planned verification: Owned Course/Section/Lecture selectors/current-work lists and same-Course/different-owner rejection; historical search stays F-09/S3.

FR-03

Feature / responsibility: F-03

Establish / verify: S1

Planned verification: Create/edit valid Draft, invalid prompt/type/count, persisted retrieval, authoring E2E.

FR-04

Feature / responsibility: F-03

Establish / verify: S1

Planned verification: Publish/close success, invalid transitions, persisted state, cross-owner rejection.

FR-05

Feature / responsibility: F-04

Establish / verify: S1

Planned verification: Real DB submission/readback, confirmation E2E and invalid-answer rollback.

FR-06

Feature / responsibility: F-04, F-06

Establish / verify: S1 identified; S2 anonymous

Planned verification: Own answers/status across logout/login; cross-student rejection; anonymous status without answer link.

FR-07

Feature / responsibility: F-05, F-06

Establish / verify: S1; extend S2

Planned verification: Frozen scale readback, correct quantitative denominators, identified text after Closed; no anonymous raw text through any owner projection.

FR-08

Feature / responsibility: F-06, SYS-03

Establish / verify: S2

Planned verification: Explicit collection-policy enforcement, raw-text prohibition, question-level/sparse privacy, identity/answer separation and truthful disclosure.

FR-09

Feature / responsibility: F-07

Establish / verify: S2

Planned verification: Single-choice 1/2/6/7-option boundaries, option ownership, new-Draft copy isolation, duplicate target lecture and subset eligibility.

FR-10

Feature / responsibility: F-08

Establish / verify: S2

Planned verification: CSV contents/escaping, closed-owner access, threshold and omission of raw/identity fields.

FR-11

Feature / responsibility: F-09

Establish / verify: S3; progress by 29 Nov

Planned verification: Reused context/list views with history filters, compatible per-metric Course/own-instructor summaries, correct answer weighting and no hidden-question input.

FR-12

Feature / responsibility: F-02, SYS-01

Establish / verify: S1; Lab 5; extend S2-3

Planned verification: Fresh migrate/seed reproduction, same-Course cross-owner fixtures, safe accounts, versioned starter seed and note fixtures.

FR-13

Feature / responsibility: F-07, SYS-01

Establish / verify: S2

Planned verification: Preview/copy starter, four-category contents, customize copied definitions, old/new source versions, unavailable version and cross-owner target rejection.

FR-14

Feature / responsibility: F-10, SYS-03

Establish / verify: S3; progress by 29 Nov

Planned verification: Private issue/action/status CRUD subset, essential timestamps, unique create/revision conflict and access guards; no history/reflection/reversal workflow.

BR-01

Feature / responsibility: F-01, SYS-03

Establish / verify: S1 onward

Planned verification: Unauthenticated calls, client identity/role spoofing, authenticated server identity and safe errors.

BR-02

Feature / responsibility: F-01-10, SYS-03

Establish / verify: S1; extend S2-3

Planned verification: Student-management, owner-owner, student-student, same-Course/different-Section and private-note access matrix.

BR-03

Feature / responsibility: F-02-04, F-06-07

Establish / verify: S1; subset S2

Planned verification: Snapshot membership, later member changes and ineligible submission rejection.

BR-04

Feature / responsibility: F-02-03

Establish / verify: S1

Planned verification: State-transition matrix and Draft non-disclosure.

BR-05

Feature / responsibility: F-03-04, F-07

Establish / verify: S1; single-choice S2

Planned verification: Draft/Closed rejection, 0/1/10/11-question publication boundaries, text-only Draft and empty eligibility rejection.

BR-06

Feature / responsibility: F-04, F-06

Establish / verify: S1; anonymous S2

Planned verification: Sequential and concurrent duplicate requests: exactly one committed participation/answer bundle.

BR-07

Feature / responsibility: F-03-04, F-07

Establish / verify: S1; choices S2

Planned verification: Required/type/rating and Unicode count boundaries, ten-answer cap, UTF-8 and surrogate-escaped JSON/body limits, forged IDs and empty submission. Detailed F-04 contract in Issue #5.

BR-08

Feature / responsibility: F-04, F-06

Establish / verify: S1; anonymous S2

Planned verification: Invalid item and forced transaction failure leave no partial participation/answers.

BR-09

Feature / responsibility: F-03, F-06-07

Establish / verify: S1; extend S2

Planned verification: Post-publication structure/mode/eligibility mutation rejected, including direct API calls.

BR-10

Feature / responsibility: F-03-04, F-06

Establish / verify: S1; anonymous S2

Planned verification: No submit-edit/resubmit or published hard-delete route; Draft deletion permitted only to owner.

BR-11

Feature / responsibility: F-03-04

Establish / verify: S1

Planned verification: Deterministic real-DB lock-order tests for close-before-submit and submit-before-close.

BR-12

Feature / responsibility: F-05, F-08-09

Establish / verify: S1; extend S2-3

Planned verification: Optional omissions, null mean, 1-5 distribution, per-question denominators and display rounding.

BR-13

Feature / responsibility: F-05-06, F-08-10

Establish / verify: S1; anonymous S2; notes/trends S3

Planned verification: Question answered count 4/5 despite total 5/10, optional/sparse responses, nonzero bins 2/3, whole-question suppression, no anonymous text and no complementary API/UI/CSV/analytics leaks.

BR-14

Feature / responsibility: F-03-06, SYS-03

Establish / verify: S1; anonymous S2

Planned verification: Identified disclosure/own answer access; anonymous disabled before accepted contract; correct mode labels.

BR-15

Feature / responsibility: F-06, SYS-03

Establish / verify: S2

Planned verification: Schema/log/API/export checks for direct and metadata-based joins under the declared threat boundary.

BR-16

Feature / responsibility: F-05-09

Establish / verify: S1 identified text; S2 privacy/export

Planned verification: Identified comments omit identity; anonymous text absent at any count on every owner surface; suppressed question stats/answered counts absent from CSV/analytics.

BR-17

Feature / responsibility: F-07, SYS-01

Establish / verify: S2

Planned verification: Exact template version / source Draft revision, concurrent edit/retirement conflict, no mixed snapshot, atomic new IDs and no copied answers/eligibility/notes.

BR-18

Feature / responsibility: F-07, F-09

Establish / verify: S2 provenance; S3 comparison

Planned verification: Same metric version accepted; edited prompt/anchors/type clears metric; matching title/category alone cannot join a trend.

BR-19

Feature / responsibility: F-09, SYS-03

Establish / verify: S3

Planned verification: Owner/mode/metric scope and per-question release before aggregation, answer-weighted sum/count with different lecture sizes, observation versus unique-student labels and no hidden input.

BR-20

Feature / responsibility: F-10, SYS-03

Establish / verify: S3

Planned verification: Reject unowned/open survey; anonymous needs at least one releasable question; unique private note and no student/CSV/analytics leakage.

BR-21

Feature / responsibility: F-10

Establish / verify: S3

Planned verification: Issue/action 0/1/2,000/2,001-code-point limits, two valid statuses, essential timestamp behavior; no mandatory reflection or reversal reason.

BR-22

Feature / responsibility: F-10, SYS-01

Establish / verify: S3

Planned verification: Stale revision conflict, atomic field/status/timestamp/revision update, unchanged survey/results; no status-history model.

BR-23

Feature / responsibility: F-02-03, F-07

Establish / verify: S1; copying S2

Planned verification: Survey/lecture/Section owner consistency, unique lecture survey across concurrent create/copy, no starter/note dependency in Sprint 1.

NFR-01

Feature / responsibility: F-01-10, SYS-03

Establish / verify: S1; regression S2-3

Planned verification: Backend access suite, password-storage inspection and safe-error checks, including source-copy and note routes as introduced.

NFR-02

Feature / responsibility: F-03-04, SYS-01, SYS-04

Establish / verify: S1; redeploy Lab 5

Planned verification: Application restart retrieval and concurrency tests; cloud redeployment durability.

NFR-03

Feature / responsibility: SYS-01-02

Establish / verify: S1; Lab 5

Planned verification: Teammate fresh-checkout setup/build/test; container and pipeline reproduction later.

NFR-04

Feature / responsibility: F-04-05, F-09, SYS-04

Establish / verify: S3

Planned verification: Recorded load run against specified dataset/concurrency/hardware.

NFR-05

Feature / responsibility: All features, SYS-02, SYS-04

Establish / verify: S1 onward

Planned verification: AC-to-planned/actual-test audit and meaningful unit/API/DB/E2E results.

NFR-06

Feature / responsibility: F-06, F-08-10, SYS-03

Establish / verify: S2; regression S3

Planned verification: Raw-text non-exposure, separately counted per-question privacy, sparse/differencing cases, storage separation and every result-consumer projection.

NFR-07

Feature / responsibility: F-01-10, SYS-04

Establish / verify: Basic S1; extend S2; final S3

Planned verification: Selected keyboard/viewport E2E plus explicit manual checks, extending to starter and note screens when implemented.

NFR-08

Feature / responsibility: SYS-02, SYS-04

Establish / verify: S1; CI/CD Lab 5 onward

Planned verification: Issue/PR/review history, release commit and test/build evidence audit.

NFR-09

Feature / responsibility: F-07, F-10, SYS-01, SYS-04

Establish / verify: S2 template; S3 note

Planned verification: Source revision/copy mutation cannot change stored survey/answer snapshots; note uniqueness/version conflicts and unchanged underlying results.

Coverage gaps and change status

Every baseline FR/BR/NFR has a planned responsibility/verification allocation. F-01/F-02/F-03/F-05 document packages merged via PR #29/#31/#32/#33; F-04 is a new local draft below. Complete cross-feature mapping/agreements remain #5 follow-through. #15 records actual tooling checks separately; no F-01-F-05 runtime acceptance test or accepted Sprint 1 release is claimed.

Unresolved gates are in decisions (decisions.md). Common Part E coordination now has draft register (sprints/sprint-1/README.md), conventions (sprints/sprint-1/shared-contract.md) and Product DoD (sprints/sprint-1/product-dod.md), supporting NFR-03/05/07/08 and SYS-01-04. They add no FR/BR/NFR IDs and do not close #5 or prove human adoption. No approved requirement removal or completed test is claimed. After contracts are written, extend this matrix with AC/test IDs; after execution, add actual file/test name, command or run, tested commit, result and evidence location.

F-01 draft contract trace (Issue #10)

All rows are F-01 / Sprint 1. The feature contract (sprints/sprint-1/f-01-authentication.md) contains the full stable 20-AC-to-test map; the STS (sprints/sprint-1/f-01-authentication-sts.md) defines 47 planned cases with levels, inputs/preconditions, action and expected outcome. Shared Product DoD and teammate acceptance remain #5 gates. Actual test file/name, tested implementation SHA/run, observed result and evidence location for every row are **Not run / not available**; these draft specifications do not constitute Part F.

FR-01 / SYS-01

Draft AC links: AC-F01-01, 03-09, 16-17, 19

Planned verification / boundary: Bootstrap/login/me/logout, hash/session persistence, absolute expiry, restart/replay and UI session-loss cases: TEST-F01-I01, I03-I09, I16-I21, I24, I26-I28, E01-E03, E05; unit policy cases.

BR-01 / SYS-03

Draft AC links: AC-F01-02, 06-12

Planned verification / boundary: Strict input/identity trust, CSRF/Origin, session/role/scoped guard cases: TEST-F01-U01-U04, U07, I06-I17, I25.

BR-02 / SYS-03

Draft AC links: AC-F01-08, 12

Planned verification / boundary: TEST-F01-U04, I09-I12, I15 establish trusted identity/guard behavior; H01-H04 require real F-02-F-05 routes/DB under dependent work and #22. No full ownership/cross-response coverage is claimed from a harness.

NFR-01 / SYS-03

Draft AC links: AC-F01-05, 08-14, 18-19

Planned verification / boundary: Credential/guard/failure/cache/log/throttle checks in TEST-F01-U03-U06, I02, I09-I19, I21-I26, E02-E05 and actual domain H01-H04.

NFR-03 / SYS-01

Draft AC links: AC-F01-11, 17

Planned verification / boundary: TEST-F01-I02, I20, I24-I25, M02; #15/#16 must provide actual runtime/lockfile/schema/setup evidence before implementation readiness is accepted.

NFR-05 / SYS-02

Draft AC links: AC-F01-20; all behavior AC

Planned verification / boundary: All AC map to STS; TEST-F01-M03 audits actual unit/API-DB/selected UI results and real TDD history later. Existing planned counts are not runner results.

NFR-07 / SYS-04

Draft AC links: AC-F01-15-16

Planned verification / boundary: TEST-F01-E01-E05 and M01; actual keyboard/viewport/state checks at 360px/1280px, with supplementary SDS reflow/zoom review.

NFR-08 / SYS-02

Draft AC links: AC-F01-20

Planned verification / boundary: TEST-F01-M03: actual preimplementation contract/test-design version, substantive human review/integration and release-SHA-linked verification under #25/#26.

Instructor-theme coverage cross-check

F-04 draft mapping: contract (sprints/sprint-1/f-04-responses.md) AC-F04-01-25 -> STS (sprints/sprint-1/f-04-responses-sts.md) TEST-F04-U01-U06/I01-I21/E01-E04/H01-H03/M01-M02, covering FR-05/06, BR-01-08/10/11/14 and NFR-01/02/05/07. All 36 are Planned/Not run; actual files/commands/implementation SHA/results remain unavailable. Full bidirectional AC/test mapping is in the paired files; no new requirement IDs or runtime PASS is added. #15 setup safety/liveness/driver/browser checks are reported only in workspace verification (sprints/sprint-1/workspace-verification.md).

Real full-stack persistence and meaningful domain workflow

LECTRA requirements / allocation: FR-01-07, FR-12; F-01-05/SYS-01 in S1.

Limit of current evidence: Planned architecture/requirements; no running application.

Owner and respondent permissions, ownership and cross-response rejection

LECTRA requirements / allocation: BR-01-02, BR-23, NFR-01; S1 foundation, regress all additions.

Limit of current evidence: Matrix and planned negative cases, no API result yet.

Define surveys, control eligibility and validation

LECTRA requirements / allocation: FR-02-05, BR-03-09; S1; richer questions/subsets FR-09/S2.

Limit of current evidence: Contracts/AC/STS still needed before coding.

Reject repeat and unpublished/closed responses

LECTRA requirements / allocation: BR-04-08, BR-11, NFR-02; S1 real DB concurrency.

Limit of current evidence: Transaction design; no executed concurrency test.

Identified and documented/tested anonymous modes

LECTRA requirements / allocation: FR-08, BR-14-15, NFR-06; identified S1, anonymous S2.

Limit of current evidence: Anonymous detailed privacy contract gate remains open.

Aggregate results, analysis and export

LECTRA requirements / allocation: FR-07/S1, FR-10/S2, FR-11/S3, BR-12-13/16/18-19.

Limit of current evidence: Planned, not working analysis or exported output.

Contracts, TDD, automated verification and reviewed releases

LECTRA requirements / allocation: NFR-05/08, SYS-02/04; every sprint.

Limit of current evidence: This PR is planning documentation; not Part E/F completion.

Starter Questionnaire (FR-13) and Teaching Improvement Notes (FR-14) are product extensions requested for consideration, not instructor theme mandates. They add no Sprint 1 implementation requirement.

Extending this matrix without inventing history

For each contract AC, add rows with `Requirement → Feature → Sprint → AC ID → planned test ID/level → actual test file/name → tested commit/run → result → evidence location`. Use `Not specified` before the contract exists, `Not run` before execution, and actual PASS/FAIL/SKIP only after observing output. Link manual checks separately from automated tests. Maintain failed/skipped cases rather than removing them from traceability.

Preserve stable IDs when wording changes; record meaningful changes in the decision log and update all dependent contracts/tests. Append IDs for new requirements. Do not reuse a retired ID for a different rule or overwrite the assessed release reference with a later commit.

Review recommendation trace, not new requirement IDs

P10 is retained in F-07/FR-13/BR-17; P05 in F-07/F-09/FR-11/BR-18-19; P14 is simplified in F-10/FR-14/BR-20-22 with sharing deferred. P15 is incorporated as exploratory SYS-04/S3 usability evaluation supporting FR-07/FR-14 user goals and NFR-07 context, not a new measured NFR or mandatory Lab 6 replacement. Exact dispositions/value/trade-offs are in the review register (baseline-review.md); the separate Initial Review REV-08 concerns explicit pre-contract decision records. Attribution uses the owner's descriptions of the teammate's reports; direct full-report verification remains OPEN-11. No test, session or original-report access is implied by these mappings.

Part C - System-Level SDS

docs/system-sds.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - System-Level Software Design Specification

Version: 0.6 (2026-11-06). Status: consolidated planning draft, not implemented or teammate-approved. Retains the cool-color theme, academic hierarchy and revision 0.5 privacy/note/scale/copy/request-limit decisions. Revision 0.6 adds bounded P15 usability evaluation to existing QA with qualified teammate-report provenance; it adds no application feature or instructor mandate. Feature-level contracts and application execution remain separate. Related issue: #3 (https://github.com/Maibokdaimhai/LECTRA/issues/3). Baseline: SRS (srs.md), decisions (decisions.md), features (features.md).

1. Stack and components

Browser

Selected tools: React, Vite, TypeScript; ordinary CSS

Responsibility: Role-specific screens, accessible inputs, client feedback and API calls. No authoritative permission decisions.

API/application

Selected tools: Node.js, Express, TypeScript, Zod

Responsibility: Session-derived identity, validation, authorization, survey transitions, response transactions and results.

Authentication

Selected tools: express-session, connect-pg-simple, Argon2id

Responsibility: Opaque cookie session with PostgreSQL storage; password hashing and revocable logout.

Domain persistence

Selected tools: PostgreSQL, Prisma ORM

Responsibility: Domain queries, migrations, constraints and atomic transactions. Reviewed parameterized SQL is allowed for row locks/constraints where needed.

Tests

Selected tools: Vitest, Supertest, Playwright

Responsibility: Unit logic, HTTP API with real PostgreSQL integration, selected browser journeys.

Delivery plan

Selected tools: Docker, GitHub Actions, GCP Cloud Run and Cloud SQL for PostgreSQL

Responsibility: Proposed Lab 5 packaging, quality gates, application runtime and durable database. No infrastructure has been created.

The frontend/test/database choices come from the project owner. The API/session/hash/validation/API-test additions fill missing responsibilities under explicit permission to choose additions. Compatible versions and type definitions must be pinned during authorized setup, before API-specific implementation contracts are finalized. No package is installed by this document.

The monolith has three logical layers, not three mandatory servers. In development, Vite proxies `/api` to Express. In release, Express serves the built frontend and `/api` on one origin. PostgreSQL is external to the application process/container. Business rules reside in application services plus database constraints, never only in React.

Diagram source (complete, with entity/edge labels):

```
flowchart LR
    UI[React browser UI] -->|Same-origin HTTP /api| API[Express routes and session guards]
```

```
API --> APP[Survey / Response / Results services]
APP -->|Prisma + parameterized SQL| DB[(PostgreSQL domain data)]
API --> SESSION[PostgreSQL session store]
SESSION --> DB
```

Proposed repository layout after setup: `apps/web`, `apps/api`, `prisma`, `tests/e2e`, and `docs`. This is a plan; those application directories do not exist yet. Use npm workspaces and one lockfile unless a recorded compatibility issue requires a different package-manager decision.

2. Major data model

User

Important fields: id, email, passwordHash, role, displayName

Relationships / constraints: Unique normalized email; role OWNER or RESPONDENT.

Course

Important fields: id, code, title

Relationships / constraints: Unique course code; academic context only, not an ownership boundary. Seeded read-only context.

Section

Important fields: id, courseId, term, sectionCode, ownerId

Relationships / constraints: FK to Course and instructor; unique `(courseId, term, sectionCode)`; each owner accesses only their Sections, including when another owner teaches the same Course.

Membership

Important fields: sectionId, studentId

Relationships / constraints: Unique pair; student role validated on seed/use. No attendance/grade data.

Lecture

Important fields: id, sectionId, title, lectureDate, sequence

Relationships / constraints: Belongs to one Section; local calendar date plus ordering sequence. Unique `(sectionId, sequence)`; dates need not be unique.

Survey

Important fields: id, lectureId, ownerId, title, status, mode, definitionRevision, publishedAt, closedAt, sourceTemplateVersionId/sourceSurveyId/sourceSurveyRevision nullable

Relationships / constraints: Unique lectureId; owner matches Section owner. S1 definitionRevision increments on Draft-definition edits; source metadata added S2 identifies the copied snapshot, not a live link.

Question

Important fields: id, surveyId, position, prompt, type, required, category nullable, ratingMin/ratingMax, ratingMinLabel/ratingMaxLabel, scaleInterpretation, sourceTemplateQuestionId nullable, metricDefinitionId nullable

Relationships / constraints: Unique survey/position; S1 stores immutable rating meaning/range/anchors with the survey. Type RATING/TEXT in S1, SINGLE_CHOICE in S2. Provenance/metric metadata are S2 additions; numeric equality alone does not imply comparable meaning.

ChoiceOption (S2)

Important fields: id, questionId, position, label

Relationships / constraints: Unique question/position; selected answer must belong to its question.

SurveyEligibility

Important fields: surveyId, studentId

Relationships / constraints: Unique pair; publication snapshot, immutable after publish.

Participation

Important fields: surveyId, studentId

Relationships / constraints: Unique pair and FK to eligibility. The participation row is the submission-status source and carries no anonymous answer ID or per-submission timestamp.

ResponseBundle

Important fields: id, surveyId, identifiedStudentId nullable

Relationships / constraints: S1 identifiedStudentId is required by mode-aware service validation and references eligibility. In anonymous mode it must be null. No precise per-bundle submission timestamp.

Answer

Important fields: bundleId, surveyId, questionId, ratingValue/textValue/optionId

Relationships / constraints: Unique bundle/question; composite foreign keys keep bundle and question in the same survey; one type-specific value only; rating range CHECK 1-5.

Session store

Important fields: sid, session payload, expiry

Relationships / constraints: Managed by connect-pg-simple in a separately named table, schema created with versioned SQL migration rather than implicit production auto-create.

QuestionnaireTemplate (S2)

Important fields: id, key, name

Relationships / constraints: Unique stable key, e.g. `lecture-feedback`; seeded catalog, no public authoring API.

TemplateVersion (S2)

Important fields: id, templateId, version, state

Relationships / constraints: Unique template/version; published versions are immutable; retiring a version prevents new selection but preserves old provenance.

TemplateQuestion / TemplateOption (S2)

Important fields: id, templateVersionId/questionId, position, category, prompt, type, required, min/max/anchor labels, scaleInterpretation/options, metricDefinitionId nullable

Relationships / constraints: Immutable source definitions preserve the same scale meaning as copied survey questions; copying creates independent rows with new IDs.

MetricDefinition (S2)

Important fields: id, key, version, canonicalPrompt, type, min/max, anchor labels, interpretation, category

Relationships / constraints: Immutable measurement identity. Source-version lineage alone is not comparability. Non-rating definitions have no numeric trend in the initial baseline.

ImprovementNote (S3)

Important fields: id, surveyId, ownerId, issueSummary, plannedAction, status, revision, createdAt, updatedAt, appliedAt nullable

Relationships / constraints: Unique surveyId; owner matches survey owner; default Planned, revision starts at 1; owner-private. No reflection requirement, reversal reason or separate history entity.

Database CHECKs/foreign keys/unique constraints cover what can be expressed locally. Cross-table rules (e.g. owner/Section consistency, answer type, response mode, required-question completeness) are checked by the authoritative service inside the transaction. Composite keys and relevant FK targets are specified fully in feature contracts and migrations before implementation. A unique index on `(surveyId, identifiedStudentId)` is additional protection for identified bundles; anonymous duplicate prevention uses Participation uniqueness.

`Classroom` in previous drafts is replaced by `Section`, not retained as a second overlapping entity. The repository has no implemented schema or migration yet; this is a planning correction, not a claim that a production migration ran. Resolve access through `Survey` → `Lecture` → `Section` → `owner` and validate redundant `Survey.ownerId`/`ImprovementNote.ownerId` consistently; never trust the supplied Course, Section or owner ID. Course-level aggregation always starts from owned Sections.

Diagram source (complete, with entity/edge labels):

```
erDiagram
    COURSE ||--o{ SECTION : offers
    USER ||--o{ SECTION : owns
    SECTION ||--o{ MEMBERSHIP : enrolls
    USER ||--o{ MEMBERSHIP : joins
    SECTION ||--o{ LECTURE : contains
    LECTURE ||--o| SURVEY : evaluates
    SURVEY ||--o{ QUESTION : defines
    SURVEY ||--o{ SURVEY_ELIGIBILITY : snapshots
    SURVEY_ELIGIBILITY ||--o| PARTICIPATION : records
    SURVEY ||--o{ RESPONSE_BUNDLE : collects
    RESPONSE_BUNDLE ||--o{ ANSWER : contains
    QUESTION ||--o{ ANSWER : receives
    QUESTIONNAIRE_TEMPLATE ||--|{ TEMPLATE_VERSION : versions
    TEMPLATE_VERSION ||--|{ TEMPLATE_QUESTION : defines
    TEMPLATE_QUESTION o|--o{ QUESTION : copied_from
    METRIC_DEFINITION o|--o{ QUESTION : measures
    SURVEY ||--o| IMPROVEMENT_NOTE : informs
```

The diagram intentionally has no Participation → anonymous ResponseBundle association. Identified bundles have a student FK as stated in the table; the absence of a drawn link is not a claim of anonymous Sprint 1 storage. A template/question provenance link points to an immutable source definition, never to live display text.

Published questions/eligibility are immutable and cannot be removed through application routes. Draft deletion cascades Draft questions only after owner/state checks. Published records have no hard-delete application operation. Schema migration and deletion behavior must preserve submitted associations.

3. Transactions and concurrency

1. Every Draft mutation, deletion and publication locks the same Survey row before checking state. Publish validates questions, owned Course/Section/Lecture and candidate membership, creates the eligibility snapshot, then commits Published state atomically. This prevents an edit racing publication from changing a published question after a stale Draft check.

2. Submit locks the Survey row before reading its authoritative state, verifies the session student is eligible, checks typed answers, inserts unique Participation, bundle and all answers, and commits together.

3. Close takes the same row lock and changes Published to Closed. The lock/commit order defines BR-11, not arrival order at the browser or a client timestamp.

4. Concurrent duplicates are rejected by the database unique constraint even if both requests passed an earlier check. Map the constraint to a safe domain error; no partial answers remain.

5. New survey creation, starter application and duplicate-to-Draft check the owned target lecture and rely on unique `Survey.lectureId` under concurrency. Copy all definitions or none; no partly populated Draft is returned as successful.

6. Note creation checks Closed/result-access policy and uses unique surveyId. Note edits check owner and expected revision, updating fields/status/essential timestamps and revision atomically. A stale edit returns 409 without overwriting newer content; no detailed transition-history write is required.

Serialize per-survey submissions initially to keep correctness simple for a small classroom. Keep lock duration short; do not hash passwords, call external services or render results while holding it. Retry recognized deadlock/serialization failures only with a bounded policy defined in the contract. A lost confirmation never permits a second write; the student checks their persisted submission status.

Prisma transaction APIs depend on the pinned ORM version. This SDS specifies behavior and locking without assuming a particular version's client syntax.

4. Authentication and session lifecycle

- Login accepts email/password, compares an Argon2id password hash, returns a generic invalid-credentials message and never logs credentials. Seeded accounts are sufficient; no signup/recovery endpoints.

- Regenerate the session ID after successful authentication. Store only the minimum server-side identity data; re-resolve user role/permissions from trusted storage on protected requests.

- Use PostgreSQL session storage, not process-local MemoryStore. Set `resave: false` and `saveUninitialized: false`; pin and verify compatible middleware/store versions.

- Cookie: `HttpOnly`, `SameSite=Lax`, `Path=/`, fixed eight-hour expiry without rolling renewal; `Secure` in HTTPS deployment. Local HTTP development may disable Secure explicitly. Store authentication time and enforce the absolute eight-hour age server-side as well; cookie/store refresh behavior must not silently extend the authenticated lifetime.

- `GET /api/auth/me` returns the current safe user identity or 401. Expired or missing sessions cannot access protected routes.

- `POST /api/auth/logout` destroys the server session and clears the cookie; subsequent replay of that cookie is unauthorized. Logout is idempotent.

- State-changing browser requests require a synchronizer CSRF token in `X-CSRF-Token`, including login/logout, plus Origin checking against the configured application origin. A session endpoint bootstraps the token. Do not treat SameSite alone as the complete CSRF control.

- Configure trusted proxy handling for the actual Cloud Run path; do not trust arbitrary forwarded headers. Add bounded login throttling before public deployment, with limits and tests specified in the authentication contract.

5. Role and record access matrix

All entries are backend rules. Inaccessible record identifiers return 404 to avoid confirming existence; an authenticated wrong role for a role-only operation returns 403; unauthenticated access returns 401. No private data accompanies rejection.

Login/logout/me

Respondent: Own session

Owner: Own session

List contexts

Respondent: Eligible Published/Closed surveys only

Owner: Course context through owned Sections, owned lectures/surveys only

Read Draft / create/edit/delete Draft

Respondent: Denied

Owner: Own only

Publish/close

Respondent: Denied

Owner: Own only

Read survey for answering

Respondent: Eligible Published/Closed; submitting requires Published

Owner: Own preview; cannot submit as student

Submit response

Respondent: Eligible, Published, not already submitted

Owner: Denied

Read submission status

Respondent: Own only

Owner: No per-student participation endpoint

Read identified answers

Respondent: Own only

Owner: No respondent-linked answer endpoint

Read anonymous answers by identity

Respondent: No such operation

Owner: No such operation

Read results/text

Respondent: Denied

Owner: Own; count while Published; Closed identified text allowed; anonymous text never; quantitative questions use mode-specific release policy

Read raw anonymous text

Respondent: No baseline operation

Owner: Denied through every result surface, regardless of survey count

Export aggregates (S2)

Respondent: Denied

Owner: Same constraints as results

Preview starter catalog/version (S2)

Respondent: Denied

Owner: Read published selectable seeded versions; no template-edit API

Apply starter / duplicate survey (S2)

Respondent: Denied

Owner: Own target lecture; source survey must also be owned; create Draft only

Read history/trends (S3)

Respondent: Denied

Owner: Owned Sections only; comparison/suppression rules still apply

Create/read/edit improvement note (S3)

Respondent: Denied, including eligible respondents

Owner: Own Closed survey with accessible results; anonymous requires at least one releasable quantitative question; private/revision checks apply

Share improvement note

Respondent: No baseline operation

Owner: No baseline operation

6. UI and API conventions

Main screens: login; student eligible-survey list, answering form and confirmation/own-status view; instructor survey list, Draft editor, survey detail/publication/closing controls, and results. Course/Section/Lecture context is visible in creation and answering flows. Later additions: mode selection, starter preview/apply, single-choice/subset controls, CSV action, history filters/trends and owner-private improvement note panel.

Every screen defines loading, empty, validation, unauthorized/expired-session and safe unexpected-error states. Disable repeated UI submission for feedback, but rely on backend/DB protection. Clear private cached UI state on logout. Result views never receive hidden identity fields. Do not display blank required text as valid or a null mean as zero.

6.1 Visual theme: cool blue and teal

The project owner requested a cool-color theme. LECTRA uses a calm, readable light interface with blue primary actions, teal secondary emphasis, pale slate backgrounds and dark slate text. This palette is a project design decision, not an instructor requirement. Apply it consistently to both instructor and student screens; roles differ through navigation and permissions, not separate branding.

6.1.1 Theme intent and implementation boundary

The visual priority is a readable lecture-feedback form and an understandable results view. Use blue to identify the next action, teal for supporting emphasis and slate for structure. Do not make every card, heading or statistic compete with the primary action. Each action group has at most one primary button; navigation and result panels are quieter than the task content.

All measurements and component choices below are LECTRA design specifications. They do not add an instructor-imposed screen quota, require a UI framework or imply an implemented design system. CSS custom properties and small shared React components are sufficient. Sprint 1 uses the same theme for both roles and supports the existing feature scope only.

6.1.2 Foundations and color tokens

Use semantic CSS custom properties so components share tokens rather than repeating arbitrary hex values. The table specifies the planned values; it is not an implemented stylesheet.

`--color-bg`

Value: `#F8FAFC`

Use: Page background.

`--color-surface`

Value: `#FFFFFF`

Use: Cards, forms, dialogs and tables.

`--color-surface-muted`

Value: `#F1F5F9`

Use: Table headers, secondary panels and subtle grouping.

`--color-border-subtle`

Value: `#CBD5E1`

Use: Decorative separators; not the sole boundary of an interactive control.

`--color-border-control`

Value: `#64748B`

Use: Input and unselected rating-control boundaries on light surfaces.

`--color-text`

Value: `#0F172A`

Use: Headings, body text and labels.

`--color-text-muted`

Value: `#475569`

Use: Supporting text, descriptions and readable placeholders.

`--color-primary`

Value: `#1D4ED8`

Use: Primary actions, links, active navigation and selected rating controls.

`--color-primary-hover`

Value: `#1E40AF`

Use: Primary action hover/pressed emphasis.

`--color-on-primary`

Value: `#FFFFFF`

Use: Text/icons on solid primary buttons and selected rating controls.

`--color-primary-soft`

Value: `#DBEAFE`

Use: Selected navigation backgrounds; pair with primary-colored text.

`--color-secondary`

Value: `#0F766E`

Use: Teal secondary emphasis and Published badges.

`--color-secondary-soft`

Value: `#CCFBF1`

Use: Teal information surfaces; pair with secondary-colored text.

`--color-focus`

Value: `#2563EB`

Use: Keyboard focus outline with separation from the control.

`--color-primary-active`

Value: `#1E3A8A`

Use: Pressed primary controls; keep white text.

`--color-secondary-hover`

Value: `#115E59`

Use: Hover on a solid teal control, if used; keep white text.

`--color-disabled-bg`

Value: `#E2E8F0`

Use: Inactive controls with explicit disabled semantics.

`--color-disabled-text`

Value: `#475569`

Use: Readable inactive labels; never use opacity on the whole control as the only disabled treatment.

`--color-backdrop`

Value: `rgb(15 23 42 / 40%)`

Use: Overlay behind a modal dialog; never behind ordinary page text.

Neutral reference scale: slate 50 `#F8FAFC`, 100 `#F1F5F9`, 200 `#E2E8F0`, 300 `#CBD5E1`, 400 `#94A3B8`, 500 `#64748B`, 600 `#475569`, 700 `#334155`, 800 `#1E293B`, 900 `#0F172A`. Lighter steps are surfaces/decorative colors, not substitutes for readable body text.

Semantic feedback may use green, amber and red even though the overall theme is cool. Preserve recognizable meaning rather than forcing every error or warning into blue.

6.1.3 Semantic states

Success / submission confirmed

Foreground: `#166534`

Background: `#F0FDF4`

Required accompanying content: Check icon and explicit confirmation text.

Warning / irreversible closing

Foreground: `#92400E`

Background: `#FFFBEB`

Required accompanying content: Warning icon and consequence text.

Error / invalid answer / denied action

Foreground: `#B91C1C`

Background: `#FEF2F2`

Required accompanying content: Error text, field association where relevant, and recovery guidance.

Draft or Closed

Foreground: `#475569`

Background: `#F1F5F9`

Required accompanying content: Explicit Draft/Closed label; Closed is not inherently an error.

Published

Foreground: `#0F766E`

Background: `#CCFBF1`

Required accompanying content: Explicit Published label; do not imply an ineligible student may answer.

The semantic foreground/background pairs also define reusable `success`, `warning`, `error`, `neutral` and `published` tokens. Apply them to badges and inline messages consistently rather than inventing screen-specific colors. Icons supplement the literal state label; they do not replace it. Identified/Anonymous privacy labels use neutral or information styling and explicit disclosure, not a green shield implying a security guarantee.

Component and chart application principles:

- Primary buttons use white text on blue; secondary buttons use a white surface, blue text and a visible control border. Destructive actions use the error color and explicit wording rather than a blue primary treatment.

- Form controls use white surfaces, dark text and control borders. Focus uses a visible 2px blue outline with a 2px surface-colored offset. Selected ratings include a checked/selected indicator and accessible state, not color alone. Disabled controls remain identifiable and expose their disabled state programmatically.

- Survey-state badges, validation and loading/submission feedback always include text or an icon with an accessible name. Color never encodes permission, privacy mode or completion by itself.

- Rating distributions use blue bars (`--color-primary`) on a light surface with visible score labels 1-5 and numeric counts. A single ordered series does not need five different colors. Compare compatible series with blue/teal plus distinct labels or patterns and an accompanying data table. Do not assume a higher pacing score is necessarily better or invent an overall

quality score from unrelated questions.

- Reserve saturated colors for actions, selection and essential information. Keep reading and answering surfaces predominantly white/pale slate without decorative gradients behind text.

6.1.4 Typography, spacing and surfaces

Use a local system sans-serif stack (`system-ui`, `-apple-system`, `"Segoe UI"`, `Tahoma`, `sans-serif`) with Thai-capable platform fallbacks; no external font service is required. Use relative CSS font units with the pixel equivalents below at the default 16px root. Do not shrink the root to defeat browser text-size preferences. Verify actual Thai/English fallback rendering on the target browser; avoid forced uppercase and decorative letter spacing in Thai text.

Page title

Size: 32px / 2rem desktop; 24px / 1.5rem narrow

Weight: 700

Line height: 1.35

Use: One page-level heading.

Section heading

Size: 24px / 1.5rem

Weight: 600

Line height: 1.4

Use: Major editor/results sections.

Card or question heading

Size: 20px / 1.25rem

Weight: 600

Line height: 1.5

Use: Survey card title or question group.

Body and entered values

Size: 16px / 1rem

Weight: 400

Line height: 1.6

Use: Form content, instructions, text feedback.

Field label and button

Size: 16px / 1rem

Weight: 500-600

Line height: 1.5

Use: Persistent labels and action names.

Supporting text and badge

Size: 14px / 0.875rem

Weight: 400-500

Line height: 1.5

Use: Help, metadata and status. Never the only presentation of a critical instruction.

Result number

Size: 32px / 2rem

Weight: 700

Line height: 1.25

Use: Count or mean, with a visible label and denominator where relevant.

Keep long reading blocks near 65 characters per line where practical; allow Thai line wrapping rather than forcing a character count. Feedback uses preserved line breaks with wrapping and is rendered as plain text, never interpreted HTML. Do not truncate a student's submitted answer in the answer-reading view.

Spacing scale

Value / rule: `4, 8, 12, 16, 24, 32, 48, 64px`; use named tokens in multiples of the 4px base.

Field label ☐ control

Value / rule: 8px.

Control ☐ helper/error

Value / rule: 8px; keep field explanation directly attached to its control.

Fields / question blocks

Value / rule: 24px between fields, 32px between question groups.

Card padding

Value / rule: 24px normally, 16px below 640px.

Radius

Value / rule: 8px controls; 12px cards/dialogs; full radius only for compact badges, not all buttons.

Border

Value / rule: 1px; subtle for decorative card/table separation, control border for active input identification.

Card elevation

Value / rule: None by default; optional `0 1px 2px rgb(15 23 42 / 6%)` for a raised card.

Dialog elevation

Value / rule: `0 16px 40px rgb(15 23 42 / 16%)` plus the modal backdrop.

Layer order

Value / rule: Base content 0, sticky navigation 10, floating menus 20, modal backdrop 30, modal dialog 40. Toast/status messages must not cover active dialog controls.

Control height

Value / rule: Minimum 44px; multiline text uses at least 4 visible lines and vertical resizing.

Do not rely on shadows to identify inputs. On a white card, white inputs still have the control border. Do not hard-code component heights around text that may wrap or grow with browser zoom.

Contrast targets follow WCAG 2.2 AA: normal text at least 4.5:1, large text at least 3:1, and essential control/state indicators at least 3:1 against adjacent colors. Calculated reference pairs are white on primary blue 6.70:1, white on teal 5.47:1, dark text on page background 17.06:1, muted text on white 7.58:1, and control border on white 4.76:1. Semantic text/background pairs above exceed 4.5:1. These are palette calculations only, not proof that an unimplemented UI meets accessibility requirements. Recheck actual combinations, focus rings, hover states and chart indicators during implementation and selected UI/manual verification under NFR-07.

Sprint 1 implements the light theme only. A dark-mode toggle is outside the current baseline; any later dark theme requires its own surface/text/semantic tokens and contrast review rather than automatic color inversion.

6.1.5 Interactive component specification

Primary button

Default: Blue surface, white label, 12px horizontal padding, 8px radius, ≥44px high.

Hover / pressed: Primary-hover / primary-active; no movement that changes layout.

Focus / selected: Shared focus outline.

Disabled / busy / error: Slate disabled tokens plus disabled semantics. Busy retains action text with progress wording and blocks repeated activation.

Secondary button

Default: White surface, primary text, control border; same sizing as primary.

Hover / pressed: Muted surface; primary text remains readable.

Focus / selected: Shared outline; selection only for genuinely toggleable controls.

Disabled / busy / error: Same disabled treatment as primary.

Text action / link

Default: Primary text; links within prose underlined.

Hover / pressed: Darker primary text, underline retained.

Focus / selected: Shared outline and meaningful accessible name.

Disabled / busy / error: Render a disabled action as a button when appropriate; do not leave a fake clickable link.

Destructive button

Default: Error foreground on white with error border for a secondary destructive choice; solid error color with white label only for the final destructive confirmation.

Hover / pressed: Darken within the error family; no blue hover override.

Focus / selected: Shared visible focus treatment.

Disabled / busy / error: Preserve the reason the action is unavailable; never present destructive completion as success before server confirmation.

Text input / textarea

Default: White surface, text token, control border, 12px internal padding. Persistent label above.

Hover / pressed: Border may use primary; no shadow required.

Focus / selected: Primary border plus shared focus outline.

Disabled / busy / error: Validation adds error border, linked message and `aria-invalid`; errors remain visible until corrected/revalidated.

Rating group

Default: Five equal-height labelled radio options, white surface and control borders.

Hover / pressed: Muted/blue-soft surface without implying committed selection.

Focus / selected: Blue/white selected option plus checked indicator; native radio keyboard behavior.

Disabled / busy / error: Display group-level validation; never preselect a score.

Single-choice group (S2)

Default: Labelled option radio list; each option wraps inside a ≥44px target.

Hover / pressed: Muted/blue-soft surface without selecting until activation.

Focus / selected: Checked indicator and primary emphasis; native radio keyboard behavior.

Disabled / busy / error: Group-level errors; optional questions can remain unanswered.

Badge

Default: Semantic foreground/background, 8px horizontal/4px vertical padding, text label.

Hover / pressed: No hover behavior unless it is actually a control.

Focus / selected: Static badges are not tab stops.

Disabled / busy / error: State remains readable; use actual survey/participation state from the backend.

Survey card

Default: White surface, subtle border, 12px radius, title and metadata, one clear action.

Hover / pressed: Only interactive parts receive control hover styling.

Focus / selected: A named title link or explicit action, not multiple nested interactive card layers.

Disabled / busy / error: Closed/submitted status keeps a suitable view action; it does not look like a fresh submit action.

Shared focus treatment is a 2px `--color-focus` outline with a 2px surface-colored gap. Check it on every actual surrounding surface; keep it outside clipping containers and visible beneath sticky headers. Use real `button`, `a`, `input`, `textarea` and radio controls before adding ARIA. Icon-only controls need an accessible name and a ≥44px hit area; decorative icons are hidden from assistive technology. No tooltip is required to understand a core action.

Question validation appears after an attempted submission or after the user leaves an edited field, rather than immediately marking an untouched empty form as wrong. On failed submission, show an error summary with links to invalid fields and move focus to it. Keep all entered answers available while validation or a recoverable request error is shown. A score is required only when the question's stored required flag says so. Optional rating/single-choice groups provide an explicit `Clear answer` control after selection; required groups do not silently default to a score. Clearing removes the value rather than sending null as an invented answer.

6.1.6 Responsive application shell

The following breakpoints are layout choices, not new supported-device features. Build mobile-first and verify at 360px and 1280px as specified in NFR-07; also inspect 320px reflow and 200% browser zoom during final UI review.

Below 640px

Navigation and content: Compact header; visible labelled navigation links wrap beneath it. No sidebar or new drawer interaction is required. Use 16px page gutters.

Form / results behavior: Single column; full-width primary action; rating options retain five equal columns at ≥44px each; question text wraps above them. Charts and feedback cards stack.

640-1023px

Navigation and content: Header navigation and 24px page gutters; optional two-column survey-card grid if content fits.

Form / results behavior: Answering form stays single column. Summary metrics may use two columns.

1024px and above

Navigation and content: Up to 240px instructor navigation column, with a content region capped at 1200px and 32px gutters. Student task navigation remains compact.

Form / results behavior: Survey lists and metrics may use grids. Answering form is capped at 760px; login card at 440px; an editor preview is optional, not Sprint 1 scope.

Do not force an answering form into multiple question columns. Header actions wrap with labels intact. Tables may have their own labelled horizontal scroll container when a genuinely tabular view cannot reflow; the page itself and ordinary forms must not overflow horizontally. Place essential action buttons outside table-scroll regions. Long course codes, titles, errors and Thai text must wrap without covering adjacent controls.

Avoid a fixed mobile submit bar in Sprint 1; put the action at the end of the form so the on-screen keyboard does not hide a question or validation. On long forms, show the survey title/context and privacy disclosure before the first question; required-item count is allowed as a static hint, not a new progress-tracking feature.

6.1.7 Screen-by-screen theme application

Login

Content hierarchy and theme: Pale page background, white centred card, LECTRA name, brief purpose, labelled email/password fields. No decorative illustration is required.

Primary action and state handling: `Log in`; generic credential error in an inline error panel, no invented success state; preserve email but do not persist the password.

Student survey list

Content hierarchy and theme: Page title, Course/Section/Lecture context, survey cards with Published/Closed and own submission status as separate labels.

Primary action and state handling: `Answer survey` only when eligible, Published and not submitted; otherwise `View submission` where applicable. Closed-unsubmitted entries explain that collection ended.

Answering form

Content hierarchy and theme: Lecture title, privacy notice, required-question explanation, ordered white question sections and rating/text controls.

Primary action and state handling: `Submit feedback`; show a persistent busy state while sending and confirmation only after the API confirms persistence. No automatic reset on a recoverable error.

Submission confirmation / own record

Content hierarchy and theme: Success panel, survey/lecture title and persisted submission status. Own identified answers appear as readable content rather than enabled editing controls.

Primary action and state handling: `Back to surveys`; no edit/resubmit promise. Future anonymous mode shows participation status without a user-linked answer view.

Instructor survey list

Content hierarchy and theme: S1 owned current-work list and Course/Section/Lecture selectors; consistent state badges. Historical date/state search is S3/F-09.

Primary action and state handling: `Create survey`; no new historical-search screen is implied by context selection; empty state links to creation only when an owned lecture is available.

Draft editor

Content hierarchy and theme: Title/context first, ordered question blocks, question type/required controls, validation and saved Draft state.

Primary action and state handling: `Save draft`; place `Publish survey` in a distinct action group with an irreversible-structure-lock explanation. Do not show a saved label before persistence.

Published detail / closing

Content hierarchy and theme: Teal Published badge, read-only question structure and response count. Results/text are withheld until Closed.

Primary action and state handling: `Close survey` opens a warning dialog explaining that responses stop and reopening is unsupported. Keep the actual server state visible if closing fails.

Closed results

Content hierarchy and theme: Neutral Closed badge; labelled metrics, per-question distributions and text-feedback sections.

Primary action and state handling: No Sprint 1 export control. Future CSV is subject to the same result permissions; do not render a disabled placeholder as an implemented feature.

Starter selection (S2)

Content hierarchy and theme: Course/Section/Lecture context, blank-versus-starter choice, source name/version and four-category preview.

Primary action and state handling: `Use starter`; create an independent Draft, then use the existing editor. Never apply over an already populated Draft or update historical surveys silently.

History / trends (S3)

Content hierarchy and theme: Owned Course/Section filters, lecture dates/states, visible per-lecture counts and compatible-metric labels.

Primary action and state handling: Inspect a lecture or compatible series; show why hidden/incomparable data is excluded without exposing its values.

Teaching Improvement Note (S3)

Content hierarchy and theme: Private label, issue/action fields, simple Planned/Applied choice and essential timestamp/revision information in the owned Closed-results screen.

Primary action and state handling: `Save note`; no share/history/reversal-reason/reflection control. A stale edit preserves unsent text and offers reload/reapply, not silent overwrite.

A privacy notice uses blue-soft or muted surfaces, plain language and a visible mode label. For identified surveys, explain that answers are linked to the account in storage although owner results omit identity labels. For future anonymous surveys, show the reviewed limitations and minimum-count rule without implying that text cannot identify its author. The notice is informational; do not invent a consent checkbox or a legal assurance outside the baseline.

6.1.8 Results and chart presentation

- Label metrics explicitly: `Submitted responses`, per-question `Average rating`, and `Answered this question`. Do not confuse participation count with the number of answer rows or the per-question denominator.

- Render a missing mean as `No responses yet` or `No answers to this question`, according to the count. Never draw a zero-length chart that implies an observed rating of zero. Zero counts within a populated 1-5 distribution remain visible as numeric zeros.

- Use horizontal blue bars with score labels on the left and exact counts on the right. A labelled HTML table presents the same values below or beside the chart; tooltips are supplemental. Keep bar/axis labels outside light fills to avoid unreadable text overlays.

- A chart has a visible question heading, scale/context and a text description. At narrow widths, preserve labels/counts and reduce plot width before reducing text size. Do not rely on color differences to distinguish two series: use direct labels and patterns/line styles or separate small charts.

- Mean values show two decimal places under BR-12. Percentages are optional display calculations whose rounding must not change source counts; their denominator must be labelled. Do not add means for single-choice questions.

- Identified text feedback uses neutral white cards, the prompt and preserved line breaks without names/IDs/times. Anonymous raw text never reaches owner UI/API/export/analytics, including hidden DOM fields or note prefill.

- Future anonymous quantitative results are released per question, not by total survey count. A hidden question shows metadata and generic `Not enough anonymous data` text without its answered count, mean or distribution. Apply the same release decision in CSV and analytics; never return hidden values to the client. Sparse-bin handling and residual inference risks are specified in Section 7.

- History/trends remain Sprint 3. Only compare question series whose meaning and scale are explicitly compatible; a matching color or title does not establish comparability.

6.1.9 Loading, errors, dialogs and motion

Initial loading

Presentation: Muted static skeletons or progress text in the content region; preserve heading/navigation.

Recovery / interaction: Announce busy status without repeatedly interrupting screen-reader output. No invented result numbers.

Empty list / no results

Presentation: Text explaining whether there are no surveys, no eligible surveys, no submissions or suppressed results.

Recovery / interaction: Only show an action the current user can actually perform. Do not add decorative charts or sample values to a real results view.

Validation error

Presentation: Error summary plus field-level messages; error icon and text.

Recovery / interaction: Move focus to summary, allow links to affected fields, preserve entered values.

Network/server error

Presentation: Inline error panel with plain explanation; no SQL, stack, token or internal request details.

Recovery / interaction: Offer retry for safe reads. After an ambiguous submit timeout, check own persisted submission status before offering another send; never claim the first request failed without knowing.

Session expired / forbidden

Presentation: Clear expired-session or generic inaccessible-resource message as appropriate.

Recovery / interaction: Clear private cached content. Do not persist answer drafts in local storage by default; do not claim an unsent draft will survive login/logout.

Success

Presentation: Persistent confirmation or inline status tied to the successful operation.

Recovery / interaction: Move focus to the confirmation heading after submission. Use a polite live region for non-navigation save/status updates.

Confirmation dialog

Presentation: White surface, labelled title/description, visible Cancel and explicit final action.

Recovery / interaction: Trap focus only while modal, close with Escape/Cancel when idle, and restore focus to the trigger. Announce failure/busy state; dismissal during a request must not imply rollback.

Use 120-180ms color/border/opacity transitions for ordinary interaction feedback. Avoid large slides, parallax, animated charts and automatic motion. Respect `prefers-reduced-motion` by removing nonessential transitions and using static progress text instead of animation where practical. Never use motion as the only indicator that an answer was saved.

6.1.10 Implementation handoff and planned visual checks

The implementation should centralize tokens in a shared stylesheet and reuse small primitives such as Button, FormField, RatingGroup, StatusBadge, SurveyCard, InlineMessage and ConfirmDialog when their behavior is actually needed. These names are design guidance, not existing components or a requirement to install a component library. Keep role/eligibility decisions in the established application/API flow; styling never grants access.

Issue #5 feature contracts must select applicable checks from the matrix below and assign real AC/test IDs. The rows are planned verification, not new completed test evidence or a claim of full WCAG conformance.

Shared palette and state consistency

Verification method: Review actual computed component styles against semantic tokens; inspect default, hover, selected, disabled, busy and error examples.

Allocation: Sprint 1 relevant screens; regress later.

Readable text/control colors

Verification method: Calculate actual rendered foreground/background pairs, including muted text, error text, borders and focus adjacent surfaces.

Allocation: Sprint 1 initial palette; extend each changed screen.

Keyboard-only core journey

Verification method: Tab/focus order, Enter/Space buttons, radio arrow keys, error-summary links, modal entry/exit and confirmation focus using selected Playwright/manual checks.

Allocation: Sprint 1 selected journeys under NFR-07.

Responsive content

Verification method: Check login, answering, editor and results at 360px/1280px; inspect long Thai/English content, 320px reflow and 200% zoom during final UI review.

Allocation: Basic Sprint 1; final regression Sprint 3.

Truthful submission/result states

Verification method: Verify no premature success, retained inputs on recoverable validation errors, correct timeout-status recovery and no fake zero means.

Allocation: F-03-05 contracts and selected UI/API tests.

Privacy presentation and payloads

Verification method: Confirm owner results lack identity fields, future suppression hides both content and data, and notices match the implemented mode.

Allocation: Identified Sprint 1; anonymous/export Sprint 2.

Motion and announcements

Verification method: Inspect reduced-motion behavior, live-region output and absence of repeated/loading announcements.

Allocation: Relevant components in Sprint 1; final review Sprint 3.

No screenshot, browser check, component implementation or passing UI test is supplied by this specification change. Record actual verification results only after those checks run against an identified implementation version.

6.2 API conventions

API prefix `/api`; JSON bodies; server-generated IDs; session cookie rather than client-selected actor. Successful reads return `{ "data": ... }`; validation failures use `{ "error": { "code": "...", "message": "...", "fields": ... } }`. Never return stacks, SQL or credential/session values. Use 201 for creation/submission, 200 for reads/transitions, 204 for successful deletion/logout, 400 for malformed input, 401/403/404 for access, 409 for duplicate/state conflict and 422 for well-formed domain validation failure.

Candidate endpoint families, to be finalized with payloads in Issue #5:

Issue #5 now has a proposed shared engineering contract (sprints/sprint-1/shared-contract.md), Product DoD (sprints/sprint-1/product-dod.md) and contract register (sprints/sprint-1/README.md). They coordinate IDs, wire/error/pagination shapes, migration ownership, body/Unicode sizing, frozen scales, UI states and verification boundaries. These are reviewable team details, not accepted runtime configuration or replacements for each feature's exact contract. The existing SRS scope/security/privacy rules remain unchanged.

Session

Planned paths: `GET /api/auth/session`, `POST /api/auth/login`, `GET /api/auth/me`, `POST /api/auth/logout`

Context/discovery

Planned paths: `GET /api/courses`, `GET /api/sections`, `GET /api/sections/:id/lectures`, `GET /api/surveys`

Survey

Planned paths: `POST /api/surveys`, `GET/PATCH/DELETE /api/surveys/:id`, `POST /api/surveys/:id/publish`, `POST /api/surveys/:id/close`

Response

Planned paths: `POST /api/surveys/:id/responses`, `GET /api/surveys/:id/my-submission`

Results

Planned paths: `GET /api/surveys/:id/results`, later `GET /api/surveys/:id/export.csv`

Starter/copy (S2)

Planned paths: `GET /api/questionnaire-templates`, `GET /api/questionnaire-templates/:id/versions/:version`, `POST /api/surveys` with a source selector, `POST /api/surveys/:id/copies`

History/trends (S3)

Planned paths: `GET /api/surveys` with owned filters, `GET /api/analytics/lecture-trends` with an exact metric-definition ID

Improvement notes (S3)

Planned paths: `GET/POST/PATCH /api/surveys/:id/improvement-note`; no public/share/delete route

BASE-04 responsibility split: F-02/S1 provides the owned Course/Section/Lecture selectors and the role-appropriate current-work/eligible survey list needed to create, manage or answer a survey. F-09/S3 adds historical date/state search and cross-lecture analysis to the same list/detail views, not a duplicate context screen. Reuse `/api/courses`, `/api/sections`, Section lecture listing and `/api/surveys`; optional historical `fromDate/toDate/status` filters are specified when F-09 is contracted. `/api/analytics/lecture-trends` is only for compatible analysis, not a second context-list API. Ownership filtering applies from S1 regardless of when search controls are added.

List endpoints use bounded pagination with default 20 and maximum 100 records; cap offset at 10,000 and use deterministic sorting with an ID tiebreaker. Historical date/state filters are F-09/S3, not required for S1 context selection. The proposed F-04 body limit is 256 KiB encoded bytes, independently of decoded type/length/count validation. Ordinary UTF-8 is not the worst case: surrogate-pair JSON escapes can use 12 ASCII bytes per Unicode code point, so ten 2,000-code-point answers can consume 240,000 bytes plus the envelope. Issue #5 must bound envelope/IDs/keys, validate a ≤8 KiB envelope budget, choose parser/compression settings and verify that maximum supported serialization fits. Arbitrary whitespace/escape padding remains subject to the cap. Reject oversized bodies with 413 before persistence, unexpected compression with an explicit unsupported-content response, more than ten answers or decoded over-limit content even when encoded bytes fit. Do not accept supplied `ownerId`, `role` or `studentId` as identity. Exact payloads and boundary tests belong in the F-03/F-04/F-05 contracts.

7. Anonymous-mode design boundary and gate

Identified mode intentionally stores a student-to-bundle link. Anonymous mode does not. Participation records enforce eligibility/one submission and expose own status; answer bundles contain no identity or participation reference. Anonymous students cannot reopen their answers through a user-linked endpoint.

Separating tables does not by itself establish anonymity. Row order, generated IDs, request timing, logs, database audit records and backups can correlate identity and answers. For F-06, its contract must define unguessable independent answer IDs, collection/order handling, absence of per-answer timing metadata, logging redaction/retention, result-release controls and adversarial tests. No identity-bearing response payloads or correlation IDs may enter answer records or exports.

The threat boundary covers owners/ordinary application users; it does not claim unlinkability against privileged transaction/network observation. Owners cannot see per-student participation. Confirmed PD-01 forbids raw anonymous text in owner Results UI, APIs, CSV, analytics and note prefill at any count. This is separate from identity/answer separation and quantitative suppression.

Collection/storage remains undecided: recommend disabling anonymous text for a simpler MVP, but do not adopt it without explicit team agreement. The alternative is collect-but-inaccessible, which needs a purpose, storage/access/retention policy and verification before F-06. An anonymous starter containing a text question must not publish until that policy is agreed and

the Draft satisfies it. Do not silently drop text, add a privileged raw-text viewer, or treat hiding it in React as enforcement.

Working quantitative policy: after closure each question needs at least five valid nonempty answers. Propose an additional sparse-bin guard of at least three answers in every nonzero rating/option bin; otherwise suppress the whole question's numeric projection, including mean, distribution and answered count. Release only frozen question metadata plus a generic suppression label. The survey's overall count may remain visible, but a total of five/ten does not unlock optional questions answered by one/two people. Never reveal complementary cells through totals, per-question means, partial CSV rows or pooled analytics. Finalize the exact guards and adversarial tests in the F-06 contract.

The count thresholds are working project choices, not instructor mandates or anonymity guarantees. Unanimous responses, external classroom knowledge, repeated observations and coordinated respondents can still support inference. No arbitrary response-subgroup, participant or cross-question filtering is included. Trends/notes must consume release decisions for each question, not a single survey-level `isAnonymousSafe` flag.

F-06 is blocked until OPEN-04 is resolved in a reviewed contract. Do not enable an anonymous checkbox before the actual privacy behavior and tests exist.

8. Database setup, configuration and delivery

Version domain schema and custom session/constraint SQL together through Prisma migrations. A documented seed produces at least two owners in distinct Sections (including Sections of the same Course), at least six students for threshold testing, one ineligible/cross-Section student, memberships and multiple lectures. Tests use a dedicated PostgreSQL test database; never reset the development or deployed database during tests. Seeds are repeatable against a disposable demo database, hash local demo passwords and avoid real student records. Versioned starter data is added in S2; note/trend fixtures in S3. Do not pre-seed an unimplemented feature and present it as working product behavior.

Configuration plan: `DATABASE_URL`, dedicated `TEST_DATABASE_URL`, `SESSION_SECRET`, `APP_ORIGIN`, `PORT`, `NODE_ENV`, and local-only demo seed credentials. Commit variable names/examples only. Obtain demo passwords via local seed/private course handoff, not real secrets in Git/PDF. Reject missing required production configuration.

Lab 5 proposal: Docker multi-stage build serving frontend/API in Cloud Run, Cloud SQL PostgreSQL for durable domain/session data, Artifact Registry for images, Secret Manager for runtime secrets, and least-privilege deployment identity. Database persistence never depends on the container filesystem. Confirm components/access under Lab 5 guidance before provisioning.

GitHub Actions will run build/unit/integration/selected E2E checks on relevant PRs with PostgreSQL test service, protect the normal release path against failed required checks, and deploy accepted `main` releases through a repeatable pipeline. A manual approval within that pipeline is acceptable. Serialize migration/deployment steps and record release SHA; never run destructive seed on production. A separate cloud staging environment is not required.

9. Verification and current limitations

Vitest covers validation/summary/state logic; Supertest drives Express with real PostgreSQL for permissions/transactions/retrieval; Playwright covers owner publish → student submit → owner closed-results and selected rejection journeys. Preserve meaningful TDD failures before corrections. Mock-only persistence is insufficient.

Current state: documentation only; no application, installed dependencies, migrations, application tests, runtime commands or measured product results. Documentation consistency checks are separate from application tests. Review/setup/privacy/resource gates are listed in the decision log (decisions.md). Feature-level contracts must finalize request/response shapes, schema details and test cases before each implementation. No human teammate review is inferred from an AI documentation audit.

The following design sections complete the system-level context for later contracts. They specify intended behavior and constraints without claiming installed packages, executable endpoints, migrations or test results.

10. Starter Questionnaire lifecycle and copy isolation

F-07 reuses the Draft editor; it is not a separate survey builder. The seed supplies one catalog entry and immutable version 1 with the four questions in the SRS. Template ownership administration and arbitrary template CRUD are excluded.

1. Owner chooses an owned Course/Section/Lecture without an existing survey.

2. Owner chooses blank survey or a specific published starter version. Preview displays name/version, ordered prompts, categories, types, required flags and rating anchors.

3. API receives the exact source version ID, never a moving `latest` alias. Recheck that the selected version remains selectable and the target lecture is still available.

4. In one transaction create the Draft, fresh questions/options, source provenance and any permitted immutable metric references. A source and target row never share the same mutable Question/Option identity.

5. Owner edits the new Draft with the existing 1-10 question/type/required constraints. Removing a copied question does not remove the template question. Added questions start without certified metric comparability.

6. Publication freezes the copied definitions and eligible set under the existing lifecycle; rendering/results read survey snapshots, not template text.

Template revision appends version 2 and its definitions through reviewed seed/migration work; never overwrite published version 1. Retiring a version hides it from new selection but cannot break old provenance. Foreign-key deletion behavior is RESTRICT for referenced published source versions/metric definitions. A copied survey may have customized text while preserving `sourceTemplateQuestionId` as provenance; provenance is not evidence of an unchanged measurement.

Duplicate-to-Draft copies an owned survey into a different owned lecture without a survey. Copy only definitions/provenance, reset state to Draft, set mode to identified by default, clear publication/closure fields, and recompute eligibility on later publication. Do not copy answers, Participation, historical eligibility snapshots, timestamps or notes. A uniqueness conflict on target lecture returns 409 without a partially created survey.

BASE-05 snapshot rule: an immutable template copy names the exact TemplateVersion and locks/checks its selectability during copying so retirement cannot cause a half-valid source. A mutable source Draft copy includes the definitionRevision shown in its preview. In one transaction, lock the source Survey row, recheck ownership/revision, read all ordered definitions/options and create the target copy; every source-definition mutation increments that revision under the same row lock. Revision mismatch returns 409 with no target copy, requiring refresh. Published/Closed sources use their frozen revision. Record source survey/revision or template version as provenance; a client cannot request a moving source or obtain a mixture of old/new questions. Finalize lock order/source-retirement tests in F-07/S2 rather than implement a new version-management workflow now.

11. Measurement meaning and analysis boundaries

Rating questions store visible 1/5 anchors and interpretation in their frozen definitions; the author must make clear whether the scale is understanding, clarity, speed or another construct. S1 authoring contracts must capture this meaning before publication. S2 adds optional immutable `MetricDefinition` provenance for exact, trusted starter-derived ratings. Existing custom S1 questions are not retroactively grouped by matching titles.

BASE-06 storage/API direction: persist ratingMin=1, ratingMax=5, both endpoint labels and a nonblank scaleInterpretation with the prompt/type/required flag in S1. Authoring validates meaning before publication; answering and result APIs return that same frozen scale metadata, and F-05 labels the average with its interpretation. A speed scale such as slow→fast is not a suitability scale and has no implicit positive direction. Mean is a descriptive summary under the selected rating convention, not an automatic teaching-quality judgement. F-03/F-05 contracts in Issue #5 define exact schema fields, payloads and readback/immutability tests.

Reorder question

Template provenance: Keep source reference.

Comparable metric: Keep when measurement unchanged.

Change required/optional

Template provenance: Keep source reference.

Comparable metric: Keep, but show answered/eligible denominators and disclose differing completion rules.

Edit prompt, type, scale anchors or interpretation

Template provenance: Keep source reference as provenance only.

Comparable metric: Clear inherited metric reference; do not let the client force it back.

Change category

Template provenance: Keep source reference.

Comparable metric: Category is grouping metadata, not a comparison key; metric remains only if the measurement definition is still exact.

Add a new custom question

Template provenance: No source reference.

Comparable metric: No automatic certified metric.

An edit back to apparently matching text does not automatically restore a cleared metric; re-create from the immutable source or perform an explicit reviewed future mapping change. Do not infer semantic equivalence with AI or fuzzy text matching. The initial trend implementation compares exact rating metric versions, not single-choice distributions with changing options.

History queries constrain `Section.ownerId` before aggregation. Filters may span multiple Sections of the same Course only when that instructor owns them, with Section boundaries labelled. Context metadata may include Course/Section, lecture title/date, survey state/mode, metric version and permitted survey counts. Question answered count, mean and distribution appear only for a releasable question; suppressed rows do not expose them. No anonymous text or per-student participation appears. Partition summaries by response mode and label required-flag/context differences rather than silently implying equal sampling conditions.

For ratings, compute sum/count using valid answered values and round only for presentation. F-09 supports meaningful Course/own-instructor feedback summaries per compatible metric and response mode, as well as per-lecture trends. Start with owned Sections, exclude each unreleasable question before aggregation, then weight by answered observations (`sum of visible scores / sum of visible answered counts`), not an unweighted mean of lecture means. Label Course/Section context, mode, contributing-lecture/answer counts and selection/date range. A student answering multiple lectures contributes multiple observations, not multiple unique students. No composite overall instructor-quality score, cross-owner ranking, hidden-data pooling or mixing incompatible scales is included. Date filters use inclusive ISO lecture dates; other timestamps use UTC with Asia/Bangkok display. UI dates must not shift with browser timezone.

12. Teaching Improvement Notes - simplified PD-02 scope

F-10 is one private issue/action note attached to the existing Closed-results screen, not a workflow-management subsystem. No student sharing, publication, discussion, notification, automatic feedback import, reflection requirement, reversal reason or detailed status history is included. For anonymous surveys, only releasable quantitative data may inform the note; raw text is never exposed or used for prefill. For identified surveys, the owner may interpret permitted comments without automatically copying raw quotations or identifying student details.

issueSummary

Planned validation / exposure: Required, trimmed nonblank, 1-2,000 Unicode code points, plain text.

plannedAction

Planned validation / exposure: Required, trimmed nonblank, 1-2,000 code points, plain text.

status

Planned validation / exposure: Planned or Applied; default Planned on creation. A normal edit can select either valid status without special transition prerequisites.

revision

Planned validation / exposure: Server integer starting at 1; updates supply the last-read revision and increment once on a committed edit.

createdAt / updatedAt

Planned validation / exposure: Server UTC timestamps. Preserve createdAt; update updatedAt on successful edits.

appliedAt

Planned validation / exposure: Current-state timestamp: set on entering Applied, retain during edits that remain Applied, clear when set back to Planned. No separate transition record or reason.

ownerId / surveyId

Planned validation / exposure: Resolve/validate through authenticated survey ownership, not a client permission grant.

Create requires an owned Closed survey with accessible results; anonymous surveys need at least one releasable quantitative question. Unique surveyId prevents concurrent duplicate notes. Update requires owner access and the correct revision; invalid fields/status/missing revision are validation failures, stale edits and duplicate creation return 409. Persist body/status/timestamps/revision in one transaction. Re-selecting the same status does not recreate appliedAt or imply another action event.

Preserve the owner's unsent edits on conflict and offer reload/deliberate reapply, not an automatic overwrite. No hard-delete, autosave or body/status-history feature is promised. Notes remain excluded from respondent, other-owner, CSV and analytics payloads. Applied means the instructor recorded an action, not that learning improvement was independently verified. Detailed contracts/tests belong to F-10/Sprint 3.

13. API projection, export and failure safety

All result consumers call one ownership/state/privacy policy with separate survey-access and per-question release decisions. Owner access or survey count alone does not override Closed-state, anonymous text prohibition or per-question quantitative guards. Do not retrieve broad raw records and hide fields only in React. Parameterize queries; validate sort/filter identifiers against an allowlist rather than interpolating request strings into SQL.

Respondent survey

Permitted content: Frozen questionnaire/context, mode disclosure, own eligibility/submission status.

Explicit omissions: Other respondents, owner results/notes, internal privacy correlations.

Own identified submission

Permitted content: Own stored answers and status within eligible survey.

Explicit omissions: Other bundles and private notes.

Own anonymous submission status

Permitted content: Submitted boolean and survey/context ID.

Explicit omissions: Answer bundle ID/content/timing or a recovery token joining identity to answers.

Published owner results

Permitted content: Survey/context/state and total submitted count.

Explicit omissions: Scores, distributions, text, individual participants and notes.

Closed owner results

Permitted content: Authorized per-question aggregates; plain-text comments only for identified surveys; generic suppression labels where needed.

Explicit omissions: Raw anonymous text at any count; identity/bundle/timing/participation data; suppressed means, bins and answered counts.

Private note

Permitted content: Issue/action/status/revision and essential timestamps to its owner only.

Explicit omissions: No status history, reflection/reversal workflow or copying into any other result/student/export payload.

Aggregate CSV uses a fixed schema: Course code, Section/term, lecture title/date, survey ID/title/mode, question ID/category/prompt/type, answered count, mean where applicable, and rating score or choice-option counts. These are per-question aggregate rows, not per-person rows. Omit hidden question statistics entirely or include a metadata-only suppressed row with null numeric cells; do not export its answered count. Include permitted denominator metadata and a

documented format version; no names, student IDs, raw answers/comments, notes or authentication data. Required-flag/metric metadata may accompany compatible analysis but do not imply instrument validity.

Quote fields and escape embedded quotes/delimiters/newlines. Neutralize spreadsheet-formula prefixes in user-authored text cells (including leading control/whitespace cases) under a reviewed export policy, preserving real numeric aggregate cells as numeric values. Test formula-like titles, Thai text, commas, quotes, multiline prompts and null means. Ordinary CSV quoting alone is not a formula-injection defense; no universal protection for every reader/save-and-reopen transformation is claimed. Use a server-generated safe filename and `text/csv; charset=utf-8` with attachment disposition; the feature contract records whether a UTF-8 BOM is included for the target spreadsheet reader and any compatibility caveats.

Private responses use no-store cache headers; avoid persistent browser caches of identity, responses or notes. Application logs exclude request/response bodies, passwords, cookies, session/CSRF values, raw feedback and user-to-anonymous-bundle correlations. Operational error codes may be logged without sensitive values; detailed logging/retention for F-06 remains a reviewed privacy gate. Do not expose debug endpoints or seed operations in the public API.

Unexpected transaction/database failures roll back and return safe errors; constraint conflicts map to named domain errors. Never convert an exception into a success confirmation. Use a generic 500 response for unexpected failures and retain safe diagnostic context. Frontend reads may offer explicit retry; ambiguous submission timeouts use own-status lookup before a second send. Exact error codes/shapes and CSRF/session failure cases belong in each feature contract.

14. Schema evolution, reproducible fixtures and operability

Proposed increments are additive: S1 User/Course/Section/Membership/Lecture/Survey/Question/Eligibility/Participation/ResponseBundle/Answer plus session store; S2 adds template/version/metric/options and anonymous-mode enforcement; S3 adds the simple ImprovementNote entity and history-query indexes; no note-status-history table. Keep existing question snapshots authoritative when adding template metadata. No automatic prompt-based metric backfill and no anonymous relabelling of identified historical answers.

Index ownership/context/history lookup paths (`Section.ownerId`, `Lecture.sectionId/lectureDate`, `Survey.lectureId/status`, question survey/order), eligibility/participation composite keys, Answer bundle/question and note survey ID. Validate actual query plans before adding broader indexes for the NFR-04 load target. Results remain derived; no separate stale materialized dashboard is required.

Demonstration/test fixtures must include: two owner Sections in the same Course; a student in one Section only; a student eligible for more than one lecture; no-answer/optional-answer surveys; 1/5/invalid rating boundaries; another owner's Draft; concurrent submit/close scenarios; anonymous surveys with total submissions five/ten but question answers four/five/two, sparse bins, and raw text never present in owner projections; source starter versions with a customized independent copy; comparable/incomparable lecture metrics; and Planned/Applied notes plus stale revisions. These are future fixture requirements, not existing generated evidence.

Run migrations explicitly before serving the new code; record applied schema version and fail safely if required schema/configuration is unavailable. Never regenerate demo data on application startup or perform destructive reset during deploy. A rollback must use code compatible with the current schema or a reviewed forward correction; do not promise destructive migration rollback without a data recovery plan.

For Lab 5, separate development, test and deployed database credentials, least-privilege runtime identity and migration privileges. Confirm backup/restore availability and describe the reproducible restore procedure with the actual GCP resources provided. Do not claim a tested backup, availability target or zero-downtime upgrade until demonstrated. Operational health endpoints expose only minimal status, not database credentials, schema contents or answers.

15. Verification responsibility and contract readiness

Identity/access

Unit plan: Session-age/validation helpers.

Real API/database plan: Valid/invalid login, logout replay, expiry, CSRF, role/owner/cross-response matrix.

Selected UI / manual plan: Login/logout and expired-session recovery.

Survey lifecycle

Unit plan: State/definition validation.

Real API/database plan: Draft edit versus publish locks, one survey per lecture, ownership, snapshot and close/submit ordering.

Selected UI / manual plan: Owner create/publish/close with persisted state.

Response

Unit plan: Type/required/Unicode validation.

Real API/database plan: Atomic save/rollback, unique concurrent participation, wrong-question rejection and restart retrieval.

Selected UI / manual plan: Student answer/confirmation/own identified readback and rejection.

Results

Unit plan: Mean/count/optional denominator.

Real API/database plan: Shared authorization/projection, no hidden identity data, no-answer and Closed-state policy.

Selected UI / manual plan: Labelled charts/tables, no false zero, text display.

Anonymous

Unit plan: Question-level thresholds, sparse-bin release and raw-text exclusion helpers.

Real API/database plan: Identity/answer separation, collection-policy enforcement, optional/sparse cases and identical UI/API/CSV/analytics omissions.

Selected UI / manual plan: Truthful disclosure, status-only self view, per-question suppressed results.

Starter/copy

Unit plan: Definition/metric invalidation helpers.

Real API/database plan: Immutable version/mutable revision snapshots, concurrent source edit/retirement, atomic independent copy and no copied responses/notes.

Selected UI / manual plan: Preview → use starter → customize → publish; source-changed refresh.

Trend

Unit plan: Compatible-metric, answer-weighted sum/count and denominator rules.

Real API/database plan: Own Sections only, question-level release before aggregate, no hidden text/statistics or incompatible pooling.

Selected UI / manual plan: Filtered lecture series and labelled Course/own-instructor per-metric feedback summaries.

Notes

Unit plan: Issue/action/status validation and current-state timestamps.

Real API/database plan: Private ownership/result access, unique create, atomic revision-safe edits and unchanged survey/results.

Selected UI / manual plan: Create/edit private note, simple Planned/Applied choice; conflicts and unauthorized cases.

F-01-05 require their complete AC/STS/DoD before implementation under Issue #5. F-06-10 need a feature contract before their own work starts, but their full endpoint details and executable tests are not required for Deliverable 1. The new system descriptions provide enough entities, ownership, dependencies and planned verification to allocate them now; they do not replace feature-level design, substantive teammate review or actual evidence.

Section 8 proposal P15 is selected as a small SYS-04/S3 usability evaluation, not a product service or additional feature. Instructors inspect implemented Closed results and identify/record a useful action; students explain eligibility, one-time participation and the actual privacy disclosure. The sprint plan §11 (sprints/plan.md) records bounded recruitment/tasks/observations and limitations. Keep observed usability evidence separate from automated tests, mandatory

Lab 6 UAT and claims of teaching effectiveness. No session result is currently available. Proposal attribution is the owner's summary of the teammate's report; no full-report access is claimed.

Reference links

- Express session middleware (https://expressjs.com/en/resources/middleware/session/): server-side session model and store/cookie options.

- connect-pg-simple (https://github.com/voxpelli/node-connect-pg-simple): PostgreSQL session-store setup and schema.

- Prisma transactions (https://www.prisma.io/docs/orm/fundamentals/transactions): transaction semantics; use the documentation matching the pinned version during setup.

- WCAG 2.2: Contrast (Minimum) (https://www.w3.org/WAI/WCAG22/Understanding/contrast-minimum.html): text contrast targets for the selected palette.

- WCAG 2.2: Non-text Contrast (https://www.w3.org/WAI/WCAG22/Understanding/non-text-contrast.html): essential control, state and chart indicators.

- PostgreSQL explicit locking (https://www.postgresql.org/docs/current/explicit-locking.html): row locks and transaction concurrency; use the documentation for the pinned PostgreSQL version at implementation time.

- PostgreSQL constraints (https://www.postgresql.org/docs/current/ddl-constraints.html): unique/foreign-key/check responsibilities and cross-row limits.

- OWASP CSV Injection (https://owasp.org/www-community/attacks/CSV_Injection): risks in spreadsheet-interpreted text cells, separate from ordinary CSV quoting.

docs/sprints/sprint-1/database-foundation.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

Issue #16 - Sprint 1 database foundation

Design recorded 2026-11-08 before implementation. Scope: persistence only; no F-01-F-05 workflow or endpoint is implemented here. Sources: shared contract (shared-contract.md), F-01 §4 (f-01-authentication.md), F-02 §6 (f-02-context-discovery.md), F-03 §§6-7 (f-03-survey-authoring.md), F-04 §§4-5 (f-04-responses.md), F-05 §6 (f-05-results.md), SDS (../../system-sds.md) and Tracker §3 (tracker.md).

Phase A: schema decisions and responsibility

The contracts agree on the S1 model. Use one additive Prisma migration history, with User/session, academic context, and survey/response increments. No parallel User table, summary table, anonymous workflow or additional product entity is needed.

User and session

Database enforcement / service boundary: Unique normalized email, role enum, bounded display name; session table exactly public.auth_session(sid varchar, sess json, expire timestamp(6)), expiry index. UTC pool options. Session JSON is represented in Prisma so subsequent migration comparisons retain the table; runtime session access remains connect-pg-simple's responsibility.

Academic context

Database enforcement / service boundary: Course code unique; Section(courseId,term,sectionCode), Membership(sectionId,studentId), Lecture(sectionId,sequence) unique. Native calendar date, positive sequence. Section owner role and Membership respondent role are checked in fixtures/services, not a cross-table CHECK.

Survey

Database enforcement / service boundary: Unique lectureId, owner FK, positive definitionRevision and coherent state/timestamps. Canonical ownership is Survey→Lecture→Section; redundant owner consistency is verified in fixtures and must be checked by the future service under its transaction.

Question

Database enforcement / service boundary: Stable UUID, unique survey/position and survey/id pairs. Positive position WITHOUT a maximum: F-03 stages positions 11-20 while reordering. Final contiguous 1-10, nonblank published definitions and at least one RATING are future publication-service checks. Draft blank prompts/labels/interpretation remain valid.

Frozen eligibility

Database enforcement / service boundary: Unique survey/student, FKs to Survey/User, no FK to live Membership. Deleting Membership cannot revoke published eligibility. Publication freezes it with state under the Survey lock in #19.

Participation / identified bundle

Database enforcement / service boundary: Participation PK and FK to eligibility; identified bundle unique survey/student and survey/id. No Participation→bundle pointer or per-response timestamp. identifiedStudentId remains nullable as required by F-04's storage contract; the S1 service MUST require a nonnull trusted actor before insertion. This is not an enabled anonymous mode.

Answer

Database enforcement / service boundary: Unique bundle/question; composite same-survey FKs to Question and ResponseBundle; exactly one rating/text column; integer rating 1-5 and text ≤2,000 PostgreSQL characters (code points). Type-to-question, required completeness and nonempty response are transaction-service checks.

Delete/freeze/transactions

Database enforcement / service boundary: Draft Question deletion cascades only with Survey; submitted Answer FKs restrict deletion. Other domain FKs restrict deletion. No automatic cascade through submissions. No SQL CHECK claims to freeze rows after publication or implement ownership/type cross-table queries. #19/#20 retain Survey FOR UPDATE locking, lifecycle/immutability, atomic writes and duplicate/close ordering.

UUID defaults use PostgreSQL gen_random_uuid(). No later-sprint source/metric/option/note fields are introduced. The first migration is independently reviewable for #17; full #16 completion still requires all applicable migrations, fixtures and verification. No contract conflict requiring a competing design was found; future services must preserve the explicit boundaries above.

Phases B-D and safe operation

The implementation uses `prisma/schema.prisma` and three ordered migrations: `202611080001_user_session`, `202611080002_academic_context`, `202611080003_survey_response`. `apps/api/src/database.ts` explicitly constructs the Prisma 7 PostgreSQL adapter/client with UTC and a bounded connect wait; it opens no application connection on import. The API still exposes only its existing liveness route. Build/typecheck generate the real client first; generated TS is compiled with the API and is ignored in source control.

Generated code, local secrets and disposable cluster data stay ignored. Never run Prisma migrate reset or seed a development/deployed database. The accepted assertTestDatabase guard remains unchanged; test migration/seed commands require it before connecting. Forward development migration is a separate explicit command/opt-in and does not run seed.

Commands and environment

Use the accepted Node 24.22.1 / npm 10.9.2 / PostgreSQL 17 profile and existing lockfile. From the root after `npm ci`:

```
npm run db:validate
npm run db:generate
npm run typecheck
npm run build
npm run test:unit
npm run test:api
```

Schema validation/generation do not connect; the Prisma config's unused URL fallback exists solely for these commands. Generated files go under ignored `apps/api/src/generated/prisma`. Do not import this server client from web code. `prisma.config.ts` also records the guarded seed entrypoint; direct `prisma db seed` still calls that same safe wrapper.

For ordinary disposable test setup, configure the ignored `.env.test.local` from the example with actual distinct development/test targets, `ALLOW_TEST_DATABASE` equal to the allowlisted test database name, and `NODE_ENV=test`:

```
npm run db:migrate:test
npm run db:seed:test
```

Seed additionally requires `SEED_SYNTHETIC_DATA` to equal the test database name and privately supplied `SEED_OWNER_PASSWORD` / `SEED_RESPONDENT_PASSWORD` (12-128 code points). No default password is committed or printed. The explicit seed creates three Owners (one with no Sections), four Respondents (one unenrolled), two Courses, three Sections (one empty), three Lectures including equal dates/different sequence, three Memberships, one identified Draft and two ordered questions. Stable IDs/natural keys are in `prisma/fixtures.ts`. Owners 1/2 have Sections of the same Course; Respondent 13 belongs only to Owner 2's Section. No Published eligibility, participation, response or session is fabricated by seed.

Seed is a single advisory-locked transaction. It inserts absent fixtures, verifies existing values/passwords and retains existing hashes; it never updates/deletes fixtures, sessions or submissions. An edited fixture, natural-key collision or different supplied password causes rollback/refusal, not a reset. A later service-edited/published seed Draft is therefore a reason for safe refusal. SQL integration fixtures separately create their own publication/submission storage; this is not implemented F-03/F-04 behavior.

For development **forward migrations only**, use the ignored `.env` with `NODE_ENV=development` and separately set `ALLOW_DATABASE_MIGRATIONS` to the intended database name, then run `npm run db:migrate:dev`. The wrapper rejects host/port query overrides and verifies the connected database before `prisma migrate deploy`. It does not reset

or seed. Inspect a failed migration and resolve it through reviewed Prisma recovery procedures; no automatic destructive repair is provided. Deployment/production operations are outside this issue.

Disposable foundation verification

The foundation suite requires a **new empty dedicated PostgreSQL 17 database**. Set the existing test URL/name opt-in and an additional `ALLOW_FOUNDATION_TESTS` matching that name, then run:

```
npm run test:db:foundation
```

Do not pre-migrate/pre-seed that database: the suite verifies it is empty, deploys the real migration history itself, verifies no-op redeployment, then seeds/compares fixtures. For another full run create another empty disposable database; there is no reset command. Never repoint it at an existing development database or container. Test-generated passwords stay in memory. Existing `npm run test:db` and `npm run check:orm` can then check tooling compatibility on the same dedicated test target.

The nine foundation cases cover fresh/idempotent Prisma deployment, repeat seed, conflict refusal, SQL constraints/reorder/rollback, typed client readback, session-table schema drift, connect-pg-simple storage compatibility, truly overlapping uniqueness (observe the loser waiting on a lock), and repeat seed preserving submitted associations. They are persistence checks, not F-01-F-05 AC/STS passes. `tests/database/constraints.sql` is reused by the suite; its local temp helpers and storage assertions roll back. It must never be run against an unguarded target. PostgreSQL may use 23503 or 23001 for the tested restrictive FK deletions; successful deletion or any other error still fails the assertion.

Actual commands/results, environment failures and remaining limitations are recorded in database verification (database-verification.md). No human review or full Issue #16 completion is inferred from the existence of schema/tests.

Part D - Three-sprint plan and team workflow

docs/sprints/plan.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - Three-Sprint Plan

Version: 0.4 (2026-11-06). Status: consolidated planning draft with Section 8 proposal dispositions; actual Sprint 1 capacity and assignments are not confirmed. Related issue: #4 (https://github.com/Maibokdaimhai/LECTRA/issues/4). References: SRS (../srs.md), features (../features.md), traceability (../traceability.md), SDS (../system-sds.md).

Operational follow-up: Sprint 1 delivery tracker (sprint-1/tracker.md) records the dated GitHub issue/assignee snapshot, execution gates and required evidence for Issue #8. Its setup is not proof of application, test, review or release completion.

1. Dates and planning authority

The instructor's dates below come from the two supplied PDFs. Proposed internal dates are team planning choices. Use the course's stated 23:59 deadlines and Asia/Bangkok for team scheduling, subject to any later course announcement.

Deliverable 1

Instructor deadline: 8 Nov 2026, 23:59

Required outcome: Whole-product baseline + engineered working Sprint 1 on main; one self-contained PDF with Parts A-F.

Lab 5

Instructor deadline: 15 Nov 2026, 23:59

Required outcome: Docker, enforced CI quality gate, durable GCP deployment and repeatable delivery.

Lab 6

Instructor deadline: 22 Nov 2026, 23:59

Required outcome: Independent cross-team UAT, legitimate defect handling and independent re-test.

Deliverable 2 / Lab 7

Instructor deadline: 29 Nov 2026, 23:59

Required outcome: Sprint 2 complete, Sprint 3 contracts AND implemented progress; approved maintenance/change evidence.

Final

Instructor deadline: 13 Dec 2026, 23:59

Required outcome: Completed Sprint 3/full product, verified release and required final submission/demo.

2. Sprint 1 - Working lecture feedback loop

Proposed window: 6-8 Nov. Goal: one complete, persisted, authorized identified-survey journey.

Included features: F-01 authentication/access, F-02 seeded Course/Section/Lecture context/discovery, F-03 Draft/publish/close, F-04 validated one-time identified response/status/readback, F-05 aggregate/text results under the visibility policy. Establish SYS-01-04 foundations. Explicit Course/Section entities replace ambiguous Classroom naming; they do not introduce administration UI.

Dependencies: accepted product scope/requirements, selected stack and System SDS, and a reviewed/versioned contract with AC/STS/DoD for each feature before its implementation. Contracts may be elaborated one feature at a time after the whole-product baseline is agreed; Sprint 2/3 screen/API detail need not be frozen now.

Suggested internal sequence:

1. 6 Nov: review Issues #1-#4 drafts, resolve immediate gates, then prepare Issue #5 contracts before coding. Issue #6 plans evidence collection in parallel.

2. 6-7 Nov: implement bounded feature branches from `staging` under separate authorized implementation Issues, meaningful TDD, teammate PR review and integration. Start with F-01/F-02, then F-03/F-04, then F-05.

3. 8 Nov: reserve time for integrated build/test, selected UI journeys, persisted retrieval/restart checks, reviewed release to main, release reference, PDF assembly and verification. Do not defer all review/evidence to the final hour.

Completion outcome:

- Owner logs in, creates/publishes a small identified survey for an owned lecture; eligible student logs in, submits once and reopens the saved outcome; owner closes and sees correct results.

- Invalid login, unauthenticated/forbidden/cross-user access, bad answers, duplicates/concurrency and Draft/Closed submissions are verified with appropriate automated coverage.

- Required build/tests are run against the submitted release; actual files/test names, commands, counts and commit are retained. Meaningful TDD evidence exists for selected important rules.

- Accepted main release, setup instructions, reviewed Issues/PRs, contribution and complete Parts A-F PDF exist. No fabricated approval, test or execution evidence.

Scope exclusions for Sprint 1: anonymous submissions, Starter Questionnaire, single-choice, subset-selection UI, survey-copy workflow, export, history/trends, Teaching Improvement Notes, scheduling and management CRUD. These are either later-sprint baseline or explicit exclusions, as recorded in the SRS.

3. Sprint 2 - Privacy and bounded core expansion

Proposed window: 9-22 Nov, leaving 23-29 Nov for Sprint 3 working progress and Lab 7. Instructor requirement: Sprint 2 complete by 29 Nov.

Included: F-06 anonymous mode, F-07 versioned Starter Questionnaire with independent Draft copies plus single-choice/copy/subset controls, F-08 aggregate CSV export. Continue release/testing/docs responsibilities. Detailed anonymous contract and privacy review precede implementation; frontend omission of names is insufficient.

Dependencies: accepted Sprint 1 increment, reviewed feature contracts, anonymous threat-boundary resolution, existing lifecycle/eligibility/aggregation. F-07/F-08 must preserve identified behavior and anonymous protections. Work on Lab 5 delivery proceeds alongside bounded features, not as a substitute for them.

Completion outcome: integrated identified/anonymous workflows, one-time participation without an owner-visible answer join, no owner-facing anonymous raw text, question-level quantitative release in results/export, an explicitly agreed text collection policy, concise four-category starter preview/copy/customization, immutable versions/consistent source snapshots, choice summaries, subset controls and updated traceability. Metric provenance precedes S3 comparisons; no retroactive grouping by title.

Proposed work order: resolve F-06 privacy contract early; implement F-07's copy boundary/version seed alongside the existing editor; integrate extra question/subset validation; have F-08 consume the same guarded result projection. F-06 and F-07 can proceed independently after their contracts but require a combined regression before release. Do not serialize all expansion behind CSV export or add a separate template application service/microservice.

Lab 5, due 15 Nov: containerize the accepted increment, demonstrate persistence after redeploy, enforce PR gates including a controlled failing check on an isolated branch, and establish repeatable main deployment. No deliberate breakage of the accepted release.

Lab 6, due 22 Nov: arrange a partner team early. Prepare at least four user-facing UAT cases covering normal, rule/boundary, role/ownership and state/persistence behavior against a recorded release. Record actual findings, triage, regression fix/review/deploy and independent re-test of at least one legitimate accepted defect. If none is found, request the TA's controlled exercise; never invent one.

4. Sprint 3 - History, integration and final verification

Proposed window: 23 Nov-13 Dec; plan around the 1-11 Dec exam period.

Included: F-09 owned Course/Section/lecture history/filtering and compatible-question trends; F-10 owner-private Teaching Improvement Notes; final integration, failure handling, usability, privacy/security regression, performance verification, unresolved defect correction and final evidence under SYS-01-04.

Dependencies: integrated Sprint 2, reviewed F-09 contract defining comparability and F-10 contract defining visibility/status/revision behavior, UAT/defect status and repeatable deployed release. F-09 and F-10 can proceed in separate bounded branches; notes depend on available Closed results, not the trend UI.

By 29 Nov: show Sprint 3 contracts, implemented working history/filtering progress and a bounded private-note create/read flow integrated with Sprint 1/2, actual verification evidence and explicit remaining work. A placeholder page or seeded note without a working authorized flow is not implemented progress. This is the team's proposed working checkpoint; the instructor requires genuine Sprint 3 progress, not this exact feature split.

F-10 outcome: owner records issue/action in one private note on an accessible Closed survey, edits with revision protection and selects Planned/Applied without a reflection, reversal reason or detailed history. Retain essential timestamps only. Verify ownership/result-access guards, unique create, stale edits, unchanged results and no note leakage into CSV/analytics. No shared-note workflow is promised.

Lab 7, due 29 Nov: obtain instructor/TA approval for a change to existing behavior. Trace impact to requirements/design/contracts/tests/code, retain the changed-behavior failing test before correction, implement/review/redeploy, and run regression. Record five dated metrics with sources and an action-oriented interpretation plus retrospective/readiness checks. Planned baseline features alone do not satisfy this maintenance requirement.

Final outcome by 13 Dec: whole baseline implemented or honestly disclosed with approved changes; automated/regression and independent UAT re-tests recorded; deployed release tied to commit; updated traceability, reproducible setup, final report and required video with both students. Use the exam period for bounded remaining work, not unplanned major features.

5. Two-person work and review allocation

Actual student names, IDs and assignments remain pending team input. The following is a rotation proposal, not a contribution record or evidence that either person has done the work.

BASE-01 is a review finding about feasibility, not a new instructor requirement to collect private schedules. Following the owner's clarification, keep this planning lightweight: names/private academic calendars are not prerequisites for reviewing the product baseline. Do not invent actual availability or pretend that equal task counts imply equal effort. Confirm concrete implementer/reviewer availability and bounded tasks in Issue #5 before calling the Sprint 1 implementation plan final.

Requirements/access/session contract + F-01

Proposed implementer/author: Student A

Proposed reviewer: Student B

Shared responsibility: Both explain identity/access and tests.

Context/survey contract + F-02/F-03

Proposed implementer/author: Student B

Proposed reviewer: Student A

Shared responsibility: Both review data/ownership/state rules.

Response contract + F-04

Proposed implementer/author: Student A

Proposed reviewer: Student B

Shared responsibility: Pair on duplicate and close/submit concurrency.

Results contract + F-05

Proposed implementer/author: Student B

Proposed reviewer: Student A

Shared responsibility: Both verify denominators/text privacy and evidence.

S2 starter/copy contract + F-07

Proposed implementer/author: Student A

Proposed reviewer: Student B

Shared responsibility: Both verify source versions, copied IDs and historical isolation.

S2 anonymous + F-06

Proposed implementer/author: Student B

Proposed reviewer: Student A

Shared responsibility: Pair on threat boundary, identity/answer separation and suppression regressions.

S2 CSV + F-08

Proposed implementer/author: Rotate after first S2 integration

Proposed reviewer: Other student

Shared responsibility: Review safe export, ownership and shared result policy.

S3 F-09 trends / F-10 notes

Proposed implementer/author: Split lead features, reverse earlier reviewer roles

Proposed reviewer: Other student

Shared responsibility: Both explain comparability, privacy, revision conflicts and UI behavior.

Sprint 2/3 and Labs 5-7

Proposed implementer/author: Rotate lead ownership per bounded Issue

Proposed reviewer: Other student

Shared responsibility: Both participate in design, code, tests, AI supervision, delivery and maintenance.

Each author prepares/updates contracts and tests as well as code. The teammate provides substantive review, not self-approval or an AI substitute. Identify actual pair work in Issues/PRs. Equal commit counts are not required; understanding and meaningful participation are.

Coarse effort model, for discussion rather than a commitment or actual time record:

Setup/database seed plus F-01 identity/session/access

Complexity: High

Illustrative focused person-hours: 8-14

Allocation / dependency: Proposed A leads identity, B reviews; shared foundation first.

F-02 context plus F-03 Draft/publish/close

Complexity: High

Illustrative focused person-hours: 10-16

Allocation / dependency: Proposed B leads; depends on foundation and identity for runtime checks.

F-04 validation/persistence/concurrency

Complexity: High

Illustrative focused person-hours: 8-12

Allocation / dependency: Proposed A leads, pair on races; needs published survey rules.

F-05 results and scale-labelled UI

Complexity: Medium

Illustrative focused person-hours: 4-6

Allocation / dependency: Proposed B leads; needs answer fixtures and results/access rules.

S1 contracts, cross-feature E2E/integration, teammate review/fixes, release and PDF evidence

Complexity: High / shared

Illustrative focused person-hours: 10-16

Allocation / dependency: Both; feature estimates include their local rule/API tests, while this row covers shared checks/docs/review.

The illustrative base totals 40-64 person-hours; a 20% uncertainty reserve gives roughly 48-77 person-hours, not elapsed hours or claimed available capacity. Actual remaining effort, skill/reuse and team availability are unknown. Re-estimate small tasks in Issue #5; do not present 6-8 Nov as proven feasible based on this model. Reserve the last scheduled work block for integration/review/release/PDF and keep buffer available rather than allocating every hour to coding. If the team's capacity cannot support the scope, escalate the delivery risk and record agreed adjustments; mandatory auth/persistence/access/testing cannot be silently removed.

Critical path: shared setup/schema → F-01/F-02 → F-03 publish lifecycle → F-04 response transaction → F-05 integrated results → system checks/review → release/PDF. Contracts and safe seed work can proceed alongside each other; reviews need the other person's available time and cannot be assumed instantaneous. This addresses planning structure only, not actual capacity confirmation.

6. Git, evidence and implementation gates

`Issue → feature/fix branch from staging → teammate-reviewed PR into staging → integration/system tests → reviewed staging-to-main release PR → recorded tag/commit → deployment after Lab 5`.

The initial baseline is README commit `a0af019`; planning work uses `docs/1-4-product-baseline` and PR #7 into `staging`. By default the two team members manage Git operations, commits, branches and PRs themselves. The owner subsequently renewed explicit permission for the assistant to commit/push this consolidated documentation on the existing branch only; merge and substantive teammate review remain with the team. Conventional Commits/no-`codex/` still applies. A branch or PR is not proof of teammate approval or accepted release.

Before coding a feature: accept the applicable baseline, resolve blocking decisions, record/version its feature contract and STS, then begin rule TDD. Do not backfill the preimplementation history. Issue #6's evidence outline may proceed in parallel; completing that plan is not completing Part F.

7. Risks and contingencies

Very short Sprint 1 window

Response: Keep seeded setup, two question types and manual close; reserve integration/review/PDF time. Do not silently drop auth, persistence, tests or teammate review.

Unreviewed drafts or missing commit permission

Response: Keep status honest; request the concrete document/version-history action before starting implementation dependent on it.

Anonymous complexity

Response: Elaborate/review privacy early; implement in S2. Do not enable an unverified anonymous label or postpone all design to S3.

Product extensions increase S2/S3 workload

Response: Keep one seeded starter and private single-note workflow; no template admin, shared publishing, discussion or AI. Review actual capacity before contracts; any approved reduction/reallocation is recorded, not silently dropped.

Misleading course/instructor analytics

Response: Scope to owned Sections, compatible metrics and per-lecture counts; no ranking, unlabelled pooling or suppressed-data inference.

Note privacy or concurrent updates

Response: Reuse result-access guards; private default; unique survey note and atomic revision/essential timestamp update, without detailed history.

Stack version incompatibility

Response: Pin compatible versions and verify migrations/session/hash/runtime behavior before coding against specific APIs.

Lab work overlaps sprint features

Response: Track delivery/UAT/maintenance evidence separately while using the same evolving application/repository.

Partner UAT delays or no legitimate defect

Response: Arrange early; report access/delay issues promptly and request TA guidance/exercise where applicable.

Scope or deadline changes

Response: Record decision, impact, requirement/feature/sprint changes and approval where necessary. Ask TA before replacing the required domain slice.

8. Review and execution status

All planned application work is unimplemented; no application build/test/UAT/deployment or teammate approval is claimed. Draft documentation for Issues #1-#4 is subject to review. Issues are not closed by drafting these files. See open decisions (../decisions.md), traceability gaps (../traceability.md) and the baseline review (../baseline-review.md).

9. Baseline allocation and risk priorities

Small identified lecture-feedback slice

Required feature allocation: S1 F-01-05 plus SYS foundations.

Why this is bounded: Seeded context, two types, manual transitions; no starter/note/anonymous UI.

Theme-required privacy and export expansion

Required feature allocation: S2 F-06/F-08.

Why this is bounded: Shared result policy and aggregate CSV only; no identity/raw/PDF export.

Owner-requested starter and question reuse

Required feature allocation: S2 F-07.

Why this is bounded: One immutable seeded questionnaire; existing editor; no arbitrary template lifecycle UI.

Owned lecture understanding

Required feature allocation: S3 F-09.

Why this is bounded: Compatible per-lecture ratings; no university dashboard, ranking or new scoring model.

Owner-requested teaching action record

Required feature allocation: S3 F-10.

Why this is bounded: One private note in existing results; no shared publication, discussion or automation.

No actual availability estimate has been supplied by either student; these windows remain targets rather than validated capacity. The owner requested a proportionate approach, so detailed allocation/availability and task estimates are a preimplementation Issue #5 follow-up rather than a request for personal schedules in this PR. Retain review/integration buffer and record any scope/sprint impact; do not mark capacity as confirmed or silently drop mandatory verification.

10. Preimplementation and release gates

Product direction

Required material: SRS, feature inventory/traceability, System SDS and feasible three-sprint allocation reviewed by both students.

Current planning status: Revised draft in this PR; human review pending.

Feature implementation start

Required material: Feature-specific design/UI/API/data details, stable AC and STS mapping, DoD and actual version history; resolve feature-specific open decisions.

Current planning status: Issue #5 for S1, equivalent contracts before later features. Not supplied by this PR.

Feature integration

Required material: Bounded Issue, implementation/tests/diff inspection, substantive teammate-reviewed PR to staging.

Current planning status: No application feature implementation or review evidence yet.

Sprint release

Required material: Integrated checks, accepted behavior, documented setup, reviewed staging-to-main PR and immutable release reference.

Current planning status: Not achieved by a docs-only PR or initial README commit.

Deliverable 1 handoff

Required material: Complete A-E plus selected real F evidence in one readable PDF; both students, navigation pages, assessed commit, limitations and safe setup.

Current planning status: Future assembly/evidence work; no completed PDF claimed.

BASE-03/04/06 handoff to Issue #5: finalize encoded/decoded F-04 limits, distinguish F-02 context APIs from F-09 search, and freeze/store/return F-03/F-05 scale labels and interpretation. BASE-02/05/07 detailed privacy/collection, copy snapshot and starter verification precedes the corresponding Sprint 2 implementation. BASE-08 detailed simplified-note contracts precede F-10/Sprint 3. Section 8 Innovation Opportunities P10/P05/P14/P15 now have individual dispositions in the review register; they are not four formal Suggestions. Full source verification remains OPEN-11, and the separate Initial Review item REV-08 is reflected by these explicit pre-contract handoffs.

Prepare the PDF/evidence outline while implementation proceeds so commands/versions/TDD outputs/reviews are captured when they happen. Do not wait until the final day to reconstruct or invent them. The final report must include all required Parts A-F; this PR's planning depth is not a substitute for working Sprint 1.

11. P15 - Bounded feedback-cycle usability evaluation

Selected disposition: Incorporate into existing SYS-04/Sprint 3 QA, not a new feature, instructor mandate or Sprint 1 task. Source is the owner's summary of Section 8 in the teammate's Comprehensive Review; the full report has not been accessed directly. P10/P05 remain in their existing bounded features; P14 remains simplified/private with sharing deferred.

Purpose: evaluate whether an instructor can use Closed feedback to identify a concrete teaching action, and whether a student understands eligibility, one-time submission and the implemented privacy policy. This complements technical/accessibility verification and independent UAT rather than replacing either.

Scope proposal: aim for one or two participants per role (two to four short sessions total), using synthetic data and the actual implemented release. Role-representative participants are preferred; if only proxies are available, record that limitation. Plan approximately 15-20 minutes per session plus one short synthesis block; these are planning targets, not claimed participation or measured effort. Confirm feasibility during S3 planning rather than expanding the baseline into a research platform.

Instructor inspects an accessible Closed survey and identifies one useful next-lecture action.

Observation to record: Whether an action is identified, which permitted result supports it, time to identify it, assistance needed and misinterpretations.

Interpretation boundary: Useful action is a qualitative observation, not proof of improved teaching outcomes or a validated evaluation instrument.

Instructor records that action in the private note, if F-10 is implemented.

Observation to record: Task completion/confusion, issue/action distinction and understanding of private visibility/status.

Interpretation boundary: Do not test or claim a sharing workflow that is outside scope; do not use raw anonymous text.

Student discovers an eligible survey and explains participation.

Observation to record: Correct understanding of eligibility, once-only submission and closed-survey behavior; help needed.

Interpretation boundary: Do not turn participation into attendance/grade measurement.

Student explains what an owner can see in identified versus anonymous mode.

Observation to record: Correct/incorrect statements about identity linkage, raw text and suppressed quantitative data; unclear disclosure wording.

Interpretation boundary: Run only against the actual agreed/implemented anonymous collection policy; do not imply perfect anonymity.

Record session ID, actual participant role/proxy status, synthetic scenario, release commit, task, observed result, time where measured, assistance, comprehension notes and resulting Issue/action. Report counts with actual denominators and disclose recruitment limitations; do not invent sessions, transcripts or statistical confidence. Keep feedback records minimal and non-identifying where practical.

Use findings to improve copy/layout or create a bounded defect/enhancement with normal traceability and review; recheck affected tasks after a fix. Existing NFR-07 and FR-07/FR-14 user goals provide context, but this small exploratory study does not create a new numeric NFR or release threshold. Lab 6's required four UAT cases, independent execution and legitimate defect/re-test evidence remain separate; do not substitute these sessions for mandatory lab evidence or claim that an early S1 UAT tested unimplemented S3 notes.

docs/sprints/sprint-1/workflow.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

Sprint 1 - Board, Teammate Review and Release Workflow

Related issue: #9 (https://github.com/Maibokdaimhai/LECTRA/issues/9). Status: documentation draft with observed Kanban configuration and teammate Write access configured; actual teammate use and human review/integration remain unverified.

1. Scope and observed facts

- The owner authorized continuing on the existing LECTRA Kanban (https://github.com/users/Maibokdaimhai/projects/7) after logging in. The existing board, columns and 25 issue cards were inspected through GitHub UI on 2026-11-06 (Asia/Bangkok); 21 are the Sprint 1 set and #1-#4 are pre-existing Done cards. No duplicate board/columns were created.

- The Sprint 1 milestone (https://github.com/Maibokdaimhai/LECTRA/milestone/1) and tracker #8 (https://github.com/Maibokdaimhai/LECTRA/issues/8) provide the issue set and allocation. All #5, #6 and #8-#26 were visibly present, with the existing assignees retained. State/assignee observations are snapshots, not proof of runtime or review completion.

- PR #27 (https://github.com/Maibokdaimhai/LECTRA/pull/27) is a separate tracker setup change awaiting review at inspection. It is not a completed Sprint 1 or permission to merge other work.

- This workflow draft uses branch `docs/9-sprint1-review-workflow` from `staging` baseline `333a9fc6a6a2905b07087c98eb5f5d931ffec107`. It does not include the unmerged PR #27 branch.

- Actual participants are GitHub users `Maibokdaimhai` and `R1NNE0`. Current assignments establish issue leads, not completed contributions or available hours. Both participate in design, implementation, tests and review.

The assignment requires Issues/board, feature/fix branches from sprint staging, substantive teammate review, integrated verification and a reviewed release to main. Specific board labels, branch names and template fields below are team conventions, not additional instructor requirements. See System SDS (../../system-sds.md), sprint plan (../plan.md) and decision log (../../decisions.md).

2. Existing Kanban states and verified setup

Reuse the existing six Status values; do not add spelling-equivalent duplicates. Specified maps to planning-ready scope and Started maps to in-progress work. A contract-writing task can have a clear specification before its output contract is written; moving it to Specified does not certify that the feature contract exists.

Backlog

Entry condition: Work is not selected or has unmet contract/foundation dependencies.

Exit / evidence rule: Move to Specified only when the bounded task can genuinely start; list remaining dependencies.

Specified

Entry condition: Scope/input/lead is clear enough to begin the task.

Exit / evidence rule: Move to Started when actual work begins, not merely because assigned. Feature-code readiness still requires its recorded contract.

Started

Entry condition: Actual bounded work is underway; includes an umbrella actively tracking a still-incomplete increment.

Exit / evidence rule: Move a bounded review-ready package to PR Review; do not move an entire delivery umbrella because one partial PR exists.

PR Review

Entry condition: A concrete PR/artifact and actual validation are ready for the opposite-member review.

Exit / evidence rule: Address findings in Fixing; Done still requires the applicable review/integration/DoD.

Fixing

Entry condition: Actual review findings or a real defect are being corrected.

Exit / evidence rule: Re-run affected checks and obtain re-review; no fabricated finding or approval.

Done

Entry condition: The full bounded issue acceptance/review/integration boundary is evidenced.

Exit / evidence rule: The existing auto-close rule closes the Issue when this status is set; do not use it as a cosmetic completion label.

Verified board arrangement after the authorized status updates:

Backlog

Cards observed: #15-#26 (12 cards).

Reason / limitation: Setup needs its bounded design; database/features/tests/release/report still have prerequisites. Final execution is not claimed ready.

Specified

Cards observed: #5, #6, #10-#14 (7 cards).

Reason / limitation: Shared contracts/DoD, evidence planning and feature-contract drafting can begin from the merged baseline. No completed contract is implied.

Started

Cards observed: #8 and #9 (2 cards).

Reason / limitation: Tracker setup is under PR #27 and the broader tracker remains active; #9 documentation/board setup is actually being performed.

PR Review / Fixing

Cards observed: No cards at this snapshot.

Reason / limitation: PR #27 remains a separate actual PR; #8 is the whole delivery tracker and must not be treated as fully review-complete.

Done

Cards observed: #1-#4 (4 pre-existing cards).

Reason / limitation: Left unchanged; no new review/approval is inferred or fabricated from these cards.

No issue was moved to Done or closed by this task, and no assignee/priority/estimate/date was invented. Record final board evidence again near the assessed release; this operational snapshot is not the final submission board.

Existing project rules inspected without modification: Auto-close issue maps Done to Issue closure; Pull request linked to issue sets Started; Pull request merged sets Done for the applicable PR item. Those rules do not override a linked umbrella's acceptance boundary. Seven workflows are enabled in the UI; no workflow was enabled/disabled here. Do not add a partial PR as a substitute for the entire tracker or assume its merge proves contract/tests/release completion.

Initial access inspection found a private project with only Maibokdaimhai listed as Admin. After the owner explicitly authorized inviting R1NNE0 with Write, the Invite action was submitted on 2026-11-06. GitHub Manage access then showed two members: Maibokdaimhai (Admin) and R1NNE0 (Write), with no pending label visible. This verifies the owner-side access configuration, not a login/use test by the teammate. Repository permissions, project visibility, authentication and approval settings were not changed.

Maintenance checklist: keep the 21 Sprint 1 cards reconciled with the milestone; update states only from actual work; attach real branch/PR/evidence links; capture the board URL/date/status/assignee view for the final report; retain the opposite member's review time. A lightweight one-primary-work-package-per-person preference is coordination guidance, not enforced capacity or equal-effort evidence.

3. Issue and contract readiness before code

The actual author/lead checks the issue's feature/FR/BR/NFR links, current baseline, intended change, exclusions, dependencies and planned reviewer. Under #5, agree shared Product DoD and ID conventions. Record/version each feature's design, UI/API/data details, observable AC and STS before implementing that feature.

The STS specifies test ID, linked AC, level, preconditions/input, action and expected result. Plan unit logic, real API/PostgreSQL persistence/access and selected UI/E2E checks with relevant negative/boundary/concurrency cases. Detailed F-01-F-05 contracts remain #10-#14, not silently supplied by a workflow template.

Issue leads own code and tests as well as the relevant design/documents. The opposite member reviews the bounded change. Record real pair work in the Issue/PR; no permanent documentation-only versus coding-only roles, equal-commit-count target or invented availability.

4. Branch and PR routing

Product/contract/process documentation

Starting point: Current accepted `staging`

Suggested branch convention: `docs/<issue>-<topic>`

PR target: `staging`

Bounded feature or setup implementation

Starting point: Current accepted `staging`, after applicable design/contract gate

Suggested branch convention: `feat/<issue>-<topic>` or `chore/<issue>-<topic>`

PR target: `staging`

Defect correction

Starting point: Current accepted `staging` or explicitly agreed isolated defect baseline

Suggested branch convention: `fix/<issue>-<topic>`

PR target: Normally `staging`; explain an exceptional baseline/route.

Sprint release

Starting point: Integrated and verified `staging`

Suggested branch convention: Existing staging branch

PR target: `main` through a separately reviewed release PR.

Use Conventional Commits and no `codex/` prefix. Do not base #9 on unmerged PR #27 or bring its diff in by cherry-pick just to obtain a pending file. If a change truly depends on an unmerged PR, state that dependency and wait or use an explicitly agreed stack; do not accidentally include unrelated work.

Before a new branch, inspect local changes and update remote references; use the correct accepted staging baseline without resetting another person's work. Updating/rebasing an existing PR must preserve needed contract/TDD history and account for real teammate feedback; do not force-push unreviewed history as a convenience.

Creating an Issue or assigning it is not permission for an assistant to commit, push, open/merge PRs or release. Use the current human authorization for each action's scope. The owner explicitly authorized committing, pushing and opening this #9 PR; teammate review, merge and release remain separate steps.

5. Reviewable PR contents

Use the proposed default PR template (../../../.github/pull_request_template.md) as a checklist/manual copy while it is being introduced. GitHub makes repository templates available after they reach the default branch; adding this file on a feature/staging branch is not proof that automatic template loading is active on the current `main`.

Each PR explains the problem/result, scope and linked Issues, feature/contract/AC references, actual source/test-design versions, changed UI/API/data layers, validation, risks/limitations and intended target. Use `Refs #8` for partial tracker setup

rather than a closing keyword that suggests the whole Sprint 1 is complete. Closing links must reflect the issue's actual acceptance scope and target-branch behavior, not be used to manufacture completion.

For important rule/defect work, include the actual intended-behavior failure before implementation/correction and passing result afterward, with versions and assertions. Do not substitute a syntax/import crash unrelated to intended behavior, weaken assertions or disable required tests to produce green output.

PR validation must identify commands, working environment, tested SHA, actual file/test names and passing/failing/skipped counts. Mark a check Not run or N/A with a reason when appropriate. Documentation-only changes may use appropriate link/structure checks and explain why app tests do not apply; do not fabricate an application build/test run for a repository that has no application yet.

6. Substantive teammate review

The reviewer is the other member, not the PR author or an AI acting as that person. The lead's current Issue annotation identifies the planned reviewer only; it is not a submitted review request, acceptance or proof that a review occurred.

Requirement and scope
Concrete questions / observations to record: Does the diff implement the stated feature/AC and exclude later-sprint work? Is a changed rule reflected in the contract?
UI/API/data consistency
Concrete questions / observations to record: Do payload/schema/constraints agree, including frozen scale metadata and validation/error behavior? Is persistence real?
Permissions and failure cases
Concrete questions / observations to record: Are role/owner/eligibility/other-user checks enforced by the backend? Are negative/boundary/concurrency cases meaningful?
Test strength
Concrete questions / observations to record: Do assertions prove outcomes/rollback/privacy rather than mirror implementation? Are failures/skips and actual execution versions visible?
History and evidence
Concrete questions / observations to record: Was the applicable contract/test design recorded before code? Is meaningful TDD evidence genuine? Are contributions/pair work accurate?
Setup and risk
Concrete questions / observations to record: Are configuration, migration/seed/restart behavior and limitations reproducible? No real secrets or unsafe data?

A review records a specific check, question, finding or reason for approval. Example format only: `Checked [actual scenario/file/version]; observed [actual outcome]; [finding or reason this satisfies AC].` Fill it with real observations; do not paste it as a completed review or call a generic `LGTM` substantive evidence. AI may prepare a checklist, but the student performs and owns their review.

Address review findings with bounded changes, update contracts/tests when justified, rerun affected checks and obtain re-review as needed. Preserve resolved conversations and actual approval references. A merge does not retroactively prove a substantive review existed.

7. Staging integration and local checks before completed CI

After real feature review/acceptance, integrate authorized PRs into `staging`. Run the agreed integration/system/selected browser checks on the integrated version; if integration fails, create/link a fix Issue/branch, preserve the failure and re-test rather than accepting a broken increment.

Before Lab 5, local commands/results tied to the actual tested commit are required evidence. This issue does not add empty CI workflows or claim build/test gates are configured. Required CI/quality-gate enforcement and repeatable Docker/GCP delivery belong to Lab 5 and are maintained afterward.

Branch protection, bypass rules, reviewer requirements, authentication and CI enforcement were not changed. The only permission change was the owner's explicitly authorized R1NNE0 Write project invitation recorded in section 2. Do not infer authorization for broader settings changes. Untested enforcement rules can prevent the intended two-person process; any later configuration needs a concrete reviewed plan and evidence that failed required checks block the normal route.

8. Release readiness and evidence

Issue #25 owns the accepted S1 release after feature/contract completion, actual integrated verification and reproducible setup. Prepare the reviewed staging→main release PR only with explicit authorization. One team member authors it and the other provides substantive review; shared Issue assignment does not permit self-approval.

After the authorized merge, record immutable release tag/SHA and run required build/tests on that actual accepted main version, not only the earlier feature/staging head. Retain meaningful names/files, commands, counts, failures/skips and actual tested SHA. Any later code fix requires appropriate new verification and a distinct accepted version; do not silently replace the assessed release.

Contract/history

Minimum fields to retain: Feature/FR/BR/NFR, AC/STS IDs, document version/commit and actual preimplementation sequence.

Feature PR

Minimum fields to retain: Issue, branch, author, actual teammate reviewer, substantive review link, checks, integration commit and real pair work.

Verification

Minimum fields to retain: Level, actual file/test name, command/run, expected/observed result, pass/fail/skip counts, tested SHA and environment.

Board snapshot

Minimum fields to retain: Actual board URL, date, visible issue/status/assignee information and relation to the assessed release; no staged fake Done cards.

Release/report

Minimum fields to retain: Reviewed release PR, tag/SHA, demonstrated app version, known limitations, both students' real contribution and final report references.

Issue #6 plans capture; #26 assembles actual evidence/PDF. Capture TDD/output/review details when they happen. Screenshots support direct evidence and readable PDF grading; no screenshot or issue count substitutes for real verification. Keep safe synthetic test access and secrets out of public artifacts.

9. Current completion boundary for #9

Workflow/board instructions and PR checklist

Status for this change: Included in this proposed change; actual publication/PR versions are recorded in #9 and its PR. Human review/integration remain pending.

Existing project board

Status for this change: Existing private LECTRA Kanban verified; all 21 S1 cards plus pre-existing #1-#4 reconciled; actual state mapping and updates recorded above.

Actual issue assignments

Status for this change: Already recorded in GitHub; proposed review pairing does not prove availability or review completion.

Real board updates and final board evidence

Status for this change: Operational updates verified through UI; recapture final board near release. No new Done/closure claimed.

Teammate project access
Status for this change: Owner-authorized Invite submitted; Manage access shows R1NNE0 (Write) and Maibokdaimhai (Admin). Actual teammate login/use remains unobserved.
Team agreement, review and integration
Status for this change: Pending actual human action; no approval or merge claimed.
Branch protection / CI checks
Status for this change: Not modified or claimed configured.

Keep #9 Open until the teammate confirms board use and this bounded documentation/configuration change receives actual teammate review/integration. The owner-side access configuration and local document checks do not prove those remaining steps or prevent independent contract drafting.

References

- GitHub: About Projects (https://docs.github.com/en/issues/planning-and-tracking-with-projects/learning-about-projects/about-projects): project/issue integration and views.

- GitHub: Customizing the board layout (https://docs.github.com/en/issues/planning-and-tracking-with-projects/customizing-views-in-your-project/customizing-the-board-layout): column/status mapping and view behavior.

- GitHub: Creating a pull request template (https://docs.github.com/en/communities/using-templates-to-encourage-useful-issues-and-pull-requests/creating-a-pull-request-template-for-your-repository): supported location and default-branch availability.

docs/sprints/sprint-1/tracker.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

Sprint 1 - Delivery Tracker and Acceptance Readiness

Related issue: #8 (https://github.com/Maibokdaimhai/LECTRA/issues/8). Status: tracking setup in progress; Sprint 1 is not complete.

1. Authority, baseline and snapshot

- Product baseline: PR #7 (https://github.com/Maibokdaimhai/LECTRA/pull/7) merged into `staging` at `333a9fc6a6a2905b07087c98eb5f5d931ffec107`.

- Working branch for this bounded change: `docs/8-sprint1-readiness-tracker`, created from the updated staging baseline. This branch contains no application implementation and is not a release.

- Repository sources: SRS (../../srs.md), features (../../features.md), traceability (../../traceability.md), System SDS (../../system-sds.md), sprint plan (../plan.md), and decision log (../../decisions.md). The two instructor PDFs remain assignment authority; this tracker adds no product requirement or feature ID.

- GitHub milestone: Sprint 1 - Deliverable 1 (https://github.com/Maibokdaimhai/LECTRA/milestone/1). Deadline: **8 November 2026, 23:59 Asia/Bangkok**.

- Issue-state/assignee snapshot observed: **2026-11-06T21:32:00+07:00**. This is a dated observation, not a live synchronized board or proof of implementation.

Observed planning setup: 21 Sprint 1 issues, all Open and assigned. Eight individual leads per member plus five shared issues do not imply equal effort or confirmed availability. The repository contains the merged planning documents and empty initial README; no S1 application, contracts, migrations or executed application tests were found at inspection. No runtime test, human approval or assessed release is claimed.

2. Current backlog and ownership

The table preserves actual issue state separately from evidence. An Open issue is not automatically unstarted, and a Closed issue would not prove correctness without its linked evidence.

#5 (https://github.com/Maibokdaimhai/LECTRA/issues/5)

Work package: Shared Part E / Product DoD

Current assignee(s): `Maibokdaimhai`, `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#6 (https://github.com/Maibokdaimhai/LECTRA/issues/6)

Work package: Evidence planning

Current assignee(s): `Maibokdaimhai`, `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#8 (https://github.com/Maibokdaimhai/LECTRA/issues/8)

Work package: Delivery tracker

Current assignee(s): `Maibokdaimhai`, `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#9 (https://github.com/Maibokdaimhai/LECTRA/issues/9)

Work package: Board / review workflow

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#10 (https://github.com/Maibokdaimhai/LECTRA/issues/10)

Work package: F-01 contract

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#11 (https://github.com/Maibokdaimhai/LECTRA/issues/11)

Work package: F-02 contract

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#12 (https://github.com/Maibokdaimhai/LECTRA/issues/12)

Work package: F-03 contract

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#13 (https://github.com/Maibokdaimhai/LECTRA/issues/13)

Work package: F-04 contract

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#14 (https://github.com/Maibokdaimhai/LECTRA/issues/14)

Work package: F-05 contract

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#15 (https://github.com/Maibokdaimhai/LECTRA/issues/15)

Work package: Workspace / verification tooling

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#16 (https://github.com/Maibokdaimhai/LECTRA/issues/16)

Work package: Schema / migrations / seed

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#17 (https://github.com/Maibokdaimhai/LECTRA/issues/17)

Work package: F-01 implementation

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#18 (https://github.com/Maibokdaimhai/LECTRA/issues/18)

Work package: F-02 implementation

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#19 (https://github.com/Maibokdaimhai/LECTRA/issues/19)

Work package: F-03 implementation

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#20 (https://github.com/Maibokdaimhai/LECTRA/issues/20)

Work package: F-04 implementation

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#21 (https://github.com/Maibokdaimhai/LECTRA/issues/21)

Work package: F-05 implementation

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#22 (https://github.com/Maibokdaimhai/LECTRA/issues/22)

Work package: Integrated API/DB/security checks

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#23 (https://github.com/Maibokdaimhai/LECTRA/issues/23)

Work package: Selected browser/E2E checks

Current assignee(s): `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#24 (https://github.com/Maibokdaimhai/LECTRA/issues/24)

Work package: Reproducible README

Current assignee(s): `Maibokdaimhai`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#25 (https://github.com/Maibokdaimhai/LECTRA/issues/25)

Work package: Reviewed release / verification

Current assignee(s): `Maibokdaimhai`, `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

#26 (https://github.com/Maibokdaimhai/LECTRA/issues/26)

Work package: Actual evidence / final PDF

Current assignee(s): `Maibokdaimhai`, `R1NNE0`

GitHub state at snapshot: Open

Completion evidence in this tracker: No completion evidence recorded here.

Each individual lead owns relevant design/contracts, code, tests and documents, with the other member as planned reviewer. Shared items require a bounded actual author/coordinator and the other reviewer for each change. Planned reviewer or shared assignment does not mean a review happened. Real availability and small task estimates are confirmed during #5 planning, not invented in this table.

3. What can start and what must wait

Planning-ready now

- #5: establish shared Product DoD, stable AC/test naming, interface/schema/security consistency and concrete bounded author/reviewer allocation.

- #10-#14: prepare F-01-F-05 contracts from the merged baseline. Each needs substantive review and an actual recorded version before its feature code. These contract drafts do not need an application to exist first.

- #6: plan evidence capture in parallel; do not wait for all implementation to finish before recording TDD, commands, versions and reviews.

- #9: prepare/use the actual project board and teammate-review workflow. This tracker does not claim that a board has been configured.

- #15: plan workspace/setup checks from the System SDS, then perform only the separately authorized setup work. A setup plan is not a completed feature contract or installed toolchain.

Execution gates and dependency order

#16 initial User/session database foundation

Inputs / completion gates: Working #15 setup, reviewed/versioned #10 User/session design and shared conventions/DoD under #5. No #11-#14 or full #16 closure gate for this subset.

What may proceed before those gates finish: Schema/fixture planning and review before these inputs; once ready, migrate/test only the accepted User/session subset and synthetic login accounts.

#16 subsequent domain migrations and full completion

Inputs / completion gates: Each context/survey/response/results schema increment needs its applicable reviewed #11-#14 contract and cross-feature consistency under #5. All required S1 schema/seed/constraints/checks are needed before #16 itself is complete.

What may proceed before those gates finish: Draft domain designs independently; no implementation of unreviewed domain rules or claim that the initial auth subset completes #16.

#17 F-01

Inputs / completion gates: Reviewed/versioned #10, accepted shared conventions/DoD, working #15 and verified #16 User/session subset. Full #16 completion and unrelated #11-#14 contracts are not prerequisites.

What may proceed before those gates finish: Intended-behavior test design after contract recording; no premature feature implementation/verification claims.

#18 F-02

Inputs / completion gates: Reviewed/versioned #11; #17 trusted identity and #16 context seed.

What may proceed before those gates finish: Context/access case design and UI specification.

#19 F-03

Inputs / completion gates: Reviewed/versioned #12; #17/#18 identity/context and #16 constraints.

What may proceed before those gates finish: State/validation test design, including Draft-edit/publication races.

#20 F-04

Inputs / completion gates: Reviewed/versioned #13; #17-#19; database uniqueness/transaction rules.

What may proceed before those gates finish: Rule tests after contract recording; no late reconstruction of failing-before evidence.

#21 F-05

Inputs / completion gates: Reviewed/versioned #14; persisted lifecycle/answers from #19/#20.

What may proceed before those gates finish: Calculation fixture and result-projection test design.

#22/#23 final integrated runs

Inputs / completion gates: Actual integrated #17-#21, safe real PostgreSQL fixtures and agreed AC/STS.

What may proceed before those gates finish: Write applicable tests early; these final checks do not replace feature-level TDD.

#24 verified README

Inputs / completion gates: Actual scripts/config/migrations/seed and working feature journey.

What may proceed before those gates finish: Outline documentation; never invent runnable commands.

#25 release

Inputs / completion gates: #9 workflow, actual #22/#23 results, #24 reproduction and fulfilled DoD; separately authorized reviewed release actions.

What may proceed before those gates finish: Review the readiness checklist; no merge/tag/release authorization from this tracker.

#26 PDF

Inputs / completion gates: #5 contracts, #6 evidence plan, actual application/review/test evidence and #25 immutable assessed release.

What may proceed before those gates finish: Capture and organize evidence when it occurs, then assemble readable final A-F content.

Critical path: shared setup and reviewed User/session subset → identity; reviewed context/domain schema increments → context/publication → response transaction → results → integrated verification/review → accepted release → assessed PDF. #16 is an incrementally delivered foundation Issue, not a requirement to finish every domain contract before authentication can start. Keep one additive migration history; verify each accepted subset and do not mark the full Issue complete early. Work on contract/evidence plans can overlap; a teammate's review time is a real dependency. Future features F-06-F-10, anonymous collection, starter/export/history/notes and Lab 5-7 completion are not added to S1.

4. Readiness gates - evidence required before marking complete

Planning baseline

Required observed evidence: Merged baseline reference, linked requirements/design and scoped issues.

Current status: Baseline merge and issue allocation observed; not proof of human review or code completion.

Part E / feature start

Required observed evidence: Reviewed/versioned feature design, UI/API/data contracts, AC/STS and Product DoD before each feature implementation.

Current status: Missing from inspected repository; #5 and #10-#14 remain Open.

Working domain increment

Required observed evidence: Actual owner create/publish → eligible student submit/readback → owner close/results through UI/API/PostgreSQL.

Current status: Not implemented/verified at inspection.

Business/access/persistence

Required observed evidence: Meaningful unit tests; real API/DB permission/rollback/concurrency checks; selected E2E; restart readback and observed results.

Current status: Not run; no pass/coverage claim.

Reviewed integration

Required observed evidence: Real Issue/contract/branch/PR links, substantive opposite-member review and staging integration.

Current status: Feature review/integration evidence not recorded here.

Release

Required observed evidence: Authorized reviewed staging→main release; actual accepted SHA/tag and build/test output on that SHA.

Current status: Not achieved; planning merge is not the S1 release.

Deliverable 1 PDF

Required observed evidence: Complete A-E plus actual F evidence, team identity/contributions, navigation pages, limitations and immutable release reference.

Current status: Not assembled or submitted.

Issue #8 stays Open until its full completion boundary is evidenced. Finishing this tracking document or assigning every issue is only tracking setup, not Sprint 1 acceptance. Do not check product/test/release boxes based on an AI statement or issue count.

5. Evidence-recording fields

For every completed AC/check, link the actual `feature/requirement → AC → planned test → test file/name/level → command or run → tested SHA → observed PASS/FAIL/SKIP → evidence location`. Record manual checks separately. Use Not specified/Not run while details or execution do not exist; do not create placeholder PASS entries.

For meaningful TDD, retain the actual intended-behavior failure before correction and passing output afterward with their versions. For a completed work package, record Issue, branch, PR author, actual reviewer, substantive review reference, integrated commit and any real pair contribution. Do not infer review from merge alone.

Capture PDF demonstrations on the stated assessed release: normal journey and persisted readback, meaningful rejection, login/logout and forbidden backend operation, with role/preconditions/steps/expected/actual and feature/AC references. Final evidence needs the actual two sampled test excerpts, two completed Issues/PRs, board state and both students'

contributions required by the handout. Keep safe demo setup and all failed/skipped/incomplete work visible.

6. Update and close-out rules

1. Refresh issue/board state and evidence links after actual work or integration; keep snapshot date and source/version clear. Do not silently rewrite historical test versions.

2. Verify the issue's own AC/DoD and linked results before marking Done. Investigate mismatches such as Closed-with-no-evidence instead of treating state as correctness.

3. Keep #5 the Part E umbrella and #6 the evidence plan. Use #26 for final actual evidence/PDF, without inventing a second Part F.

4. Changes to product scope/requirements require normal decision/traceability/contract updates. This tracker does not override source policy, create approvals or authorize further implementation/Git/release actions.

5. Before closing #8, both students inspect the completed gates and the released application's actual evidence. Release/PDF completion and known limitations must be explicit; obtain real review rather than auto-closing from task-list progress.

7. Immediate handoff

Next bounded product work is #5 shared contract/DoD conventions and the appropriate feature contract, for example #10 (F-01, lead Maibokdaimhai; planned reviewer R1NNE0). The other member can draft #11/#12/#14 under the agreed allocation, while #6 plans evidence. The owner authorized committing/pushing this bounded tracker change and opening its PR into staging. Publication does not implement or close any child task, prove teammate approval or authorize a release; use the actual Git/PR history for publication evidence.

Part E - Feature contracts, AC, STS and Product DoD

docs/sprints/sprint-1/README.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

Sprint 1 - Part E Contract Register

Version 0.1, 2026-11-06. Working draft for umbrella #5 (https://github.com/Maibokdaimhai/LECTRA/issues/5). Shared owners: Maibokdaimhai and R1NNE0. This register records proposed documents and review gates; it is not an approval, completed contribution table or implementation/test result.

1. What must precede implementation

#5 has two responsibilities: common Product Definition of Done/conventions, and coordination of the five feature contracts #10-#14. It is not a sixth product feature or a separate copy of every child Issue. Complete the common reviewable foundation first, then elaborate/review each feature's own contract before coding that feature. A feature does not wait for all five contracts or for the umbrella to close; it waits for its own contract, shared conventions/DoD and its real setup/feature dependencies.

Instructor sources are `group_work_specs_v1.pdf` sections 5.2 and 8.2, and `project_deliverable_1_v1.pdf` sections 3.5-3.6. They require preimplementation feature design, applicable UI/API/data specification, stable AC, STS, DoD, meaningful verification/TDD and human review evidence. The file names, ID syntax, exact protocol/limits and document layout here are team choices. See SRS source authority (../../srs.md), shared engineering contract (shared-contract.md) and Product DoD (product-dod.md).

Common foundation under #5

Bounded outcome: Review the Product DoD, ID/error/UI/data conventions, dependency boundaries and initial opposite-member review allocation.

What it does not prove: Does not implement auth, create all feature contracts, or approve unknown student availability.

Feature contract under #10-#14

Bounded outcome: Record that feature's design, exact UI/API/schema/transaction details, stable AC and mapped STS; obtain real teammate review and retain its version.

What it does not prove: A written contract is not an executed test or a working feature.

Setup and feature work #15-#21

Bounded outcome: Record bounded setup/schema designs; implement the reviewed feature using the actual shared foundation and capture tests when they run.

What it does not prove: Tooling setup does not satisfy domain AC; seed does not depend on working login UI.

Integration/release/report #22-#26

Bounded outcome: Verify combined real behavior, accepted reviewed integration and release-SHA evidence/PDF.

What it does not prove: A contract-only PR or opening an Issue cannot complete Part F.

Minimum foundation for #17 is the reviewed F-01 contract plus shared accepted DoD/conventions and the needed User/session subset of #15/#16. Do not wait for an unrelated future result screen or unimplemented survey seed to authenticate a synthetic account. Domain migrations/fixtures still wait for their applicable reviewed feature/schema design.

#16 is phased within one additive migration history: first User/auth_session and synthetic login accounts after #15/#10/shared review; then Course/Section/Membership/Lecture under #11, survey/question/eligibility under #12, response constraints under #13 and any results-related schema detail under #14. Each phase needs its applicable accepted contract and real verification, not acceptance of every later phase in advance. #17 consumes the verified first subset without waiting for #16 to close. #16 closes only when its whole S1 scope is actually implemented/verified. The tracker execution gates (tracker.md) use this same distinction.

2. Document register and truthful readiness

#5 common foundation

Current artifact: This register; shared contract (shared-contract.md); Product DoD (product-dod.md)

Lead / planned reviewer: Shared Issue owners; review records in PR #29

Current boundary: Shared documentation merged via PR #29; cross-feature agreement/traceability follow-through remains under #5. New edits here are not yet reviewed.

F-01 / #10

Current artifact: Authentication contract (f-01-authentication.md); STS (f-01-authentication-sts.md)

Lead / planned reviewer: Maibokdaimhai / R1NNE0

Current boundary: PR #29 approved/merged for documentation; 20 AC/47 planned cases. No implemented auth or executed feature tests.

F-02 / #11

Current artifact: Context contract (f-02-context-discovery.md); STS (f-02-context-discovery-sts.md)

Lead / planned reviewer: R1NNE0 / Maibokdaimhai

Current boundary: PR #31 GitHub-approved/merged; review text is generic, so substantive-review evidence still needs real human follow-through. Interface agreements remain precode gates.

F-03 / #12

Current artifact: Survey contract (f-03-survey-authoring.md); STS (f-03-survey-authoring-sts.md)

Lead / planned reviewer: R1NNE0 / Maibokdaimhai

Current boundary: PR #32 approved/merged for documentation; actual schema/interface/lock agreement and implementation verification remain separate.

F-04 / #13

Current artifact: Response contract (f-04-responses.md); STS (f-04-responses-sts.md)

Lead / planned reviewer: Maibokdaimhai / R1NNE0

Current boundary: New local draft: 25 AC/36 planned cases, no human review or F-04 execution.

F-05 / #14

Current artifact: Results contract (f-05-results.md); STS (f-05-results-sts.md)

Lead / planned reviewer: R1NNE0 / Maibokdaimhai

Current boundary: PR #33 approved/merged for documentation; rounding/wire/query/privacy agreements and real implementation remain separate gates.

Assignments above reflect the existing owner-authorized GitHub allocation; review names are plans, not sent review requests or completed work. Both members own design/code/tests for their bounded features and review the other's work. Actual time/availability and estimates are unconfirmed; no private schedule collection or equal-commit/Issue-count target is required. Before making a firm implementation commitment, each lead confirms the next bounded task and actual review opportunity in its Issue. Unknown capacity does not block drafting this common foundation or count as consent/availability.

3. Minimum structure for each child contract

Each feature supplies its own concrete details; do not fill a copied template with unsupported completion statements:

1. Version/status/source authority; feature/FR/BR/NFR/SYS IDs; lead/planned reviewer; scope/exclusions; dependencies.

2. Behavior/workflow/business rules; role and record permission matrix; failures/boundaries; ambiguous-request recovery.

3. UI navigation/fields/loading/empty/validation/expired/forbidden/error states, following the existing cool theme and keyboard/viewport targets.

4. Applicable API method/path, exact request/success/error shape, safe projection, validation, status/precedence and no-change layers stated explicitly.

5. Data fields/types/constraints/migration ownership, authoritative transactions/lock order and reproducible safe fixtures where relevant.

6. Stable observable AC and complete mapped STS: ID, linked AC, level, preconditions/input, action and expected result. Assign actual source files/results only after they exist.

7. Meaningful TDD targets, Product DoD version plus feature-specific evidence, unresolved decisions with owners/gates and actual contract/review history.

The shared contract (shared-contract.md) gives the conventions and cross-feature checklist. A feature-specific exception must be explained, reviewed and reflected in dependent contracts; an assistant must not silently select a conflicting wire/schema policy.

4. #5 acceptance coverage and remaining work

Feature/requirement/permission/workflow links

Evidence prepared by this change: Shared boundary matrix, inventory/traceability and merged F-01/F-02/F-03/F-05 contracts; draft F-04.

What remains before #5 can close: F-04 substantive review, cross-feature agreements and final consistency/traceability.

UI/API/data detail and explicit no-change layers

Evidence prepared by this change: Shared protocol/schema/UI conventions; F-01 exact contract.

What remains before #5 can close: Each remaining child supplies exact layer details, constraints and migrations.

Stable observable AC

Evidence prepared by this change: Naming rules; F-01 AC-F01-01 through AC-F01-20.

What remains before #5 can close: All other feature AC, including negative/boundary/access cases.

STS and AC coverage

Evidence prepared by this change: Required STS structure; F-01 mapping with 47 planned cases.

What remains before #5 can close: Each remaining STS and cross-feature coverage audit. No executed result inferred.

Unit, API/real DB and selected browser coverage

Evidence prepared by this change: Product DoD and shared risk/level matrix.

What remains before #5 can close: Feature-specific preconditions/actions/assertions and actual execution in implementation.

Login/access/ownership/eligibility/response/lifecycle cases

Evidence prepared by this change: Shared integration handoffs; F-01 cases and explicit real-domain checks.

What remains before #5 can close: Child design for actual survey/response/results routes and transaction/race fixtures.

TDD rules/history

Evidence prepared by this change: Common TDD/evidence plan plus F-01 targeted rules.

What remains before #5 can close: Actual RED/GREEN versions/results when coding; no retrospective reconstruction.

Product DoD

Evidence prepared by this change: Product DoD draft (product-dod.md), scoped separately for docs, features and release.

What remains before #5 can close: Actual teammate adoption/review of this version and later evidence of compliance.

Preimplementation version/review history

Evidence prepared by this change: Proposed source; actual publication refs recorded in #5/#10 and PR.

What remains before #5 can close: Real substantive opposite-member review and accepted contract versions before code.

Keep #5 Open. Shared/F-01/F-02/F-03/F-05 documentation has merged, while #13 is a new draft and cross-feature agreements/complete traceability still need coordination. Merge/approval metadata is not executed feature verification. Record accepted source versions and substantive review evidence accurately. #6 plans evidence/PDF capture; #26 assembles actual evidence; neither is replaced by this register.

5. Current work and next bounded actions

- Review the shared conventions/DoD and F-01 alignment. Resolve disagreements here before implementation rather than create competing per-feature meanings.

- Review #13 and coordinate the already merged #10/#11/#12/#14 interfaces; no message, agreement or human review is fabricated on behalf of either student.

- #15 records actual runtime/lockfile/test commands and bounded setup results; #16 coordinates one migration history and safe fixtures. Existing F-01 candidates remain uninstalled/unverified proposals.

- After each accepted contract and available prerequisites, do only that feature's implementation and capture meaningful tests/history. Review/integrate, then run cross-feature checks before release.

No commit, push, PR, implementation, test execution or human review is authorized merely by adding a row to this register. Use the project owner's actual scoped authorization for publication/release actions.

docs/sprints/sprint-1/shared-contract.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

Sprint 1 - Shared Engineering Contract

Version 0.1, 2026-11-06; status updated 2026-11-07. Common documentation for #5 (https://github.com/Maibokdaimhai/LECTRA/issues/5), alongside the contract register (README.md) and Product DoD (product-dod.md), approved/merged via PR #29. Additional proposed wire/normalization/schema choices in child contracts still need coordinated review before affected code. These conventions do not prove implementation or executed product verification.

1. Authority, scope and naming

Instructor outcomes are identified in the SRS (../../srs.md) and register. Existing LECTRA business rules remain authoritative working scope: F-01-F-05 in S1, identified rating/text surveys, real identity and persistence, Section ownership, frozen publication/eligibility, one immutable response and authorized aggregates/text. Anonymous mode, choice/subset/starter/export/history/notes remain later-sprint work. Numeric limits, exact wire/schema names and IDs below are proposed team details selected to make those rules implementable consistently.

Requirements/features
Convention: Preserve FR-xx, BR-xx, NFR-xx, F-01-F-10 and SYS-01-SYS-04. Do not renumber them to match a filename or create a second identity for the same rule.
Feature AC
Convention: `AC-F01-01`, `AC-F02-01`, etc. Full IDs in authoritative tables; append new IDs, retain changed/retired history.
Feature STS
Convention: `TEST-F01-U01` unit, `I01` API/DB, `E01` selected UI/E2E, `M01` supplementary/manual/process, `H01` cross-feature handoff; replace F01 for other features. State the level in every STS row.
Shared/release criteria
Convention: DOD-01-DOD-12 in Product DoD; use a feature AC or named system responsibility for implementation tests, not a new product feature just to number a process check.
Cross-feature tests
Convention: Allocate a primary owning STS ID and reference other AC/features. An H-case is planned delegated coverage until its actual route/result exists; do not count it as already passed twice.
JSON / code / database
Convention: camelCase JSON/domain fields, uppercase wire enum values below; database mapping is explicit in the reviewed Prisma/SQL schema. Display labels may say Draft/Published/Closed without changing wire meaning.
Artifact status
Convention: Draft -> actual reviewed/versioned contract -> implemented/verified -> reviewed/integrated -> released, with real references for each boundary. A filename or checked design row is not an approval.

Every STS row includes full test ID, linked AC, level, preconditions/fixtures/input, action and expected observable outcome. The actual-result extension records actual source/test file, case name, command/environment, tested SHA, outcome/counts and evidence location when executed. Stable design IDs do not need to equal framework function names; maintain the mapping. Example ID forms are conventions, not real executed tests.

2. Protocol and error conventions

2.1 Shared transport

One browser origin serves UI and `/api`; local Vite proxies `/api` to Express. Use same-origin credentialed fetch and the F-01 session/Origin/CSRF policy. No client actor/role selector, JWT refresh endpoint, permissive credentialed CORS or second browser API origin is introduced.

Request JSON keys are explicitly allowlisted in each feature's schema; reject unknown identity/privilege keys instead of treating them as authority. Accept application/json with optional UTF-8 charset for JSON writes, no compressed bodies in the S1 profile, JSON objects at the top level, strict type/decoded validation and per-route byte limits. Bytes are measured before JSON parsing, independent of Content-Length claims/chunking. API success is sent only after the authoritative DB commit/save/destroy succeeds. Unexpected errors use a safe generic envelope, never raw SQL/stack/cookie/token/input values.

Single read / successful transition

Shared shape or rule: `{ "data": ... }`; creation/submission 201, reads/transitions 200, successful deletion/logout 204 without a body. Feature contract names the exact object.

Paginated list

Shared shape or rule: `{ "data": { "items": [], "pagination": { "limit": 20, "offset": 0, "total": 0 } } }`. Total is the authorized filtered set only, not another owner's or all students' rows.

Safe error

Shared shape or rule: `{ "error": { "code": "CODE", "message": "safe text" } }`. Validation may add `fields` with safe field paths/reasons, never echoed input.

Field paths

Shared shape or rule: `email`, `title`, `questions[0].prompt`, `answers[0].value`; `_form` for schema/cross-field errors. The feature contract fixes actual paths and messages.

Cache

Shared shape or rule: Auth and private data responses use Cache-Control: no-store; no persistent browser cache/storage for identity, drafts/answers or results. Clear private state on logout/detected session loss.

Read errors / ambiguous writes

Shared shape or rule: Explicit safe read retry is allowed. After an ambiguous response submission, query own persisted status; do not assert failure or blindly submit again. Resolve auth ambiguity through bootstrap/me as F-01 specifies.

2.2 Identity and rejection order

Use F-01's exact method/Origin/transport/session rules. For protected domain operations: after outer transport/session handling, resolve trusted authentication, then CSRF for unsafe methods, then role, syntactic/domain input validation and owner/eligibility-scoped record access. Wrong role is rejected before exposing record details. A valid-format but missing/out-of-scope record returns the same 404 envelope; a malformed UUID can be 422 after authentication/role without a DB cast error. Feature contracts must specify state/duplicate/domain-validation precedence where two domain failures overlap.

Authentication resolves a request-local immutable actor from the session and trusted User table. Ownership follows Survey -> Lecture -> Section -> owner; sharing a Course grants no permission. A client-supplied ownerId/studentId/userId/role never chooses the actor. Services pass the actor ID into scoped DB predicates and reject inconsistent redundant ownership data. No frontend-only access enforcement.

400 MALFORMED_JSON

Use: Invalid JSON syntax.

401 AUTH_REQUIRED / SESSION_EXPIRED / INVALID_CREDENTIALS

Use: Missing/unusable/expired session or generic credentials failure; F-01 fixes exact distinctions.

403 ORIGIN_FORBIDDEN / CSRF_INVALID / FORBIDDEN_ROLE

Use: Origin/token violation or authenticated wrong-role operation; no private data.

404 NOT_FOUND

Use: Missing/inaccessible authorized-scope resource, same safe outward shape.

405 METHOD_NOT_ALLOWED

Use: Recognized path unsupported method, Allow header, no side effect.

409 state/uniqueness/revision conflict

Use: Child specifies codes such as SURVEY_STATE_CONFLICT, SURVEY_ALREADY_EXISTS, RESPONSE_ALREADY_SUBMITTED or REVISION_CONFLICT; map actual DB constraints safely. Do not return a success on a rejected duplicate.

413 BODY_TOO_LARGE / 415 UNSUPPORTED_CONTENT

Use: Encoded-byte ceiling or unsupported content type/compression, before persistence.

422 VALIDATION_FAILED

Use: Well-formed schema/type/range/required/ID validation; safe field mapping.

429 LOGIN_RATE_LIMITED

Use: F-01 login bound with Retry-After; no account existence signal.

503 AUTH_SERVICE_UNAVAILABLE / SERVICE_UNAVAILABLE

Use: Known unavailable auth store/DB or domain DB dependency, no memory fallback or false success.

500 INTERNAL_ERROR

Use: Unexpected failure, safe outward envelope and safe diagnostics only.

These shared codes are proposed names. F-02-F-05 must finalize their exact non-auth state/duplicate/validation statuses and precedence in the child contract. Do not infer a complete error matrix from this short registry. An exception requires a documented reason and impact review across callers/tests.

2.3 Lists and IDs

Use `limit` default 20, range 1-100, `offset` default 0, range 0-10,000; nonnegative canonical decimal query syntax with no fractional/negative/NaN values. Invalid values return 422. Apply role/owner/eligibility filtering before count/pagination; child contracts define deterministic order plus ID tiebreaker. Unknown query/filter fields are rejected under the endpoint's exact schema, not silently reinterpreted as F-09 historical search. S1 context selectors and current-work/eligible lists remain F-02; date/state history search is F-09/S3.

Propose server-generated canonical UUIDs (36 ASCII characters with hyphens) for S1 entity identifiers. Clients use only IDs from authorized projections; valid syntax never grants access. #16 and child contracts must agree generation/DB mappings before installation/implementation. Client temporary editor keys cannot become authoritative persisted IDs. Role enums: OWNER/RESPONDENT; survey status: DRAFT/PUBLISHED/CLOSED; S1 mode: IDENTIFIED; question type: RATING/TEXT. No selectable ANONYMOUS/SINGLE_CHOICE path is implemented by naming future baseline concepts.

Dates: server event times are ISO-8601 UTC instants; lectureDate is a calendar date `YYYY-MM-DD`, not a timestamp shifted by browser timezone. F-01 internal security times remain epoch milliseconds with fixed absolute deadlines. No response/bundle per-submission timestamp or participant ordering is added to owner result projections.

3. Shared data, validation and request sizing

3.1 Data meanings and constraints

User/session

Shared invariant / owning contract: F-01 defines trusted single role, normalized unique email/hash, safe identity, auth_session shape/expiry and cookie/token policy. #16 owns one reviewed User/session migration; #17 configures/runtime-verifies the store.

Course/Section/Lecture/Membership

Shared invariant / owning contract: F-02 defines seeded read-only hierarchy and authorized projections. Unique Course code, Section course/term/code, Lecture Section/sequence and membership pair; Section has one owner. Seed/setup is independent of login UI.

Survey

Shared invariant / owning contract: One per lecture by DB uniqueness; ownership matches lecture's Section, not merely Course. Draft -> Published -> Closed, no reopen. F-03 defines definitionRevision and all mutation/publication preconditions.

Question

Shared invariant / owning contract: Stable server ID, unique survey/position, prompt/type/required; RATING stores min=1/max=5 and endpoint labels/interpretation; TEXT has no rating scale. F-03 defines exact wire/schema mapping and publication validation.

SurveyEligibility

Shared invariant / owning contract: Frozen survey/student pair selected from Section membership at publication. F-03 commits snapshot/state together. Later membership edits do not change it.

Participation

Shared invariant / owning contract: Unique survey/student pair with eligibility FK. Authoritative own-submission status, not answer-row count; no answer-bundle ID or per-submission timestamp added.

ResponseBundle / Answer

Shared invariant / owning contract: F-04 atomic participation/bundle/answers. Identified student association references that survey's eligibility; one identified bundle per survey/student. Composite links keep answer's question/bundle in the same survey; one typed value; rating CHECK 1-5.

Results

Shared invariant / owning contract: Derived from committed answers under F-05, not separately editable stored summary. Owner while Published sees count only; Closed identified results follow no-identity comment projection.

The table coordinates ownership; exact SQL/Prisma types/constraints/delete behavior remain a reviewed #16/feature artifact, never an inferred migration already applied. Expressible local invariants use FK/CHECK/unique constraints; cross-table role/owner/type/completeness invariants use authoritative service/transaction validation with actual tests. Redundant owner IDs must agree with the canonical relation. No client ID equality check substitutes for trusted lookup.

Use Unicode code-point counts for domain text bounds, not UTF-16 code units or encoded-byte counts. Reject invalid types rather than coerce strings to ratings/booleans. Required text rejects whitespace-only input; optional blank text normalizes to no answer. Preserve nonblank response content as plain text; rendering escapes it. Exact title/prompt trimming and Draft-save incomplete-state policy belong to F-03, so publication-only validity is not mistakenly imposed on every temporary editor field.

Survey title <=120; prompt <=500 code points

Required cross-feature interpretation: Nonblank published values; F-03 states Draft persistence rules and tests 0/1/max/max+1 boundaries.

Published survey 1-10 questions, at least one RATING in S1

Required cross-feature interpretation: Text-only or zero-question publication rejected. SINGLE_CHOICE remains S2; no later feature required to publish S1.

Rating integer 1-5

Required cross-feature interpretation: No default score, numeric-string/boolean/null coercion or missing-optional zero. Persist/display same frozen scale meaning in authoring, answering and results.

Text answer <=2,000 code points; at most ten answers

Required cross-feature interpretation: Unknown/duplicate/wrong-survey question IDs and wrong-type values rejected; every required answer valid; at least one nonempty answer even when all optional.

Scale labels / interpretation

Required cross-feature interpretation: Proposed labels 1-120 and interpretation 1-500 code points, nonblank after trim; F-03/#16 must adopt consistent columns and tests before code. These new exact label bounds are team proposals, not teacher limits.

Freeze title/question definitions/order/required flags/scales/mode/eligibility after publication through state-checked writes, not only disabled UI. Definition revisions change on actual Draft-definition edits under F-03's row lock; do not create an unrelated competing revision model in another feature. No submitted-answer edit/withdrawal API or Published/Closed hard delete is added.

3.2 BASE-03 common transport proposal for F-04

Adopt the following bounded candidate envelope for #13 to finish, review and test as its exact submit contract:

```
{
  "answers": [
    { "questionId": "<canonical UUID>", "value": 4 },
    { "questionId": "<canonical UUID>", "value": "A point to explain next time" }
  ]
}
```

Only `answers` at the top level; each item only questionId/value; numeric rating or text string determined by the stored question type. No client type override, student/owner/role ID, null fabricated value or arbitrary metadata. Omit unanswered optional questions; an optional blank text item normalizes to no stored answer. Question IDs are unique and belong to the survey in the authorized path. F-04 defines atomic normalization/validation and the exact 201 confirmation/status/readback shapes; this shared envelope alone does not complete #13.

Set a proposed auth POST ceiling of 8,192 bytes (F-01), survey-definition write ceiling of 262,144 bytes (F-03 to adopt/test), and response submission ceiling of 262,144 bytes (256 KiB). Do not put a smaller global parser limit ahead of those routes. Other state-transition requests use their bounded JSON schema/8 KiB ceiling unless the child contract records a reason. Reject compressed content with 415 in the S1 profile; configure parser inflation accordingly. Decoded limits are enforced independently after parsing; no persistence on 413/415 or invalid content.

Worst-case response sizing: ten 2,000-code-point supplementary-character text values serialized as surrogate-pair JSON escapes occupy 240,000 ASCII bytes. Reserve up to 8,192 bytes for the fixed top/item keys, punctuation, ten bounded UUIDs and ordinary supported envelope formatting; total 248,192 <262,144. This is a conservative transport bound even though an actually publishable S1 survey must include a rating. It does not authorize a ten-text-only survey. Keys/IDs/count remain strictly bounded; arbitrary padding or unusual serializations beyond the byte cap are not promised acceptance. The 8 KiB reserve is a supported fixture/serializer budget, not a custom raw-JSON substring parser requirement.

For survey definitions, ten maximum RATING questions can contain 10 x (500 prompt +120 min label +120 max label +500 interpretation) plus a 120-code-point title. At twelve bytes per escaped supplementary code point, that is 150,240 value bytes; reserve 16,384 bytes for its bounded definition envelope/IDs/other fields, giving 166,624 <262,144. A 64 KiB global authoring limit would not support this worst-case representation. F-03 must finalize the exact create/update envelope and verify the reserve against its supported serializer.

Document-only sizing check during drafting: compact illustrative Python JSON fixtures measured 80,663 UTF-8 / 240,663 surrogate-escaped bytes for the conservative ten-text response envelope, and 51,936 / 152,096 bytes for ten maximum rating definitions with canonical IDs. Both fit the candidate ceiling and envelope reserves. These are serializer-size observations on proposed shapes, not execution against an application parser, accepted F-03/F-04 payloads or domain PASS results.

Under #13, generate the actual maximum UTF-8 and surrogate-escaped fixtures, measure encoded bytes and show the supported maximum reaches parsing/validation without 413; test 262,144/262,145-byte transport boundaries and 2,000/2,001 decoded code-point boundaries independently. Under #12 verify the maximum survey-definition fixture fits its 256 KiB ceiling, including ten prompts/scales. These calculations/proposals are not executed parser tests; child acceptance remains pending actual contract review and later runtime evidence.

3.3 BASE-06 frozen scale projection and result definitions

Proposed shared question scale shape is `ratingScale: { min: 1, max: 5, minLabel, maxLabel, interpretation }` for RATING, `ratingScale: null` for TEXT. F-03 maps it to ratingMin/ratingMax/ratingMinLabel/ratingMaxLabel/scaleInterpretation columns; F-04 answering reads and F-05 results return that frozen definition. Same range alone never means higher is better, equivalent wording or comparable metric versions. No S2 metric/template lineage fields are required in S1.

F-05 reports submitted-student responseCount separately from each question's answeredCount. A missing optional answer contributes neither a score nor that question's denominator. Distribution covers score 1 through 5, including zero bins; bin counts sum to answeredCount. Mean is sum/answeredCount, null at zero. Proposed display convention is two decimal places with decimal half-up rounding of the nonnegative rational mean; choose/document API precision and a robust calculation in #14, with a tie fixture such as sum=121/count=40 -> displayed 3.03. Do not infer an overall instructor score or an unlabelled average across questions. This refines the baseline's two-decimal display choice, not an instructor-specified rounding method.

Owner result projections: Published includes only allowed survey metadata and responseCount; Closed identified can include question metadata/numerics and text comments as plain text. Comments exclude user/student IDs, names, avatars, bundle/participation IDs and submission timestamps; no participant list/identity join. Content can itself identify a student, and small identified groups have no promised anonymity threshold. Respondents can retrieve only their own status/identified answers through F-04; owners get no respondent-linked answer endpoint. Every child names an allowlist and tests absent forbidden fields, not merely hiding them in UI.

4. Transaction and failure consistency

All domain reads/writes enforce role/ownership/eligibility server-side. Transaction callbacks avoid password hashing, external calls and frontend rendering while holding survey locks. Use one consistent lock order and actual Postgres constraints; do not claim request arrival order defines the outcome.

Draft edit/delete versus publish

Required contract ownership and assertions: F-03 locks/checks the same Survey row; published definitions cannot mutate after a stale Draft check. Publication validates questions/owner/nonempty members and commits snapshot/state atomically.

Two creates for one lecture

Required contract ownership and assertions: F-03 plus #16 unique Survey.lectureId; one succeeds, other safe 409; no duplicate survey or partial definitions.

Duplicate submit

Required contract ownership and assertions: F-04 checks state/eligibility under Survey lock, enforces unique participation/identified bundle and atomically commits participation/bundle/answers. Sequential/concurrent duplicate leaves exactly one committed response.

Close versus submit

Required contract ownership and assertions: F-03/F-04 same Survey lock: if close commits first, reject submit; if submit commits first, Closed results include it. Use barrier-controlled tests for both orders.

Invalid answer or transaction fault

Required contract ownership and assertions: F-04 rolls back every related row; no participation-only completion or success UI. Map expected constraint conflicts safely; unexpected error is failure.

Lost submit confirmation

Required contract ownership and assertions: F-04 own-status read discovers actual committed outcome; immutable submitted answers are not resubmitted/edited as a recovery shortcut.

Store/session failure or logout/read overlap

Required contract ownership and assertions: F-01 safe failure, no memory fallback; no old-session resurrection after acknowledged logout. This does not cancel an already authorized domain transaction.

Result read/restart

Required contract ownership and assertions: F-05 derives from committed authoritative rows; reads do not mutate answer/state; fixture result survives app restart.

Do not add unconditional transaction retries or silently retry non-idempotent POSTs. Any deadlock/serialization retry policy must be bounded and reviewed in the owning contract; expected uniqueness/state rejection is not a retryable success. #16 coordinates one migration history including custom session SQL; feature leads define invariants; no two competing initial schemas or startup destructive resets. Disposable seed/test cleanup is guarded and separate from development/deployed data.

5. Shared UI, privacy and test-design coverage

Use System SDS section 6 (../../system-sds.md) for the existing cool blue/teal light theme, semantic tokens and accessible component states. No new design library, dark-mode toggle or separate role branding is added. Each child provides navigation/fields and loading/empty/validation/busy/401/403/404/5xx states, server-confirmed success, keyboard/focus behavior and 360px/1280px core journey verification. Preserve entered response content on recoverable validation/network error; expiry/logout clears private state and never promises draft recovery. F-01 login passwords are deliberately cleared after completed attempts, so response-form preservation is not a reason to persist passwords.

Display truthful identified-mode disclosure before answering: the answer remains linked to the student in storage; owners see aggregates and unlabelled text after closure, and text may itself reveal identity. Do not call it anonymous, publish per-student participation, add raw-data admin endpoints or automatically send feedback outside the product. F-06's later anonymous collection/privacy decisions remain open; no anonymous toggle is enabled here.

FR-01, BR-01/02, NFR-01

Minimum planned coverage in owning child/integration work: Valid/invalid login; expiry/logout replay; guest 401, wrong role 403, other owner/respondent rejection; identity spoofing; CSRF/Origin. F-01 harness is complemented by real feature routes.

FR-02/12, BR-02/03/04/23

Minimum planned coverage in owning child/integration work: Same-Course/different-owner Sections, hidden Drafts/ineligible surveys, filtered lists/pagination/empty states, safe seed/setup without auth cycle.

FR-03/04, BR-04/05/09/10/23

Minimum planned coverage in owning child/integration work: Draft/publication boundaries, frozen scale readback, nonempty eligibility, one survey per lecture and edit/publish/concurrent creation races.

FR-05/06, BR-03/05/06/07/08/10/11, NFR-02

Minimum planned coverage in owning child/integration work: Required/optional/type/Unicode/byte limits, ineligible/Draft/Closed rejection, duplicate concurrency, whole rollback, close/submit order, own readback after logout/login/restart and ambiguous timeout.

FR-07, BR-02/12/13/14/16

Minimum planned coverage in owning child/integration work:
Known-value/no-data/optional-denominator/rounding/bin fixtures, Published count-only, Closed plain-text projection, wrong owner/role, escaping and no-identity fields.

NFR-03/05/07/08, SYS-01-04

Minimum planned coverage in owning child/integration work: Clean setup, actual mapped unit/API-DB/selected E2E tests, meaningful TDD, shared UI states, substantive review/integration and actual release version/results.

Meaningful TDD targets are expiry/regeneration/revocation and trusted role rules in F-01; scoped discovery in F-02; publication/freeze invariants in F-03; atomic once-only response and close/submit order in F-04; denominator/no-data/projection rules in F-05. Keep actual intended-behavior RED/GREEN versions/results during implementation, not fabricated records produced by this planning document.

6. Adoption checklist and dependency handoffs

Product DoD/ID/error/UI conventions

Owner / concrete next artifact: Both #5 owners; review these files and each child alignment

Current state: Draft proposed, no human adoption yet.

F-01 actual runtime/session cap/schema compatibility

Owner / concrete next artifact: #10/#15/#16/#17; exact installed runtime/lockfile, native hash/store/migration smoke checks

Current state: Candidate metadata in F-01 only; no dependency installed or API code executed.

F-02 exact list projections/order and context access

Owner / concrete next artifact: #11 with shared pagination/enum/UUID meanings

Current state: Pending child contract.

F-03 exact authoring/revision/scale schema and max-body fixtures

Owner / concrete next artifact: #12/#16; adopt/update proposal with exact payload/status/transaction tests

Current state: Pending child contract.

F-04 exact envelope/rejection precedence and confirmation/readback

Owner / concrete next artifact: #13; adopt/update 256 KiB/8 KiB-reserve proposal and test plan

Current state: Pending child contract; calculation only, no runtime test.

F-05 numeric precision/rounding/projection and chart alternatives

Owner / concrete next artifact: #14; exact allowlist and known-value fixtures

Current state: Pending child contract.

Preimplementation/task/review versions

Owner / concrete next artifact: Each lead/opposite reviewer; actual publication refs in #5/#10 and PR, accepted review versions when real

Current state: Human adoption pending; no fabricated capacity, review, commit, result or release.

An unresolved child decision prevents implementation of that affected behavior, not all documentation progress. Contract review is a real human task; this AI-assisted consistency work does not supply it. Keep #5 and unaccepted child Issues Open, record justified changes and do not change branch protection/permissions/deployment as a side effect of documenting a convention.

docs/sprints/sprint-1/product-dod.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA - Product Definition of Done

Version 0.1 criteria, status updated 2026-11-07 under #5 (https://github.com/Maibokdaimhai/LECTRA/issues/5). Shared documentation received R1NNE0 approval on PR #29 (https://github.com/Maibokdaimhai/LECTRA/pull/29#pullrequestreview-5807020832) and merged at `9f6d1bff2bc8185d054098cc048670e438118e81`. This records documentation acceptance, not fulfillment of the product DoD or acceptance of new cross-feature proposals. Applies to F-01-F-05 and integrated Sprint 1; later changes require versioned review. Scope/register: Part E (README.md). Protocol/ID/data conventions: shared contract (shared-contract.md).

1. Authority and how to apply this document

Instructor requirements come from `group_work_specs_v1.pdf` sections 5.2/8.2 and `project_deliverable_1_v1.pdf` sections 3.5/3.6: implement required behavior, execute meaningful planned verification, complete human review/integration, keep setup/docs current and disclose incomplete work. The instructor also requires the working domain increment, access/persistence tests and assessed-release evidence. DOD IDs, evidence tables and the feature/release separation below are team conventions for demonstrating those outcomes, not additional instructor-assigned feature counts or test quotas.

Three different boundaries must remain distinct:

Documentation/contract task
Completion evidence: Concrete source/design/AC/STS/DoD consistency, appropriate document checks, actual authorized version/PR, and substantive teammate review/integration. It can complete without claiming a working app or application tests.
Implemented feature
Completion evidence: Applicable DOD-01-DOD-10 below, feature-specific AC and evidence, actual teammate-reviewed integration and disclosed remaining dependencies. A feature is not Done because the contract was written.
Sprint 1 release/Deliverable 1
Completion evidence: All required F-01-F-05 behavior plus DOD-01-DOD-12 at integrated product/release scope. Feature completion does not itself prove an accepted main release or complete Parts A-F PDF.

No global requirement to wait for every feature contract before starting one feature. Before implementation, that feature's contract/STS and the shared DoD/conventions must have actual reviewed/versioned agreement, and its real setup/domain prerequisites must be available. Technical foundation work may proceed under its own recorded bounded setup design; it is not permission to implement unspecified domain rules.

2. Product completion criteria

The table states required future outcomes. None of the entries is a checked-off result in this draft. Feature-specific N/A cases need a reason and reviewer agreement, never a silent exemption from required product-level verification.

DOD-01
Observable condition for Done: Implemented behavior matches the accepted feature scope and each applicable AC across its stated UI/API/data layers.
Required evidence and boundary: Feature/FR/BR/NFR -> stable AC -> actual test/check mapping, tested versions and observed outcome; later-sprint omissions explicit. No mock-only success or renamed scope used to hide missing behavior.

DOD-02

Observable condition for Done: Feature SDS, applicable UI/API/schema details, AC/STS and significant rule changes are versioned before their implementation.

Required evidence and boundary: Actual contract/test-design commit/review and implementation sequence; decision/rationale/impact for revisions. A spec-only commit is useful, not a required number of commits. Never reconstruct history.

DOD-03

Observable condition for Done: Important pure logic has meaningful unit verification, with relevant positive/negative/boundary assertions.

Required evidence and boundary: Actual test file/case/command/result. Examples: expiry, validation, allowed transitions, denominators/rounding. A stub assertion, zero meaningful tests or code-shaped assertions are insufficient.

DOD-04

Observable condition for Done: Persistence, access and transactions use real API/PostgreSQL integration verification.

Required evidence and boundary: Real DB rows/constraints/readback and safe rejection/rollback assertions; restart retrieval where applicable. Auth/role/ownership/eligibility and concurrent duplicate/close ordering must be exercised on actual feature routes, not only a guard mock.

DOD-05

Observable condition for Done: Selected critical journeys run through actual UI/API/database and show usable error/access states.

Required evidence and boundary: Selected Playwright cases plus justified supplementary manual UI observations; core keyboard/labels/focus at 360px/1280px. No fake frontend actor selector or mocked login used as authentication proof.

DOD-06

Observable condition for Done: Meaningful rule/defect/change work preserves intended-behavior failing-before/passing-after evidence without weakened assertions.

Required evidence and boundary: RED/GREEN case, real versions, command/output and explanation. Unrelated syntax/import failure alone does not demonstrate the rule. Apply to important rules, not artificial TDD for prose-only edits.

DOD-07

Observable condition for Done: Auth/security/privacy projections are enforced on the backend and current UI surfaces truthfully describe the implemented mode.

Required evidence and boundary: No plaintext credentials/real secrets/logged cookies/tokens/raw feedback; trusted identity; safe errors/no-store; respondents cannot manage/cross-read; owner scope and comment projection tested. S1 is identified; anonymous features remain disabled until their later contract/tests are accepted.

DOD-08

Observable condition for Done: Actual required build/typecheck/relevant tests were run on the changed/integrated version and inspected; failures/skips are disclosed and resolved for required scope.

Required evidence and boundary: Commands, environment/schema/lockfile, source/test names, pass/fail/skip counts, tested SHA and safe output. A feature branch check does not prove the later integrated/main version. No invented coverage percentage or disabled required test.

DOD-09

Observable condition for Done: Bounded Issue/branch/PR traceability, substantive opposite-member review and integration are complete for the accepted work.

Required evidence and boundary: Real PR base from staging, actual author/reviewer, specific check/question/finding/reason, correction/recheck and integration version. AI audit/self-approval is not teammate review. Both students' actual contributions/pair work are described accurately.

DOD-10

Observable condition for Done: Setup/configuration/migrations/seed and feature documentation match the actual behavior, and known limitations are disclosed.

Required evidence and boundary: Reproducible actual migrate/seed/run/build/test instructions, example configuration without real secrets, safe synthetic fixture data and test-DB safeguards; actual source of any unresolved issue. No startup reset, memory-only durable data or invented commands.

DOD-11

Observable condition for Done: The integrated Sprint 1 domain journey, meaningful rejection and access restrictions are accepted and released through a reviewed staging-to-main PR.

Required evidence and boundary: Owner login/create/publish -> eligible student login/validate/submit once/read persisted outcome -> owner close/summary; duplicate/Draft/Closed and access rejection; actual system/integration checks; substantive release review and immutable main release tag/SHA. Apply at release level, not as a requirement that every docs PR builds an app.

DOD-12

Observable condition for Done: Deliverable 1 contains readable Parts A-F and actual release-linked evidence/contributions in one team PDF, with repo sources/tests/docs retained.

Required evidence and boundary: Both students' supplied names/IDs, theme/context, repo and actual assessed tag/SHA; build/tests on that actual accepted main version, selected readable evidence and known gaps; PDF checked for completeness/legibility. #6 plans, #26 assembles. No fabricated participant information or review history.

Docker, completed CI/CD and GCP setup are Lab 5 outcomes, designed for now and maintained afterward. Their absence is not a new Sprint 1/Deliverable 1 failure invented by this DoD. Actual local build/test and release evidence are still required at this checkpoint. Do not claim cloud deployment, enforced CI gates or a backup was tested until it happened.

3. Contract-document acceptance checklist

Use this for the current #5 shared-document change and each #10-#14 contract task. These are proposed review checks, not completed approvals:

- [ ] Source authority and scope are explicit; team choices/proposals are distinguished from instructor outcomes.

- [ ] The shared document or bounded feature has a concrete design, relevant dependency/permission/error/boundary behavior and applicable layer details. For a feature contract, no-change layers are stated.

- [ ] AC are observable with stable IDs; each maps to suitable STS cases with ID, level, input/precondition, action and expected outcome. Review the assertions' ability to catch a wrong implementation, not just row counts.

- [ ] UI/API/data/security meanings agree with the shared contract and baseline. Cross-feature ownership/migration/transaction responsibilities are assigned and unresolved gates have an owner/next action.

- [ ] Links, tables/Markdown structure, ID uniqueness/coverage and diff hygiene were actually checked, with results identified as document checks.

- [ ] Actual authorized publication version and substantive opposite-member review/integration are recorded; future application verification remains Planned/Not run. A drafted checklist is not human adoption.

The shared #5 change supplies the DoD and conventions. It does not have to invent AC for nonexistent app code, run unrelated application tests, impersonate R1NNE0 or close the umbrella before its other contracts are reviewed.

4. Evidence and result-state rules

Contract acceptance

Minimum fields: Feature/shared document path/version, actual source commit, real human reviewer/review link, dispositions and accepted change scope.

Planned verification

Minimum fields: Requirement, feature/sprint, AC ID, STS ID/level, fixtures/preconditions/input, action and expected observable outcome.

Actual verification

Minimum fields: Actual test file/case, command/date/environment/lockfile/schema, tested SHA, observed result and pass/fail/skip counts, safe output/reference.

TDD

Minimum fields: Intended rule/assertion, real failing version and output, real passing version and output, actual change rationale; no retroactive fabrication.

Review/integration

Minimum fields: Issue, branch, actual author/opposite reviewer, substantive review, fix/recheck, integrated version and actual pair work where applicable.

Release/report

Minimum fields: Actual integrated checks, reviewed release PR, accepted tag/main SHA, post-merge build/test output and readable selected PDF evidence/contributions.

Use Planned before execution; Not run if a planned check was not executed; PASS/FAIL only after observing output; SKIP only when the runner actually skips and its reason is reported; N/A only with an applicable-scope explanation. Blocked requires a real dependency/condition and owner/action. These states do not mean the same thing. Required failed/skipped/not-run behavior cannot be called Done merely by listing a limitation; record the gap and resolve it or obtain an actual authorized scope decision.

Do not erase failing output or rewrite the assessed SHA after a later correction. Relevant post-fix regression uses the changed version; a new accepted release gets a distinct reference and verification. A screenshot supports readable evidence but does not replace API/DB assertions or substantive human review.

5. Adoption and remaining boundary

Initial shared-document adoption is recorded by the actual PR #29 approval and merge above. Both Issue #5 owners still need to agree on remaining cross-feature alignment and review subsequent amendments. Each feature references the actual accepted Product DoD version; no new amendment approval is inferred from the initial review. Amend through normal recorded scope/review steps when necessary; do not silently make all later policies retroactive.

Current state: shared/F-01/F-02/F-03/F-05 document packages merged; F-04 is a new draft requiring review; tooling setup has its own verification record, while domain implementation/feature tests/release/PDF remain unavailable. #5 remains Open for F-04 acceptance and cross-feature agreements/traceability. This file's existence or a tooling smoke pass satisfies no product Done claim.

docs/sprints/sprint-1/f-01-authentication.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-01 - Authentication, Sessions and Backend Access Contract

Version 0.3 criteria, status updated 2026-11-07: phased dependency correction received R1NNE0 approval (https://github.com/Maibokdaimhai/LECTRA/pull/29#pullrequestreview-5807020832), with final conflict-only sync merged via PR #29. AC/STS IDs unchanged. Preimplementation document for #10 (https://github.com/Maibokdaimhai/LECTRA/issues/10), under Part E #5 (https://github.com/Maibokdaimhai/LECTRA/issues/5). Lead Maibokdaimhai, reviewer R1NNE0. Documentation acceptance is not auth implementation, migration or executed F-01 tests.

Product baseline originated at `333a9fc6a6a2905b07087c98eb5f5d931ffec107`. Proposed with the shared prerequisite on `docs/5-sprint1-shared-contracts`; synchronized with `staging` at `b3f644a7ca42c3750a7f673153aeba87d3c6d999`, preserving the merged PR #27 tracker and PR #28 workflow. Actual publication/review versions are recorded in #5/#10 and PR #29; changes-requested review is not approval. Related implementation: #17 (https://github.com/Maibokdaimhai/LECTRA/issues/17); setup #15 (https://github.com/Maibokdaimhai/LECTRA/issues/15); database #16 (https://github.com/Maibokdaimhai/LECTRA/issues/16). Test design: F-01 STS (f-01-authentication-sts.md). Shared references: register (README.md), engineering conventions (shared-contract.md), Product DoD (product-dod.md).

1. Authority, scope and dependencies

Instructor: `group_work_specs_v1.pdf` **section 5.2, Theme 10 and section 8.2;** `project_deliverable_1_v1.pdf` **sections 2, 3.5 and 3.6**

Required outcome or selected design: Real login/logout/current identity, meaningful roles, hashed credentials, backend access restrictions, preimplementation feature design/AC/STS/DoD, actual automated verification and substantive teammate review. Authentication alone does not complete Sprint 1.

Existing LECTRA baseline: SRS (../../srs.md), SDS sections 4-5 (../../system-sds.md), feature inventory (../../features.md)

Required outcome or selected design: Seeded OWNER/RESPONDENT accounts; PostgreSQL-backed opaque sessions; Argon2id; absolute eight-hour authenticated lifetime; synchronizer CSRF token and Origin checks; same-origin delivery; no signup/recovery/SSO.

This contract, proposed team detail

Required outcome or selected design: Exact payloads/errors, 30-minute preauthentication session, input limits, cookie names, package candidates, logout no-op policy, throttling and test IDs below. These are design choices, not instructor-prescribed numbers or protocols.

Requirement links: FR-01; BR-01/BR-02; NFR-01/03/05/07/08; SYS-01/02/03. FR-12 supplies seeded identities through SYS-01. Full record-level BR-02 verification also belongs to F-02-F-05 and integrated Sprint 1 tests; the authentication foundation cannot certify routes that do not exist yet.

In scope: four auth endpoints; login/session-expiry/logout UI behavior; reusable authenticated/role/record-scope boundaries; session and User schema coordination; safe identity/error/cache/log projections. All UI/API/data layers need work. Survey/answer/result schemas and business transitions have no change in F-01; their own contracts supply them. No user-management UI, password changes, remember-me, token refresh, JWT/local-storage credentials, anonymous answers or deployment setup is added.

Drafting #10 does not wait for every other contract or for umbrella #5 to close. Before #17 implementation, obtain actual teammate review of this version, adopt/reconcile the shared draft Product DoD/ID conventions in #5, and record the needed verified #15/#16 User/session foundation. Unrelated later domain schema/UI work is not a prerequisite to authenticating a seeded account. Domain feature implementers consume this interface and add real ownership/eligibility checks on their routes. #22/#23 own cross-feature integration/browser evidence; #25/#26 own release/PDF evidence.

The initial #16 User/auth_session migration and hashed synthetic login-account seed require accepted #10/shared conventions and #15 setup, not every #11-#14 contract or full #16 closure. Subsequent context/survey/response/results schema work waits for its respective reviewed contract. #17 may proceed after the verified initial subset; the full #16 Issue remains Open until all its S1 scope is evidenced. This matches the register (README.md) and tracker (tracker.md), and does not authorize domain implementation from an auth-only schema.

2. Component and dependency contract

Proposed modules after authorized setup: `apps/api` auth routes/services/guards plus session-store configuration, `apps/web` login/auth state/API wrapper, and `prisma/migrations` for domain and custom session SQL. Paths are planned, not existing source files. Use Node `crypto` for random tokens and length-checked constant-time comparison; use maintained session/hash middleware rather than a custom cookie signature algorithm.

Registry metadata inspected on 2026-11-06 provides the following candidates. This is a reproducible selection proposal, not a completed installation/compatibility run. #15 must pin exact Node/npm/PostgreSQL patch versions, all direct dependencies/dev types and one `package-lock.json`, then demonstrate install/typecheck/build/hash/session/migration smoke checks before #17. Record any justified candidate change here before coding against a different API.

Runtime / manager / database

Proposed candidate: Node 24 LTS line; npm 11.16.0; PostgreSQL 17 line; UTC DB connections

Compatibility/setup responsibility: #15 records exact Node/PostgreSQL patches and both students' actual platforms. Node 24 satisfies the inspected engine ranges; native Argon2 and DB execution remain unverified.

API and validation

Proposed candidate: express 5.3.0; zod 4.6.7; TypeScript 5.9.3

Compatibility/setup responsibility: #15 pins compatible Express/Node type packages; no assumption that the registry's newest TypeScript major is appropriate.

Sessions

Proposed candidate: express-session 1.19.0; connect-pg-simple 10.0.0; pg 8.23.1

Compatibility/setup responsibility: Add compatible `@types/express-session`, `@types/connect-pg-simple`, `@types/pg` where needed. #16 versions session DDL; #17 configures store behavior.

ORM

Proposed candidate: prisma, @prisma/client and @prisma/adapter-pg all 7.10.1

Compatibility/setup responsibility: Keep the three versions aligned. Use the PostgreSQL driver adapter required by the selected Prisma 7 design; #15 owns module/generator/config setup. Do not mix a prerelease CLI with a different client.

Passwords / throttling

Proposed candidate: argon2 0.45.2; express-rate-limit 8.7.3

Compatibility/setup responsibility: #15 verifies native hash/verify on actual machines; #17 supplies the configured limiter and safe error mapping.

Verification candidates

Proposed candidate: Vitest 5.1.0; Supertest 7.3.1; @playwright/test 1.65.0

Compatibility/setup responsibility: #15 coordinates Vite 8.3.6/React 19.3.1 and actual peer resolution with the web setup. Candidates share Node 24 support; browser installation/execution has not occurred.

`pg`, `@prisma/adapter-pg` and `express-rate-limit` are explicit additions to the earlier named stack. No CSRF package, JWT library, Redis service, UI framework or account-administration dependency is required by this proposal. Do not interpret this list as authorization to install packages.

Setup follow-through (#15, 2026-11-07): the local working tree pins Node 24.22.1 and npm 10.9.2 (replacing the npm 11.16.0 candidate above) with one lockfile. Workspace design (workspace-setup.md) and actual tooling observations (workspace-verification.md) distinguish installed/native/driver compatibility from unimplemented credential/session behavior.

Teammate reproduction, real User/session schema and F-01 AC execution remain separate prerequisites/evidence; no auth test result is inferred from the Argon2 package round trip.

3. Session lifecycle and authority

3.1 States and transitions

No usable session

Behavior: Protected reads return 401. Bootstrap may create a guest session containing a CSRF token and fixed 30-minute guest deadline; it grants no role.

Guest/preauthentication session

Behavior: Login requires its token and matching Origin. Repeated bootstrap preserves its token/deadline; it does not extend lifetime.

Successful login

Behavior: Verify credentials, regenerate SID (destroy old guest session), create a new CSRF token, set trusted user ID/authenticatedAt/authExpiresAt, and await store save before returning success. The old SID/token must not authorize requests.

Authenticated session

Behavior: Re-resolve User from PostgreSQL on each protected request. Keep only user ID, security timestamps/token and middleware cookie metadata in the session; never store trusted role/ownership claims from the client.

Expired/invalid session or missing User

Behavior: Deny access, invalidate the session where available and clear stale cookie. Bootstrap can replace it with a guest session. Never silently authenticate or renew the old session.

Logout

Behavior: For a live session, validate Origin/CSRF, destroy it in PostgreSQL and clear the cookie only after confirmed revocation. Subsequent requests using the saved old cookie are unauthorized.

Multiple independent logins are permitted; logout revokes that browser's session only. There is no logout-all-devices or single-session-per-account rule. No role-changing API exists; a trusted DB role change is reflected on the next request. A deleted User or invalid persisted role makes a session unusable, rather than trusting a stale role in JSON.

3.2 Lifetime and persistence

Authenticated lifetime is exactly `28,800,000` milliseconds from the server-recorded successful authentication time; access is permitted only while `authenticatedAt <= now < authExpiresAt`. Validate timestamp types/order and `authExpiresAt = authenticatedAt + 28,800,000`; future authentication times or malformed state are rejected. At the exact deadline, access fails. Guest lifetime is `1,800,000` milliseconds and never confers authenticated access. Use UTC instants, not local calendar arithmetic.

Set `resave: false`, `saveUninitialized: false`, `rolling: false`, store `disableTouch: true`, and `createTableIfMissing: false`. Bootstrap intentionally initializes/saves a guest session despite saveUninitialized being false. Do not mutate/save live auth sessions on ordinary reads. Cookie and store deadlines must not exceed the recorded absolute deadline, including explicit save/touch paths: cap the cookie's serialized expiry and store `set` expiry to that deadline, not now plus another eight hours. A small store/response adapter may enforce the cap after middleware resets; finalize its tested implementation in #17. Server age checks remain authoritative even if a cookie is manually replayed or the store retains an expired row. Never rely only on eventual pruning or browser cookie removal.

Only bootstrap/login/logout may write auth session state. Ordinary domain handlers cannot rewrite it. Await save/regenerate/destroy callbacks and handle errors before success. After logout acknowledgement, concurrent completed reads must not recreate an old SID through resave/touch; exercise an overlapping read/logout test. A request authorized before logout may finish; this contract does not promise cancellation of already authorized in-flight domain transactions.

Application restart uses the same PostgreSQL store and secret configuration; unexpired sessions remain usable without resetting their absolute deadlines. A changed session secret may invalidate cookies; do not call that persistence success or

add secret rotation accidentally. Invalid signatures, expired/missing rows and unrecognized client-chosen SIDs never grant identity.

4. Credentials, schemas and migration ownership

4.1 Credential input and hashing

Login accepts exactly `email` and `password`. Normalize email with surrounding trim and lowercase consistently with seeded unique email storage; support the seeded ASCII email format, length 1-254 characters after normalization, with syntactically valid email. Password is a string of 1-128 Unicode code points, with no trim, lowercase, normalization or silent truncation. This is a login bound, not a new-user password policy. Synthetic seed passwords are at least 12 characters and satisfy the bound. Blank email/password produces 422; a nonempty whitespace password is checked exactly and normally fails credentials.

Use Argon2id PHC-encoded hashes with fresh random salt (at least 16 bytes), memoryCost at least 19,456 KiB, timeCost at least 2, parallelism 1 and hash length at least 32 bytes. This selected starting configuration follows the referenced OWASP guidance; measure the actual native implementation in setup before increasing cost. Seed does not store plaintext. Unknown email executes verification against a fixed synthetic dummy hash with the same cost, then returns the same 401 body as a wrong password. This reduces a timing discrepancy without promising timing indistinguishability. A malformed stored hash/internal verifier failure is a safe server failure, never successful authentication.

No real password/hash, email/password body, SID cookie or CSRF value enters logs, screenshots or evidence. Test-only synthetic credentials may be supplied through explicit local seed/test configuration; keep actual secret values out of Git/PDF. Treat API bodies as untrusted; SQL access is parameterized.

4.2 Domain schema contract

id

Proposed storage / constraint: UUID primary key, generated by trusted server/seed

Use: Opaque application identity; not supplied to choose the logged-in actor.

email

Proposed storage / constraint: Unique normalized varchar(254), non-null

Use: Lookup only; self identity does not need to return it. Seed rejects normalization collisions.

passwordHash

Proposed storage / constraint: Non-null text containing Argon2id PHC encoding

Use: Server/seed only; excluded from all projections.

role

Proposed storage / constraint: Non-null enum OWNER or RESPONDENT

Use: Loaded from trusted User table on each protected request.

displayName

Proposed storage / constraint: Non-null 1-120 code points

Use: Safe self projection, rendered as plain text.

This refines the User model already allocated to #16, not a second User table/migration. #16 authors/co-ordinates one domain migration/seed; #17 consumes it and must not create a competing initial schema. Demo fixtures include two owners and at least two respondents with synthetic `.test` addresses; Section/eligibility fixtures for domain tests remain #16/F-02-F-05.

4.3 Session store DDL contract

Version custom SQL alongside Prisma migrations, using connect-pg-simple's table shape with the selected name `public.auth_session`:

sid

Contract: varchar, non-null primary key; middleware-generated identifier. Treat as a credential in storage/log policy.

sess

Contract: json, non-null; middleware cookie metadata plus guest/auth payload described below. No password, raw answers or trusted cached role.

expire

Contract: timestamp(6) without time zone, non-null, following the store adapter's schema; UTC connection/session timezone is required for correct interpretation.

expiry index

Contract: B-tree on expire, named `auth_session_expire_idx`; prune expired rows without using pruning as authorization.

Payload is a discriminated guest or authenticated state: guest has `csrfToken`, `guestCreatedAt`, `guestExpiresAt`; auth has `userId`, `authenticatedAt`, `authExpiresAt`, `csrfToken`. Times are epoch milliseconds; token is 32 random bytes in unpadded base64url (43 characters). Session JSON is internal, never an API identity source supplied by clients. No User FK exists inside JSON; trusted User lookup invalidates deleted/unknown accounts.

#16 owns copying/adapting the selected package DDL into a reviewed Prisma migration, omitting obsolete `WITH (OIDS=FALSE)` syntax from the upstream sample for PostgreSQL 17, and matching table/index names above. Do not enable runtime auto-create, run an unversioned package SQL file on startup, or let Prisma subsequently drop an unmanaged table. Represent the session table in Prisma's migration schema (mapped names/types) or explicitly exclude it using a tested migration strategy; #15/#16 must demonstrate a second no-op migration does not drop/change it. Domain application code still accesses sessions only through the store. Store and ORM may use separate pools against the same database; startup/shutdown closes both.

Repeatable seed does not reset authenticated sessions silently on startup. Migrate explicitly before service startup; tests fail early if the schema is absent. Tests use an explicitly allowlisted disposable test database and separate credentials/URL; test reset must refuse development/deployed DBs. Missing tables/DB failures must not fall back to memory.

5. Browser security and request processing

5.1 Configuration profiles

Local development/test HTTP

Origin / transport / proxy: Exact configured origin such as `http://localhost:5173`; Vite proxies `/api`; Express trust proxy false

Session cookie: `lectra.sid`; HttpOnly; SameSite=Lax; Path=/; no Domain; Secure=false explicitly. Loopback-only development; not a public HTTP profile.

HTTPS deployment

Origin / transport / proxy: One exact configured HTTPS origin; frontend/API share it; trusted ingress path explicitly verified in Lab 5

Session cookie: `__Host-lectra.sid`; HttpOnly; Secure; SameSite=Lax; Path=/; no Domain. Absolute remaining lifetime only.

Clearing uses the same cookie name/path/domain/security attributes, with an expired value; do not accidentally leave a second-path cookie. No remember-me checkbox or local/session-storage bearer credential. Cookie settings are backend configuration, not a client-selected switch. Reject missing/weak session secret (minimum 32 random bytes), malformed/multiple/wildcard APP_ORIGIN and inconsistent production HTTP/cookie settings before listening. No real secret is shown in example configuration.

Planned server configuration: `APP_ORIGIN`, `DATABASE_URL`, `SESSION_SECRET`, `NODE_ENV` and validated deployment-specific trust-proxy setting. Test DB configuration belongs to #15. Do not accept forwarded protocol/host/IP as trusted by default, compute allowed Origin from an untrusted Host header, set trust proxy true for all callers, or enable

permissive credentialed CORS. Direct local API port is an implementation service, not a second browser origin. HTTPS/proxy behavior must be tested using the actual documented proxy path before cloud use; no Cloud Run access/path is assumed here.

5.2 Origin, CSRF and precedence

Unsafe methods require a single Origin exactly equal to configured scheme/host/port, after standards-based URL-origin normalization. Reject missing, `null`, multiple, foreign, wrong-scheme or wrong-port Origin with 403 ORIGIN_FORBIDDEN. No Referer or forwarded-header fallback. All browser callers use same-origin fetch; do not forward CSRF headers to unrelated URLs. Bootstrap/read requests reject an explicitly foreign Origin; bootstrap also rejects `Sec-Fetch-Site: cross-site`. Same-origin reads may omit Origin. No CORS permission is emitted for other origins.

`GET /api/auth/session` creates/returns a session-bound token; never put it in a URL, cookie readable by JS, persistent browser storage or logs. Unsafe requests send `X-CSRF-Token`. A live session requires exact token equality after fixed-format/length validation; compare equal-length bytes in constant time. Missing/wrong/cross-session/old pre-login tokens return 403 CSRF_INVALID. Token persists within a session and rotates on login regeneration; do not rotate on every GET and break parallel tabs. It is held in memory and refreshed from bootstrap when necessary.

Logout no-op exception: for an absent, expired or already revoked session, a same-origin logout with an empty JSON object and a correctly formatted token returns 204 and clears the stale cookie; there is no live session against which to compare it and no privilege is granted. Missing/malformed token is still 403. For every live guest/auth session, exact equality remains mandatory. This narrowly specified exception makes replayed logout idempotent; it is not a bypass for login, domain writes or logout of a live session. Tests distinguish these branches explicitly.

Use this rejection order so mixed-invalid cases have predictable results:

1. Origin and method policy, then transport/content-type/body-byte bounds, then session-store loading and safe parser errors. Unsupported method is 405 with Allow; no GET logout.

2. On protected domain operations, resolve authentication before CSRF, then role, then scoped record lookup/business validation. A correctly originated unauthenticated request returns 401, not private record data. Do not reveal whether a hidden record exists.

3. Login: live guest/bootstrap and CSRF check, active-authenticated-session conflict check, strict body validation, login rate limit, trusted credential verification, regeneration/save, success. An invalid/expired bootstrap produces CSRF_INVALID and requires rebootstrap, never a token exemption.

4. Logout: token policy above, strict empty-object validation, destroy/clear or no-op. Do not turn a store failure into the no-op branch.

No application state-changing operation uses GET. Bootstrap writes security session metadata only. Clients never automatically retry a login/domain mutation merely because a token expired; obtain a fresh token and require a deliberate resubmission. A 401 clears private client state; 403 role denial does not claim the session expired.

6. Exact API contract

All four endpoints return `Cache-Control: no-store`; auth requests use JSON and `credentials: same-origin`. Authentication responses never include passwordHash, SID, cookie signature, other users, Section memberships or feedback. The safe user projection is exactly `id`, `displayName`, `role`. Auth timestamps returned as `expiresAt` are ISO-8601 UTC instants. CSRF token is returned only by bootstrap and successful login.

GET /api/auth/session

Input / precondition: No body. Usable guest/auth cookie optional; token bootstrap policies apply.

Success: 200 `{ "data": { "authenticated": false, "user": null, "expiresAt": null, "csrfToken": "<token>" } }` for guest. Authenticated form has true, safe user, absolute expiresAt, same session token. Guest deadline remains server-internal.

POST /api/auth/login

Input / precondition: Valid bootstrap cookie/token, matching Origin; exact JSON `{ "email": "owner-a@example.test", "password": "<synthetic input>" }`.

Success: 200 `{ "data": { "user": { "id": "<uuid>", "displayName": "Owner A", "role": "OWNER" }, "expiresAt": "<UTC instant>", "csrfToken": "<new token>" } }` and regenerated signed session cookie. RESPONDENT uses the same shape.

GET /api/auth/me

Input / precondition: Valid unexpired authenticated session; no body.

Success: 200 `{ "data": { "user": { "id": "<uuid>", "displayName": "Owner A", "role": "OWNER" }, "expiresAt": "<UTC instant>" } }`. Missing/invalid auth returns 401.

POST /api/auth/logout

Input / precondition: Matching Origin, token policy above, exact JSON `{}`.

Success: 204, no body, cookie cleared after confirmed destruction or defined no-op. No redirect response or GET logout route.

Examples are shape illustrations, not issued tokens/users/results. Success is sent only after the required PostgreSQL operation completes. Login while already authenticated returns 409 ALREADY_AUTHENTICATED with no identity switch, deadline renewal or mutation; use logout before changing account.

Auth POST transport limit is 8,192 encoded bytes, separate from F-04's response-body limit. Accept only application/json (optional UTF-8 charset), no content compression, JSON object bodies only. Reject extra keys (including role/userId/ownerId/studentId), arrays/null, wrong types, missing fields and length violations; never silently strip spoofing fields or use them as authority. Enforce both byte limit and decoded limits. Ignore identity claims in unrelated headers/query strings/cookies as permission sources; only the signed session and trusted User lookup determine the actor.

Error envelope and outcomes

Use `{ "error": { "code": "CODE", "message": "safe text" } }`; validation alone may include `fields: { "email": "safe reason", "password": "safe reason", "_form": "safe reason" }`. Do not echo input values or internal messages. Shared #5 must adopt/reconcile these codes before feature implementation.

400 MALFORMED_JSON

Condition / safe client behavior: Invalid JSON syntax; no credential/hash/session-auth mutation.

401 INVALID_CREDENTIALS

Condition / safe client behavior: Unknown email and wrong password have exactly the same code/message: `Email or password is incorrect.` No authenticated session created.

401 AUTH_REQUIRED

Condition / safe client behavior: Missing, forged, revoked, invalid-state session or missing/invalid User. Clear stale/private client state; never expose another account.

401 SESSION_EXPIRED

Condition / safe client behavior: Server can identify a loaded auth session at/past its deadline; otherwise missing/pruned expiry uses AUTH_REQUIRED. UI treats both as session loss.

403 ORIGIN_FORBIDDEN / CSRF_INVALID

Condition / safe client behavior: Failed Origin or token policy; no login/logout/domain mutation. Rebootstrap deliberately for token loss; no automatic POST replay.

403 FORBIDDEN_ROLE

Condition / safe client behavior: Authenticated wrong role on a role-only route. No private response fields.

404 NOT_FOUND

Condition / safe client behavior: Missing or inaccessible record after a correct role check; same outward shape. Domain contracts supply actual routes/scoped queries.

405 METHOD_NOT_ALLOWED

Condition / safe client behavior: Known auth path with unsupported method; Allow lists supported methods, with no side effect.

409 ALREADY_AUTHENTICATED

Condition / safe client behavior: Login cannot silently replace/renew a live authenticated account.

413 BODY_TOO_LARGE / 415 UNSUPPORTED_CONTENT

Condition / safe client behavior: Auth body exceeds 8 KiB / unsupported content type or compression. Reject before hashing or auth writes.

422 VALIDATION_FAILED

Condition / safe client behavior: Well-formed body violates the exact login/logout schema; safe field errors only.

429 LOGIN_RATE_LIMITED

Condition / safe client behavior: Login attempt bound exceeded; safe message and integer Retry-After seconds, no account-existence detail.

503 AUTH_SERVICE_UNAVAILABLE

Condition / safe client behavior: Session get/set/regenerate/destroy or trusted User lookup fails due to unavailable DB/store. No memory fallback, partial success or claim of completed logout.

500 INTERNAL_ERROR

Condition / safe client behavior: Unexpected failure, including corrupt stored hash/internal verification failure; no raw stack/SQL/credential output.

Throttling proposal: one local API process permits ten schema-valid, correctly originated/tokened login attempts per trusted client IP per 15-minute window, including success/failure; the eleventh is 429 before hashing. Use the package's IP normalization/IPv6 behavior, not a naive forwarded-header key. No account lockout, user-specific threshold or CAPTCHA is added. Reset/test it using an injected/test clock without 15-minute sleeps. Local in-memory throttle counters are explicitly process-local and reset on restart; authentication sessions remain PostgreSQL-backed. Before public multi-instance deployment, #15/Lab 5 must adopt/review a shared limiter store or equivalent ingress policy and verify proxy/IP/rate behavior. This local limiter is not a claim of distributed abuse prevention.

7. Backend access and UI contract

7.1 Guard interfaces and domain handoff

Authentication middleware produces immutable request-local `actor: { userId, role }` after trusted lookup. A role guard consumes that actor; a scoped record loader uses its userId in the server/database predicate. Do not accept an actor object from request JSON or authorize by matching two client-supplied IDs. Resource absence/out-of-scope is 404. Caller-supplied Section/Course context cannot broaden the predicate. Each domain feature must enforce its own guard on every route, not just its list UI.

Bootstrap/login/logout/me

Guest: Endpoint-specific rules above

RESPONDENT: Own session only

OWNER: Own session only

Owner-only context/Draft/lifecycle/results

Guest: 401

RESPONDENT: 403

OWNER: Scoped to own Section/lecture/survey; out-of-scope 404.

Eligible survey read / response / own submission

Guest: 401

RESPONDENT: Eligibility/state/own-user constraints; hidden record 404; own actor only.

OWNER: Role-only respondent operation 403; owned preview is a separate owner read.

Another respondent's answers / per-student owner participation list

Guest: 401

RESPONDENT: No cross-user endpoint/permission.

OWNER: No respondent-linked answer or participation-list endpoint.

F-01 guard tests can use a test-only handler harness to demonstrate role/status handling; do not ship debug routes or call that real survey access coverage. F-02-F-05 contracts and #22 must run direct API/real-DB ownership, same-Course/different-Section, eligibility and cross-response tests on actual feature routes. No hidden UI button or demo role dropdown grants permission.

7.2 UI behavior

Use the existing cool-theme SDS (../../system-sds.md) tokens/components, light theme only; no new palette/library. Login card max width 440px, labelled email/password, one Log in action, no role selector. Password uses type=password and autocomplete=current-password; email uses autocomplete=username. Native keyboard/form behavior is supported; do not disable password-manager paste.

Initial auth check

Observable behavior: Bootstrap/check current identity before private content renders. Show a bounded loading state; no flash of another user's page or synthetic authenticated identity.

Ready / submit

Observable behavior: Client checks required/format limits for feedback; server repeats validation. Submit once while busy, disable repeated action and announce progress. No success navigation before 200.

Valid login

Observable behavior: Replace auth/token state from server; clear old private caches first. OWNER opens owner context shell; RESPONDENT opens eligible-survey shell. Domain data/empty states are F-02, not fabricated seed cards in F-01.

Invalid credentials / validation

Observable behavior: Show generic credential message or linked field errors, move focus to error summary; preserve email, clear password after the completed attempt. Password never survives reload or enters persistent storage.

Token/Origin error

Observable behavior: Show safe error; token loss may refresh bootstrap for a deliberate retry. Never retry credentials automatically or preserve a password for background resend. Origin misconfiguration is reported as setup failure.

Network/server/rate error

Observable behavior: Show safe retry instruction; 429 respects Retry-After. A timed-out login has unknown outcome: bootstrap/current identity before another deliberate login, rather than asserting failure or blindly resending.

Protected request returns 401

Observable behavior: Clear actor/private queries/answer drafts and in-memory old CSRF token; show login with a session-ended message. Rebootstrap before deliberate login. Do not promise unsent-answer recovery.

Logout clicked

Observable behavior: Immediately stop private rendering and clear private state; block new protected navigation while revocation is pending. Retain token only transiently for the logout retry.

Logout 204

Observable behavior: Clear all local auth/token state, show login; back/direct navigation cannot restore private content without a fresh authenticated server check.

Logout error/timeout

Observable behavior: Private UI remains hidden; state says server sign-out is not confirmed. Offer a deliberate retry/bootstrap check, with no false success. Do not erase the ability to retry revocation and imply the server session is gone.

Auth context is memory-only; browser refresh resolves from server. Shared tabs can encounter expiry/logout via their next authenticated read or visibility revalidation; they must not reuse cached private content after a detected 401. This does not promise instantaneous cross-tab notification. Test labels, keyboard submit/focus, busy/error states and no horizontal page overflow at 360px/1280px; final UI review may supplement with 320px reflow/200% zoom per SDS.

8. Stable acceptance criteria and verification map

All AC below are proposed, observable implementation outcomes. All tests/checks are Planned, not passed. Their complete preconditions/action/assertions are in the STS (f-01-authentication-sts.md). IDs remain stable; append rather than renumber accepted IDs.

AC-F01-01

Required observable outcome: Bootstrap returns a persisted session-bound token, correct guest/auth projection and no-store; repeated live bootstrap does not renew token/deadline.

Planned verification IDs: TEST-F01-I01, I27

AC-F01-02

Required observable outcome: Exact login/logout schema and transport/decoded bounds reject malformed, oversized, unsupported or identity-spoofing bodies without authentication writes.

Planned verification IDs: TEST-F01-U01, I06, I15

AC-F01-03

Required observable outcome: Each seeded role can log in with exact password and normalized email; /me returns the trusted safe current identity.

Planned verification IDs: TEST-F01-I03, I04, E01

AC-F01-04

Required observable outcome: Unknown email and wrong password return the same 401 body without authenticated session; existing auth is not silently switched/renewed by login.

Planned verification IDs: TEST-F01-I05, I28

AC-F01-05

Required observable outcome: Stored credentials are salted Argon2id; exact nontrimmed password verification succeeds/fails correctly; corruption/errors never grant identity.

Planned verification IDs: TEST-F01-U06, I24, I26

AC-F01-06

Required observable outcome: Successful login regenerates SID/token, destroys guest SID and waits for durable save; old token/SID cannot authenticate.

Planned verification IDs: TEST-F01-I07, I13

AC-F01-07

Required observable outcome: Auth is valid just before eight hours and denied exactly at/after it; reads/touch/save/restart cannot extend cookie/store/server deadline. Invalid/future timestamps fail.

Planned verification IDs: TEST-F01-U02, U07, I08, I20

AC-F01-08

Required observable outcome: Every protected request resolves trusted User/role; deleted/invalid users lose auth and client identity claims never elevate permission.

Planned verification IDs: TEST-F01-I09, I15

AC-F01-09

Required observable outcome: Confirmed logout revokes the stored session; cookie replay is unauthorized; repeated/absent-session logout follows the documented token no-op policy.

Planned verification IDs: TEST-F01-I16, I17, E02

AC-F01-10

Required observable outcome: Login/logout/unsafe routes enforce exact Origin and session-bound CSRF, including cross-session/old-token rejection and the explicit logout-only no-op branch.

Planned verification IDs: TEST-F01-U03, I13, I14, I17, E04

AC-F01-11

Required observable outcome: Local HTTP versus HTTPS cookies, clearing and validated proxy/configuration behave as specified; spoofed forwarded headers do not make an insecure caller trusted.

Planned verification IDs: TEST-F01-I02, I25, M02

AC-F01-12

Required observable outcome: Guard boundary gives unauthenticated 401, authenticated wrong-role 403 and missing/out-of-scope 404 without private data. Real domain integrations remain explicitly assigned.

Planned verification IDs: TEST-F01-U04, I10, I11, I12, H01-H04

AC-F01-13

Required observable outcome: DB/store/verifier failures produce safe failure, never memory fallback or successful login/logout acknowledgement; failed revocation remains disclosed/retryable.

Planned verification IDs: TEST-F01-I18, I26, E05

AC-F01-14

Required observable outcome: Auth errors/identity projections/logs/cache behavior expose no credentials, SID, other-user payload or private cached content after session loss.

Planned verification IDs: TEST-F01-U05, I23, E02, E03

AC-F01-15

Required observable outcome: Login has usable labelled/keyboard/busy/error/timeout behavior and server-derived role navigation at the specified widths.

Planned verification IDs: TEST-F01-E01, E04, M01

AC-F01-16

Required observable outcome: Session expiry/logout hides private UI, rechecks before protected re-entry and distinguishes server-revocation failure from success.

Planned verification IDs: TEST-F01-E02, E03, E05

AC-F01-17

Required observable outcome: Reviewed migration/seed and test-DB safeguards reproduce User/session storage; sessions survive restart with unchanged absolute deadline.

Planned verification IDs: TEST-F01-I20, I24, I25, M02

AC-F01-18

Required observable outcome: The tenth allowed attempt and eleventh rejected attempt/reset behave under the documented per-process limiter; public distributed limitation is explicit.

Planned verification IDs: TEST-F01-I22

AC-F01-19

Required observable outcome: Concurrent session reads do not resurrect a revoked session; logging out one independent session does not revoke another.

Planned verification IDs: TEST-F01-I19, I21

AC-F01-20

Required observable outcome: Preimplementation contract/test-design versions, reviewed Product DoD, actual test results and substantive teammate integration are linked before F-01 is called Done.

Planned verification IDs: TEST-F01-M03

9. Completion, TDD and unresolved gates

The Product Definition of Done v0.1 draft (product-dod.md) is owned by #5 (https://github.com/Maibokdaimhai/LECTRA/issues/5) and exists alongside this contract; it has not yet been human-reviewed/adopted. This F-01 checklist specializes DOD-01-DOD-10, with DOD-11-DOD-12 applied at integrated release/report scope. Record the actual accepted DoD commit/review before #17; do not treat this link as approval. The following remains a proposed feature completion checklist:

- [ ] Feature contract and STS are versioned and substantively reviewed before #17 implementation; shared ID/error/DoD conventions are agreed under #5.

- [ ] #15 runtime/package/type/module choices and #16 User/session migration ownership are verified; record lockfile/schema versions and both contributors' actual work.

- [ ] Applicable AC are implemented across UI/API/PostgreSQL; actual domain access handoff checks H01-H04 run under their feature/integration ownership before claiming full BR-02/Sprint 1 completion.

- [ ] Unit, real API/DB and selected browser checks execute with actual file/name/command/SHA/pass-fail-skip counts; justified manual checks supplement them. No required test is silently skipped or weakened.

- [ ] Preserve intended-behavior RED then GREEN for absolute expiry, SID/CSRF regeneration, logout replay and trusted role guard rules. An unrelated import failure is not sufficient TDD evidence.

- [ ] Actual opposite-member PR review, findings/recheck and integration are linked. Build/typecheck and relevant regression use the integrated version; release build/tests later target the actual accepted main SHA under #25.

- [ ] Actual setup/config/migrate/seed/run/check commands, cookie profiles, limitations and evidence references are documented. Source/tests/docs remain in the repo; #26 places assessable selected evidence in the single report PDF.

Record each run as test ID, actual source/test file, intended/observed behavior, command, environment/schema/lockfile version, tested SHA and counts/output link. For RED/GREEN keep both real versions/results when they occur. Proposed file names and commands in STS are not execution evidence. This documentation task does not implement tests or produce an application PASS result.

#5 shared DoD and naming/error consistency

Proposed disposition / required evidence: Draft shared register/conventions/Product DoD now exist and retain these AC-F01 / TEST-F01 IDs/auth envelope; accept or revise coherently before #17. Do not wait for every child contract or call #5 complete from F-01 alone.

OPEN-02 runtime compatibility

Proposed disposition / required evidence: Candidates are metadata-checked only. #15 must record exact runtime patches, one lockfile, native hash and actual client/store/migration smoke results; update this contract on a material change.

Session migration ownership

Proposed disposition / required evidence: #16 owns one reviewed User/session migration; #17 configures the store, caps immutable deadlines and supplies runtime tests. Demonstrate UTC handling and no accidental Prisma drop.

Logout exception / lifetime caps

Proposed disposition / required evidence: Teammate must inspect the no-live-session token policy, middleware/store save/expiry cap and concurrent read/logout cases before contract acceptance. No blanket CSRF exemption is proposed.

Local versus public throttle/proxy

Proposed disposition / required evidence: Local single-process limiter proposed for S1; shared deployment control and exact ingress trust remain a Lab 5 gate. Do not claim public deployment readiness from local counters.

Real record-level authorization

Proposed disposition / required evidence: F-02-F-05 contracts consume actor/guards and supply route-specific real-DB tests; #22 closes integration gaps. A passing guard harness alone is insufficient.

10. Technical sources

Sources guide implementation choices; they do not create instructor requirements. Metadata/documentation inspected on 2026-11-06; pin and recheck during #15 rather than install `latest` blindly.

- Express session API (https://expressjs.com/en/resources/middleware/session/): session storage/callback/cookie semantics, including save/touch behavior.

- connect-pg-simple (https://github.com/voxpelli/node-connect-pg-simple) and v10 table shape (https://raw.githubusercontent.com/voxpelli/node-connect-pg-simple/v10.0.0/table.sql): store/schema/expiry options; review SQL for the target PostgreSQL version.

- Prisma 7 system requirements (https://www.prisma.io/docs/orm/v7/reference/system-requirements) and connection pools (https://www.prisma.io/docs/orm/v7/prisma-client/setup-and-configuration/databases-connections/connection-pool): runtime/driver-adapter setup.

- node-argon2 (https://github.com/ranisalt/node-argon2), OWASP password storage (https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html), and OWASP CSRF prevention (https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html): credential and preauthentication/CSRF guidance.

- Node release lifecycle (https://nodejs.org/en/about/previous-releases) and express-rate-limit (https://express-rate-limit.mintlify.app/overview): runtime selection and local/distributed limiter boundaries.

- Exact candidate metadata examples: express 5.3.0 (https://registry.npmjs.org/express/5.3.0), session 1.19.0 (https://registry.npmjs.org/express-session/1.19.0), store 10.0.0 (https://registry.npmjs.org/connect-pg-simple/10.0.0), prisma 7.10.1 (https://registry.npmjs.org/prisma/7.10.1), client 7.10.1 (https://registry.npmjs.org/@prisma%2Fclient/7.10.1), adapter 7.10.1 (https://registry.npmjs.org/@prisma%2Fadapter-pg/7.10.1), pg 8.23.1 (https://registry.npmjs.org/pg/8.23.1), argon2 0.45.2 (https://registry.npmjs.org/argon2/0.45.2), limiter 8.7.3 (https://registry.npmjs.org/express-rate-limit/8.7.3), TypeScript 5.9.3 (https://registry.npmjs.org/typescript/5.9.3).

docs/sprints/sprint-1/f-01-authentication-sts.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-01 - Software Test Specification

Version 0.2, 2026-11-06: link the shared draft DoD/conventions; all 47 planned IDs unchanged. Related contract: F-01 authentication (f-01-authentication.md), Issue #10 (https://github.com/Maibokdaimhai/LECTRA/issues/10), implementation #17 (https://github.com/Maibokdaimhai/LECTRA/issues/17). Shared references: Product DoD draft (product-dod.md), engineering conventions (shared-contract.md). Status for every case below: **Planned / not executed**. No test source, application result, RED/GREEN history or human review exists from writing this STS.

1. Execution model, fixtures and result records

IDs use `TEST-F01-Uxx` for unit, `Ixx` for API/real-PostgreSQL integration, `Exx` for selected browser/E2E, `Mxx` for justified manual/process checks and `Hxx` for actual domain integration handed to dependent work. AC references use the full `AC-F01-xx` IDs defined in the contract; abbreviated numeric ranges below refer to that prefix. Every expanded parameter row is an individual assertion/scenario in the actual implementation, even when grouped under one stable design ID.

Proposed locations after setup: API unit `apps/api/src/auth/**/*.test.ts`, real DB/API `apps/api/tests/auth.integration.test.ts`, browser `tests/e2e/auth.spec.ts`. These are plans, not files asserted to exist. #15 defines actual scripts/runner/config and records reproducible commands. Do not copy a command into evidence before it exists and runs. Use Vitest for units, Supertest for HTTP integration, real PostgreSQL for store/User/schema and Playwright against the actual app/API for browser cases.

Users O-A/O-B and R-A/R-B

Contract for future execution: Separate UUIDs; OWNER/RESPONDENT roles; `.test` synthetic emails; display names; unique salted Argon2id hashes. Keep plaintext synthetic password variables only in explicit local/test setup, not logs/evidence.

Session jars A/B

Contract for future execution: Independent cookie jars and guest bootstrap tokens, then real login where required. Save an old signed cookie only in test memory for replay/fixation assertions; redact it from snapshots/reporters.

Database

Contract for future execution: Disposable allowlisted PostgreSQL test database with reviewed User/auth_session migrations. Assert DB name/URL safety before reset; no dev/deployed DB credentials or destructive reset there. Run suite-isolated data or serialize destructive session tests.

Time

Contract for future execution: Inject server clock/limiter clock through test composition, never via a public header/query parameter. Use real DB session rows and explicitly controlled expiry values; do not wait eight hours or 15 minutes. Browser and store expiry behavior must still be checked, not only a mocked helper.

Failures / barriers

Contract for future execution: Inject failing store/DB operation at test composition boundaries; retain real DB assertions for before/after state. Use barriers to overlap read/logout rather than race-prone sleeps. Fault injection is not a replacement for normal real persistence tests.

Data snapshots

Contract for future execution: Capture row counts/identities and safe state before/after rejection. Assert no new authenticated row and no unauthorized mutation; a guest CSRF row is not itself an authenticated login.

Public deployment profile

Contract for future execution: Local TLS/proxy test fixture or equivalent verified cookie/transport harness with exact trusted path; cloud resources are not assumed. Label response-header-only cookie inspection separately from actual browser Secure-cookie behavior.

For each actual result retain: stable test and AC IDs, source/test file and case name, command, date, runtime/OS/lockfile/schema, tested SHA, expected/observed result, counts and output reference. Report failed/skipped cases and unresolved dependencies. No screenshot alone proves server revocation or DB persistence. Do not upload cookies, raw session JSON, hashes, tokens or credentials as evidence.

2. Unit specifications

Each row's action uses the future production helper or maintained library wrapper. Assertions target observable rules and projections, not duplicate its code. Unit mocks are allowed for pure boundary collaborators; persistence claims require section 3.

TEST-F01-U01

Linked AC: AC-F01-02

Preconditions / inputs: Exact email/password object; email with surrounding spaces/case; missing/extra keys; array/null; password lengths 0/1/128/129 code points, including non-BMP characters and nonempty spaces; normalized email length 254/255.

Action: Validate/normalize each parameter and verify password input remains unchanged.

Expected outcome: Valid bound values accepted with normalized email only; wrong shape/extra identity fields rejected; no password trim/truncation. Email must satisfy syntax as well as length.

TEST-F01-U02

Linked AC: AC-F01-07

Preconditions / inputs: AuthenticatedAt=t, authExpiresAt=t+28,800,000; clocks at t-1, t, deadline-1, deadline, deadline+1; malformed/null/string/NaN/inverted/extended timestamps.

Action: Evaluate actual age/state policy.

Expected outcome: Valid only within the half-open interval; exact deadline/future/invalid state rejected. No locale/DST arithmetic changes lifetime.

TEST-F01-U03

Linked AC: AC-F01-10

Preconditions / inputs: Session token A; correct A, missing token, different B, short/long/invalid alphabet, duplicate header forms.

Action: Run token parser/comparison and applicable live-session policy.

Expected outcome: Only one correctly formatted equal token accepted; length is validated before constant-time comparison. No thrown length exception or token value in error output.

TEST-F01-U04

Linked AC: AC-F01-12

Preconditions / inputs: No actor, trusted respondent, trusted owner; owned/missing/foreign record from injected loader; forged client actor data.

Action: Exercise authentication/role/scoped-loader boundaries independently.

Expected outcome: 401/403/404 according to the contract; trusted actor ID passed to loader; client actor ignored. These are guard tests, not actual domain persistence coverage.

TEST-F01-U05

Linked AC: AC-F01-14

Preconditions / inputs: Trusted User object also containing email/passwordHash/internal fields; injected internal error with SQL/secret markers.

Action: Project self identity and map error to HTTP-safe envelope/log metadata.

Expected outcome: Allowlisted id/displayName/role only; safe error code/message; markers and private fields absent from response/log serialization.

TEST-F01-U06

Linked AC: AC-F01-05

Preconditions / inputs: Two hashes of the same synthetic password with selected Argon2id costs; matching/wrong/trailing-space/different Unicode passwords.

Action: Use actual argon2 hash/verify, inspect PHC algorithm/cost/salt, compare separate encodings.

Expected outcome: Correct exact password verifies; variants fail; hashes differ due to salt; parameters meet contract. Unexpected verifier error is propagated safely, never treated as true.

TEST-F01-U07

Linked AC: AC-F01-07

Preconditions / inputs: Guest/auth fixed deadline and middleware cookie expiry proposed before/equal/after deadline, including later save/touch.

Action: Exercise the actual lifetime-cap adapter/wrapper selected in #17.

Expected outcome: Serialized cookie/store expiry never exceeds the immutable deadline; read/touch/save cannot create renewed authentication. Integrated behavior must also pass I08.

3. API and real database specifications

Use actual HTTP requests through the configured Express stack and PostgreSQL unless a row explicitly describes a test-only guard/fault-injection harness. Inspect persisted state through a test-only DB connection. Do not ship test routes or backdoors in the product.

TEST-F01-I01

Linked AC: AC-F01-01

Preconditions / inputs: No cookie; correct bootstrap origin policy; empty disposable session table.

Action: GET session; inspect real guest row and cookie, call GET session again with that cookie; call /me.

Expected outcome: Bootstrap 200 has token, false/null identity/expiry and no-store; guest row has 30-minute fixed deadline. Second bootstrap preserves token/deadline; /me 401. No user identity or auth row is fabricated.

TEST-F01-I02

Linked AC: AC-F01-11

Preconditions / inputs: HTTP local app and HTTPS/trusted-proxy profile; live session and configurable forwarded headers.

Action: Bootstrap/login/logout in each profile; inspect headers; send spoofed X-Forwarded-Proto/Host/For from an untrusted local connection.

Expected outcome: Correct cookie name/HttpOnly/SameSite/Path/no Domain; Secure only in HTTPS profile; clear matches scope. Untrusted forwarded values do not change trust/origin/IP. M02 supplements actual browser TLS behavior.

TEST-F01-I03

Linked AC: AC-F01-03

Preconditions / inputs: O-A seeded in real User table; guest bootstrap A; differently cased/padded valid email, exact password.

Action: POST login, then GET /me using returned cookie.

Expected outcome: Both 200; trusted OWNER/id/displayName; UTC absolute expiresAt; durable User/session lookup succeeds. Email normalization consistent with seed; no secret fields.

TEST-F01-I04

Linked AC: AC-F01-03

Preconditions / inputs: R-A seeded; valid guest token/password.

Action: POST login, reload current identity through /me.

Expected outcome: 200 with RESPONDENT role and correct self ID; identical endpoint/session shape to owner, no role-selector input.

TEST-F01-I05

Linked AC: AC-F01-04

Preconditions / inputs: Valid bootstrap; one wrong password for existing email and one unknown syntactically valid email.

Action: Attempt both logins below throttle bound; inspect bodies and store state; instrument verifier invocation without logging values.

Expected outcome: Same 401 INVALID_CREDENTIALS message/body; unknown email performs dummy-hash verification; no auth row/success cookie. Do not assert identical wall-clock timings.

TEST-F01-I06

Linked AC: AC-F01-02

Preconditions / inputs: Correct Origin/token; matrix of malformed JSON, arrays/null, missing/unknown/wrong-type fields, decoded length limits; bounded/padded JSON exactly 8,192 bytes and 8,193 bytes; non-JSON/compressed content; unsupported auth methods.

Action: Send each HTTP request; compare before/after auth rows and hash-call counters.

Expected outcome: 400 syntax, 422 schema, 413 oversized, 415 type/compression, 405 method with Allow as applicable. Exactly 8,192 bytes is not rejected solely for size; credential outcome depends on valid content. No rejected request authenticates/writes auth state.

TEST-F01-I07

Linked AC: AC-F01-06

Preconditions / inputs: Real guest row/SID/token, O-A valid; barrier/fault control on store save.

Action: POST login; verify persisted new SID/token; replay guest cookie/token; delay final save.

Expected outcome: Regenerated SID and token differ; old guest SID is removed and cannot authenticate or authorize login with its old token. No 200 before durable save; new cookie works only after success. No real SID/token printed.

TEST-F01-I08

Linked AC: AC-F01-07

Preconditions / inputs: Real auth row, controlled clock and cookie replay; row expiry explicitly retained where needed.

Action: /me just before, exactly at and after eight hours; call bootstrap and explicit save/touch path before deadline; inspect cookie/store caps. Include invalid/future/extended timestamps.

Expected outcome: Success only before deadline; 401 at/after/invalid state; stale cookie cleared, no renewed auth. Stored row retained or pruned cannot bypass server deadline; live reads never extend fixed expiry.

TEST-F01-I09

Linked AC: AC-F01-08

Preconditions / inputs: Logged-in user and real trusted User row.

Action: Modify role in test DB, then request role-only harness; delete User or seed invalid session userId/role state, request /me.

Expected outcome: Next request reflects trusted new role; missing/invalid User is 401. Session JSON/client cached role does not preserve removed permissions. No role-change product API is introduced.

TEST-F01-I10

Linked AC: AC-F01-12

Preconditions / inputs: No cookie, forged signature, unknown SID, revoked SID and guest cookie separately.

Action: GET /me and protected test harness with correct Origin when required.

Expected outcome: 401 with safe envelope and no private data; no arbitrary client-chosen cookie creates authenticated identity.

TEST-F01-I11

Linked AC: AC-F01-12

Preconditions / inputs: Real login as each role; test-only route composes production auth/role guard.

Action: RESPONDENT calls OWNER-only handler and OWNER calls RESPONDENT-only handler; use valid token on writes.

Expected outcome: 403 FORBIDDEN_ROLE, handler mutation not executed; allowed role passes guard. This verifies middleware integration, not actual survey endpoints.

TEST-F01-I12

Linked AC: AC-F01-12

Preconditions / inputs: Real session; test-only handler composes production scope guard with a controlled owned-resource loader.

Action: Read owned, missing and other-owner fixture; include a spoofed ownerId.

Expected outcome: Only trusted-actor-owned fixture allowed; missing/foreign both 404 with identical safe shape; no fake ownership evidence claimed. Real DB scope queries are H01-H04.

TEST-F01-I13

Linked AC: AC-F01-06, AC-F01-10

Preconditions / inputs: Two independent live sessions/tokens, old pre-login token, each auth endpoint and unsafe guard harness.

Action: Send missing/wrong/cross-session/stale token; then correct token. Include duplicate token header.

Expected outcome: 403 CSRF_INVALID and no relevant mutation for invalid live-session token; correct token succeeds. Rotation after login invalidates old guest token.

TEST-F01-I14

Linked AC: AC-F01-10

Preconditions / inputs: Valid session/token; Origin matrix: configured value, missing, null, foreign hostname, wrong scheme/port, multiple; spoof Host/forwarded values.

Action: POST login/logout and unsafe harness for each; cross-site/foreign-origin bootstrap; same-origin GET without Origin.

Expected outcome: Only configured unsafe Origin accepted. Invalid Origin gives 403 before auth mutation; Host/forwarded data cannot change allowlist. Bootstrap rejects foreign Origin/cross-site metadata; ordinary same-origin GET need not send Origin.

TEST-F01-I15

Linked AC: AC-F01-02, AC-F01-08

Preconditions / inputs: O-A/R-A credentials and attacker-controlled role/userId/ownerId/studentId body keys; fake headers/query actor values.

Action: Attempt login with extra fields; then call /me/role harness with fake actor metadata.

Expected outcome: Extra auth-body keys give 422; headers/query cannot alter trusted identity/role. No escalation or unrelated-user data. Domain payload schema tests remain their feature contracts.

TEST-F01-I16

Linked AC: AC-F01-09

Preconditions / inputs: Logged-in A with saved cookie/token; real store.

Action: POST logout; verify row deletion/clear cookie; replay cookie for /me, then repeat logout with saved well-formed token and matching Origin.

Expected outcome: Logout 204 only after delete; replay /me 401; repeated logout 204 under no-live-session rule. No server session survives/reappears.

TEST-F01-I17

Linked AC: AC-F01-09, AC-F01-10

Preconditions / inputs: No, expired, revoked, live guest and live authenticated sessions; token missing/malformed/correct-format-but-wrong/correct.

Action: POST {} logout for the policy matrix with matching/foreign Origin.

Expected outcome: Missing/malformed token always 403; foreign Origin 403. No-live session plus well-formed token is 204/no privilege. Live guest/auth requires equality; wrong token 403 and row retained. Store failure never treated as no-live session.

TEST-F01-I18

Linked AC: AC-F01-13

Preconditions / inputs: Normal real-DB fixture; injected unavailable store get/set/regenerate/destroy or trusted User lookup, one failure at a time.

Action: Bootstrap/login/me/logout as applicable; inspect status/body and row state after restoring DB.

Expected outcome: 503 with safe envelope; no memory fallback or 200 login/204 logout on failure. Failed destroy may leave row usable, which UI must disclose; tests do not assert revocation falsely. No partially successful auth cookie sent on save/regenerate failure.

TEST-F01-I19

Linked AC: AC-F01-19

Preconditions / inputs: Same User logged in independently with jars A/B.

Action: Logout A; replay A and read B.

Expected outcome: A becomes unauthorized, B remains authenticated with its original deadline. No unexpected logout-all policy.

TEST-F01-I20

Linked AC: AC-F01-07, AC-F01-17

Preconditions / inputs: User/auth rows persisted; same secret; controlled absolute deadline; actual server process/pool.

Action: Stop app/close pools, start a new process against same DB/secret; /me before and after deadline using saved cookie.

Expected outcome: Unexpired session/User survive restart; unchanged authExpiresAt; expired replay still 401. Neither reseed nor process memory is the persistence mechanism.

TEST-F01-I21

Linked AC: AC-F01-19

Preconditions / inputs: Real auth row; read handler paused after session load; no resave/touch writes on reads.

Action: Overlap /me read with logout; finish paused read after acknowledged logout; request /me again and inspect store.

Expected outcome: Already-authorized read may finish as documented; it cannot recreate revoked SID. All later reads are 401 and auth row stays absent. Use synchronization barriers and assert durable final state.

TEST-F01-I22

Linked AC: AC-F01-18

Preconditions / inputs: Fresh limiter clock/store, valid bootstrap, trusted client IP, attempts below CSRF/schema failures excluded by order.

Action: Ten valid-shaped credential attempts, concurrent eleventh, then advance to window reset; test fake forwarded IP and separate trusted keys.

Expected outcome: First ten reach credential check; eleventh 429 before hashing, safe code and Retry-After; reset restores quota. Client-supplied IP cannot reset quota. Record package IPv6 normalization behavior and process-local restart limitation.

TEST-F01-I23

Linked AC: AC-F01-14

Preconditions / inputs: Live auth and controlled failures containing synthetic secret markers in internal objects; request/response logger spy at configured boundary.

Action: Exercise successful/error bootstrap/login/me/logout; inspect headers, responses and safe logger output.

Expected outcome: no-store on auth successes/errors; exact user allowlist; no password/hash/SID/cookie/CSRF/body markers in logs/errors. Bootstrap/login token exists only where contract permits, never in URLs or unrelated payloads.

TEST-F01-I24

Linked AC: AC-F01-05, AC-F01-17

Preconditions / inputs: Fresh allowlisted test DB, reviewed migration/seed, UTC DB/session connections.

Action: Apply migrations, inspect User/auth_session types/indexes/constraints; seed twice; test normalized duplicate email; insert/read a store session and generate/apply a no-op migration.

Expected outcome: One User schema and session table/index; no plaintext password/collisions; repeatable seed behavior documented; store reads/writes correct expiry; no automatic table creation or subsequent Prisma drop. Never paste hashes/session payload into evidence.

TEST-F01-I25

Linked AC: AC-F01-11, AC-F01-17

Preconditions / inputs: Missing/weak secret, malformed/wildcard/multiple origin, unsafe HTTPS/cookie/proxy combinations, absent schema/DB, dev URL presented to test reset.

Action: Start validated configuration and exercise reset/startup safeguards.

Expected outcome: Fail safely before serving protected traffic/reset; no exposed debug/config secret, insecure production fallback or destructive dev-DB reset. Valid local profile still starts when its schema exists.

TEST-F01-I26

Linked AC: AC-F01-05, AC-F01-13

Preconditions / inputs: Existing synthetic user with deliberately corrupt test-only hash or injected verifier exception.

Action: Login with valid Origin/token/schema; restore fixture afterward.

Expected outcome: 500 INTERNAL_ERROR, no authentication grant/secret detail. Verifier exception cannot be cast to a truthy login result or confused with missing-account fallback.

TEST-F01-I27

Linked AC: AC-F01-01

Preconditions / inputs: Live auth, then expired/revoked cookie; stable live auth token.

Action: Bootstrap each state.

Expected outcome: Live auth returns trusted safe user/absolute expiry with unchanged token/deadline. Expired/revoked cookie yields a new guest token with false/null identity; no silent renewal.

TEST-F01-I28

Linked AC: AC-F01-04

Preconditions / inputs: Authenticated O-A; valid token; valid R-A or O-A credentials in a new login request.

Action: POST login and inspect existing identity/token/deadline.

Expected outcome: 409 ALREADY_AUTHENTICATED; no account switch/new auth row/deadline extension. Logout then a fresh bootstrap is the supported change-account path.

4. Selected browser/E2E and supplementary checks

Use independent browser contexts for users, real API/PostgreSQL and synthetic data. Do not mock successful authentication or inject frontend role state to pass a journey. A test-only server clock/fault control stays outside production HTTP surfaces. Do not assert role-specific domain content before F-02 exists; authenticate/navigate to its real shell and disclose the integration dependency.

TEST-F01-E01 / UI-E2E

Linked AC: AC-F01-03, AC-F01-15

Preconditions / inputs: Real O-A and R-A; login page, 360px and 1280px; keyboard-only selected journey.

Action: Focus labelled fields, submit invalid then valid credentials; attempt duplicate click during delayed login; refresh after success.

Expected outcome: Generic error/focus summary and cleared password on completed failure; no duplicate UI request while busy; real identity selects correct shell; refresh resolves server state; no private-content flash/horizontal page overflow.

TEST-F01-E02 / UI-E2E

Linked AC: AC-F01-09, AC-F01-14, AC-F01-16

Preconditions / inputs: Real login and private page; browser history.

Action: Log out, press back, reload/directly navigate private URL; inspect actual protected API request.

Expected outcome: Login/session-ended UI; private client state removed, no cached private rendering; protected API 401. Test server row/replay separately in I16.

TEST-F01-E03 / UI-E2E

Linked AC: AC-F01-14, AC-F01-16

Preconditions / inputs: Two tabs and real session; advance controlled server clock beyond expiry or logout from the other context sharing cookie.

Action: Trigger protected read or visibility revalidation; then navigate back.

Expected outcome: Detected 401 clears private caches/drafts/auth and shows login; next login bootstraps correctly. No claim of instantaneous tab notification or automatic unsent-answer recovery.

TEST-F01-E04 / UI-E2E

Linked AC: AC-F01-10, AC-F01-15

Preconditions / inputs: Real bootstrap, deliberately stale/missing in-memory token; delayed/timed-out login response.

Action: Submit, refresh bootstrap deliberately, resubmit credentials; simulate ambiguous response and resolve current identity.

Expected outcome: Safe CSRF error and password cleared; no automatic POST/password retry; successful new login uses new token. Ambiguous outcome checks server identity before claiming failure/resending.

TEST-F01-E05 / UI-E2E

Linked AC: AC-F01-13, AC-F01-16

Preconditions / inputs: Real authenticated UI; destroy operation fails once through private test composition.

Action: Click logout; observe failure; restore store and deliberately retry.

Expected outcome: Private content hidden immediately; failure says server sign-out unconfirmed, with working retry. No false logout success; after confirmed 204 protected access is 401.

TEST-F01-M01 / manual UI

Linked AC: AC-F01-15

Preconditions / inputs: Actual built login/loading/error/logout states, actual tested SHA, 360px/1280px and SDS supplementary reflow/zoom checks.

Action: Inspect visible focus, labels/error association, password masking/paste, wrapping and busy/error announcements using keyboard/accessibility inspection.

Expected outcome: Record actual observations/screenshots and defects; no hidden role selector, overflow or inaccessible error focus in assessed journey. Manual result supplements E01, not a substitute for API/DB tests.

TEST-F01-M02 / setup and TLS

Linked AC: AC-F01-11, AC-F01-17

Preconditions / inputs: Fresh checkout and allowlisted DB; actual documented #15 setup; local HTTPS/trusted-proxy test fixture when available.

Action: Teammate reproduces migrate/seed/start/check; inspect real browser cookie acceptance/clearing and forwarded-header rejection through documented fixture.

Expected outcome: Record actual runtime/schema/lockfile/commands/results; HTTPS browser respects Secure/__Host scope; local HTTP profile works explicitly. If unavailable, mark Not run and resolve before deployment claims. No GCP resources assumed.

TEST-F01-M03 / process audit

Linked AC: AC-F01-20

Preconditions / inputs: Real contract/test-design commits, #5 Product DoD, implementation/TDD versions, PR reviews and integrated/release results when they exist.

Action: Audit timestamps/history and trace requirement -> AC -> actual tests/results; inspect substantive opposite-member review and reported skips/limitations.

Expected outcome: Feature contract precedes code; RED/GREEN demonstrates intended behavior; test commands/names/counts match real SHA; approval is human and release evidence is actual. Missing evidence remains pending, not fabricated to satisfy checklist.

5. Real domain-access handoff checks

These checks are planned cross-feature requirements and cannot be passed by the F-01 guard harness. The listed dependent feature owner supplies exact request/schema details in its own contract, uses the shared authentication flow and real PostgreSQL, and links the resulting test/version under #22. They preserve BR-02/NFR-01 without widening F-01 into all domain implementation.

TEST-F01-H01 / API-DB integration

Linked AC / source: AC-F01-12; BR-01/02, FR-02

Preconditions / inputs: O-A and O-B own distinct Sections of the same Course; real contexts.

Action and responsible work: F-02 #11/#18: O-A directly reads O-B's context/survey IDs, including spoofed Course/owner metadata.

Expected outcome: 404/no private fields; shared Course confers no ownership. Guest 401, role-only student denial 403.

TEST-F01-H02 / API-DB integration

Linked AC / source: AC-F01-12; BR-01/02, FR-03/04

Preconditions / inputs: R-A and O-B; O-A's real Draft/Published survey.

Action and responsible work: F-03 #12/#19: respondent attempts manage/publish/close; other owner attempts same.

Expected outcome: Respondent role denied 403; foreign-owner resource 404; no persisted definition/state/eligibility mutation.

TEST-F01-H03 / API-DB integration

Linked AC / source: AC-F01-12; BR-01/02, FR-05/06

Preconditions / inputs: Two respondents with distinct real submissions/eligibility, owner session.

Action and responsible work: F-04 #13/#20: attempt another user's response retrieval and identity spoofing on submission/status; owner attempts respondent-linked lookup.

Expected outcome: Only session-derived own response/status; spoofing cannot expose/write for another account. No owner respondent-linked endpoint; no mutation/data leak. Exact endpoint/status follows F-04 contract.

TEST-F01-H04 / API-DB integration

Linked AC / source: AC-F01-12; BR-01/02, FR-07

Preconditions / inputs: O-A owns results, O-B owns another Section, R-A eligible student.

Action and responsible work: F-05 #14/#21: direct results requests as guest/respondent/foreign owner and inspect successful projection.

Expected outcome: Guest 401, wrong-role 403, other owner 404; authorized result has no respondent-linked answers, participation list, auth/session data or hidden fields.

6. Coverage audit and meaningful TDD plan

The contract's AC table is the authoritative coverage map; every one of its 20 AC has at least one STS row here. There are 47 stable planned cases: 7 unit, 28 API/DB (including clearly labelled harness/fault variants), 5 browser, 3 supplementary/process and 4 dependent real-domain checks. These are specification counts, not executed/passing test counts; parameterization may produce a different actual runner count. STS existence alone does not satisfy NFR-05 or full BR-02.

Absolute expiry and no renewal

Planned first failing behavior assertion: U02/I08 reject at exact deadline and observe no extension after earlier reads/save; initially fail on an implementation that renews or accepts equality.

Passing implementation / evidence boundary: Use actual production policy/store/cookie cap; retain RED/GREEN SHAs/output. A clock-helper mock alone cannot establish store/browser behavior.

SID/token regeneration

Planned first failing behavior assertion: I07/I13 prove guest SID/token remains valid before the fix and must become invalid after authentication.

Passing implementation / evidence boundary: Real store old-row removal/new-row persistence and token rejection after correction. Do not prewrite a passing final implementation then invent an older failure.

Revocable logout and concurrent reads

Planned first failing behavior assertion: I16/I21 demonstrate unauthorized old-cookie replay/no resurrection after acknowledged logout.

Passing implementation / evidence boundary: Durable delete and read/save policy verified; failed destroy remains failure.

Trusted identity and role guard

Planned first failing behavior assertion: U04/I09/I11 reject untrusted actor/role and reflect trusted DB changes.

Passing implementation / evidence boundary: Real User lookup and middleware guard behavior; H01-H04 prove actual resource integration later.

Use normal separate commits/versions under authorized work; no artificial commit-count target. Keep assertions strong and disclose failures/skips. Once #15 establishes commands, run the relevant suite, inspect failures/assertions and retain raw safe output when each rule is developed. Reconcile with the shared Product DoD in #5 before #17 implementation and keep actual result links separate from this planned design.

docs/sprints/sprint-1/f-02-context-discovery.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-02 - Owned Context and Eligible Survey Discovery Contract

Version 0.1, 2026-11-06. Proposed preimplementation contract for Issue #11; implementation belongs to #18. Lead: R1NNE0; planned opposite-member reviewer: Maibokdaimhai, following the dated tracker (tracker.md). These are proposed responsibilities, not completed contributions or human approval. No application, migration, executable test or passing result is supplied here. Verification design: F-02 STS (f-02-context-discovery-sts.md).

1. Authority, purpose and scope

Read with the SRS (../../srs.md), Feature Inventory (../../features.md), traceability (../../traceability.md), System SDS (../../system-sds.md), decision log (../../decisions.md), Sprint Plan (../plan.md), tracker (tracker.md) and workflow (workflow.md). The instructor sources remain `group_work_specs_v1.pdf` sections 5.2, 6 Theme 10 and 8.2, and `project_deliverable_1_v1.pdf` section 3.5. Exact endpoint schemas, ordering and AC/STS IDs below are proposed team designs, not instructor-prescribed interfaces.

The public Issue #11 page could not be retrieved during drafting. The owner's supplied Issue #11 requirements are the issue-level source used here; no additional remote checklist, comment, approval or live issue state is asserted.

F-02 provides the smallest read-only path from a trusted actor to an owned lecture or eligible survey. It supplies four existing endpoint families, context selectors/current-work lists and the caller's participation boolean. It does not create academic records, publish a survey, read a questionnaire/answer bundle, submit feedback or calculate results.

Provisional PR #29 reference

The shared contract, Product DoD and F-01 files are not in this working tree. The locally readable PR #29 snapshot `fc64e2cc16557d77d67ef278d56e05c86c2621fc` was inspected as a **provisional** reference, not copied, merged or adopted. See its shared conventions (https://github.com/Maibokdaimhai/LECTRA/blob/fc64e2cc16557d77d67ef278d56e05c86c2621fc/docs/sprints/sprint-1/shared-contract.md), F-01 contract (https://github.com/Maibokdaimhai/LECTRA/blob/fc64e2cc16557d77d67ef278d56e05c86c2621fc/docs/sprints/sprint-1/f-01-authentication.md) and Product DoD (https://github.com/Maibokdaimhai/LECTRA/blob/fc64e2cc16557d77d67ef278d56e05c86c2621fc/docs/sprints/sprint-1/product-dod.md). Reconcile the accepted versions under #5 before #18 code; this document does not assert the PR's current approval/merge state.

This proposal follows their `AC-F02-xx` / `TEST-F02-U/I/E/M/Hxx` naming, camelCase JSON, uppercase enums, safe error envelope, bounded pagination and session-derived actor. The two filenames follow the owner's requested names and the provisional F-01 contract/STS pairing. No shared file is edited by this task.

2. Requirements and layer responsibilities

FR-02

F-02 responsibility: Owned Course/Section/Lecture navigation; only eligible Published/Closed respondent discovery.

Acceptance coverage: AC-F02-02 through AC-F02-08

FR-12; SYS-01

F-02 responsibility: Specify reproducible academic context/relationship fixtures; #16 authors migrations/seed.

Acceptance coverage: AC-F02-01, AC-F02-20

BR-01

F-02 responsibility: Use F-01's trusted server identity, never supplied actor fields.

Acceptance coverage: AC-F02-02, AC-F02-10, AC-F02-11

BR-02

F-02 responsibility: Section ownership, same-Course isolation, self-only participation and safe projections.

Acceptance coverage: AC-F02-03 through AC-F02-10

BR-03

F-02 responsibility: Discover from the publication eligibility snapshot, not current Membership.

Acceptance coverage: AC-F02-07, AC-F02-08, AC-F02-17

BR-04

F-02 responsibility: Hide Drafts from respondents; show Published/Closed without granting submission permission.

Acceptance coverage: AC-F02-06, AC-F02-07, AC-F02-19

BR-23

F-02 responsibility: Resolve Survey through Lecture/Section; one survey per lecture is a shared F-03/#16 invariant.

Acceptance coverage: AC-F02-01, AC-F02-05, AC-F02-06, AC-F02-19

NFR-01

F-02 responsibility: Backend scoping, safe failures, no credentials or private owner/other-student data.

Acceptance coverage: AC-F02-02, AC-F02-10, AC-F02-18

NFR-03

F-02 responsibility: Repeatable safe setup and documented real commands once implemented.

Acceptance coverage: AC-F02-01, AC-F02-20

NFR-05

F-02 responsibility: Every AC has planned verification; actual results/history remain separate.

Acceptance coverage: All AC; AC-F02-20

NFR-07

F-02 responsibility: Keyboard, labels, loading/empty/error states and 360px/1280px layouts.

Acceptance coverage: AC-F02-14 through AC-F02-16

UI and API read services require implementation. Database definition/seed changes are coordinated through #16, not a second F-02 migration history. **No change in F-02** to password/session storage, auth endpoints, question definitions, publication writes, response/answer writes, result calculations, analytics or deployment infrastructure. F-02 consumes User, Survey, SurveyEligibility and Participation interfaces owned jointly with their relevant features; it does not redefine their writes.

3. Actors, access and visibility

F-01 resolves immutable request-local `actor: { userId, role }` from the signed session and trusted User row on every request. F-02 never builds an actor from URL/query/body/header values. A session role cached in React cannot grant access.

Course list

OWNER: Courses having at least one Section owned by this actor.

RESPONDENT: 403; use safe context embedded in eligible surveys.

No usable authenticated identity: 401

Section list for a Course

OWNER: Only this actor's Sections, after establishing owned Course access.

RESPONDENT: 403

No usable authenticated identity: 401

Lectures for a Section

OWNER: Only after resolving `Section.ownerId = actor.userId`.

RESPONDENT: 403

No usable authenticated identity: 401

Survey list

OWNER: Owned surveys, including Draft/Published/Closed; optional owned lecture selector.

RESPONDENT: Only Published/Closed with `SurveyEligibility.studentId = actor.userId`; own submitted boolean only.

No usable authenticated identity: 401

A shared Course is not shared ownership. Course existence alone cannot authorize a Section, Lecture or Survey. Owner Survey queries constrain the full `Survey -> Lecture -> Section.ownerId` relation and require redundant Survey.ownerId to agree. Mismatched rows are excluded from discovery; #16/F-03 must reject creating them. A valid UUID or membership in another Section never expands scope.

Respondent discovery uses **SurveyEligibility**, even if current Membership was later added/removed. Participation is `EXISTS Participation(surveyId, actor.userId)`; there is no join to another student's answers or participation list. Respondent collections omit inaccessible records and return 200 with the caller's remaining set, including an empty set. They do not return 403 merely because unrelated surveys exist.

For a named owner-context parent, missing and inaccessible resources both return the same 404. Respondent direct questionnaire/response reads belong to F-03/F-04: they must similarly hide Draft/ineligible IDs with 404, independently of list filtering. Those are explicit handoff tests, not a new F-02 detail endpoint.

4. Workflows and navigation handoffs

4.1 Owner

1. After F-01 resolves OWNER, load owned Courses and current-work surveys independently.

2. Select a Course; clear previous Section/Lecture selections and fetch its owned Sections.

3. Select a Section; clear the previous Lecture and fetch its lectures.

4. Select a Lecture. `existingSurvey = null` offers the F-03 create action; otherwise offer that survey's F-03 management or F-05 Closed-results action. Do not create another survey optimistically.

5. `GET /api/surveys?lectureId=...` scopes the work list to that owned lecture. Clearing the selection removes that query and returns all owned work. Closed records can remain in this operational list; this is not a date/state history search.

4.2 Respondent

Load `GET /api/surveys` after F-01 resolves RESPONDENT. Each card shows its safe academic context, survey state/mode and own submitted status. It cannot enumerate the general Course/Section catalog.

Published

Own submitted: false

Action / explanation: Answer survey: navigate to the F-03 questionnaire read/F-04 response workflow.

Published or Closed

Own submitted: true

Action / explanation: View submission: navigate to F-04 own identified status/answer retrieval. No edit/resubmit promise.

Closed

Own submitted: false

Action / explanation: Collection ended; no Answer action.

Draft or not eligible

Own submitted: Either

Action / explanation: No card or content. Direct target access is rechecked by its owning feature.

F-02 supplies navigation by authorized survey/lecture IDs, not duplicate detail/answer APIs or privileged client action URLs. Exact target UI routes are a preimplementation F-03/F-04/F-05 agreement in section 10; no working target screen is claimed now. Target services always revalidate current identity/state/eligibility. A survey closing or a Draft being deleted after a list read may invalidate a link: show the target's safe denial/state message and refresh the list. A rendered action is not a reservation or permission to write.

5. Exact proposed API contract

5.1 Common read protocol

All F-02 operations are authenticated GETs, return JSON and `Cache-Control: no-store`, and perform no application-domain writes. Use same-origin credentialed fetch and F-01's read Origin/session policy; no CSRF token is required for these safe reads. An explicitly foreign Origin is rejected under F-01; a same-origin GET can omit Origin. F-02 does not weaken login/write CSRF rules or extend a session deadline.

For requests passing F-01's outer Origin/method/session handling, order checks as authentication, endpoint role, exact query/path syntax, scoped parent access, then read/projection. Correctly originated guest/expired requests return 401 before domain input/existence details; authenticated respondents on owner-only context routes receive 403 before UUID/parent validation. Query validation errors can be 422; syntactically valid hidden/missing named parents are 404. Do not infer parent existence from different envelopes or total counts.

Known context paths support GET only; unsupported methods return 405 with `Allow: GET` and no domain write. The shared `/api/surveys` path's non-GET operations belong to F-03; do not install an F-02 method guard that blocks its POST. Any framework-generated HEAD handling must be reconciled with the agreed method policy before code, not accidentally bypass authentication or leak counts.

List success is exactly `{ "data": { "items": [], "pagination": { "limit": 20, "offset": 0, "total": 0 } } }`, with the item type below. `total` counts only authorized records after this endpoint's selectors. There are no additional response fields or unlisted nested fields.

5.2 Input, pagination and ordering

limit

Contract: Optional single canonical decimal string; default 20, integer 1-100. No sign, fraction, exponent, leading zeros, whitespace, empty value, array or duplicate key.

offset

Contract: Optional single canonical decimal string; default 0, integer 0-10,000. `0` is valid; otherwise no leading zeros. Same strict shape rules.

courseId, sectionId, lectureId

Contract: UUID syntax: 36-character lowercase hexadecimal hyphenated `8-4-4-4-12` representation; trusted seed/server generates IDs. No trim, case rewriting, array, duplicate parameter or DB cast exception. Version-generation policy remains #16/#5 agreement; format is not authorization.

Other fields

Contract: Reject with 422, including actor/role/student/owner IDs, arbitrary sort, `fromDate`, `toDate`, `status`, search and response-subgroup fields. No silent F-09 filter support.

GET body

Contract: Not an input surface; reject a nonempty body with 400 `UNEXPECTED_BODY`, without parsing it as actor/filter authority. No F-04 JSON limit or write behavior is redefined.

Only parameters listed for a particular endpoint are allowed. Path `sectionId` is not a query option. Reject out-of-range pagination before arithmetic/query execution; do not coerce invalid syntax. An authorized collection with `offset >= total` returns 200, empty items and its real total, including offset 10,000. Do not fetch an unbounded list to paginate in React.

Ordering is fixed, with PostgreSQL `C` text collation for textual keys so machine locale does not change pages: Courses by code ascending then id ascending; Sections by term descending, sectionCode ascending, id ascending; Lectures by sequence ascending then id ascending; Surveys by lectureDate descending, lecture sequence descending, survey id ascending. Term order is lexical, not a claim of chronological term interpretation. Calendar dates stay `YYYY-MM-DD` without timezone conversion. IDs provide stable tiebreakers across equal dates/text. Repeated reads of unchanged data yield the same pages; concurrent commits between separate page requests may change them, so the UI permits refresh rather than promising a frozen multi-request snapshot.

5.3 Endpoint definitions

GET /api/courses

Role; allowed query: OWNER; limit, offset

Authorization/filter and success items: Select distinct Courses for which an owned Section exists. Item: CourseSummary. Sharing a Course does not expose other owners/Sections or their counts. No owned Sections means empty collection.

GET /api/sections

Role; allowed query: OWNER; required courseId, limit, offset

Authorization/filter and success items: First establish an owned Section exists for that Course; missing/foreign-only Course returns 404. Then list only owned Sections in it. Item: SectionSummary. An out-of-range page is empty, not 404.

GET /api/sections/:sectionId/lectures

Role; allowed query: OWNER; limit, offset

Authorization/filter and success items: Resolve owned Section before listing. Missing/foreign Section returns 404; owned Section with no lectures returns empty. Item: LectureSummary.

GET /api/surveys

Role; allowed query: OWNER or RESPONDENT; limit, offset; lectureId optional for OWNER only

Authorization/filter and success items: OWNER: all three states scoped through owned Section, optionally to an owned Lecture; a valid missing/foreign selected Lecture gives 404. RESPONDENT: reject lectureId as unsupported query, then list only Published/Closed with own eligibility. Items: OwnerSurveySummary or RespondentSurveySummary.

Parent-selector access is checked even when pagination would produce no items. Eligible respondents do not need separate catalog endpoints because each survey carries the necessary context. There is no F-02 `GET /api/surveys/:id`: retain that path for the owning F-03 read contract.

5.4 Allowlisted item schemas

CourseSummary

Exact fields: `{ id: UUID, code: string, title: string }`

SectionSummary

Exact fields: `{ id: UUID, courseId: UUID, term: string, sectionCode: string }`

LectureSummary

Exact fields: `{ id: UUID, sectionId: UUID, title: string, lectureDate: calendarDate, sequence: positiveInteger, existingSurvey: null or SurveyRef }`

SurveyRef

Exact fields: `{ id: UUID, title: string, status: DRAFT or PUBLISHED or CLOSED, mode: IDENTIFIED }`; owner-only lecture projection.

OwnerSurveySummary

Exact fields: `{ id: UUID, title: string, status: DRAFT or PUBLISHED or CLOSED, mode: IDENTIFIED, course: CourseSummary, section: SectionSummary, lecture: LectureRef }`

LectureRef

Exact fields: `{ id: UUID, title: string, lectureDate: calendarDate, sequence: positiveInteger }`

RespondentSurveySummary

Exact fields: Same context/id/title fields as OwnerSurveySummary, but status is PUBLISHED or CLOSED, plus `participation: { submitted: boolean }`. Mode is IDENTIFIED in S1.

All fields are non-null except `existingSurvey`. Existing Survey title follows F-03's actual stored Draft policy; F-02 must not impose publication-only validity on an incomplete Draft. S1 persisted schema/mode is IDENTIFIED; future anonymous records require the later accepted F-06 projection/disclosure contract, not silent relabelling here. Respondent title/context comes only from a visible Published/Closed survey.

Never return owner/student account IDs, owner email/displayName, enrollment/eligibility lists, other participation, response counts/means/comments, question bodies, answer/bundle IDs, source/template metadata, session/token fields or private notes. Owner summaries omit participation entirely; absence must not be serialized as a null per-student field. F-05 owns response-count/results reads. Render all persisted text escaped as plain text, including seed strings resembling markup.

5.5 Error contract

Errors use `{ "error": { "code": "CODE", "message": "safe text" } }`; validation may add `fields` mapping only the paths `limit`, `offset`, `courseId`, `sectionId`, `lectureId`, `_form` to safe reasons. Never echo supplied values, SQL, stack, session data or inaccessible metadata.

400 UNEXPECTED_BODY

Condition and fixed outward message: Nonempty GET body: `This request does not accept a body.`

401 AUTH_REQUIRED / SESSION_EXPIRED

Condition and fixed outward message: F-01 exact session policy/messages; clear private UI. Not a new F-02 lifecycle.

403 ORIGIN_FORBIDDEN

Condition and fixed outward message: F-01 exact Origin policy/message; do not reclassify as empty data.

403 FORBIDDEN_ROLE

Condition and fixed outward message: Authenticated wrong role for owner context: `This operation is not available for your role.`

404 NOT_FOUND

Condition and fixed outward message: Valid-format missing or inaccessible named parent: `Resource not found.` Same status/body for both.

405 METHOD_NOT_ALLOWED

Condition and fixed outward message: Recognized context path, unsupported method: `Method not allowed.` Respect shared-path routing above.

422 VALIDATION_FAILED

Condition and fixed outward message: Invalid/missing/unknown/duplicate query or malformed UUID: `Check the request parameters.` Safe field reasons; no SQL cast error.

503 AUTH_SERVICE_UNAVAILABLE

Condition and fixed outward message: F-01 store/trusted User dependency unavailable; no fallback identity.

503 SERVICE_UNAVAILABLE

Condition and fixed outward message: Known unavailable F-02 domain database dependency: `The service is temporarily unavailable.` Never a fabricated empty/success response.

500 INTERNAL_ERROR

Condition and fixed outward message: Unexpected failure: `An unexpected error occurred.` Safe diagnostics only.

New `UNEXPECTED_BODY` wording and all proposed wire details require shared #5/F-01 reconciliation before implementation. No mutation succeeds on error. F-02 must not log raw cookies/tokens, request bodies or broad row dumps. Safe status/route diagnostics exclude account-linked submission information.

6. Data model, seed and query responsibilities

User

F-02 meaning / required relationship: Trusted UUID and OWNER/RESPONDENT role; credentials remain F-01.

Implementation owner: F-01 defines; #16 authors one migration/seed.

Course

F-02 meaning / required relationship: UUID, unique code, title; academic context only.

Implementation owner: F-02/#16 coordinate exact columns/types and nonblank synthetic metadata.

Section

F-02 meaning / required relationship: UUID; required Course FK and OWNER User FK; term/sectionCode; unique course/term/sectionCode.

Implementation owner: #16 migration; seed/service checks owner role because a simple FK alone does not enforce it.

Lecture

F-02 meaning / required relationship: UUID; required Section FK; title, DATE lectureDate, positive integer sequence; unique section/sequence; dates need not be unique.

Implementation owner: #16 migration/seed.

Membership

F-02 meaning / required relationship: Required Section and RESPONDENT User FKs; unique section/student pair. No attendance/grade fields.

Implementation owner: #16; seed/service checks respondent role. No F-02 member CRUD.

Survey

F-02 meaning / required relationship: Unique Lecture FK, owner matching its Section, title/status/mode. Absent survey is normal.

Implementation owner: F-03 owns authoring/state rules; #16 coordinates constraints. F-02 reads existingSurvey/context only.

SurveyEligibility

F-02 meaning / required relationship: Unique survey/student pair; frozen at publication.

Implementation owner: F-03 writes atomically with publication; #16 schema; F-02 uses own-row EXISTS.

Participation

F-02 meaning / required relationship: Unique survey/student pair referencing eligibility; status only, not answer data.

Implementation owner: F-04 owns atomic submission writes; #16 schema; F-02 reads own-row EXISTS.

Do not create a duplicate User, Survey, eligibility or participation schema. Agree exact Prisma/SQL field mappings, FK targets, nullability and deletion behavior in #16 before code. Academic context/membership rows are seeded/read-only to the application; do not cascade-delete submitted associations or introduce public seed/admin routes. Question/Answer definitions and response transactions remain outside F-02.

Seeds reproduce at least two owners with different Sections in the same Course, another Course, multiple lectures (including equal dates with different sequences), an owned Section with no lectures, an owner with no Sections, and students with

differing Membership/eligibility. Use synthetic data only. Minimal context seed can exist before F-03/F-04; publication/participation integration fixtures are added under their reviewed schemas, not fabricated as implemented workflows. Seed roles/FKs/unique relationships are validated without requiring the login UI. Test-only Membership changes demonstrate that later enrollment changes do not rewrite published eligibility.

Queries apply authorization and selector predicates **before** count/order/offset/limit. Use distinct Course selection and EXISTS/semi-joins for eligibility/participation, not fan-out joins that duplicate survey cards or count answer rows. The count and items, parent checks and participation projection within one response use one read-only consistent database snapshot (proposed PostgreSQL REPEATABLE READ transaction; confirm pinned Prisma support under #15/#16). PostgreSQL documents the distinction between per-statement and transaction snapshots in its transaction isolation reference (https://www.postgresql.org/docs/current/transaction-iso.html#XACT-REPEATABLE-READ); consult the pinned version during setup. No table/survey lock, eligibility rewrite or implicit seed runs on a read. Do not expose uncommitted publication snapshots or partial submissions. Pagination is consistent within a response, not frozen across subsequent HTTP requests.

Indexes start from existing PK/FK/unique needs and scoped reads: Section owner/course, Lecture section/sequence, Survey lecture/state and eligibility/participation survey/student pairs; reverse student/survey lookup may be added if query evidence justifies it. #16 owns actual index/migration decisions. This contract promises correctness and bounded pages, not an unmeasured performance result.

7. UI contract

Use the existing SDS cool blue/teal light theme, native labelled controls, explicit state text and semantic feedback. No new design system or dashboard is introduced. Proposed owner/respondent list route names must be aligned with F-01 shells before code; their responsibilities are fixed here even if final UI paths differ.

Owner selection

Required behavior: Label Course, Section and Lecture; default to no selection, not an invented authorized context. Use the paginated APIs for each selector/list. Change of parent clears child selection, data and page offset.

Selector/list pagination

Required behavior: Previous/Next with page/range context and disabled boundary semantics; retain selected parent, limit and deterministic order. Reset offset to 0 on parent/lecture filter changes. Show selected labels even when another page is displayed; permit reload/reset if data changes.

No owned Courses

Required behavior: Explain no assigned teaching context; no create/admin action.

Owned context with no lectures/work

Required behavior: Distinguish no lectures from no survey for a selected lecture; only the latter offers F-03 creation when that target workflow exists.

No eligible surveys / out-of-range page

Required behavior: Neutral empty state, no fake cards/charts. For a now-empty later page, offer previous/reset navigation without automatic retry loops.

Respondent cards

Required behavior: Show Course code/title, Section/term, lecture title/date, survey title, Published/Closed, identified mode and separate own Submitted/Not submitted status. Actions follow section 4.2; no owner participation list.

Loading / rapid changes

Required behavior: Show loading text/busy state; clear unrelated child rows while fetching. Cancel or ignore superseded requests; an old parent response cannot populate a new selection. Never flash another user's/parent's cached content.

401 / logout

Required behavior: F-01 clears private lists, selection/cache and pending request generations; return to login/session-ended state. A late successful fetch cannot restore content after logout or a user switch.

403 / 404

Required behavior: Safe unavailable/access message, no guessed hidden names. Clear inaccessible dependent data and allow returning to an authorized parent/list; do not mislabel as session expiry.

Network / 5xx

Required behavior: Explain read failure with an explicit retry. Do not show zero records, a successful create/submit or permanent empty state as the result of an error.

Stale action

Required behavior: The target feature rechecks authority/state. Explain its safe rejection and refresh discovery; do not retry a create/submit automatically.

Keyboard / responsive

Required behavior: Associated labels, logical Tab order and native activation; loading/error announcements and visible focus. At 360px and 1280px content/actions wrap without page overflow or color-only permission cues. Preserve ISO lecture date without browser-timezone shifts; Thai/English text wraps.

No answer drafts or survey definitions are stored/edited by this UI. Only request-local/in-memory context is cached; clear on auth loss. F-04 owns identified-mode disclosure before answering; F-02's mode label must not contradict it or advertise anonymous support.

8. Stable acceptance criteria

All outcomes and linked cases are **Planned / Not run**. Full STS inputs/actions/expected results are in the companion file. Accepted IDs remain stable; append or record justified revisions rather than renumbering.

AC-F02-01

Observable outcome: Reproducible synthetic hierarchy satisfies required roles/FKs/unique relationships; #16 owns its schema without duplicate auth/domain tables.

Planned STS IDs: TEST-F02-I01, TEST-F02-M02

AC-F02-02

Observable outcome: All reads require trusted F-01 identity; owner context routes reject respondents before resource detail; client actor data grants nothing.

Planned STS IDs: TEST-F02-I02, TEST-F02-I03

AC-F02-03

Observable outcome: Course list contains exactly Courses having an owned Section, once each, without cross-owner data/counts.

Planned STS IDs: TEST-F02-I04

AC-F02-04

Observable outcome: Section list requires owned Course access and returns only own Sections; missing/foreign-only parent is indistinguishable 404.

Planned STS IDs: TEST-F02-I05

AC-F02-05

Observable outcome: Lecture list requires owned Section access, supports empty Sections and exposes only the authorized existing-survey reference.

Planned STS IDs: TEST-F02-I06

AC-F02-06

Observable outcome: Owner survey list is Section-scoped across all three states; optional lecture selection cannot broaden ownership or reveal another Section's survey.

Planned STS IDs: TEST-F02-I07

AC-F02-07

Observable outcome: Respondent list includes only own-eligible Published/Closed surveys and never Draft or unrelated context.

Planned STS IDs: TEST-F02-I08, TEST-F02-I09

AC-F02-08

Observable outcome: Post-publication Membership changes do not add/remove discovery eligibility; only frozen eligibility controls it.

Planned STS IDs: TEST-F02-I10

AC-F02-09

Observable outcome: Each respondent sees only their persisted submitted boolean; another student's participation never changes it.

Planned STS IDs: TEST-F02-I11, TEST-F02-H02

AC-F02-10

Observable outcome: Exact safe projections exclude questions/answers/results/identities/session/private fields; text is plain, owner participation absent.

Planned STS IDs: TEST-F02-U02, TEST-F02-I12

AC-F02-11

Observable outcome: Exact query/UUID syntax, duplicate/unknown fields, GET bodies and deferred history filters are rejected safely without domain writes.

Planned STS IDs: TEST-F02-U01, TEST-F02-I13

AC-F02-12

Observable outcome: Pagination defaults/bounds and authorized totals are correct; empty/out-of-range pages do not expose another actor's counts.

Planned STS IDs: TEST-F02-U03, TEST-F02-I14, TEST-F02-I16

AC-F02-13

Observable outcome: Stable documented ordering/tiebreakers produce repeatable unchanged-data pages and preserve calendar dates.

Planned STS IDs: TEST-F02-I15

AC-F02-14

Observable outcome: Owner/Respondent empty/loading/availability distinctions and parent-reset/page actions match server data without invented workflow success.

Planned STS IDs: TEST-F02-I16, TEST-F02-E01, TEST-F02-E02

AC-F02-15

Observable outcome: Retry, permission/session-loss and superseded-request behavior never restores unrelated/private stale content or treats failure as empty success.

Planned STS IDs: TEST-F02-E03, TEST-F02-E04

AC-F02-16

Observable outcome: Both list journeys are labelled, keyboard-operable and usable at 360px/1280px with visible focus and wrapped content.

Planned STS IDs: TEST-F02-E01, TEST-F02-E02, TEST-F02-M01

AC-F02-17

Observable outcome: Reads leave domain data unchanged; one response's count/items/participation use a consistent committed snapshot during publication/submission.

Planned STS IDs: TEST-F02-I17, TEST-F02-I18

AC-F02-18

Observable outcome: Database/auth dependency failure produces the safe defined error, no-store and no private diagnostics, not a fabricated empty collection.

Planned STS IDs: TEST-F02-I19, TEST-F02-E04

AC-F02-19

Observable outcome: Actions derive from current state/own status; target features revalidate stale/ineligible requests; no F-03/F-04 write is implemented in F-02.

Planned STS IDs: TEST-F02-U04, TEST-F02-I20, TEST-F02-H01, TEST-F02-H02

AC-F02-20

Observable outcome: Accepted contract/STS/DoD, actual setup/test/history and substantive teammate integration are linked before claiming F-02 Done.

Planned STS IDs: TEST-F02-M02

9. Verification and completion evidence

Planned verification has pure query/projection/action rules, real API/PostgreSQL authorization/relationship/pagination tests, selected UI journeys and separately owned cross-feature handoffs. A mocked list or F-01 guard harness does not prove scoped SQL or snapshot behavior. F-02 takes primary ownership of the same-Course discovery checks delegated as TEST-F01-H01 in provisional PR #29; link the actual F-02 cases/result once accepted instead of counting them twice.

Meaningful TDD targets are wrong-owner scoping before pagination, frozen eligibility versus mutable Membership, own Participation EXISTS and Draft exclusion. Retain actual intended-behavior RED/GREEN versions/output during implementation, not now. Do not invent runtime commands, framework test paths, passing counts or review links.

Before #18: obtain real opposite-member review, reconcile shared #5/F-01 conventions, pin compatible runtime/ORM under OPEN-02 and record the applicable #16 schema/seed design. Feature completion then needs implemented AC, real tests/results (including selected UI), safe setup/documentation, substantive review/integration and disclosed handoff status. Provisional Product DoD DOD-01 through DOD-10 apply within F-02's scope; DOD-11/12 remain integrated release/PDF gates. Record the accepted DoD source/version, not a fabricated adoption.

Each actual case result records requirement/feature/AC/STS, test file/name/level, command/date/environment/schema/lockfile, tested SHA, expected/observed outcome, pass/fail/skip counts and evidence reference. Distinguish manual checks and delegated H-cases from local automated execution. #22/#23 verify combined product behavior; #6 plans capture, #25 owns assessed release, #26 assembles actual evidence. This documentation task satisfies none of those application gates.

10. Dependencies, proposed agreements and coordinated follow-up

Shared IDs, safe errors, canonical UUID/query policy and Product DoD

Owner / required agreement before affected code: Both #5 owners plus #10/#11 reviewers; use merged PR #29 or a later accepted version.

Current boundary: Shared documentation is merged; remaining F-02-specific interface/normalization/error choices still need coordinated adoption before affected code.

Trusted auth/role/session/Origin behavior and UI shells

Owner / required agreement before affected code: F-01 #10/#17 and F-02 #11/#18.

Current boundary: Consume F-01; no auth implementation or new session rule.

Academic schema, seed, collation and consistent read transaction

Owner / required agreement before affected code: #16 with #11; #15 verifies pinned Prisma/PostgreSQL support.

Current boundary: One reviewed migration history; F-02 can use empty Survey tables before F-03 runtime exists, but cannot query absent schema.

Survey/ref fields and questionnaire read/management target

Owner / required agreement before affected code: F-03 #12/#19 with #11; agree exact target UI routes and schema before F-02 handoff code.

Current boundary: F-02 returns context/reference only; F-03 owns detail/state/write/eligibility publication.

Participation relation and own-submission target

Owner / required agreement before affected code: F-04 #13/#20 with #11.

Current boundary: Shared own-status meaning is EXISTS Participation; F-04 owns atomic writes/readback; H02 remains pending until real routes exist.

Results navigation

Owner / required agreement before affected code: F-05 #14/#21 with #11.

Current boundary: No results/count/comment payload added to discovery.

Phased database gate

Owner / required agreement before affected code: Both #5 owners / #16 coordinator; use merged Tracker section 3.

Current boundary: Initial User/session subset requires #15, reviewed #10 and shared conventions; later context/domain increments require their applicable reviewed contracts. Full #16 closure still requires the whole S1 scope. PR #29 is merged, so the earlier all-contract-start gate/provisional-reference wording is superseded.

Shared trace/register/index updates

Owner / required agreement before affected code: Coordinated follow-up after acceptance.

Current boundary: Link these two files, AC/STS mappings and TEST-F01-H01 ownership later; shared files intentionally unchanged.

F-02 contracts/test design can be reviewed now without working auth or other feature code. Runtime verification needs real F-01 and the schema/fixtures actually exercised; final end-to-end handoffs need the target features. Unresolved agreements prevent their dependent implementation, not documentation progress. Course/Section/Lecture/member CRUD, history filters, anonymous mode, templates, CSV, notes and analytics remain excluded.

docs/sprints/sprint-1/f-02-context-discovery-sts.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-02 - Software Test Specification

Version 0.1, 2026-11-06. Contract: Owned Context and Eligible Survey Discovery (f-02-context-discovery.md), Issue #11; implementation #18. Lead: R1NNE0; planned reviewer: Maibokdaimhai. **Every case is Planned / Not run.** There are no executable test files, application results, RED/GREEN outputs or human approvals supplied by this STS.

1. Execution model and fixtures

Use provisional PR #29 naming: U = unit, I = HTTP/real-PostgreSQL integration, E = selected UI/E2E, M = supplementary/manual/process and H = dependent cross-feature integration. These are design IDs, not runner pass counts. Parameter matrices under one ID can become multiple executed cases; record actual counts separately. Commands and actual test paths are established by #15/#18, not invented here.

Tests use real F-01 login/session identity, actual F-02 HTTP routes and a separately allowlisted disposable PostgreSQL test database. A test-only injected actor is not authentication proof. Pure units can use controlled inputs; relationship/security claims require real DB assertions. Test composition may inject failures/barriers without adding public debug endpoints. Never reset development/deployed data or publish passwords, hashes, cookies, tokens or raw session JSON in output.

O-A, O-B, O-EMPTY

Required synthetic setup / meaning: Distinct OWNER Users; O-EMPTY owns no Sections. No real student/staff data.

R-A, R-B, R-NEW

Required synthetic setup / meaning: Distinct RESPONDENT Users. R-A and R-B have different eligibility and participation; R-NEW can be added to Membership after publication.

C-SHARED, C-OTHER

Required synthetic setup / meaning: Courses; Sections S-A and S-B in C-SHARED owned by O-A and O-B. O-A owns a Section in C-OTHER and S-EMPTY with no lectures. Multiple owned Sections in C-SHARED test Course deduplication.

L-A1, L-A2, L-B1, L-FREE

Required synthetic setup / meaning: Lectures scoped to their Sections; L-A1/L-A2 share a date but have distinct sequences. L-FREE has no survey. Include Thai/English and markup-like metadata for rendering.

Q-DRAFT, Q-PUB, Q-CLOSED, Q-FOREIGN

Required synthetic setup / meaning: Surveys on distinct lectures; own Draft/Published/Closed and another owner's survey. Published/Closed questions/eligibility match reviewed F-03 schema. R-A is eligible for Q-PUB/Q-CLOSED; Draft eligibility is absent under normal publication rules.

Participation

Required synthetic setup / meaning: R-A has submitted Q-CLOSED but not Q-PUB; R-B can have participation in Q-PUB without making R-A submitted. Only eligibility-backed rows; real submissions tested in H02.

Pagination

Required synthetic setup / meaning: Deterministic generated synthetic dataset exceeding 100 records; two owners' records interleaved in ordering. Use accepted #16 constraints, valid unique IDs/relationships and stable expected authorized IDs.

Snapshot/failure controls

Required synthetic setup / meaning: Real DB connections plus barriers around the count/items read boundary and competing committed writes. Inject known dependency faults at private composition boundaries. No sleeps presented as concurrency proof.

Fixture names are aliases, not production IDs. #16 generates actual canonical UUIDs; examples in documents are not executable seed output. Raw test fixtures may directly prepare valid reviewed database state for F-02 reads; that does not demonstrate implemented publication/submission. H01/H02 supply actual route-based product evidence later.

2. Unit cases

TEST-F02-U01

Linked AC: AC-F02-11

Level: Unit

Preconditions / fixtures: Future production query parser; no DB.

Input: Required UUID absent/malformed/uppercase/padded; duplicate keys; numeric strings 0/1/100/101 and offset 0/10,000/10,001; signs, fractions, exponent, leading zero, empty and unknown keys.

Action: Validate each endpoint's exact allowed parameter set; include respondent lectureId and date/state filters.

Expected result: Only canonical permitted shapes accepted; defaults only when absent, never coercion; safe 422 field paths with no echoed value. UUID syntax grants no permission.

TEST-F02-U02

Linked AC: AC-F02-10

Level: Unit

Preconditions / fixtures: Projection inputs deliberately contain owner/student identity, question/answer/result, session, participation-list and note fields.

Input: Owner and respondent rows with own boolean; markup-like text.

Action: Use actual allowlist projection helper; inspect serialized keys.

Expected result: Exact contract fields only; owner has no participation key; respondent has one own submitted boolean. Text is data, not interpreted markup. Rendering escaping also verified by E02/M01.

TEST-F02-U03

Linked AC: AC-F02-12

Level: Unit

Preconditions / fixtures: Production page/range helper with authorized totals 0, 1, 20, 21, 100+.

Input: Defaults, first/last/beyond-last pages and numeric boundaries.

Action: Compute validated page/range and Previous/Next state.

Expected result: Requested valid bounds retained, no negative/overflow arithmetic, correct boundaries and empty-page navigation. Unit total input alone is not proof of scoped database count.

TEST-F02-U04

Linked AC: AC-F02-19

Level: Unit

Preconditions / fixtures: Production action selection from authorized summaries.

Input: Owner Lecture existingSurvey null/Draft/Published/Closed; student Published/Closed x submitted true/false.

Action: Derive actions from the exact matrix.

Expected result: Create only without existing survey; management/results per owning feature; Answer only Published-unsubmitted; own record for submitted; Closed-unsubmitted explanatory state. Never invent a write grant from a button.

3. HTTP and real PostgreSQL cases

For all cases assert safe response shape/no-store and relevant before/after domain state. Use real F-01 sessions unless testing guest rejection. Never replace SQL scoping with a mocked owned-resource loader and call the result DB authorization coverage.

TEST-F02-I01

Linked AC: AC-F02-01

Level: API/DB setup

Preconditions / fixtures: Fresh allowlisted test DB; accepted #16 migrations and synthetic fixtures.

Input: Seed twice; invalid duplicate membership/Section key/lecture sequence and invalid FK; role-mismatched seed candidates.

Action: Apply actual migrations/seed; inspect relationships and rejection boundaries using safe assertions.

Expected result: Reproducible valid context, unique/FK constraints enforced, wrong-role owner/member rejected by seed/service validation, no second User/schema. No login UI or startup reset required.

TEST-F02-I02

Linked AC: AC-F02-02

Level: API/DB

Preconditions / fixtures: No cookie, guest, expired/revoked/forged cookie, separate requests; real F-01 policy.

Input: All four GET paths, including malformed query/hidden parent, correctly originated.

Action: Call directly without usable authentication; inspect response and domain rows.

Expected result: 401 according to F-01, no resource/query detail or private data and no domain write. Session invalidation by F-01 is not misreported as a domain mutation.

TEST-F02-I03

Linked AC: AC-F02-02

Level: API/DB

Preconditions / fixtures: Real RESPONDENT session.

Input: Each owner-only context endpoint with valid/invalid/foreign parent IDs.

Action: Request directly; repeat with spoofed role/owner headers.

Expected result: 403 FORBIDDEN_ROLE before parent/UUID validation, no context/existence leak; headers do not promote role. Survey discovery remains allowed for respondent.

TEST-F02-I04

Linked AC: AC-F02-03

Level: API/DB

Preconditions / fixtures: O-A/O-B/O-EMPTY; shared Course with multiple S-A owned Sections.

Input: GET courses with default and small pages.

Action: Compare IDs/total to expected owned Course set for each actor.

Expected result: Each owned Course appears once; no other-owner-only Course/count; O-EMPTY gets empty 200. Shared Course does not project another owner's Section/account.

TEST-F02-I05

Linked AC: AC-F02-04

Level: API/DB

Preconditions / fixtures: O-A/O-B Sections in C-SHARED; Course owned only by O-B; missing UUID.

Input: GET sections with each courseId and valid page.

Action: Read as O-A; compare foreign-only/missing parent bodies, including offset beyond total.

Expected result: Own Sections only; shared Course does not admit S-B; foreign-only/missing Course identical 404 even on empty page. An authorized out-of-range page remains 200.

TEST-F02-I06

Linked AC: AC-F02-05

Level: API/DB

Preconditions / fixtures: O-A's lectures, S-EMPTY, S-B and missing Section; L-FREE.

Input: GET Section lectures.

Action: Compare returned rows/existingSurvey references; request foreign/missing Section.

Expected result: Only own lecture rows; L-FREE has null, existing refs have safe fields; S-EMPTY empty 200; foreign/missing identical 404, no hidden lecture/survey.

TEST-F02-I07

Linked AC: AC-F02-06

Level: API/DB

Preconditions / fixtures: Own surveys in three states and Q-FOREIGN in same Course's S-B.

Input: GET surveys without selector and with own/foreign/missing lectureId.

Action: Read as O-A; check canonical Section ownership and selected totals.

Expected result: Own Draft/Published/Closed only; own lecture scopes or returns authorized empty set; hidden/missing lecture same 404. Owner projection omits participation. A deliberately inconsistent redundant Survey.ownerId fixture is excluded.

TEST-F02-I08

Linked AC: AC-F02-07

Level: API/DB

Preconditions / fixtures: R-A eligible Published/Closed; R-B has a different eligible set.

Input: GET surveys as each respondent.

Action: Compare complete IDs/state/context/total against own eligibility.

Expected result: Only own eligible Published/Closed; each row carries safe context and IDENTIFIED mode; no independent Course catalog or other student's opportunities.

TEST-F02-I09

Linked AC: AC-F02-07

Level: API/DB

Preconditions / fixtures: Draft plus ineligible Published/Closed, interleaved with visible surveys; valid R-A session.

Input: Unfiltered survey list and pages.

Action: Inspect body, total, ordering and every nested field.

Expected result: Draft/ineligible surveys and their context absent; total counts only visible set. No generic 403 for an otherwise valid empty collection; direct detail denial remains H01.

TEST-F02-I10

Linked AC: AC-F02-08

Level: API/DB

Preconditions / fixtures: Published eligibility snapshot includes R-A, excludes R-NEW; isolated test membership changes.

Input: Remove R-A's Membership; add R-NEW to Membership; do not edit eligibility.

Action: Read discovery as both after commits.

Expected result: R-A retains the eligible survey; R-NEW does not gain it. Query must not silently derive eligibility from current enrollment. Unrelated Section data remains inaccessible.

TEST-F02-I11

Linked AC: AC-F02-09

Level: API/DB

Preconditions / fixtures: R-A eligible Q-PUB unsubmitted; R-B eligible and submitted; R-A submitted Q-CLOSED.

Input: GET surveys before/after a valid fixture Participation commit for R-A.

Action: Read as R-A and R-B; compare own booleans across logout/login.

Expected result: R-B never makes R-A submitted; only R-A's persisted pair changes R-A's value. No names/IDs/times/list of participants or answer-bundle lookup. Route-based atomic submission remains H02.

TEST-F02-I12

Linked AC: AC-F02-10

Level: API/DB

Preconditions / fixtures: Real populated domain rows with private account/result/answer data and markup-like titles.

Input: All allowed list responses; fake identity headers and query actor keys.

Action: Inspect exact recursive key allowlists and safe values; verify malicious keys are rejected, not authority.

Expected result: No forbidden fields in successful/error payloads; owner participation absent; response content is not another person's identity/answers. no-store and no sensitive row/body/session logging.

TEST-F02-I13

Linked AC: AC-F02-11

Level: API/DB

Preconditions / fixtures: Real owner/respondent sessions and safe DB snapshots.

Input: Query matrix from U01; duplicate courseId/limit, malformed path UUID, fromDate/toDate/status/sort; nonempty GET body; POST context routes.

Action: Send actual HTTP requests; inspect errors and domain state.

Expected result: Exact 422/400/405 as specified, safe reasons/no SQL casts, no domain changes. F-02 does not consume or block F-03's POST /api/surveys. Explicit foreign-Origin read follows F-01's 403; normal same-origin GET needs no CSRF token.

TEST-F02-I14

Linked AC: AC-F02-12

Level: API/DB

Preconditions / fixtures: More than 100 authorized rows plus other-owner/ineligible rows interleaved.

Input: Missing pagination; limit 1/100; offset 0/last/10,000; 101/10,001 and malformed values.

Action: Page through each list family and compare exact IDs/totals.

Expected result: Default 20/0, correct authorized totals before limit; no duplicate Courses or fan-out survey cards; valid beyond-end empty 200; invalid bounds 422. Cannot infer other actors' counts.

TEST-F02-I15

Linked AC: AC-F02-13

Level: API/DB

Preconditions / fixtures: Same dates/different sequences, equal sort keys across Sections, stable IDs, Thai/English metadata.

Input: Repeat identical pages and perform adjacent-page traversal with unchanged DB.

Action: Compare IDs against the contract's C-collation/text and date/sequence/id order; vary browser timezone for displayed date in UI coverage.

Expected result: Repeatable stable ordering with UUID tiebreaker, no missing/duplicate rows in unchanged dataset; DATE remains the same calendar date. No claim that pages freeze across later commits.

TEST-F02-I16

Linked AC: AC-F02-12, AC-F02-14

Level: API/DB

Preconditions / fixtures: O-EMPTY, S-EMPTY, L-FREE, respondent with zero visible surveys; authorized beyond-last offset.

Input: Each collection/parent case.

Action: Read and distinguish collection existence/access from page emptiness.

Expected result: Empty 200 with true authorized total where parent is accessible; foreign named parent still 404. No invented create/admin/result action or fake sample rows.

TEST-F02-I17

Linked AC: AC-F02-17

Level: API/DB

Preconditions / fixtures: Safe before snapshots of academic, survey, eligibility, participation and answer tables.

Input: Repeated authorized/denied/paginated reads.

Action: Call F-02 and compare persisted domain rows/values.

Expected result: No domain writes, seed execution, eligibility refresh or definition/state/answer change. F-01 security-state handling is tracked separately.

TEST-F02-I18

Linked AC: AC-F02-17

Level: API/DB

Preconditions / fixtures: Real read transaction; second connection and barriers; count/items boundary; valid F-03/F-04-compatible fixture commits.

Input: Concurrent atomic publication/eligibility or Participation commit while one response is being built.

Action: Pause/commit/resume; inspect both the initial response and a fresh subsequent request.

Expected result: Each response has internally consistent committed count/items/own status; no Published-without-eligibility or mixed read. New request can observe the later commit. No sleeps or mock-only concurrency proof; actual publish/submit routes are H01/H02.

TEST-F02-I19

Linked AC: AC-F02-18

Level: API/DB

Preconditions / fixtures: Real session; separately injected unavailable auth store/User lookup and F-02 DB dependency; unexpected controlled error with secret markers.

Input: Valid context/discovery requests.

Action: Trigger each failure and inspect response/cache/log fields; restore dependency.

Expected result: Defined safe 503 auth/domain or 500 unexpected error; never 200 empty fallback, private diagnostics or memory identity. Subsequent valid read can recover without replaying a write.

TEST-F02-I20

Linked AC: AC-F02-19

Level: API/DB

Preconditions / fixtures: Read a Published-unsubmitted card or owner existing Draft reference; then commit valid close/participation or Draft deletion through isolated fixture setup.

Input: Fresh F-02 read after state change.

Action: Compare new summaries and derived navigation inputs with earlier response.

Expected result: Closed/unsubmitted has no Answer; own submitted offers own record; deleted Draft becomes absent on owned lecture. Old response is not a write authorization. No claim that direct fixture updates implement lifecycle/submission.

4. Selected UI and supplementary cases

Use actual F-02 UI/API/PostgreSQL with real F-01 authentication. Do not inject a frontend actor or hardcode success cards. Cross-feature targets remain H01/H02; inspect F-02 link identity/action without pretending an unimplemented target completed. Record Not run/blocked dependencies honestly.

TEST-F02-E01

Linked AC: AC-F02-14, AC-F02-16

Level: UI/E2E

Preconditions / fixtures: Real O-A; populated/empty contexts; more than one selector page; 360px and 1280px.

Input: Keyboard-only Course/Section/Lecture selections and list pagination.

Action: Navigate, change parent, select free/existing-survey lecture, return/refresh pages.

Expected result: Labelled usable selectors, child/page resets, correct safe context/actions, distinct empty states, visible focus and no horizontal overflow. No cross-owner cards. Target completion is not claimed without H01.

TEST-F02-E02

Linked AC: AC-F02-14, AC-F02-16

Level: UI/E2E

Preconditions / fixtures: Real R-A; Published/Closed and submitted/unsubmitted fixtures; markup-like/Thai metadata.

Input: Keyboard list navigation at both widths; next/previous and empty page reset.

Action: Inspect card states, labels, context dates and action identities.

Expected result: Correct Answer/View submission/Collection ended states; no Draft/ineligible or other participation; text escaped, dates stable and layout operable. No private owner data or fake submission confirmation.

TEST-F02-E03

Linked AC: AC-F02-15

Level: UI/E2E

Preconditions / fixtures: Real UI; delayed old-parent list response and later new-parent response; subsequent auth loss/user switch.

Input: Rapid parent changes, then logout/401 before an in-flight success returns.

Action: Release requests out of order and revisit the screen.

Expected result: Old responses cannot repopulate another parent/user's view; dependent state resets and 401 clears all private data/request generation. 403/404 show safe unavailable state without claiming session expiry.

TEST-F02-E04

Linked AC: AC-F02-15, AC-F02-18

Level: UI/E2E

Preconditions / fixtures: Real read UI; controlled network/503 failure then recovery, plus empty successful collection.

Input: Retry and permission/error navigation.

Action: Trigger failure, inspect messages/busy states, restore and explicitly retry.

Expected result: Failure distinguished from no-data; no fake zero/success or automatic write. Retry gets real data; loading/error announced, no stale private rows after an access loss.

TEST-F02-M01

Linked AC: AC-F02-16

Level: Manual UI

Preconditions / fixtures: Actual built views and tested SHA; Thai/English, long metadata, 360px/1280px; SDS supplementary 320px/200% zoom.

Input: Keyboard, labels, focus, screen-reader/accessibility inspection and viewport changes.

Action: Inspect normal/loading/empty/error/pagination/disabled states.

Expected result: Record real observations/defects; readable wrapping, labelled controls, announcements and focus, no color-only status. Supplement E-cases rather than substitute for backend tests.

TEST-F02-M02

Linked AC: AC-F02-01, AC-F02-20

Level: Setup/process

Preconditions / fixtures: Before code: real source/review records; after implementation: actual safe setup commands, migrations/seed, test files/results and integration.

Input: Accepted #5/#11/#16 versions and actual execution evidence when available.

Action: Audit requirement-to-AC/STS coverage; teammate reproduces safe context setup and checks actual output/history.

Expected result: Contract precedes code; one schema history, actual review/RED-GREEN and mapped command/SHA/counts are retained. No fabricated accepted DoD, seed run, contribution or test result. This document check alone cannot mark the future execution/process case passed.

5. Cross-feature handoff cases

TEST-F02-H01

Linked AC: AC-F02-19

Level: Real API/DB + selected UI integration

Preconditions / fixtures: Accepted F-03 implementation and real F-01/F-02; owned lecture, another owner's same-Course Section, eligible/ineligible respondents.

Input: Owner selection/create target; respondent visible/ineligible/Draft survey IDs.

Action / primary responsibility: F-03 #12/#19 with F-02 #18: follow owned lecture into real authoring; publish via actual route; refresh discovery; directly request Draft/ineligible questionnaire as respondents.

Expected result: Owned published survey becomes visible only after atomic eligibility commit; foreign-owner create/manage rejected with no mutation; Draft/ineligible detail is indistinguishable 404. Existing survey uniqueness remains F-03/#16. Map actual F-03 AC before running; no invented IDs.

TEST-F02-H02

Linked AC: AC-F02-09, AC-F02-19

Level: Real API/DB + selected UI integration

Preconditions / fixtures: Accepted F-04 implementation; real two respondents, eligible Published survey and actual own-submission workflow.

Input: Authorized card ID, valid/invalid direct target; submission and close-after-list scenario.

Action / primary responsibility: F-04 #13/#20 with F-02 #18: submit through actual route, refresh list after logout/login; follow own record; attempt cross-response access/stale Closed submit.

Expected result: Participation changes only after committed successful submission; own boolean/record persists; another user never gains access. Target state/eligibility/duplicate failures follow accepted F-03/F-04 contracts with unchanged data. No list action bypasses revalidation.

TEST-F02-I04 through I07 provide the actual discovery scope coverage delegated as TEST-F01-H01 in the provisional F-01 STS. Reconcile the accepted cross-reference under #5/#22; it is one observed result referenced by both contracts, not two independent passes. H01/H02 remain planned dependent checks until target contracts/implementations and real results exist.

6. Coverage and evidence status

There are **20 stable AC** in the contract and **32 planned STS cases** here: 4 unit, 20 API/DB, 4 UI/E2E, 2 supplementary/manual/process and 2 cross-feature handoff cases. Every AC has planned coverage. Counts describe design rows, not assertions executed, runner totals or passing tests. All actual result fields are **Not run / not available**.

Primary TDD assertions: reject O-A access to S-B within the same Course; exclude Draft/ineligible records before pagination/count; preserve snapshotted eligibility after Membership changes; derive own status only from the caller's Participation. Save actual failing intended-behavior assertions and later passing versions/output during authorized implementation. Do not generate historic failures after writing the final implementation.

For each actual run retain full test/AC IDs, requirement/feature, real file/case, level, preconditions/data/schema/lockfile, command/date/environment, tested SHA, expected/observed result, pass/fail/skip counts and safe evidence location. Keep failures/skips and later re-tests with their own versions; manual/process observations remain separate. Teammate review, Product DoD adoption, integration and release references are pending. No application or test execution was performed to author this specification.

docs/sprints/sprint-1/f-03-survey-authoring.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-03 - Survey Authoring, Publication and Closing

Version 0.2 · 2026-11-07 · Issue #12 · Sprint 1 · **Proposed engineering contract; not implemented or accepted.**

1. Purpose, authority and scope

Specify F-03 before application implementation: an Owner selects an owned Lecture, creates/edits/deletes its Draft, publishes a complete identified survey, and closes it. Respondents can read only eligible Published/Closed definitions. This document specifies intended behavior, not evidence that it exists. All cases in the STS (f-03-survey-authoring-sts.md) are Planned / Not run.

Authority: SRS (../../srs.md) §§2-7, Feature Inventory (../../features.md), Traceability (../../traceability.md), System SDS (../../system-sds.md) §§2-6,11,13-15, decisions (../../decisions.md), Sprint Plan (../plan.md), tracker (tracker.md) §§2-4 and workflow (workflow.md) §§3-8. The supplied Issue #12 task is the issue-scope source; the remote Issue page could not be retrieved. Instructor deliverable expectations require preimplementation feature UI/API/data design, observable AC and planned unit/integration/E2E specifications; implementation, executed evidence and teammate acceptance remain later gates.

The updated staging baseline supplies local shared conventions (shared-contract.md), F-01 (f-01-authentication.md), Product DoD (product-dod.md), contract register (README.md) and F-02 (f-02-context-discovery.md). F-03 follows their authentication/transport definitions and the Tracker's phased Issue #16 policy; it no longer depends on the earlier PR #29 proposal snapshot. F-04/F-05 feature contracts remain separate dependencies. Resolve F-03-specific schema/interface agreements in §11 before dependent implementation; the presence of these documents is not implementation, executed verification or acceptance of this F-03 contract.

FR-03

F-03 obligation / boundary: Owned Lecture Draft creation, ordered RATING/TEXT authoring, partial Drafts, deletion

Acceptance criteria: AC-F03-01-10,22-25

FR-04

F-03 obligation / boundary: Valid publication and closing; UI reflects committed state

Acceptance criteria: AC-F03-08,11-20,22-23

BR-02

F-03 obligation / boundary: Backend role, canonical ownership and safe projections

Acceptance criteria: AC-F03-02,04,21

BR-03

F-03 obligation / boundary: Frozen eligibility from one publication snapshot; later membership changes do not alter it

Acceptance criteria: AC-F03-12-16

BR-04

F-03 obligation / boundary: DRAFT → PUBLISHED → CLOSED; Respondents cannot discover Drafts

Acceptance criteria: AC-F03-04,11,17-18

BR-05

F-03 obligation / boundary: Nonblank title, 1-10 valid questions, at least one RATING in S1, nonempty eligibility

Acceptance criteria: AC-F03-06-08,12-13

BR-07

F-03 obligation / boundary: Freeze required/type/rating meaning and stable question IDs for F-04 validation; F-04 owns answer validation

Acceptance criteria: AC-F03-05,07,14,26

BR-09

F-03 obligation / boundary: No post-publication edits of definition, order, required flags, mode or eligibility

Acceptance criteria: AC-F03-11,14-15

BR-10

F-03 obligation / boundary: Only Draft deletion; no response editing/deletion or hard deletion of Published/Closed surveys

Acceptance criteria: AC-F03-10-11,17

BR-11

F-03 obligation / boundary: Close uses the same Survey transaction lock as F-04 submit

Acceptance criteria: AC-F03-19-20,26

BR-14

F-03 obligation / boundary: IDENTIFIED only and truthful account-link disclosure before answering

Acceptance criteria: AC-F03-04,14,26

BR-23

F-03 obligation / boundary: Canonical Section ownership; database-enforced one survey per Lecture, including races

Acceptance criteria: AC-F03-02-03

NFR-01

F-03 obligation / boundary: Authenticated, scoped operations; safe errors, sessions and projections

Acceptance criteria: AC-F03-02,04,21

NFR-02

F-03 obligation / boundary: Real database transactions, rollback, restart persistence; F-04 handoff

Acceptance criteria: AC-F03-15-20,25-26

NFR-05

F-03 obligation / boundary: Bidirectional AC/STS, meaningful unit/real PostgreSQL/selected E2E and genuine later results

Acceptance criteria: AC-F03-26 and all mapped cases

NFR-07

F-03 obligation / boundary: Keyboard, labels, visible feedback at 360px and 1280px

Acceptance criteria: AC-F03-22-24

BR-05 also permits SINGLE_CHOICE in the whole product; it is Sprint 2 and is rejected here. Excluded: starter questionnaires, copies/reuse, provenance/metric management, anonymous mode, enrollment/academic-context administration, response submission, results calculations, history filters, improvement notes, export, CI and deployment. F-03 must not make any of them prerequisites for S1 publication.

2. Actors, ownership and visibility

The authenticated F-01 session supplies the trusted User ID and single role; request headers/body cannot select an actor. OWNER and RESPONDENT are separate roles, not a combined privilege. Canonical ownership is `Survey → Lecture → Section.ownerId = session.userId`; on create it is `Lecture → Section.ownerId`. A shared Course never grants another Section's permissions. Redundant `Survey.ownerId` is server-derived and must match the Section owner. Ownership transfer is outside scope.

Create for Lecture

OWNER: Owned Lecture only

RESPONDENT: 403

Unauthenticated: 401

Read definition

OWNER: Own Draft/Published/Closed only

RESPONDENT: Published/Closed AND frozen SurveyEligibility only

Unauthenticated: 401

Save/delete Draft

OWNER: Own Draft only, matching revision

RESPONDENT: 403

Unauthenticated: 401

Publish

OWNER: Own Draft, matching revision and complete validation

RESPONDENT: 403

Unauthenticated: 401

Close

OWNER: Own Published only

RESPONDENT: 403

Unauthenticated: 401

Missing/inaccessible Lecture or Survey returns the same 404 envelope; do not distinguish another owner's resource. Respondent Draft/ineligible reads are 404, even with guessed IDs, current Section membership, or participation elsewhere. Eligible Respondents retain Published/Closed read access after membership removal; later enrollment alone does not grant it. F-02 owns discovery and own-participation status. F-03 returns definitions, never answers, participant lists, participation flags, aggregate results or counts.

3. Functional workflows and lifecycle

1. F-02 supplies an owned Lecture ID and existing-survey navigation. POST creates an empty Draft (title `""`, questions `[]`, revision 1, mode IDENTIFIED); no valid questionnaire is required yet. The unique Lecture association is checked by PostgreSQL, not a discovery flag.

2. Owner loads the definition and edits title/questions locally. Save replaces the complete Draft definition atomically, retaining IDs for existing questions. Array order becomes positions 1…n. Save confirmation uses the server response only.

3. Owner saves before requesting publication. Publish confirms that the saved definition will be frozen and the selected Section's members at the publication snapshot will become eligible. Server rechecks ownership, revision, full definition and eligibility inside the publication transaction.

4. Published owner view is read-only except Close. Eligible Respondents obtain the frozen questionnaire/disclosure for F-04. Close confirmation changes state only after server commit. Closed owner view remains read-only; F-05 owns results

navigation and presentation.

5. Draft deletion requires confirmation and the loaded revision. A successful 204 releases the Lecture association; a later new Draft has new Survey/question IDs. Published/Closed records cannot be deleted.

DRAFT

Save definition / delete: Allowed with expectedRevision

Publish: Allowed only if complete and eligible

Close: 409 INVALID_STATE

Respondent definition: 404

PUBLISHED

Save definition / delete: 409 INVALID_STATE

Publish: 409 INVALID_STATE

Close: Allowed

Respondent definition: 200 if frozen-eligible

CLOSED

Save definition / delete: 409 INVALID_STATE

Publish: 409 INVALID_STATE

Close: 409 INVALID_STATE

Respondent definition: 200 if frozen-eligible

There is no reopening or reverse transition. Repeated publish/close is a 409, not a second successful transition. Neither transition changes `definitionRevision`; it identifies the last saved definition. `publishedAt` is set once on publication and retained; `closedAt` is set once on closing. Both are server UTC timestamps, null before the corresponding transition. Ordering is defined by locks/commits, not browser or timestamp comparison.

4. Validation and definition representation

These are proposed exact F-03 interface choices, consistent with the baseline limits. Validate server-side; UI feedback is supplementary. JSON property names are case-sensitive; reject unknown keys and implicit coercions. IDs use canonical lowercase UUID strings, enums use uppercase values. No ownerId, status, mode, positions, timestamps or eligibility fields are client-writable.

Trim leading/trailing Unicode whitespace from title, prompt, labels and interpretation using the JavaScript `String.trim()` semantics before validation/storage. Count Unicode code points of the resulting string, not UTF-16 code units or bytes; do not normalize case or Unicode composition. Reject unpaired UTF-16 surrogates and U+0000 with 422 INVALID_DEFINITION (PostgreSQL text cannot store NUL). Internal whitespace is retained. The limits below apply to stored normalized strings; transport byte limits apply to raw requests independently.

title

Draft save: String, 0-120 code points

Publication: 1-120, nonblank

questions

Draft save: Array, 0-10 entries

Publication: 1-10 entries, at least one RATING

prompt

Draft save: String, 0-500 code points

Publication: 1-500, nonblank

type

Draft save: Exactly RATING or TEXT

Publication: Same

required

Draft save: Strict boolean, per question

Publication: Same, frozen; all may be optional

RATING ratingScale

Draft save: Exact object: min 1, max 5 (integers), minLabel/maxLabel strings 0-120 each, interpretation string 0-500

Publication: Same numeric range; both labels and interpretation nonblank

TEXT ratingScale

Draft save: Exactly null; rating metadata not accepted

Publication: Same

Question identity

Draft save: id is existing owned-Draft UUID or null for a new question; no duplicate IDs

Publication: Server-assigned IDs persist unchanged

Label/interpretation length limits and normalization are F-03/shared-agreement proposals, not newly attributed instructor requirements. A Draft can be empty, text-only, or contain blank content, but cannot contain malformed types/scales or over-limit fields. F-04 must use the published required flags, stable IDs and frozen scale: integer rating 1-5; text ≤2,000 code points; required text non-whitespace; reject unknown/duplicate/wrong-survey IDs, wrong types and an entirely empty response even if every question is optional (BR-07). F-03 does not implement those submission rules.

PATCH is whole-definition replacement, not JSON Patch: every item supplies all fields below. Retained IDs stay stable through text/type edits and reordering. Omitted existing IDs are removed; null IDs receive server UUIDs. Unknown, foreign-survey and repeated IDs return generic field validation without revealing existence. Positions are server-derived, unique and contiguous. No revision history table or separate question-write API is needed.

```
{
  "expectedRevision": 1,
  "title": "Lecture feedback",
  "questions": [
    {
      "id": null,
      "prompt": "How fast was the lecture?",
      "type": "RATING",
      "required": true,
      "ratingScale": {
        "min": 1,
        "max": 5,
        "minLabel": "Very slow",
        "maxLabel": "Very fast",
        "interpretation": "Higher means faster, not necessarily better."
      }
    },
    {"id": null, "prompt": "Suggestions", "type": "TEXT", "required": false, "ratingScale": null}
  ]
}
```

`expectedRevision` is a positive safe integer. Every real saved definition change increments revision exactly once; normalized no-op saves return the same revision. A stale no-op still conflicts. Two saves with new null-ID questions are changes, not no-ops. Publish/delete require the current revision too; Close does not because the definition is already frozen. Revision conflicts never silently overwrite data.

5. API contract

5.1 Six endpoints

All paths include `/api`; UUID path parameters only, no query parameters on these endpoints. Shared F-02 `GET /api/surveys` remains a separate discovery handler. No duplicate listing or response APIs are introduced. Success with a representation uses `{ "data": <definition> }`; DELETE has no body.

POST /api/surveys

Actor and scope: OWNER; Lecture belongs to own Section

Exact request JSON / raw byte ceiling: `{ "lectureId": "<uuid>" }`; 8 KiB

Success: 201 owner definition; Location `/api/surveys/<id>`

State / revision / transaction: New Draft revision 1; creation transaction and unique lectureId

GET /api/surveys/:id

Actor and scope: OWNER own Survey; RESPONDENT frozen-eligible Published/Closed

Exact request JSON / raw byte ceiling: No body or query

Success: 200 role projection

State / revision / transaction: Consistent read snapshot; no mutation

PATCH /api/surveys/:id

Actor and scope: OWNER own Survey

Exact request JSON / raw byte ceiling: Whole-definition object in §4; 256 KiB

Success: 200 owner definition

State / revision / transaction: Draft, matching expectedRevision; row-locked atomic replacement

DELETE /api/surveys/:id

Actor and scope: OWNER own Survey

Exact request JSON / raw byte ceiling: `{ "expectedRevision": 1 }`; 8 KiB

Success: 204, empty

State / revision / transaction: Draft, matching revision; row-locked deletion

POST /api/surveys/:id/publish

Actor and scope: OWNER own Survey

Exact request JSON / raw byte ceiling: `{ "expectedRevision": 1 }`; 8 KiB

Success: 200 owner definition

State / revision / transaction: Draft, matching revision, full validation and nonempty eligibility; row-locked transaction

POST /api/surveys/:id/close

Actor and scope: OWNER own Survey

Exact request JSON / raw byte ceiling: {}; 8 KiB

Success: 200 owner definition

State / revision / transaction: Published; same Survey lock as submission; no revision input

All mutation bodies are required JSON objects, including Close. DELETE JSON support must be verified in client/parser integration. Protected GET rejects a body or query with 422 INVALID_REQUEST. Unsupported methods on a recognized route return 405 with the route family's Allow header, after Origin, transport, session and applicable unsafe-method CSRF checks; an unsupported method must not bypass authentication or become a write. Route-family method handling must retain F-02's collection GET. Allow is GET/POST for the collection, GET/PATCH/DELETE for a definition, and POST for each

transition (serialize as comma-separated method names).

5.2 Role projections

Owner definition contains only `id, lectureId, title, status, mode, definitionRevision, publishedAt, closedAt, context, questions, privacyDisclosure`. Respondent definition contains only `id, lectureId, title, status, mode, context, questions, privacyDisclosure`. Definition revision/timestamps are management metadata and not required for submission. Every question is `{id, position, prompt, type, required, ratingScale}`; TEXT scale is null, RATING scale is the §4 object. Return questions in ascending position, never database natural order. There is no pagination on a bounded single definition (maximum ten questions).

Proposed safe context matches the prior F-02 draft shape: `course:{id,code,title}`, `section:{id,courseId,term,sectionCode}`, `lecture:{id,title,lectureDate,sequence}`. IDs are UUID strings, code/title/term/sectionCode are strings, sequence and question positions are positive integers. Per SDS §2, lectureDate is a local calendar date, serialized here as `YYYY-MM-DD` without timezone conversion; confirm that exact representation with #11/#16. publishedAt/closedAt serialize as ISO 8601 UTC strings with a Z suffix or null. IDs and display metadata describe the survey, not membership. Explicit serializer allowlists omit ownerId, studentId, Membership/Eligibility lists, auth/session fields, provenance, participation and response data. Do not return raw ORM rows.

`mode` is always IDENTIFIED. Proposed disclosure text: “This survey is identified. Your answers remain linked to your account in storage. The survey owner sees summaries and unlabelled written feedback after closing, without your account identifier. Your written content may still identify you. Small groups can also make summaries identifiable.” F-04 must display this before answering; it must not describe the mode as anonymous or promise that text or aggregates cannot identify someone. F-05 separately provides the baseline's Published response count and Closed results. F-03 does not expose either.

Example 201 creation body (synthetic IDs/context, no stored participants). GET/PATCH/publish/close use the same owner envelope with the committed state/definition; the Respondent GET removes definitionRevision/publishedAt/closedAt and otherwise follows its allowlist above:


```
{
  "data": {
    "id": "00000000-0000-4000-8000-000000000101",
    "lectureId": "00000000-0000-4000-8000-000000000102",
    "title": "",
    "status": "DRAFT",
    "mode": "IDENTIFIED",
    "definitionRevision": 1,
    "publishedAt": null,
    "closedAt": null,
    "context": {
      "course": {"id": "00000000-0000-4000-8000-000000000103", "code": "CPE334", "title": "Software Engineering"},
      "section": {"id": "00000000-0000-4000-8000-000000000104", "courseId": "00000000-0000-4000-8000-000000000103", "
term": "Demo term", "sectionCode": "A"},
      "lecture": {"id": "00000000-0000-4000-8000-000000000102", "title": "Demo lecture", "lectureDate": "
2026-11-07", "sequence": 1}
    },
    "questions": [],
    "privacyDisclosure": "This survey is identified. Your answers remain linked to your account in storage. The
survey owner sees summaries and unlabelled written feedback after closing, without your account identifier. Your
written content may still identify you. Small groups can also make summaries identifiable."
  }
}
```


Every protected success/error response uses `Cache-Control: no-store`. Safe validation fields name allowed paths (for example `questions[0].prompt`), never submitted text, account identifiers or database diagnostics.

5.3 Security perimeter, errors and precedence

Consume F-01's trusted session and shared middleware, including absolute session expiry, regenerated login session and logout invalidation; F-03 neither creates sessions nor extends expiry. Follow the staging shared/F-01 convention: same-origin cookies; reject explicit foreign or `null` Origin on every protected route, require exact configured Origin plus session synchronizer CSRF token on unsafe methods, and allow omitted Origin on a safe same-origin GET. Missing/invalid CSRF is 403 CSRF_INVALID. No permissive CORS override or reliance on disabled UI controls.

Order: (1) shared Origin/transport perimeter, (2) session authentication, (3) unsafe-method CSRF, (4) route method then role, (5) syntactic path/body validation, (6) ownership/eligibility-scoped resource lookup, then (7) locked state, expectedRevision, semantic definition, eligibility in that order. Transport errors can precede authentication; malformed JSON cannot be interpreted as a business operation. Known field types/lengths are checked in step 5; nonblank publishability and related-row question identity are step 7. Thus a valid-shaped edit of a Published survey is 409, while malformed JSON is 400, and a wrong-role well-formed request is 403 before record lookup. An inaccessible record with valid syntax is always 404. Tests use otherwise valid requests to isolate each boundary.

400 MALFORMED_JSON

Trigger / applicable endpoints: JSON parse failure on a JSON body

Persistent effect: None

401 AUTH_REQUIRED

Trigger / applicable endpoints: Missing, forged, revoked or invalid-state session, missing/invalid User, or expired session whose row is missing/pruned; all six routes

Persistent effect: None; follow F-01 private-state cleanup

401 SESSION_EXPIRED

Trigger / applicable endpoints: Server identifies a loaded authenticated session at/past its absolute deadline; missing/pruned expiry instead uses AUTH_REQUIRED

Persistent effect: None; same F-01 private-state cleanup

403 ORIGIN_FORBIDDEN / CSRF_INVALID / FORBIDDEN_ROLE

Trigger / applicable endpoints: Shared Origin/CSRF checks; authenticated Respondent management

Persistent effect: None

404 NOT_FOUND

Trigger / applicable endpoints: Missing or inaccessible scoped Lecture/Survey; Respondent Draft/ineligible read

Persistent effect: None; identical safe message

405 METHOD_NOT_ALLOWED

Trigger / applicable endpoints: Unsupported method for a recognized route

Persistent effect: None; Allow header

409 SURVEY_ALREADY_EXISTS

Trigger / applicable endpoints: Create collides on Survey.lectureId, including race

Persistent effect: No second Survey

409 INVALID_STATE

Trigger / applicable endpoints: Valid-shaped save/delete/publish/close in a forbidden state

Persistent effect: None

409 REVISION_CONFLICT

Trigger / applicable endpoints: Draft save/delete/publish expectedRevision is stale

Persistent effect: None; GET to reconcile

422 INVALID_REQUEST / INVALID_DEFINITION

Trigger / applicable endpoints: Bad UUID/schema, extra keys, question IDs, field limits, scale/type or publishability

Persistent effect: None; safe fields where applicable

422 ELIGIBILITY_EMPTY / ELIGIBILITY_INVALID

Trigger / applicable endpoints: Publication snapshot empty or contains invalid non-Respondent membership

Persistent effect: No partial snapshot/transition; no identities in error

413 BODY_TOO_LARGE

Trigger / applicable endpoints: More than endpoint's raw byte ceiling

Persistent effect: None

415 UNSUPPORTED_CONTENT

Trigger / applicable endpoints: Mutation not application/json (optional UTF-8 charset), or non-identity Content-Encoding

Persistent effect: None

503 AUTH_SERVICE_UNAVAILABLE

Trigger / applicable endpoints: F-01 session-store or trusted User lookup unavailable before domain handling

Persistent effect: No domain mutation; no authentication fallback

503 SERVICE_UNAVAILABLE / 500 INTERNAL_ERROR

Trigger / applicable endpoints: Known database unavailability / unexpected failure

Persistent effect: Known failed transaction rolls back; uncertain commit outcome reconciled by GET/discovery (§7), never blindly retried

Error shape: `{ "error": { "code": "REVISION_CONFLICT", "message": "The survey changed. Reload before trying again." } }`; optional `fields` maps allowed field paths to safe fixed messages. Do not include revision/current record details on 404, SQL, stack traces, tokens or answer content. Logs use operation/correlation ID and safe error class, not request bodies or session secrets. Map only the expected uniqueness constraint to SURVEY_ALREADY_EXISTS; other database faults are not validation errors.

A byte is not a code point. Set per-route parser ceilings, rejecting >8,192 or >262,144 bytes; exact ceilings are permitted if the JSON is otherwise valid. Measure actual streamed bytes even without Content-Length; reject compressed bodies rather than decompressing unbounded input. A smaller global parser must not reject an otherwise permitted authoring request. Worst-case escaped content for ten RATING questions is `(120 + 10 × (500 + 120 + 120 + 500)) × 12 = 150,240` bytes plus bounded keys/IDs/envelope (under 16 KiB), below 256 KiB. Test real boundary fixtures and high-code-point content; a published-valid survey must fit. The app proxy must not silently impose a smaller limit. These exact limits/error names remain shared-convention agreements (§11).

6. Data responsibilities - handoff to Issue #16

Issue #16 (SYS-01) owns Prisma schema, migrations, indexes, seed roles and DB constraints. Issue #12 specifies invariants; implementation Issue #19 owns F-03 service/UI behavior. No migration is part of this issue. Use the accepted stack (React/Vite, Express/Zod, Prisma/PostgreSQL); exact versions remain the baseline's OPEN-02 gate.

Section ☐ Course, Owner

Required invariant / proposed constraint: PK; Course/User FKs; index Section.ownerId; Owner role consistent

Service responsibility: All permissions derive from Section.ownerId; no co-teaching/ownership transfer

Lecture ☐ Section

Required invariant / proposed constraint: PK; Section FK; index Lecture.sectionId and discovery order fields

Service responsibility: Look up through owned Section on creation; cannot reparent in F-03

Survey ☐ Lecture

Required invariant / proposed constraint: PK UUID; NOT NULL unique lectureId FK; ownerId FK; status/mode enums; positive definitionRevision

Service responsibility: Derive ownerId; IDENTIFIED only S1; enforce lifecycle/field immutability under lock

Question ☐ Survey

Required invariant / proposed constraint: PK UUID; surveyId FK; positive integer position; unique (surveyId,position); index covered by unique key

Service responsibility: Contiguous final 1…n, n ≤10; stable IDs; whole replacement under Survey lock

Question meaning

Required invariant / proposed constraint: Prompt/type/required; ratingMin/Max, endpoint labels, scaleInterpretation

Service responsibility: Map ratingScale to named SDS columns; TEXT rating columns null; RATING 1/5; draft blank vs publish nonblank

Membership ☐ Section, User

Required invariant / proposed constraint: Unique (sectionId,studentId); FKs; Section-leading key

Service responsibility: #16 seed validates RESPONDENT roles; publication validates selected rows again

SurveyEligibility ☐ Survey, User

Required invariant / proposed constraint: Unique (surveyId,studentId); FKs to Survey/User, not live Membership

Service responsibility: Insert frozen publication set once; never derive eligibility anew on read

Participation / ResponseBundle / Answer

Required invariant / proposed constraint: Existing SDS keys/eligibility links; Answer.questionId FK prevents deleting referenced definitions

Service responsibility: F-04 owns writes; F-03 closing preserves all rows; published deletion impossible

Database and application validations complement each other. Timestamp/state coherence and rating type constraints belong in #16's reviewed schema; nonblank/1-10/cross-table membership requirements are transaction/service checks unless an agreed DB constraint also enforces them. Redundant owner consistency requires a reviewed invariant/seed check; a plain ownerId FK alone does not prove Section ownership.

To reorder with a nondeferrable unique (surveyId,position), while holding the Survey lock stage all existing positions by +10 (11…20), delete omitted rows, then update retained/insert new rows to final 1…n in the same transaction. The DB position CHECK must be positive, not ≤10, to allow staging; the service enforces final bounds. No reader sees intermediate positions; a failure rolls back the complete operation. Do not delete/recreate retained Question IDs to avoid ordering collisions. Issue #16 must accept this strategy or agree and test an equivalent atomic strategy before migrations.

Draft deletion removes only its Questions and Survey in one transaction. Never configure a blanket application delete path that cascades through submitted responses. Use restrictive Answer/response FKs as defense in depth. Source/provenance and single-choice tables are not prerequisites for this S1 schema subset.

7. Transactions and concurrency

Use real PostgreSQL transactions. All F-03 definition writes, Draft deletion, publish, close and F-04 submit serialize on the **same Survey row**, using a parameterized `SELECT … FOR UPDATE` or proven equivalent. Acquire the lock before inspecting mutable state/revision or writing dependent rows, recheck canonical ownership, and hold it until commit/rollback. Prisma read/update without that database lock is insufficient. Lock order for existing surveys is Survey then dependent rows. No external/network calls inside the transaction; construct the success projection from that transaction's result and return it only after commit, without an unlocked requery that could return a later writer's definition. Known transient faults may be retried only through reviewed policy, never blind client mutation retries.

Create / create

Authoritative outcome: No Survey row exists to lock. Resolve owned Lecture and insert server-derived Draft in a transaction; unique Survey.lectureId yields exactly one 201 and one 409 for concurrent successful competing inserts. A rollback permits the other creation.

Save / save

Authoritative outcome: Lock, verify Draft then expectedRevision, validate question identities and write atomically. Two real changes using the same revision produce one 200/revision+1 and one 409 REVISION_CONFLICT; no merged fields. No-op retains revision only after matching expectedRevision.

Save / publish

Authoritative outcome: Both require the displayed revision and same lock. Save first: revision changes, publish is stale 409. Publish first: freezes definition, save is 409 INVALID_STATE. No partly saved published definition.

Delete / other Draft mutation

Authoritative outcome: Same lock and revision; committed deletion makes the other operation 404; a prior changed revision makes deletion 409. No orphan questions or bypass via guessed question IDs.

Publish

Authoritative outcome: Lock Draft, check revision, validate whole definition, obtain membership snapshot as below, insert all Eligibility rows and set PUBLISHED/publishedAt in one transaction. Readers see either the original Draft with no snapshot or the committed frozen state with the complete snapshot.

Membership / publish

Authoritative outcome: After acquiring Survey lock, use **one authoritative SQL SELECT statement** to materialize Section Membership plus User role at PostgreSQL READ COMMITTED statement snapshot. This set is the eligibility boundary. Commits visible before that statement are included; additions/removals committed after its snapshot do not alter the set, even if they precede publication commit. Uncommitted changes are invisible. Validate all selected users are Respondents and set nonempty; do not count first then requery a different set.

Close / submit

Authoritative outcome: Both take Survey lock before state checks. If Close commits first, submit sees CLOSED and rejects with no participation/bundle/answers. If submit commits first, its complete response remains when Close commits. A rolled-back Close does not close; a rolled-back submit adds no response. F-03 never writes a response on behalf of F-04.

Publish / publish; close / close

Authoritative outcome: First valid committed transition wins (200); second acquires lock, sees changed state and returns 409 INVALID_STATE. Original timestamps/definition/eligibility are not rewritten.

Publish / close

Authoritative outcome: Starting from Draft: if Close locks first it rejects 409 INVALID_STATE, then publication may succeed and leave Published. If publication commits first, waiting Close observes Published and may commit Closed. There is no queued intent to close a Draft later; the state under lock decides each operation.

Any write fault

Authoritative outcome: Roll back Survey, Questions, staged positions, Eligibility and timestamps together as applicable. Fault before/during commit must not produce success. If commit acknowledgment is lost, treat client outcome as uncertain and reconcile by GET/discovery; never claim rollback without knowing it occurred.

S1 membership changes are seed/setup operations, not an enrollment API. Publication's defined snapshot avoids requiring a nonexistent membership-writer locking protocol. Eligibility references User, not Membership, so later membership removal does not delete it. User deletion/role changes are outside the S1 application scope; #16 seeds and test setup must preserve published eligibility. If future membership workflows require a different snapshot boundary, coordinate the baseline/F-02/F-04 contracts first.

GET definition uses a read-only REPEATABLE READ transaction snapshot for parent/context/questions so a concurrent save cannot produce a mixed revision/title/question set; a single SQL statement producing the complete scoped representation is an equivalent option. Multiple READ COMMITTED queries alone are not sufficient. GET does not mutate or take the exclusive Survey lock. A read just before publication/closing can legitimately show the earlier state; the next request observes committed changes. PostgreSQL row locking (https://www.postgresql.org/docs/current/explicit-locking.html) and statement/transaction snapshots (https://www.postgresql.org/docs/current/transaction-iso.html) describe the database mechanisms, not executed project evidence.

8. UI contract

Proposed routes: F-02 owned Lecture action opens `/surveys/:id/manage` after create, existing-survey action opens the same management view; eligible Respondent action opens `/surveys/:id` for F-04's answer journey. Confirm route names with #11/#13 rather than introduce duplicate discovery pages. All protected screens use the SDS §6.1 visual/accessibility patterns and F-01 session handling.

Create

Required behavior: Selected Lecture/Course/Section context visible; explicit Create Draft action; disable repeated action while pending. Existing-survey conflict refreshes F-02 discovery and opens the owned existing survey only after scoped retrieval.

Draft editor

Required behavior: Labelled title, question prompt/type/required controls; RATING fixed 1-5 plus editable endpoint labels and interpretation; TEXT has no scale controls. Add/remove and keyboard Up/Down reorder; stable local keys until server IDs return. Empty Draft explains how to add questions; max ten enforced with server validation authoritative.

Save

Required behavior: Display unsaved state and loaded revision. Save allows incomplete valid-shaped Drafts; field limits/type errors shown next to controls and in a focusable summary. Replace local IDs/revision with confirmed server representation; never display Saved during a pending/failed request.

Publish

Required behavior: Require saved local state and review of persisted questions/scale/privacy; show confirmation of immutability and Section-member snapshot boundary. Blank/invalid draft remains saveable but not publishable. Server eligibility/validation errors retain recoverable editor values; do not invent a preview count endpoint or claim all current members remain eligible later.

Published / Closed

Required behavior: Definition read-only, Draft save/delete hidden; Close only while Published, with confirmation and pending state. Closed shows persisted status, no reopen. F-05 results are a separate handoff, not fabricated F-03 results.

Respondent

Required behavior: Display frozen questionnaire/identified disclosure for eligible Published/Closed read; Draft/ineligible/missing shows unavailable without private metadata. F-04 owns answer inputs, submission state and confirmation; Closed cannot enable submit.

Conflict

Required behavior: On 409 revision conflict retain unsaved values in memory and explain Reload then manually reapply to current question IDs/revision; no automatic overwrite/retry. On state conflict reload read-only committed definition and clearly mark unsaved changes as not stored.

Network / failure

Required behavior: Keep recoverable values, show actionable retry/reconcile message. An uncertain create uses owned-Lecture discovery; uncertain save/publish/close uses GET before retry. For uncertain delete, 404 means unavailable, not proof of this user's deletion. Never show mutation success before confirmation.

Authentication / navigation

Required behavior: On 401 clear private loaded/unsaved data per F-01 and return to login; do not promise draft recovery after session loss. Warn before leaving unsaved editor; no localStorage persistence of private definitions. 404 removes inaccessible resource details.

Loading / accessibility

Required behavior: Distinct loading/empty/error states; prevent duplicate pending actions without removing keyboard access to errors. Native labelled controls, visible focus, error-summary links, dialog focus return and meaningful reorder/remove focus. Test at 360px/1280px without horizontal form overflow.

The identified disclosure is truthful about storage; hiding names is not anonymity. Owner previews show the same interpretation/endpoint labels that Respondents and F-05 will use; higher values must not be labelled “better” unless that is what the explicit scale means.

9. Acceptance criteria and bidirectional traceability

All criteria below are proposed, observable acceptance targets, not satisfied results. Each TEST ID is expanded in the STS; that document also maps every case back here.

AC-F03-01

Required observable outcome: Creating on an owned empty Lecture returns 201 empty IDENTIFIED Draft revision 1, canonical owner and committed definition retrievable by GET.

Planned TEST-F03 cases: I01

AC-F03-02

Required observable outcome: All six routes enforce §2 server-side; foreign-owner records are 404, Respondent management 403, unauthenticated access 401, with no mutation or private data.

Planned TEST-F03 cases: I02,I23

AC-F03-03

Required observable outcome: Concurrent creates for one Lecture yield exactly one Survey; committed winner 201 and conflicting loser 409.

Planned TEST-F03 cases: I03

AC-F03-04

Required observable outcome: Owner reads own three states; Respondent reads only frozen-eligible Published/Closed, never Draft. Projections, question order and disclosure match §5.2; no participant/answer/owner-identity leak.

Planned TEST-F03 cases: U06,I04,I24,E04

AC-F03-05

Required observable outcome: Save atomically adds/edits/removes/reorders questions with retained stable IDs and contiguous positions; invalid/foreign/duplicate IDs cause 422 and no change.

Planned TEST-F03 cases: U05,I05

AC-F03-06

Required observable outcome: Normalization and Unicode limits in §4 accept exact bounds and reject one over; Draft blanks allowed, publication blanks rejected, malformed Unicode/NUL safely rejected.

Planned TEST-F03 cases: U01,I06

AC-F03-07

Required observable outcome: RATING/TEXT and required booleans follow §4; 1-5 scale fixed, labels/interpretation preserved; malformed scales, coercions and unsupported types return 422.

Planned TEST-F03 cases: U02,I07

AC-F03-08

Required observable outcome: Save accepts 0-10 questions; publication rejects 0/text-only, accepts valid 1 or 10 with RATING, and rejects 11. No failed publication creates eligibility/state changes.

Planned TEST-F03 cases: U03,I08

AC-F03-09

Required observable outcome: Real change increments once; normalized no-op with current revision does not. Stale writes conflict; concurrent real saves with same revision have one winner and no lost update.

Planned TEST-F03 cases: U04,I09

AC-F03-10

Required observable outcome: Matching-revision Draft delete returns 204 and removes only its definition; stale delete 409, absent 404, Published/Closed 409; Lecture can receive a new Draft afterward.

Planned TEST-F03 cases: I10

AC-F03-11

Required observable outcome: Only DRAFT→PUBLISHED→CLOSED is allowed. Published/Closed definitions, modes and eligibility cannot be edited/deleted/reopened; invalid transitions are 409 for valid-shaped requests.

Planned TEST-F03 cases: U04,I11,E04

AC-F03-12

Required observable outcome: Valid publication commits full frozen definition and exactly the selected eligible snapshot together; no partial state visible.

Planned TEST-F03 cases: I12,H01

AC-F03-13

Required observable outcome: Empty eligibility or invalid member roles prevent publication with 422 and unchanged Draft/zero snapshot rows.

Planned TEST-F03 cases: U03,I13

AC-F03-14

Required observable outcome: After publication, membership changes do not alter frozen access; required/type/scale/order/mode stay fixed and identified disclosure remains truthful for F-04/F-05.

Planned TEST-F03 cases: U06,I11,I14,H03

AC-F03-15

Required observable outcome: Controlled edit/publish races produce exactly §7's two outcomes: save-first revision conflict or publish-first invalid-state rejection, never mixed published content.

Planned TEST-F03 cases: I15

AC-F03-16

Required observable outcome: Controlled membership/publish tests prove the one-statement snapshot boundary before/after committed changes, including invisible uncommitted changes.

Planned TEST-F03 cases: I16

AC-F03-17

Required observable outcome: Authorized Close changes Published to Closed once, retains publishedAt/revision and all questions/eligibility/responses, and sets closedAt only on success.

Planned TEST-F03 cases: I17,H03

AC-F03-18

Required observable outcome: Sequential and concurrent duplicate publish/close produce one successful transition and subsequent 409, without timestamp/snapshot duplication or rewriting. Concurrent publish/close from Draft follows §7: close-first 409 then Published; publish-first permits subsequent Closed.

Planned TEST-F03 cases: U04,I18

AC-F03-19

Required observable outcome: Close/submit follows BR-11's lock/commit order; close-first rejects submission without rows, submit-first response survives closing. A protocol harness alone is not actual F-04 integration evidence.

Planned TEST-F03 cases: I19,H02

AC-F03-20

Required observable outcome: Injected write/known precommit failures leave no partial definition/order/snapshot/state changes; safe error, no success. Unknown commit outcome triggers reconciliation, not a fabricated rollback claim.

Planned TEST-F03 cases: I20

AC-F03-21

Required observable outcome: Shared session/Origin/CSRF/access, route body ceilings, strict JSON/error precedence, safe logs and no-store responses follow §5; spoofed actor/mode cannot bypass checks.

Planned TEST-F03 cases: I21,I23

AC-F03-22

Required observable outcome: Owner completes real create/save/publish and Published/Closed read-only navigation with persisted state confirmation, no premature success.

Planned TEST-F03 cases: E01,E04

AC-F03-23

Required observable outcome: Validation, state/revision conflicts and network uncertainty show §8 recovery without automatic overwrite or false success; recoverable unsaved content retained, session loss clears private state.

Planned TEST-F03 cases: E02,E03

AC-F03-24

Required observable outcome: Core authoring/publication/closing controls are labelled, keyboard usable, focus/error handling visible at 360px and 1280px.

Planned TEST-F03 cases: E05,M01

AC-F03-25

Required observable outcome: After process restart against the same PostgreSQL database, committed Draft/Published/Closed definitions, IDs/order/revisions/timestamps and snapshots remain unchanged.

Planned TEST-F03 cases: I22

AC-F03-26

Required observable outcome: Before implementation, reviewed contract/schema/security/handoff agreements exist; later acceptance has actual mapped unit/API/PostgreSQL/E2E/handoff results, meaningful RED/GREEN and human review, with pending work explicit.

Planned TEST-F03 cases: M02,H01,H02,H03

10. Verification and completion boundaries

The STS (f-03-survey-authoring-sts.md) specifies 40 planned cases: 6 unit, 24 API/real PostgreSQL integration, 5 UI/E2E, 2 supplementary/process, 3 cross-feature handoffs. All 26 AC have forward/reverse links. Document structure/link/traceability checks do not execute those tests. No implementation, schema, passing counts, teammate approval, TDD history, issue closure, release or PDF evidence is claimed here.

Provisional Product DoD 01-10 apply at feature level: implemented AC; preimplementation contracts/history; meaningful unit tests; real persistence/access/transaction integration; selected E2E/keyboard/responsive checks; genuine intended-behavior RED/GREEN; backend security/disclosures; actual build/test version/counts; substantive teammate review/integration; reproducible setup/docs. DoD 11-12 are integrated main release and A-F PDF gates, not satisfiable by this document. Confirm exact wording against the adopted shared version before acceptance.

Issue #12 can supply a reviewable contract package; it cannot establish implementation #19 or Sprint completion. Record actual results with test ID, real file/test name, command, environment, tested SHA, expected/observed outcome, pass/fail/skip counts and artifact/review links when available. Keep planned evidence distinct from executed results. Human teammate review remains pending.

11. Dependencies, open agreements and coordinated updates

Tracker snapshot: Issue #12 lead R1NNE0, planned reviewer Maibokdaimhai; no review occurrence or availability is asserted. #10 F-01 supplies auth; #11 F-02 supplies owned context/discovery; #13 F-04 supplies actual submit; #14 F-05 supplies count/results; #15 tooling; #16 SYS-01 schema; #19 F-03 implementation; #22 API integration; #23 E2E; #25 release; #26 evidence/PDF. #5 owns shared DoD/contracts and #6 evidence planning. Leads/reviewers remain the tracker/human team's authority.

Shared conventions alignment

Required decision before dependent code: Record the staging shared/F-01/DoD versions used; apply their authentication/transport codes and session distinctions. Review remaining F-03-specific projection, normalization and body-limit agreements without changing shared middleware silently

Owner / next coordination: #5/#10 with #12 reviewer

F-02 interface

Required decision before dependent code: Reconcile actual accepted #11 contract with §5.2 context serialization, selected-Lecture/create/existing links, role projections and UI routes; no duplicated discovery handler

Owner / next coordination: #11/#12

Schema subset

Required decision before dependent code: Approve §6 constraints, stable question IDs, reorder staging, redundant ownership invariant, Eligibility FKs, role fixtures and locking SQL/Prisma integration

Owner / next coordination: #16/#12; no F-03 migrations

F-04 lock and answers

Required decision before dependent code: Adopt the same Survey lock and BR-11 ordering, frozen required/type/scale/IDs, disclosure and validation handoff; actual submit route/status contract remains #13, not invented here

Owner / next coordination: #12/#13/#16

F-05 meaning/privacy

Required decision before dependent code: Preserve frozen IDs/scale and closed response set; F-05 count/results projections, never identified account links to owner

Owner / next coordination: #12/#14

Dependency order

Required decision before dependent code: Follow Tracker §3: initial #16 User/session migration and synthetic login seed require working #15, reviewed #10 and accepted shared conventions/DoD. Later domain migrations require their respective reviewed feature contracts. #17 may start against the verified initial subset without full #16 completion or unrelated #11-#14 contracts. F-03 implementation #19 still requires reviewed #12, #17/#18 identity/context and its applicable verified #16 schema/constraints; full #16 closes only after its entire S1 scope is evidenced

Owner / next coordination: #5/#16/#12; tracker maintainers

Recommended later shared-file changes (not performed): add these two contract links under F-03 in `docs/README.md`; link AC-F03-01-26 and the STS in the F-03 row of `docs/traceability.md` and the contract reference in `docs/features.md`; after review, reference §6-7's accepted revision/snapshot/reorder details from `docs/system-sds.md` §§2-3,11; update `tracker.md` #12/#19/#16 contract/evidence references and status only on actual review/implementation evidence. Keep subsequent dependency updates consistent with the existing phased Tracker policy and record each reviewed/verified schema subset without claiming full #16 completion early. No existing shared file is changed by this package.

Ready to submit for independent specification and teammate review once the paired document checks are complete. This is not authorization to code against unresolved shared/schema/handoff agreements, mark tests passed, or close delivery gates.

docs/sprints/sprint-1/f-03-survey-authoring-sts.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-03 - Software Test Specification

Version 0.2 · 2026-11-07 · Issue #12 · **Every case: Planned / Not run.**

1. Scope and execution boundary

This is the preimplementation test design for the F-03 engineering contract (f-03-survey-authoring.md), especially §§2-9. It specifies 40 stable cases linked to 26 AC; it contains no application test code, executed results, passing assertions or review approval. U = unit; I = API with real PostgreSQL; E = selected UI/E2E; M = supplementary/process; H = cross-feature handoff. Subscenarios within a case must be independently asserted/parameterized when implemented; 40 planned specification cases are not a prediction of runner assertion/test counts.

The contract's §9 table is the forward AC→test index. The linked-AC column below is the reverse index; `AC-F03-xx` always refers to that table, and all case IDs begin `TEST-F03-`. No AC is satisfied merely by writing a case. F-04 answer validation and F-05 calculations are not reimplemented in F-03 unit tests; H02/H03 require the real accepted adjacent feature implementations before they can be recorded as executed integration evidence.

2. Fixtures, harness and result recording

Use synthetic Owner A and Owner B with distinct Sections of the same Course; each owns at least two Lectures. Respondents R1/R2 belong to A's Section, R3 only to B's, R4 initially outside A's. Include an owned empty Lecture and Draft/Published/Closed surveys on different Lectures (one Survey per Lecture). Include both empty/incomplete Draft and complete 1-RATING/10-question definitions, optional TEXT and explicit scale meaning such as slow→fast. Publication fixtures must include frozen Eligibility; current Membership alone is not enough. F-04-populated fixtures with Participation/ResponseBundle/Answers are required where preservation is asserted. #16 owns migrations/seeds; isolated test setup may insert invalid role Membership to prove publication rejects it, but no production admin API is added.

Use accepted Vitest/Supertest/Playwright tooling after working #15 and verified applicable #16 schema subsets exist. The initial User/session subset follows reviewed #10/shared conventions; F-03 domain migrations follow reviewed #12 and their applicable context/schema dependencies. Full #16 completion is not an F-01 starting gate. Integration uses real migrated PostgreSQL, real HTTP middleware and F-01 sessions/CSRF (unless a unit case explicitly isolates pure logic); never substitute SQLite/in-memory repositories for transaction/access evidence. Independent connections and explicit barriers prove both race orders; record affected row counts and complete before/after snapshots. Do not infer serialization from Promise scheduling, sleeps, mocked locks or only response codes. Test setup resets isolated data, not another developer's database.

All negative mutation checks assert no persisted changes to Survey/Question/Eligibility and any seeded response rows. Auth/ownership tests use otherwise valid payloads and valid CSRF where needed so they reach the intended boundary. On errors inspect response headers/body and captured safe logs. Fault injection is a test-only seam or controlled DB failure, never an application endpoint; distinguish known rollback from lost commit acknowledgment. E2E uses real APIs/database and isolated sessions; no mocked success response can prove persistence.

When implemented, record actual test file/name, command, environment/DB version, immutable tested SHA, expected/observed outcome, pass/fail/skip counts, safe artifacts and review references. Document failed and skipped cases honestly. A documentation check is not application execution. Current result for **every row below is Planned / Not run**.

3. Unit cases - 6 planned

TEST-F03-U01

Linked AC: AC-F03-06

Level: Unit

Preconditions / fixtures: Pure normalization/definition validator; Thai and supplementary-plane characters

Input: Title 0/120/121, prompt 0/500/501, labels 0/120/121, interpretation 0/500/501 code points after trim; NUL, lone surrogates, composed/decomposed strings

Action: Validate Draft and publication profiles; compare normalized values

Expected observable result: Exact maxima accepted; one over rejected; blanks Draft-only; no UTF-16 overcount or implicit composition/case changes; NUL/surrogates rejected safely.

TEST-F03-U02

Linked AC: AC-F03-07

Level: Unit

Preconditions / fixtures: Question schema/scale validator

Input: RATING/TEXT; booleans vs strings; min/max 1/5 vs 0/6/fractions/strings; null/missing/extra scales; SINGLE_CHOICE/unknown types

Action: Validate each strict schema and serialized scale

Expected observable result: Only §4 schemas accepted; TEXT scale exactly null; RATING anchors/interpretation retained, no invented positive direction; malformed/coerced values rejected.

TEST-F03-U03

Linked AC: AC-F03-08, AC-F03-13

Level: Unit

Preconditions / fixtures: Publication readiness logic

Input: 0/1/10/11 questions, text-only, blank title/prompt/meaning, nonempty/empty/invalid-role eligibility set

Action: Evaluate Draft versus publication validation

Expected observable result: Draft accepts incomplete 0-10; publish requires nonblank valid 1-10 including RATING and nonempty Respondent-only set; appropriate safe validation codes.

TEST-F03-U04

Linked AC: AC-F03-09, AC-F03-11, AC-F03-18

Level: Unit

Preconditions / fixtures: State/revision decision logic

Input: Every lifecycle operation in all three states; matching/stale revision; normalized no-op vs real change

Action: Evaluate decisions without a DB

Expected observable result: Only forward transitions/Draft edits; state precedes stale-revision errors; stale no-op conflicts; matching no-op unchanged revision, real edit +1; repeat transitions rejected. Does not prove locking.

TEST-F03-U05

Linked AC: AC-F03-05

Level: Unit

Preconditions / fixtures: Existing questions Q1/Q2/Q3

Input: Reorder/edit retained IDs, omit Q2, append null ID; repeated/foreign/unknown IDs

Action: Build replacement plan using deterministic server-ID provider

Expected observable result: Retained IDs preserved, omitted ID deleted, new ID allocated, final positions contiguous; invalid ID sets fail as a whole without identity disclosure.

TEST-F03-U06

Linked AC: AC-F03-04, AC-F03-14

Level: Unit

Preconditions / fixtures: Raw record deliberately includes user IDs, eligibility, answers and auth fields

Input: OWNER/RESPONDENT projections; IDENTIFIED RATING/TEXT definitions

Action: Serialize both role projections

Expected observable result: Exact allowlists and ordered frozen scales; no raw/extra fields or participants/results; accurate disclosure and IDENTIFIED mode, never an anonymity promise.

4. API and real PostgreSQL cases - 24 planned

TEST-F03-I01

Linked AC: AC-F03-01

Level: API + PostgreSQL

Preconditions / fixtures: A authenticated; own empty Lecture; valid CSRF/Origin

Input: POST `{lectureId}` then GET Location

Action: Create; inspect returned definition and database

Expected observable result: 201, Location, empty title/questions, IDENTIFIED/DRAFT, revision 1, null transition timestamps; owner derived from Section; GET and committed rows agree.

TEST-F03-I02

Linked AC: AC-F03-02

Level: API + PostgreSQL

Preconditions / fixtures: A/B same Course different Sections; R1; no session; valid role-specific fixtures

Input: Each of six endpoints with owned/foreign/missing IDs, valid bodies and tokens

Action: Exercise role/ownership matrix including create for B's Lecture

Expected observable result: Own operations permitted as state allows; no session 401 AUTH_REQUIRED; R1 management 403 FORBIDDEN_ROLE; foreign/missing owner resources identical 404 NOT_FOUND; no private body/log data or database changes on rejection.

TEST-F03-I03

Linked AC: AC-F03-03

Level: API + PostgreSQL

Preconditions / fixtures: Same owned empty Lecture; independent connections

Input: Two valid concurrent create requests

Action: Barrier inserts against unique lectureId; release both and inspect rows

Expected observable result: Exactly one committed Survey/201 and one 409 SURVEY_ALREADY_EXISTS; no orphan Questions or second Survey. Rollback-winner variant permits competing successful create.

TEST-F03-I04

Linked AC: AC-F03-04

Level: API + PostgreSQL

Preconditions / fixtures: Own three states; R1 frozen-eligible, R4 only later current-member, R3 other Section

Input: GET each Survey as A/B/R1/R3/R4

Action: Read definitions with real sessions

Expected observable result: Owner own three states 200; eligible Published/Closed 200; Respondent Draft/ineligible and foreign Owner 404; correct order/projections, no participation/answers/ownerId.

TEST-F03-I05

Linked AC: AC-F03-05

Level: API + PostgreSQL

Preconditions / fixtures: Draft with Q1/Q2/Q3 and current revision

Input: Full PATCH reorder Q3/Q1, edit/type-change Q1, remove Q2, new null-ID question; duplicate/foreign/unknown ID variants

Action: Save and inspect stable IDs/positions; issue invalid variants with current revision

Expected observable result: Single committed replacement; retained IDs unchanged, new ID unique, Q2 absent, 1…n positions. Invalid IDs return safe 422 with complete rollback; no temporary staged positions visible.

TEST-F03-I06

Linked AC: AC-F03-06

Level: API + PostgreSQL

Preconditions / fixtures: Incomplete and complete Drafts, one-case-at-a-time isolation

Input: U01 boundary strings serialized as UTF-8 and escaped JSON, including Thai/non-BMP, whitespace, NUL/lone surrogate

Action: PATCH then GET/DB; publish blanks and exact valid maxima

Expected observable result: Stored normalized text/code points exact; valid maxima round-trip; 422 for one over/invalid Unicode; blank Draft save allowed but publication rejected; no corruption or partial write.

TEST-F03-I07

Linked AC: AC-F03-07

Level: API + PostgreSQL

Preconditions / fixtures: Draft current revision

Input: U02 scale/type cases plus unknown fields, client mode/ownerId/status, prompt wrong type

Action: PATCH through actual parser/Zod/service

Expected observable result: Exact RATING/TEXT accepted, metadata persisted; all coercion/unsupported/S2/actor-field attempts safe 422 and unchanged revision/definition.

TEST-F03-I08

Linked AC: AC-F03-08

Level: API + PostgreSQL

Preconditions / fixtures: Fresh isolated Drafts; nonempty eligible Section; separate test-only DB fixture with 11 questions to test defensive publication validation

Input: 0/1/10/11 questions and text-only cases

Action: Save shapes; publish saved Drafts; send 11-entry update; publish the deliberately invalid 11-question fixture

Expected observable result: 0-10 Drafts allowed; 11 update 422; publication 0/text-only/11-fixture 422, valid 1/10 containing RATING 200; failed publication no snapshot/timestamp. No production API may create the invalid fixture.

TEST-F03-I09

Linked AC: AC-F03-09

Level: API + PostgreSQL

Preconditions / fixtures: Draft revision r; independent sessions/connections

Input: Two different real PATCH changes with expectedRevision r; normalized no-op and stale variants

Action: Barrier concurrent saves; inspect winner; save no-op at new revision; retry stale

Expected observable result: Exactly one 200/r+1, one 409 REVISION_CONFLICT, no mixed definition; current no-op keeps revision; stale no-op rejected; no silent lost update.

TEST-F03-I10

Linked AC: AC-F03-10

Level: API + PostgreSQL

Preconditions / fixtures: Owned Draft with Questions; other surveys; Published/Closed fixtures

Input: DELETE matching/stale revision; nonexistent; then POST same Lecture

Action: Delete/retrieve/inspect relation rows; try forbidden deletes

Expected observable result: Valid 204 empty and only target Draft/Questions removed; GET 404; stale 409, absent 404, Published/Closed 409; new Draft succeeds with new ID; other data unchanged.

TEST-F03-I11

Linked AC: AC-F03-11, AC-F03-14

Level: API + PostgreSQL

Preconditions / fixtures: Own Published/Closed frozen definitions and responses

Input: Valid-shaped PATCH/delete/publish/close across state matrix; separate unknown-field mode/eligibility/reopen attempts

Action: Execute all forbidden transitions and compare complete frozen rows

Expected observable result: State violations 409 without changes; unrecognized mutation fields/routes cannot modify state and follow §5 syntax/routing errors; IDs/order/required/scales/mode/eligibility/answers remain fixed.

TEST-F03-I12

Linked AC: AC-F03-12

Level: API + PostgreSQL

Preconditions / fixtures: Complete Draft revision r; R1/R2 valid members; independent reader

Input: POST publish expectedRevision r

Action: Pause after eligibility insertion before commit; read from second connection, then commit and read

Expected observable result: Before commit reader sees original Draft/no eligibility; after, Published plus exactly R1/R2 snapshot and frozen definition; revision retained, publishedAt set; no participant list in response.

TEST-F03-I13

Linked AC: AC-F03-13

Level: API + PostgreSQL

Preconditions / fixtures: Complete owned Draft; empty Section then invalid Owner-role Membership injected in isolated setup

Input: Publish each fixture

Action: Inspect error and all related rows

Expected observable result: 422 ELIGIBILITY_EMPTY / ELIGIBILITY_INVALID; safe no-identity errors; Draft/revision/questions unchanged, no eligibility or timestamp stored.

TEST-F03-I14

Linked AC: AC-F03-14

Level: API + PostgreSQL

Preconditions / fixtures: Published survey frozen for R1/R2

Input: Remove R1 Membership, add R4 Membership; read as both; attempt definition/flag/scale changes

Action: Commit setup membership changes; use real GET and valid-shaped PATCH

Expected observable result: R1 still 200; R4 404; frozen question metadata/eligibility unchanged; edit 409; truthful identified disclosure still returned; no dynamic recalc or privacy-mode switching.

TEST-F03-I15

Linked AC: AC-F03-15

Level: API + PostgreSQL

Preconditions / fixtures: Complete Draft revision r; explicit lock barriers

Input: PATCH edit and publish both expectedRevision r

Action: Run save-lock-first then publish-lock-first on separate reset fixtures

Expected observable result: Save-first: edit 200/r+1, publication 409 stale, still Draft/no eligibility. Publish-first: publication 200, edit 409 state; definition wholly original, complete snapshot; never mixed content.

TEST-F03-I16

Linked AC: AC-F03-16

Level: API + PostgreSQL

Preconditions / fixtures: Draft, R1/R2 membership; two DB connections with instrumentation around authoritative membership SELECT

Input: Add R4/remove R1 committed before vs after SELECT snapshot; uncommitted addition/removal variant

Action: Control commit order around SELECT, not just publish request start; finish publication

Expected observable result: Snapshot includes exactly changes visible to that statement; later commits do not alter selected IDs even before publication commit; uncommitted changes invisible; no count/requery discrepancy.

TEST-F03-I17

Linked AC: AC-F03-17

Level: API + PostgreSQL

Preconditions / fixtures: Own Published survey with frozen eligibility/questions and seeded F-04 response bundle/answers

Input: POST close {}

Action: Close and inspect every relevant row

Expected observable result: 200 CLOSED, new closedAt; publishedAt/revision/definition/eligibility/response rows identical; no answer deletion/update; repeat operation covered by I18.

TEST-F03-I18

Linked AC: AC-F03-18

Level: API + PostgreSQL

Preconditions / fixtures: Draft ready to publish; separate Published fixture; fresh Draft for publish/close race

Input: Duplicate sequential then parallel publish/close; concurrent publish versus Close from Draft in both lock orders

Action: Use two real connections and barriers; compare first transition's timestamp/snapshot and final state

Expected observable result: Duplicates: one valid 200, later 409 INVALID_STATE, first timestamp retained, no duplicate eligibility/revision rewrite. Publish/close: close-first 409 then publication 200 leaves Published; publish-first 200 then Close 200 leaves Closed; no closing a Draft or premature transition.

TEST-F03-I19

Linked AC: AC-F03-19

Level: API + PostgreSQL protocol

Preconditions / fixtures: Real F-03 Close route; private test transaction simulates F-04's documented Survey-lock/PUBLISHED-check/atomic inserts; valid eligible response fixture

Input: Controlled close-first and submit-first plus rollback variants

Action: Hold/release same Survey lock from independent connections; inspect all response rows

Expected observable result: Close-first committed means harness rejects with zero new rows; submit-first committed rows survive Close; rollback adds no false state/response. This proves protocol only, not actual F-04 route; H02 remains required.

TEST-F03-I20

Linked AC: AC-F03-20

Level: API + PostgreSQL

Preconditions / fixtures: Isolated fixtures for each mutation; test-only fault seam

Input: Failure after create insert, during reorder/remove/insert, Draft delete, partial eligibility insertion, state/timestamp update, known precommit failure; separately lost commit acknowledgment

Action: Inject faults, observe HTTP, reread through independent connection; reconcile unknown outcome

Expected observable result: Known failures roll back complete operation, no staged positions/partial eligibility/timestamp; 503 known outage or 500 unexpected, no sensitive errors/success. Lost acknowledgment is treated as uncertain: GET determines committed state, no automatic retry/false rollback claim.

TEST-F03-I21

Linked AC: AC-F03-21

Level: API + PostgreSQL

Preconditions / fixtures: Authenticated authorized actor; valid CSRF; real route parsers/proxy config

Input: Malformed JSON, bad UUID/revision, missing/extra keys, GET body/query, unsupported methods; bytes 8,192/8,193 and 262,144/262,145, absent Content-Length, wrong content type/encoding

Action: Exercise each route's perimeter and documented precedence; valid boundary JSON uses whitespace padding; send high-code-point ten-question definition

Expected observable result: Assert HTTP status and error.code: malformed JSON 400 MALFORMED_JSON; input validation 422 INVALID_REQUEST/INVALID_DEFINITION per §5; unsupported method 405 METHOD_NOT_ALLOWED with accurate Allow incl F-02 GET; over-limit body 413 BODY_TOO_LARGE; unsupported content type/compression 415 UNSUPPORTED_CONTENT. Exact-ceiling valid body accepted (204 for delete as applicable); no smaller parser rejects legal authoring; errors no-store, safe fields/logs, no writes on rejection.

TEST-F03-I22

Linked AC: AC-F03-25

Level: API + PostgreSQL + process

Preconditions / fixtures: Persisted Draft/Published/Closed with questions and eligibility; saved pre-restart snapshot

Input: Stop/start actual API process against unchanged database; fresh login if necessary

Action: Retrieve as authorized actors and compare DB rows

Expected observable result: All committed content, stable IDs/order/revisions/timestamps and snapshots survive; no startup seed reset or in-memory-only persistence.

TEST-F03-I23

Linked AC: AC-F03-02, AC-F03-21

Level: API + PostgreSQL + F-01

Preconditions / fixtures: Real F-01 login sessions for A/R1, CSRF; controlled-clock loaded authenticated session at/past its deadline; separate missing/pruned/forged/revoked/invalid-state session and missing/invalid User fixtures; unavailable auth-store/lookup variant

Input: Missing/bad CSRF, missing/foreign/null Origin on unsafe requests, explicit foreign Origin GET, safe GET without Origin; Respondent management; spoof actor header/body; session expiry/logout and auth dependency failure

Action: Call six routes with otherwise valid fixture payloads and valid earlier perimeter checks to isolate each auth condition; compare rows/logs and headers

Expected observable result: Assert HTTP status and error.code: loaded expired authenticated session 401 SESSION_EXPIRED; missing/pruned expiry or other unusable session/User 401 AUTH_REQUIRED; Origin denial 403 ORIGIN_FORBIDDEN; missing/invalid unsafe-method CSRF 403 CSRF_INVALID; authenticated Respondent management 403 FORBIDDEN_ROLE; unavailable auth store/trusted User lookup 503 AUTH_SERVICE_UNAVAILABLE. Safe GET omission allowed; spoofing cannot change actor or bypass role/ownership; private no-store responses and safe logs; no domain mutation on denial.

TEST-F03-I24

Linked AC: AC-F03-04

Level: API + PostgreSQL

Preconditions / fixtures: Raw private fields/answers present; concurrent owner save with real row lock

Input: GET while save changes title/questions/revision

Action: Read via consistent snapshot before/during/after save and inspect exact response keys

Expected observable result: Each response is wholly old or wholly committed new definition, never mixed parent/questions; only role allowlist; no answer/count/participant/auth fields; errors and successes no-store.

5. UI/E2E cases - 5 planned

TEST-F03-E01

Linked AC: AC-F03-22

Level: UI/E2E

Preconditions / fixtures: Real A session/API/PostgreSQL, owned Lecture; publication-valid members

Input: Create, title, RATING labels/meaning, optional TEXT, reorder/edit/remove/add, Save, Publish confirm

Action: Complete owner journey; delay responses to observe pending state; reload after each committed stage

Expected observable result: Stable server IDs/order/content persist, incomplete Draft save works, publish only saved valid definition; success only after real confirmation; Published read-only state/disclosure reflects GET.

TEST-F03-E02

Linked AC: AC-F03-23

Level: UI/E2E

Preconditions / fixtures: Owner Draft editor with unsaved content; real backend failure/invalid fixtures

Input: Over-limit field, blank publication content, zero eligibility, controlled network uncertainty

Action: Save/publish; follow feedback and recovery; attempt leave with unsaved changes

Expected observable result: Labelled field/error-summary feedback, focus usable, values retained on recoverable failures; unsaved publication requires save; no false Saved/Published; uncertain operation reconciles GET/discovery before deliberate retry.

TEST-F03-E03

Linked AC: AC-F03-23

Level: UI/E2E

Preconditions / fixtures: Two real owner sessions editing same Draft; separate expiry fixture

Input: Concurrent conflicting edit then publish/state conflict; expire/logout local session

Action: Save stale editor; reload/reapply deliberately; repeat with 401 and uncertain delete/create

Expected observable result: 409 never overwrites; recoverable values retained in memory, latest IDs/revision used for deliberate reapply; publication changes view to read-only; 401 clears private state; uncertain delete 404 says unavailable, no unproved deletion success.

TEST-F03-E04

Linked AC: AC-F03-04, AC-F03-11, AC-F03-22

Level: UI/E2E

Preconditions / fixtures: Owner Published/Closed; eligible/ineligible Respondents; Draft URL

Input: Navigate direct URLs, inspect controls, close as Owner; try bypass API

Action: Exercise lifecycle/read-only and unavailable views with real API

Expected observable result: No postpublication edit/delete/reopen; only Published Close control; Closed persisted on reload; eligible disclosure/frozen questionnaire, Closed no submit; Draft/ineligible unavailable without leaked context; server rejects bypass.

TEST-F03-E05

Linked AC: AC-F03-24

Level: UI/E2E

Preconditions / fixtures: Real owner authoring workflow at 360px and 1280px

Input: Keyboard-only create/edit Up/Down/remove/save/publish/close, invalid fields, dialogs

Action: Tab/Enter/Space through core controls; inspect labels/focus/error links and layout

Expected observable result: All actions keyboard operable, no drag-only reorder, stable sensible focus after removal/reorder/dialog close, visible validation, no horizontal form overflow at required widths.

6. Supplementary/process cases - 2 planned

TEST-F03-M01

Linked AC: AC-F03-24

Level: Manual supplement

Preconditions / fixtures: Implemented UI, synthetic Thai/mixed-script content, 360px/1280px and SDS zoom review

Input: Keyboard, long labels, error summary, dialogs, reorder and remove

Action: Human checks focus/label clarity, readable meaning, responsive layout and 200% zoom; record observations

Expected observable result: Core journeys usable at required widths, labels/errors/focus visible; problems recorded with actual evidence. This supplements E05, not a substitute for executable E2E.

TEST-F03-M02

Linked AC: AC-F03-26

Level: Process/evidence audit

Preconditions / fixtures: Proposed contract/STS now; later actual schema, implementation, teammate review and results

Input: Versioned contracts, agreements, genuine RED/GREEN, run records, human review/setup records

Action: At precode gate check agreed versions; later reconcile AC/results and feature DoD 01-10; route release/PDF gates to #25/#26

Expected observable result: All agreements resolved before dependent code; actual history/results/review traceable with failures/skips; no fabricated passes or assistant approval; missing evidence remains pending. Release DoD 11-12 not claimed by feature docs.

7. Cross-feature handoffs - 3 planned

TEST-F03-H01

Linked AC: AC-F03-12, AC-F03-26

Level: Integrated F-02/F-03 API + UI

Preconditions / fixtures: Accepted F-02 real discovery plus F-03/F-01/#16; A/B same Course, frozen vs later membership

Input: A selects own Lecture, creates/publishes; eligible/ineligible students discover/read; B guesses A's IDs

Action: Follow actual discovery→authoring→publication→questionnaire links; tie run to F-02 H01 if retained

Expected observable result: No duplicated discovery or broken navigation; one survey per Lecture; Owner scoped; eligible Published listed/read, Respondent Draft hidden/ineligible rejected; context/scale shapes agree. Not run; requires actual F-02/F-03 routes, not just their documentation.

TEST-F03-H02

Linked AC: AC-F03-19, AC-F03-26

Level: Integrated F-03/F-04 API + PostgreSQL

Preconditions / fixtures: Accepted real F-04 submit route and F-01; same Survey lock agreed; published questions/eligibility

Input: Real valid submit vs Close in both orders; required/type/rating 1/5 vs 0/6/fraction, blank/2,000/2,001 text, unknown/duplicate/wrong-survey IDs, wholly empty optional response; duplicate submit

Action: Barrier actual routes; inspect participation/bundle/answers, submission confirmation and frozen metadata/disclosure

Expected observable result: BR-11 enforced by actual route, close-first no writes, submit-first included; BR-07 invalid answers and duplicates rejected under F-04's accepted contract; identified disclosure before answer; no new F-03 submission endpoint. I19 alone cannot close this handoff.

TEST-F03-H03

Linked AC: AC-F03-14, AC-F03-17, AC-F03-26

Level: Integrated F-03/F-05 API + UI

Preconditions / fixtures: Accepted real F-05, Published survey with known F-04 responses and explicit slow→fast scale

Input: Close survey, retrieve owner summary/text; attempt other-owner results

Action: Compare pre-close frozen definitions/responses with Closed results and UI

Expected observable result: Count/results follow F-05 state policy; Closed summary uses surviving answers, stable question IDs/labels/interpretation without assuming higher=better; no account identifiers/identity joins to owner; other-owner denied; F-03 has not modified any response.

8. Meaningful TDD candidates and completion gate

Choose a small, genuine sequence during implementation, preserving actual failing and passing output against the actual versions. Do not create retrospective RED records or count import/syntax failure as intended-behavior RED. Suitable candidates:

Stable whole-definition revision/order

Planned candidate cases: U05, I05, I09

Intended RED assertion before behavior exists: Retained question ID/order or stale-write rejection fails an intended assertion

Intended GREEN evidence: Correct DB rows/revision and no lost update under real concurrency

Unique Lecture Survey

Planned candidate cases: I03

Intended RED assertion before behavior exists: Competing creation fails exact one-Survey/409 assertion

Intended GREEN evidence: Real PostgreSQL unique constraint and safe mapping produce expected outcome

Publish freeze

Planned candidate cases: I12,I13,I15,I16

Intended RED assertion before behavior exists: Partial snapshot or wrong race/eligibility boundary violates assertion

Intended GREEN evidence: Atomic state/snapshot and both controlled race orders proven

Close serialization and rollback

Planned candidate cases: I19,I20; later H02

Intended RED assertion before behavior exists: Close-first protocol admits response or failure leaves partial rows

Intended GREEN evidence: Real locked transactions reject/preserve correctly; later real F-04 integration independently recorded

Candidate selection is a plan, not an obligation to invent one RED/GREEN artifact for every parameter. Important rules still require the full relevant planned coverage, even if a different genuine TDD slice is selected. A unit GREEN does not replace real DB/handoff results.

Before implementation: review both documents, record the staging shared/F-01/DoD and F-02 versions used, and resolve F-03-specific contract §11 agreements: applicable phased #16 migration/lock/reorder/snapshot design, #13 close/submit protocol and #14 frozen scale/privacy. #19 still requires reviewed #12, #17/#18 identity/context and its verified applicable schema dependencies; the auth foundation does not wait for unrelated later domain contracts or full #16 completion. Before feature acceptance: implement mapped cases, record actual outcomes and failures/skips, complete substantive teammate review and reproducible setup, and retain actual versions/history. Before release: #22/#23 integrated verification, #25 accepted main release and #26 actual evidence/PDF gates remain separate. No gate is marked complete by this STS.

docs/sprints/sprint-1/f-04-responses.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-04 - Identified Response Submission and Own Retrieval Contract

Version 0.1, 2026-11-07. Proposed under #13 (https://github.com/Maibokdaimhai/LECTRA/issues/13), implementation #20 (https://github.com/Maibokdaimhai/LECTRA/issues/20), shared Part E #5 (https://github.com/Maibokdaimhai/LECTRA/issues/5). Lead Maibokdaimhai; planned opposite-member reviewer R1NNE0. Contract and STS (f-04-responses-sts.md) are drafts; no response implementation, human approval or executed F-04 tests are claimed.

Baseline staging `090a5288ac57085d7d7107744d976c31ffd8192d`, including merged F-01/shared, F-02 (f-02-context-discovery.md), F-03 (f-03-survey-authoring.md) and F-05 (f-05-results.md). Sources: SRS (../../srs.md), shared conventions (shared-contract.md), Product DoD (product-dod.md). Instructor outcomes are real validated/persistent eligible responses, duplicate/unpublished/Closed rejection, own/cross-user access, preimplementation AC/STS/DoD and actual verification. Exact wire shapes, error precedence, routes and limits below are team designs, not teacher-prescribed protocols.

1. Scope, traceability and workflow

Requirements: FR-05/06; BR-01-08/10/11/14; NFR-01/02/05/07; SYS-01/02/03/04. F-03 supplies the published identified questionnaire/disclosure and frozen eligibility; F-01 resolves trusted identity/security; F-02 supplies eligible discovery/own submitted flag; F-05 derives results from committed typed answers. #16 owns one reviewed migration/seed history. No competing questionnaire endpoint or mutable response Draft is introduced.

In scope: eligible RESPONDENT form, strict typed normalization/validation, atomic one-time submit, durable confirmation, read-only own submission/status, ambiguity recovery and backend negative/concurrency/access verification. UI/API/data all require work. No F-04 change to Survey definitions/lifecycle, result calculations or auth lifecycle. Exclude anonymous/choice/subset/export/history/notes, response edit/delete/withdrawal, autosave/local-storage drafts, response lists/other-user lookup, admin UI or deployment.

1. F-02 discovers an eligible Published/Closed survey and own submitted boolean. F-04 loads F-03 GET `/api/surveys/:id` plus its own status, using real identity; no stale list flag authorizes writing.

2. Before answering, show F-03's identified disclosure and frozen question order/type/required/scale. If already submitted, show immutable own answers. If Closed and not submitted, show collection ended without an active form.

3. Collect optional/required inputs; no default rating. Validate locally for feedback, then submit once with F-01 Origin/token and strict JSON. Only committed 201 is success.

4. On ambiguous timeout/disconnect, query own submission status before offering another deliberate send. If committed, show saved answers; if not, preserve in-memory inputs for a deliberate retry while still eligible/Published. No automatic POST replay.

5. Own status/identified answers remain readable after closure, logout/login and app restart using the same PostgreSQL data; later membership changes do not alter the frozen eligibility. Logout/401 clears private local drafts/cache.

2. Access, API and projections

F-01 actor `{userId,role}` is authoritative. OWNER calls to respondent-only routes are 403 FORBIDDEN_ROLE before resource lookup. No usable identity is 401 AUTH_REQUIRED, or SESSION_EXPIRED when a loaded session is identifiable at/past deadline. Missing/pruned expired row uses AUTH_REQUIRED. F-04 cannot accept a caller-selected actor from body/query/header.

Scoped resource access requires the authenticated RESPONDENT's SurveyEligibility and Survey state Published/Closed. Missing/ineligible/Draft IDs are the same 404 NOT_FOUND, even if a malformed seed contains Draft eligibility. Current Membership alone grants/revokes nothing. Valid UUID syntax never grants permission. Mode other than IDENTIFIED

returns 409 MODE_NOT_SUPPORTED after scoped access/state handling; no anonymous fallback or student-to-anonymous-answer lookup exists.

POST /api/surveys/:id/responses

Exact input: Canonical lowercase UUID path; no query keys; exact object with answers array as below; same Origin and valid session-bound CSRF

Success / meaning: 201 `{ "data": { "surveyId": "<uuid>", "submitted": true, "answers": [ { "questionId": "<uuid>", "value": 4 } ] } }` after the entire transaction commits. Return only the caller's persisted normalized answers in frozen question-position order.

GET /api/surveys/:id/my-submission

Exact input: Same path format; no body/query; same-origin safe read may omit Origin per F-01

Success / meaning: 200 `{ "data": { "surveyId": "<uuid>", "submitted": false, "answers": null } }` when eligible but no participation. Submitted returns true and the same own answer-array shape as POST, including after Closed.

The examples are shape illustrations, not actual IDs/results. A response can omit optional questions; do not insert fabricated null/zero answers. Submitted answers array includes only stored answers and stable question IDs; prompts/scales come from frozen F-03 definition. No student/user/owner IDs, bundle/answer/participation IDs, other users, timestamp, session/token or aggregate data in either response. Content is private to this student; explicit allowlist and Cache-Control: no-store on successes/errors. Do not return raw ORM relations.

```
{
  "answers": [
    { "questionId": "00000000-0000-4000-8000-000000000511", "value": 4 },
    { "questionId": "00000000-0000-4000-8000-000000000512", "value": "Please explain the last example again." }
  ]
}
```

Both routes read own state only; do not add userId/studentId selectors. Unsupported methods on the route family return 405 with Allow POST or GET, after shared Origin/session/applicable unsafe CSRF checks. No PATCH/DELETE response operation. Frontend proposed routes `/surveys/:id/respond` and `/surveys/:id/submission` must be adopted with F-02 navigation before affected code; unimplemented route placeholders do not satisfy these journeys.

3. Validation and normalization

Outer JSON is an object with only answers. Each entry has only questionId and value; maximum ten entries, unique canonical question IDs. Extra role/studentId/ownerId/userId/type fields or query keys are rejected rather than ignored. JSON string ratings, booleans, arrays, objects, null, nonfinite/fractional/out-of-range values are never coerced into a score. A JSON number written as 1.0 is the numeric integer 1 after parsing.

RATING

Accepted value / normalization: Number, integer 1-5; required question must occur. Optional omitted means no answer; no implicit zero or first radio selection.

TEXT

Accepted value / normalization: String <=2,000 Unicode code points before normalization; reject unpaired UTF-16 surrogates and U+0000 before SQL. Required value must contain non-whitespace content using String.trim() only for the blank check. Preserve the nonblank original text, including surrounding spaces/newlines/composition, for own readback and F-05 comments.

Optional blank TEXT

Accepted value / normalization: If within input limits but trim() is empty, normalize to no stored answer. An over-limit blank string still violates the decoded limit. Omission is preferred.

Unknown/duplicate/wrong-survey question

Accepted value / normalization: 422 INVALID_ANSWERS with safe indexed field reason; never reveal another survey's question content/existence.

Required and whole-response completeness

Accepted value / normalization: Validate every required frozen question; at least one nonempty valid answer after normalization, even if all questions are optional. Empty array or all optional blanks rejected.

Transport: maximum **262,144 encoded bytes**, no smaller global parser in front of this route, application/json with optional UTF-8 charset, no compressed content. Measure streamed bytes regardless of Content-Length; 262,145 is 413 BODY_TOO_LARGE; unsupported encoding/type is 415 UNSUPPORTED_CONTENT. Byte and decoded limits are independent. Malformed JSON is 400 MALFORMED_JSON. Raw body/validation input is not logged or echoed in errors.

BASE-03 envelope bounds: fixed keys, at most ten 36-character UUIDs, no arbitrary metadata. Ten maximum supplementary-character text strings using surrogate escapes consume 240,000 bytes; an 8,192-byte envelope reserve gives 248,192 <262,144. That is a conservative transport fixture; S1 publication still requires at least one rating, so ten TEXT questions do not become publishable. A maximum valid questionnaire (one rating plus nine 2,000-code-point texts) must also fit UTF-8 and escaped forms. Arbitrary padded/expanded serializations beyond the cap are not promised acceptance. The reserve is a fixture/serializer bound, not a custom raw-JSON substring parser. Runtime boundary tests remain planned.

4. Authoritative transaction, concurrency and recovery

After shared perimeter/auth/CSRF/method/role and syntactic path/body validation, begin a short PostgreSQL transaction. Resolve/lock the scoped Survey using `FOR UPDATE OF Survey` with frozen eligibility and non-Draft visibility; do not acquire a broad unscoped foreign Survey lock first. F-03 close and all definition/publication transitions use the same Survey row. No password hashing, external calls or UI rendering inside this transaction.

Under that lock, use this order: scoped access -> PUBLISHED state -> IDENTIFIED mode -> existing Participation -> question/type/required semantic validation -> Participation insert -> identified ResponseBundle insert -> typed Answers insert -> commit. Thus a well-shaped repeated request after Closed returns 409 INVALID_STATE; on an eligible Published survey an already-submitted caller gets 409 RESPONSE_ALREADY_SUBMITTED before semantic answer validation. Syntactically malformed requests may be rejected earlier. Test each isolated case with otherwise valid inputs, plus explicit mixed-invalid precedence cases.

Exactly one transaction may create Participation(surveyId,studentId); DB uniqueness also protects against a missed precheck. A rejected duplicate creates no second bundle/answers and never returns 201. Database uniqueness errors are mapped only for the recognized participation/identified-bundle conflict, not arbitrary SQL errors. Every inserted row commits together or rolls back together, including injected failures after each insert phase.

Close/submit ordering is BR-11: close obtains the row lock and commits first -> waiting submit rejects Closed with no response; submit obtains/commits first -> close subsequently includes it. Arrival time/client timestamps do not decide the winner. Use deterministic barriers and two actual DB connections to prove both orders. No optimistic UI success, in-memory lock or sequential-only test proves this race.

Use bounded DB waits (proposed lock wait 3 seconds) and no automatic retry of non-idempotent POST. Recognized lock timeout/deadlock/serialization/unavailability rolls back where outcome is known, then returns safe 503 SERVICE_UNAVAILABLE; unexpected failure is 500 INTERNAL_ERROR. If commit acknowledgement is lost, do not claim rollback or success from a timeout alone: reconnect and GET own status. The immutable one-submission key prevents a deliberate second attempt from creating another response. Finalize actual Prisma/SQL timeout handling with #16 before code.

GET own status uses a single consistent SQL statement or read-only REPEATABLE READ snapshot for state/eligibility/Participation/bundle/answers. It does not lock the Survey exclusively or modify anything. A read during submission may legitimately show false from the earlier snapshot; recheck after the submit completes. Participation true but absent/mismatched identified bundle, or a bundle without expected participation, is an integrity failure (safe 500), not a false empty answer or exposure of another user. No product repair endpoint is introduced.

5. Data contract and migration ownership

#16 authors one additive migration/seed history. F-04 specifies the following constraints/services; no migration or domain schema is implemented by this document or #15 tooling probes.

SurveyEligibility

Required invariant: PK/unique(surveyId,studentId), Survey/User FKs, frozen after publication. Service verifies eligible account role during publication.

Participation

Required invariant: PK(surveyId,studentId), composite FK to SurveyEligibility with RESTRICT for referenced deletion; authoritative own submitted boolean. No bundle ID or per-submission timestamp.

ResponseBundle

Required invariant: UUID id PK; surveyId; identifiedStudentId nullable in baseline storage for later modes. In S1 IDENTIFIED service requires the trusted nonnull actor ID before insert; composite FK(surveyId,identifiedStudentId) to eligibility; unique(surveyId,identifiedStudentId), unique(surveyId,id). No precise submission timestamp.

Answer

Required invariant: Composite PK/unique(bundleId,questionId); surveyId; ratingValue integer nullable/textValue text nullable. Composite FKs(surveyId,bundleId) and (surveyId,questionId) target matching bundle/question unique pairs. Exactly one typed value; rating CHECK 1-5; text length CHECK <=2,000 characters where supported.

Cross-table/type/completeness

Required invariant: Backend transaction checks S1 nonnull identified user, role/eligibility, stored Question.type, same survey, required answers and nonempty normalized response. SQL CHECKs must not query other tables. #16 must explicitly review how mode-aware rules are enforced; nullable storage alone is not privacy or validation.

No separate response-edit state/table, Participation -> bundle relation or response timestamp is added as an anonymous shortcut. Do not relabel these identified rows anonymous later. Preserve the existing F-03 frozen scale/IDs and F-05 unlabelled text projection; F-04 writes no summary rows. Any later anonymous design is F-06's reviewed schema/privacy work.

Safe fixtures: two owners in distinct Sections of one Course, two eligible respondents, one ineligible respondent, Published/Closed/Draft surveys, required/optional rating/text, known non-BMP and whitespace text, multiple lecture submissions and controlled race fixtures. Use a dedicated allowlisted PostgreSQL test DB; never reset dev/deployed DBs or seed on startup. Real schema/persistence checks wait for #16; the current #15 tooling probe is not evidence for these constraints.

6. Exact errors and UI states

Use `{ "error": { "code": "CODE", "message": "safe text" } }`; optional fields use allowed paths such as answers[0].value or _form, never submitted answer values/other-user IDs. Shared error/precedence inheritance is F-01/F-03's reviewed perimeter; F-04's INVALID_ANSWERS/duplicate/state details are proposed coordinated additions under #5.

401 AUTH_REQUIRED / SESSION_EXPIRED

Condition / persistent effect: F-01 distinction above; no domain mutation, clear private client content.

403 ORIGIN_FORBIDDEN / CSRF_INVALID / FORBIDDEN_ROLE

Condition / persistent effect: Invalid origin/token or OWNER on respondent-only route; no data leak/write.

404 NOT_FOUND

Condition / persistent effect: Missing/ineligible/Draft resource with valid path syntax; same outward shape.

405 METHOD_NOT_ALLOWED

Condition / persistent effect: Unsupported method after shared checks; Allow header, no write.

409 INVALID_STATE / MODE_NOT_SUPPORTED / RESPONSE_ALREADY_SUBMITTED

Condition / persistent effect: State/mode/duplicate in documented order; no partial or second response.

422 INVALID_REQUEST / INVALID_ANSWERS

Condition / persistent effect: Syntactic/schema/unknown keys/UUID versus question/type/required/range/Unicode/completeness failure; safe fields.

400 MALFORMED_JSON / 413 BODY_TOO_LARGE / 415 UNSUPPORTED_CONTENT

Condition / persistent effect: Transport/parser failure before persistence; no body echo.

503 AUTH_SERVICE_UNAVAILABLE

Condition / persistent effect: Shared session/trusted User store unavailable before domain handling; no fallback.

503 SERVICE_UNAVAILABLE / 500 INTERNAL_ERROR

Condition / persistent effect: Domain DB/lock failure or unexpected/integrity failure. Known failures roll back; uncertain commit outcome uses own-status recovery rather than fabricated success/rollback.

UI uses existing cool-theme tokens/light components, single-column form, labelled native rating radios and textarea, required explanation, explicit Clear answer on optional rating, no default score. Show frozen endpoint labels and interpretation; higher is not automatically better. Count Unicode code points; HTML maxlength alone counts UTF-16 units and cannot be the only supported-text validator. Keep nonblank text plain/escaped on own readback, never HTML.

Loading/empty/denied/Closed/submitted/error states are distinct. Disable double-click while request pending; announce progress and show success only after committed API confirmation. On 422 keep entered values, focus an error summary/field links. On recoverable network/server error preserve memory-only inputs and resolve uncertain status; no local/session-storage drafts. On 401/logout clear private fields/cache, return to login and do not promise unsent draft restoration. On a confirmed prior submission show saved immutable answers and no edit/resubmit button. Late responses after logout/account/survey change must not restore stale private content. Selected UI checks cover keyboard/focus and 360px/1280px layouts; no full accessibility-compliance claim.

7. Stable acceptance criteria

All cases in the STS (f-04-responses-sts.md) are Planned / Not run; the #15 tooling checks do not execute these AC.

AC-F04-01

Observable outcome: Eligible Published identified survey renders F-03 frozen definitions/disclosure and current own status, without creating another definition API.

Planned STS IDs: TEST-F04-H01, E01

AC-F04-02

Observable outcome: Required/optional ratings are strict integers 1-5, with no default/coercion/optional zero; missing required rejects.

Planned STS IDs: TEST-F04-U01, I02, I03, E02

AC-F04-03

Observable outcome: Text preserves valid nonblank content, enforces code-point/blank/NUL/surrogate rules and normalizes bounded optional blank to absence.

Planned STS IDs: TEST-F04-U02, I04, E02

AC-F04-04

Observable outcome: Unknown/duplicate/wrong-survey IDs, wrong type and empty normalized response reject without partial persistence.

Planned STS IDs: TEST-F04-U03, U05, I05, I06

AC-F04-05

Observable outcome: 256 KiB byte/compression/parser and decoded limits are independent; supported UTF-8/escaped maximum fits and oversized request writes nothing.

Planned STS IDs: TEST-F04-I07

AC-F04-06

Observable outcome: Actor is server-resolved; guest/wrong-role/spoofed identity cannot submit/read for another account.

Planned STS IDs: TEST-F04-I08, I17

AC-F04-07

Observable outcome: Frozen eligibility controls both endpoints despite later Membership changes; Draft/ineligible/missing remains hidden.

Planned STS IDs: TEST-F04-I09

AC-F04-08

Observable outcome: Closed/non-Published requests never create a response; documented state/duplicate precedence holds.

Planned STS IDs: TEST-F04-I10, I11

AC-F04-09

Observable outcome: Valid POST commits one Participation/bundle/all normalized typed answers and returns only persisted own data in question-position order.

Planned STS IDs: TEST-F04-U06, I01

AC-F04-10

Observable outcome: Sequential repeat returns duplicate conflict without second/changed response.

Planned STS IDs: TEST-F04-I11

AC-F04-11

Observable outcome: Concurrent same-student submit produces exactly one success/committed bundle; loser safely rejected.

Planned STS IDs: TEST-F04-I12

AC-F04-12

Observable outcome: Invalid item or forced failure at each write phase leaves no partial rows or success confirmation.

Planned STS IDs: TEST-F04-I02, I13

AC-F04-13

Observable outcome: Real Survey lock order determines close-first rejection versus submit-first inclusion; no timestamp/arrival shortcut.

Planned STS IDs: TEST-F04-I14, I15, H01

AC-F04-14

Observable outcome: Frozen definitions/required flags/scale are consumed without update; no response edit/delete/reopen operation exists.

Planned STS IDs: TEST-F04-H01, I18

AC-F04-15

Observable outcome: Own false/true status and persisted identified answers survive closure/logout-login/restart; consistent read does not fabricate integrity recovery.

Planned STS IDs: TEST-F04-I16, E01

AC-F04-16

Observable outcome: Other-student lookup, forged query/body identity and owner respondent-linked access are denied without leakage.

Planned STS IDs: TEST-F04-I17, I21

AC-F04-17

Observable outcome: UI pending/confirmation/readonly states reflect real API outcomes; no duplicate UI POST or premature success.

Planned STS IDs: TEST-F04-E01, E02

AC-F04-18

Observable outcome: Ambiguous acknowledgement queries own persisted status before deliberate retry; no automatic response resend.

Planned STS IDs: TEST-F04-I20, E03

AC-F04-19

Observable outcome: Auth/Origin/CSRF/method/schema/state errors match exact codes/precedence with no database/internal/input exposure.

Planned STS IDs: TEST-F04-U04, I10, I18, I20

AC-F04-20

Observable outcome: Private response data is absent from caches/storage/logs/other-user payloads; expiry/logout removes stale client content.

Planned STS IDs: TEST-F04-I21, E04

AC-F04-21

Observable outcome: Reviewed real schema enforces relevant FK/unique/range/typed-column invariants with atomic backend cross-table checks.

Planned STS IDs: TEST-F04-I19

AC-F04-22

Observable outcome: Unsupported mode never stores or reveals an identified/anonymous fallback; no extra student-linked anonymous retrieval.

Planned STS IDs: TEST-F04-I10

AC-F04-23

Observable outcome: F-02 participation flag and F-05 count/denominator/text projections match actual committed normalized rows.

Planned STS IDs: TEST-F04-H02, H03

AC-F04-24

Observable outcome: Accepted contract/STS/DoD, real meaningful RED/GREEN, mapped outcomes, opposite-member review/integration and limitations precede feature Done.

Planned STS IDs: TEST-F04-M02

AC-F04-25

Observable outcome: Core form/readback/errors support labelled keyboard/focus and narrow/wide layouts with truthful identified disclosure.

Planned STS IDs: TEST-F04-E01, E02, E04, M01

8. DoD, history and coordination gates

Product DoD DOD-01-DOD-10 apply to the implemented feature; DOD-11/12 are integrated release/PDF gates. Before #20, version/review this contract+STS, adopt the proposed F-04 wire/error/normalization/UI-route agreements with #5/#11/#12/#14 and verify applicable #15/#16 plus #17-#19 foundations. A contract-only PR can complete documentation scope without claiming executed app tests; real feature acceptance requires implementation, actual unit/API-real-DB/selected UI results, safe setup, substantive opposite-member review/integration and disclosed gaps.

Meaningful TDD targets: normalized required/completeness rule, atomic rollback/one response under concurrent submission, close/submit lock order and own-user projection. Retain actual intended-behavior RED before correction and GREEN afterward with real test files/names/commands/versions/results; no import-error substitute, weakened assertion or retroactive fabricated commits. Record failure/skip counts, tested implementation SHA/schema/lockfile and safe output when executed. No code or test execution is performed by this specification.

F-03 definition, eligibility and Survey lock

Owner / actual next artifact: #12/#13/#16: adopt the same committed frozen IDs/scales/disclosure and FOR UPDATE row ordering; no separate lock authority.

F-02 own status/navigation

Owner / actual next artifact: #11/#13: agree routes and EXISTS Participation meaning; late list/status UI cannot grant access.

F-05 data/projection

Owner / actual next artifact: #13/#14: nonblank original text, absent optional answers, typed rows and no identity-aligned owner arrays; actual H03 when both features run.

Shared protocol/error/limits

Owner / actual next artifact: #5/#10/#13: adopt exact 201/200 payloads, INVALID_ANSWERS/duplicate/state precedence, Unicode/byte/parser policy and safe failures. Existing auth codes unchanged.

Schema/native timeout/read consistency

Owner / actual next artifact: #16/#13: review composite keys/FKs, nullable storage versus S1 service invariant, constraints, indexes, wait/fault mapping and real Postgres fixtures before writing migrations/services.

Human acceptance/evidence

Owner / actual next artifact: Actual opposite-member review and accepted source versions pending. Existing #15 smoke results cannot fill these F-04 result fields.

These unresolved agreements block their dependent code, not contract drafting or bounded tooling setup. Update shared register/traceability after actual review; do not mark #5 or #20 complete from this draft.

docs/sprints/sprint-1/f-04-responses-sts.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-04 - Response Software Test Specification

Version 0.1, 2026-11-07. Paired contract (f-04-responses.md), Issue #13, later implementation #20. Every case is **Planned / Not run**; current #15 tooling checks are unrelated to F-04 acceptance. There are 25 stable AC and 36 planned cases: 6 unit, 21 API/real DB, 4 selected browser, 3 dependent integrations and 2 supplementary/process checks. Parameterization may produce different actual runner counts.

Fixtures: isolated allowlisted PostgreSQL DB with reviewed #16 schema; real F-01 OWNER/RESPONDENT sessions/token jars; two owners/Sections of one Course, two eligible students, ineligible student, Draft/Published/Closed contexts, required/optional rating/text, controlled Unicode values and deterministic two-connection race barriers. Hashes/cookies/tokens/raw answer content are excluded from retained logs/screenshots. Fault injection/test clocks stay private to test composition, never public endpoints. Inspect actual row counts/typed values after every rejection/rollback, not just status codes.

Planned files after authorized implementation: `apps/api/tests/responses.unit.test.ts`, `apps/api/tests/responses.integration.test.ts`, `tests/e2e/responses.spec.ts`; these files do not exist from writing this STS. #15 defines actual runners; #20/#22/#23 later record real source/test names, command/date/environment/schema/lockfile, tested SHA, expected/observed result, pass/fail/skip counts and safe output. M checks remain separate from automated counts.

Unit cases

TEST-F04-U01

Linked AC: AC-F04-02

Preconditions / input: Frozen required/optional RATING; values missing/1/5/0/6/1.5/string/boolean/null

Action: Validate actual production normalizer

Expected outcome: Only actual integers 1-5 accepted; missing optional absent, missing required rejects; no coercion/default.

TEST-F04-U02

Linked AC: AC-F04-03

Preconditions / input: Required/optional TEXT; 0/1/2000/2001 code points, non-BMP characters, spaces/newlines, NUL/unpaired surrogate

Action: Normalize/check actual text helper

Expected outcome: Valid original nonblank text preserved; required blank rejects; bounded optional blank omitted; over-limit/invalid Unicode rejects independently.

TEST-F04-U03

Linked AC: AC-F04-04

Preconditions / input: Repeated/unknown/wrong-survey question IDs, wrong typed values, arbitrary keys

Action: Validate against frozen question map

Expected outcome: Safe indexed invalid-answer/request errors; no foreign question value/existence leakage or partial normalized success.

TEST-F04-U04

Linked AC: AC-F04-19

Preconditions / input: Internal SQL/constraint/answer markers and expected known conflicts

Action: Map safe domain errors

Expected outcome: Exact allowed code/status/field paths; no private input/SQL/stack/cookie markers. Unknown errors do not become duplicate success.

TEST-F04-U05

Linked AC: AC-F04-04

Preconditions / input: All optional questionnaire; [], blank TEXT only, one valid rating/text plus blanks

Action: Normalize and apply completeness

Expected outcome: Zero nonempty answers rejects; one valid nonempty answer accepted with blanks omitted, required map still enforced.

TEST-F04-U06

Linked AC: AC-F04-09

Preconditions / input: Input answer order differs from frozen positions; optional omitted questions

Action: Build safe own projection

Expected outcome: Stored answers returned in question-position order, exact questionId/value only; no bundle/user/time fields or invented missing values.

API / real PostgreSQL cases

TEST-F04-I01

Linked AC: AC-F04-09

Preconditions / input: Eligible R-A, Published IDENTIFIED, valid rating/text plus optional blank, actual schema/session

Action: POST then inspect all related rows/own readback

Expected outcome: 201 only after one atomic commit; exactly one participation/bundle, correct typed nonblank answers, no optional-blank row; safe ordered own payload.

TEST-F04-I02

Linked AC: AC-F04-02, AC-F04-12

Preconditions / input: Valid-shaped response missing/blank required item alongside valid answers

Action: POST, compare before/after DB state

Expected outcome: 422 INVALID_ANSWERS; no participation/bundle/answer changes or success confirmation.

TEST-F04-I03

Linked AC: AC-F04-02

Preconditions / input: Frozen RATING with wrong scalar types/range/fraction and boundaries 1/5

Action: POST each otherwise valid request

Expected outcome: Invalid values reject without rows; 1/5 accepted in independent clean eligible fixtures. No implicit conversion.

TEST-F04-I04

Linked AC: AC-F04-03

Preconditions / input: TEXT boundaries/whitespace/non-BMP/NUL/unpaired-surrogate cases

Action: POST and GET own answers

Expected outcome: Code-point bound/blank policy enforced before SQL; valid raw text round-trips exactly, no 500 cast/encoding shortcut or truncation.

TEST-F04-I05

Linked AC: AC-F04-04

Preconditions / input: Unknown, duplicated or another survey's question IDs

Action: POST with valid auth/eligibility

Expected outcome: 422 INVALID_ANSWERS, safe fields only; no foreign metadata or partial rows.

TEST-F04-I06

Linked AC: AC-F04-04

Preconditions / input: Array/null top level, extra role/studentId/type keys, >10 answers, empty/all-optional blanks

Action: POST each schema/completeness case

Expected outcome: INVALID_REQUEST versus INVALID_ANSWERS per contract, no ignored spoof fields or write.

TEST-F04-I07

Linked AC: AC-F04-05

Preconditions / input: Chunked/no Content-Length body fixtures, exact 262144/262145 bytes, maximum valid UTF-8/escaped content, unsupported compression/type, malformed JSON

Action: Send through actual route parser/proxy

Expected outcome: Bound accepted by transport when otherwise valid; +1 byte 413, encoding/type 415, syntax 400; decoded 2001 still rejects under cap; no persistence on rejection. Conservative ten-text transport fixture does not make text-only publication valid.

TEST-F04-I08

Linked AC: AC-F04-06

Preconditions / input: Guest/forged/revoked/expired sessions, OWNER, RESPONDENT and fake client identity claims

Action: Direct POST/GET with otherwise valid request

Expected outcome: 401 AUTH_REQUIRED/SESSION_EXPIRED, 403 FORBIDDEN_ROLE as specified; trusted RESPONDENT only, no actor elevation/write for another student.

TEST-F04-I09

Linked AC: AC-F04-07

Preconditions / input: Published snapshot eligible R-A then membership removed; newly enrolled R-B not in snapshot; Draft/missing fixtures

Action: Read own status/submit each identity/state

Expected outcome: Frozen R-A access remains; R-B/Draft/missing 404 same shape, no hidden definition or write; no membership-only authorization.

TEST-F04-I10

Linked AC: AC-F04-08, AC-F04-19, AC-F04-22

Preconditions / input: Scoped eligible Closed/Published surveys, existing participation, unsupported mode fixture and semantically invalid answer

Action: POST in documented mixed-invalid order; GET unsupported mode

Expected outcome: State before mode/duplicate/semantic validation, scoped Draft/ineligible hidden first; exact 409 INVALID_STATE/MODE_NOT_SUPPORTED, no identified fallback/write/data leak.

TEST-F04-I11

Linked AC: AC-F04-08, AC-F04-10

Preconditions / input: One committed response, Published then Closed in separate parameter cases

Action: Repeat POST and inspect persisted content/counts

Expected outcome: Published repeat 409 RESPONSE_ALREADY_SUBMITTED, Closed repeat 409 INVALID_STATE; exactly original rows/content remain.

TEST-F04-I12

Linked AC: AC-F04-11

Preconditions / input: Same eligible student, Published survey, two real DB connections/simultaneous valid requests

Action: Barrier-release concurrent POSTs, inspect final state

Expected outcome: Exactly one 201, one safe duplicate conflict; one participation/bundle/answer set and no partial loser state.

TEST-F04-I13

Linked AC: AC-F04-12

Preconditions / input: Force failure after participation, bundle and answer insertion in separate real transaction cases

Action: POST under controlled fault injection then inspect DB

Expected outcome: Whole transaction rolls back, no success/partial rows; valid retry can still submit once. Failure hooks not shipped as public routes.

TEST-F04-I14

Linked AC: AC-F04-13

Preconditions / input: F-03 Close holds same Survey row and commits before waiting submit

Action: Release close/submit in deterministic order

Expected outcome: Close succeeds; submit rejects Closed, no response; no arrival-time/timestamp guess.

TEST-F04-I15

Linked AC: AC-F04-13

Preconditions / input: Submit holds same Survey row, close waits

Action: Commit submit then close, read closed data

Expected outcome: One committed response included after closing, no split state; both use actual DB lock/transaction behavior.

TEST-F04-I16

Linked AC: AC-F04-15

Preconditions / input: Eligible unsubmitted/submitted fixtures and real identity; no reseed during restart

Action: GET false, submit, GET true; close, logout/login, stop/restart app against same DB; inject inconsistent fixture separately

Expected outcome: Correct immutable own readback through valid states/restart; no GET mutation; malformed participation/bundle integrity gives safe 500, not another user's/empty fabricated answer.

TEST-F04-I17

Linked AC: AC-F04-06, AC-F04-16

Preconditions / input: Two respondents' real submissions plus owner session

Action: Try userId/studentId query/body/header, foreign survey, unsupported cross-response selection

Expected outcome: No cross-user lookup or ownership leak; extra keys rejected, own actor unchanged, owner role denied.

TEST-F04-I18

Linked AC: AC-F04-14, AC-F04-19

Preconditions / input: Shared auth/Origin/CSRF fixtures; unsupported PATCH/DELETE/POST-on-read; missing versus loaded-expired session

Action: Direct requests through actual middleware

Expected outcome: Exact shared codes, no write from unsupported method or stale token, Allow correct; no response edit/delete or session renewal.

TEST-F04-I19

Linked AC: AC-F04-21

Preconditions / input: Real reviewed schema, safe direct SQL fixtures for unique/FK/typed-column/range constraints

Action: Attempt duplicate participation/bundle, cross-survey question/bundle, two typed values, out-of-range rating

Expected outcome: Expected DB constraints fail; service additionally enforces cross-table type/required/mode semantics. Do not claim a cross-table CHECK exists.

TEST-F04-I20

Linked AC: AC-F04-18, AC-F04-19

Preconditions / input: Controlled DB unavailability/lock timeout/deadlock and lost HTTP/commit acknowledgement

Action: Submit, restore DB/read own status before deliberate retry

Expected outcome: Safe 503/500, known failure rollback; uncertain commit reconciles to actual saved/not-saved state. No auto POST retry or second response.

TEST-F04-I21

Linked AC: AC-F04-16, AC-F04-20

Preconditions / input: User-specific text/ID markers and safe log spy; another user's/owner-facing call

Action: Inspect responses/cache/logs and rejected access

Expected outcome: Exact own allowlist/no-store; no unrelated user/bundle/time/session fields, logged body/raw feedback or private data in denials.

Selected browser / dependent integration / supplementary checks

TEST-F04-E01 / UI-E2E

Linked AC: AC-F04-01, AC-F04-15, AC-F04-17, AC-F04-25

Preconditions / input: Real browser/session/API/DB, Published eligible survey, 360px/1280px

Action: Discover, read disclosure/scales, answer, double-click while delayed, submit/reopen after login

Expected outcome: No default rating or premature success/duplicate UI POST; persisted readonly own answers and usable narrow/wide layout.

TEST-F04-E02 / UI-E2E

Linked AC: AC-F04-02, AC-F04-03, AC-F04-17, AC-F04-25

Preconditions / input: Required/optional questions and validation errors

Action: Keyboard fill, clear optional rating, submit invalid then corrected text/score

Expected outcome: Error summary/field focus, entered values preserved on 422, optional answer omitted, code-point counter correct, no persistent answer draft or fake success.

TEST-F04-E03 / UI-E2E

Linked AC: AC-F04-18

Preconditions / input: Real commit succeeds but acknowledgement is lost, and separate known-not-committed failure case

Action: Observe timeout, check own status, deliberately retry only if not submitted

Expected outcome: Saved outcome wins over local timeout; no background resend or duplicate; recoverable unsent inputs remain memory-only.

TEST-F04-E04 / UI-E2E

Linked AC: AC-F04-20, AC-F04-25

Preconditions / input: Open form/private readback; session expiry/logout/account switch; delayed fetch

Action: Trigger 401/logout, navigate, release delayed response

Expected outcome: Private data cleared/hidden; stale response cannot restore it; safe login/session-ended message, no recovery promise.

TEST-F04-H01 / actual F-03 integration

Linked AC: AC-F04-01, AC-F04-13, AC-F04-14

Preconditions / input: Reviewed F-03/#19 and F-04 real schema/routes

Action: Read frozen definition/scales/disclosure after publish, run both lock orders and forbidden definition edits

Expected outcome: Same immutable IDs/type/required/scale and Survey lock authority; submission never edits definition; actual routes, not mock lock harness.

TEST-F04-H02 / actual F-02 integration

Linked AC: AC-F04-23

Preconditions / input: Real discovery + response transaction

Action: Compare F-02 submitted flag before/after commit/failure and refreshed state

Expected outcome: Exactly EXISTS own Participation, no premature true or roster/answer join.

TEST-F04-H03 / actual F-05 integration

Linked AC: AC-F04-23

Preconditions / input: Known committed responses including optional blanks and original text

Action: Close/read real owner results

Expected outcome: Correct responseCount/per-question denominators/bins/mean input, absent blanks and preserved unlabelled text; no identified-student join/rows in owner projection.

TEST-F04-M01 / manual UI

Linked AC: AC-F04-25

Preconditions / input: Actual implementation SHA, form/errors/readback and keyboard

Action: Inspect labels/radio keys/clear/error-focus/plain-text rendering/wrapping at specified widths

Expected outcome: Record actual observations/defects; supplements automated UI, no blanket accessibility compliance.

TEST-F04-M02 / process audit

Linked AC: AC-F04-24

Preconditions / input: Accepted contract/STS/DoD/schema/interface records and later actual implementations/results

Action: Verify precode sequence, intended RED/GREEN, complete AC mapping, reviewer/integration and disclosed failures/skips

Expected outcome: Real files/commands/SHAs/results only; missing evidence remains pending, no AI self-approval or feature claim of final release/PDF completion.

TDD targets: required/normalization completeness; atomic rollback/once-only concurrency; close/submit order; safe own projection. Preserve actual intended-behavior failures before implementation/correction and later passing versions/output. A runner/import failure is not rule evidence. Real API/DB/browser tests cannot be replaced by #15 liveness/driver smoke checks, and unit mocks do not prove durability or ownership. Resolve the paired contract's final coordination gates before dependent code; no AC is marked passed here.

docs/sprints/sprint-1/f-05-results.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-05 - Identified Aggregate Results and Privacy Projections

Version 0.2 · 2026-11-07 · Issue #14 · Sprint 1 · **Proposed engineering contract; not implemented or accepted.**

1. Purpose, scope and source status

Specify the Survey Owner's results view before implementing F-05: count only while Published; frozen per-question rating aggregates and identified text comments after Closed. Results are derived from committed responses, never independently editable records. The paired STS (f-05-results-sts.md) contains planned checks, not execution evidence.

Sources: SRS (../../srs.md) §§2-7, Feature Inventory (../../features.md) F-05, Traceability (../../traceability.md), System SDS (../../system-sds.md) §§2-6,11,13-15, decisions (../../decisions.md), Sprint Plan (../plan.md) §2, tracker (tracker.md) §§2-4 and workflow (workflow.md) §§3-8. The supplied Issue #14 attachment defines this task. The remote Issue page was unavailable; no additional remote checklist is assumed.

PR #29 has merged into the current staging baseline. Use its local shared conventions (shared-contract.md), F-01 contract (f-01-authentication.md), Product DoD (product-dod.md) and contract register (README.md), together with the local F-02 contract (f-02-context-discovery.md), rather than the earlier PR #29 proposal snapshot. Authentication errors and phased Issue #16 dependencies follow these staging sources and the Tracker. Resolve remaining F-05-specific agreements in §12 against the reviewed adjacent contracts before dependent code; this source alignment does not establish F-05 implementation, executed verification or teammate acceptance.

Scope excludes anonymous collection/suppression policies, single-choice, CSV/export, filters/history/trends, overall instructor scores, Teaching Improvement Notes, response retrieval/submission and lifecycle mutations. BR-16 is covered by identity-free identified comments and keeping this JSON view distinct from future aggregate-only export. This feature does not implement the later export/privacy extensions.

2. Requirement traceability

FR-07

F-05 obligation and boundary: Authorized Published count; Closed per-question aggregates and identified comments, no respondent-linked answers

Acceptance criteria: AC-F05-01-14,18

BR-02

F-05 obligation and boundary: Owner-only endpoint, canonical ownership, same-Course isolation, no respondent-linked records

Acceptance criteria: AC-F05-04-05,12,14

BR-12

F-05 obligation and boundary: Per-question answered denominator; five bins, exact mean, two decimals, null/no-data

Acceptance criteria: AC-F05-06-10

BR-13

F-05 obligation and boundary: Published count only; Closed identified results without minimum-count suppression

Acceptance criteria: AC-F05-01-03,10,21

BR-14

F-05 obligation and boundary: Truthful IDENTIFIED notice; no anonymity promise; F-04 owns the pre-answer disclosure

Acceptance criteria: AC-F05-11-14,18,21

BR-16

F-05 obligation and boundary: Identified plain text only in authorized Closed results; no identity fields/export route; no anonymous text fallback

Acceptance criteria: AC-F05-12-14,21

NFR-01

F-05 obligation and boundary: F-01 trusted identity, backend authorization, safe errors/logs/cache and output encoding

Acceptance criteria: AC-F05-04-05,13-14,16,19

NFR-02

F-05 obligation and boundary: Derived consistent reads survive application restart; close/submit handoff preserves committed data

Acceptance criteria: AC-F05-15,17,22

NFR-05

F-05 obligation and boundary: Stable AC and bidirectional planned STS; actual results/review/history remain later evidence

Acceptance criteria: AC-F05-22 and every mapped case

NFR-07

F-05 obligation and boundary: Labelled accessible values, keyboard and visible states at 360px/1280px

Acceptance criteria: AC-F05-18-20

3. Actors, ownership and lifecycle

F-01 supplies an authenticated User ID and a freshly trusted OWNER role; no body, query or header may choose an actor. Authorization follows `Survey → Lecture → Section.ownerId = session.userId`. Sharing a Course grants no permission to another Section. Server-derived redundant Survey.ownerId must agree with the canonical Section ownership, but it is not a replacement for this predicate. Section ownership transfer is outside the baseline.

Missing, forged, revoked or invalid-state session, missing/invalid User, or expired session whose row is missing/pruned

Result: 401 AUTH_REQUIRED after the shared Origin perimeter

Loaded authenticated session identifiable at/past its absolute deadline

Result: 401 SESSION_EXPIRED after the shared Origin perimeter; missing/pruned expiry instead uses AUTH_REQUIRED

Authenticated RESPONDENT, including an eligible participant

Result: 403 FORBIDDEN_ROLE, before Survey lookup

OWNER; missing/inaccessible Survey

Result: Identical 404 NOT_FOUND; no existence/state/count disclosure

OWNER; own DRAFT

Result: 409 RESULTS_NOT_AVAILABLE; no response count, questions or fabricated zero statistics

OWNER; own PUBLISHED, IDENTIFIED

Result: 200 count-only projection (§4)

OWNER; own CLOSED, IDENTIFIED

Result: 200 full Closed projection (§4), including zero/small counts

OWNER; own unsupported mode, including ANONYMOUS fixture

Result: 409 MODE_NOT_SUPPORTED; no counts, comments or quantitative fallback

Check scoped existence before state/mode. For an owned record, reject DRAFT before unsupported mode; no future privacy mode can fall through the identified serializer. S1 does not add an anonymous threshold engine. GET neither closes a survey nor changes definitions, answers, eligibility or participation.

4. Owner API and response projections

4.1 Endpoint and inputs

One endpoint: **GET** `/api/surveys/:id/results`, OWNER only, no request body, no query parameters. `:id` is a canonical lowercase UUID string (proposed shared ID serialization). Reject every supplied query key, including ownerId, studentId, questionId, status, mode, sort, page, cursor and format, rather than silently ignoring an attempted alternate projection. No respondent answer lookup, student filter, separate comment detail URL or new discovery route is introduced.

Success is 200 with `{ "data": ... }`. Survey metadata is exactly `id,title,status,mode,context`, where safe context is `course:{id,code,title}`, `section:{id,courseId,term,sectionCode}`, `lecture:{id,title,lectureDate,sequence}`. Display strings remain untrusted text. IDs are UUID strings; sequence is a positive integer; lectureDate is the SDS's local calendar date serialized `YYYY-MM-DD`, never timezone-shifted. Confirm this proposed context serialization with F-02/#16. No owner account identifier, transition/submission timestamps, eligibility roster or definition provenance is included.

Published data has **only** `survey` and `responseCount`. Omit questions, means, distributions and comments entirely, not null/empty placeholders. Example (synthetic identifiers/context):

```
{
  "data": {
    "survey": {
      "id": "00000000-0000-4000-8000-000000000501",
      "title": "Lecture feedback",
      "status": "PUBLISHED",
      "mode": "IDENTIFIED",
      "context": {
        "course": {"id": "00000000-0000-4000-8000-000000000502", "code": "CPE334", "title": "Software Engineering"},
        "section": {"id": "00000000-0000-4000-8000-000000000503", "courseId": "
00000000-0000-4000-8000-000000000502", "term": "Demo term", "sectionCode": "A"},
        "lecture": {"id": "00000000-0000-4000-8000-000000000504", "title": "Demo lecture", "lectureDate": "
2026-11-07", "sequence": 1}
      }
    },
    "responseCount": 6
  }
}
```

4.2 Closed data and ordering

Closed data has exactly `survey,responseCount,questions`; survey has the same safe metadata with status CLOSED. Questions are the complete frozen definition in ascending stored position (maximum ten, not only answered questions). Each has `questionId,position,prompt,type,required,ratingScale`. Map questionId from Question.id; preserve it exactly. No Answer IDs are public.

RATING adds `answeredCount,distribution,mean`; ratingScale is `{min:1,max:5,minLabel,maxLabel,interpretation}` from the persisted publication snapshot. Distribution is an ordered five-element array `{score,count}` for scores 1-5, including zeros. Mean is null or an exact two-decimal **string**, e.g. `"3.50"`, avoiding JSON-number loss of trailing zeros. This wire representation and half-up rounding are F-05 proposals requiring shared acceptance (§12), not instructor-specified conventions.

TEXT has ratingScale null and adds only `comments`, an array of plain strings. It has no mean/distribution and no invented numeric scale. Return each nonblank persisted comment separately; preserve duplicates, line breaks and text content. Optional omitted/blank answers are absent under F-04's normalization rule, not empty cards. Sort per question by the stored string's UTF-8 byte sequence, equivalent to PostgreSQL `COLLATE "C"` on the UTF-8 database. Identical strings are indistinguishable ties; retain every occurrence. This does not order by person, bundle or time, and does not correlate comments across different questions. No server comment IDs or response-aligned arrays are exposed. A UI array position is merely a local rendering key, not a submission identity.

For S1 this one read returns all comments of the selected Closed survey, with no pagination, client-selected ordering or silent truncation. At most 2,000 code points per persisted text answer is F-04's limit. Do not impose an undocumented comment cap that loses valid feedback. Query/index verification remains necessary; later scaling work must preserve the same access/privacy policy rather than silently change the result shape.

Example Closed **question entries** inside `data.questions` (survey metadata/responseCount follow §4.1; responseCount is 6 for this fixture):


```
[
  {
    "questionId": "00000000-0000-4000-8000-000000000511",
    "position": 1,
    "prompt": "How clear was the content?",
    "type": "RATING",
    "required": true,
    "ratingScale": {"min": 1, "max": 5, "minLabel": "Not clear", "maxLabel": "Very clear", "interpretation": "Higher
means clearer content."},
    "answeredCount": 6,
    "distribution": [{"score": 1, "count": 1}, {"score": 2, "count": 1}, {"score": 3, "count": 1}, {"score": 4, "
count": 1}, {"score": 5, "count": 2}],
    "mean": "3.33"
  },
  {
    "questionId": "00000000-0000-4000-8000-000000000512",
    "position": 2,
    "prompt": "Suggestions",
    "type": "TEXT",
    "required": false,
    "ratingScale": null,
    "comments": ["Clear examples", "Same feedback", "Same feedback"]
  }
]
```


Construct explicit allowlisted representations; do not return broad ORM rows and strip fields only in React. No names, avatars, student/respondent IDs, Membership/Eligibility/Participation rows, ResponseBundle/Answer IDs, sessions or timestamps appear anywhere in owner JSON, HTML, hidden DOM/data attributes or client storage. Per-score counts are aggregates; text content is intentionally individual but unlabelled, not a respondent-linked answer record.

4.3 Errors, security and precedence

Use the baseline server-side session/absolute expiry and shared F-01 middleware; F-05 does not regenerate/extend sessions or implement login. Follow the staging shared/F-01 Origin rule: reject explicit foreign or `null` Origin with 403 ORIGIN_FORBIDDEN; protected same-origin safe GET may omit Origin and does not require a CSRF token. Unsupported unsafe methods still pass the shared Origin/session/applicable CSRF checks before 405; they must not become mutation handlers. No permissive CORS exception.

Order: shared Origin/transport checks → session → supported method/applicable CSRF → OWNER role → UUID/body/query validation → scoped Survey lookup → state/mode policy → result queries and serialization. Thus a Respondent's otherwise valid request is 403 without a lookup, an Owner's malformed UUID/query is 422, and a well-formed inaccessible ID is 404 regardless of its actual state. Do not leak Draft existence through a premature 409.

400 MALFORMED_REQUEST

Trigger: HTTP/transport syntax rejected by shared middleware

Response / effect: Safe error, no result data

401 AUTH_REQUIRED

Trigger: Missing, forged, revoked or invalid-state session, missing/invalid User, or missing/pruned expired session row

Response / effect: Clear private client data; login handoff

401 SESSION_EXPIRED

Trigger: Server identifies a loaded authenticated session at/past its absolute deadline; missing/pruned expiry instead uses AUTH_REQUIRED

Response / effect: Same private-state cleanup and login handoff

403 FORBIDDEN_ROLE / ORIGIN_FORBIDDEN / CSRF_INVALID

Trigger: Authenticated wrong role, Origin or applicable unsafe-method CSRF denial

Response / effect: No resource metadata; CSRF does not apply to supported GET

404 NOT_FOUND

Trigger: Missing or foreign-owner Survey

Response / effect: Same safe message: “Survey not available.”

405 METHOD_NOT_ALLOWED

Trigger: Unsupported method on results route after security checks

Response / effect: Allow: GET; no write

409 RESULTS_NOT_AVAILABLE

Trigger: Own Draft

Response / effect: Safe unavailable state, no counts/results

409 MODE_NOT_SUPPORTED

Trigger: Own non-identified Published/Closed survey

Response / effect: Fail closed, no anonymous fallback

422 INVALID_REQUEST

Trigger: Bad UUID, any body or query, malformed supported request shape

Response / effect: Safe fixed message/allowed field paths, no input echo

503 SERVICE_UNAVAILABLE

Trigger: Known database unavailability

Response / effect: No partial/previous result disguised as success; safe read retry

500 INTERNAL_ERROR / RESULTS_INCONSISTENT

Trigger: Unexpected failure / detected invalid persisted result invariants (§6)

Response / effect: No partial analytics; safe diagnostic class only

Envelope: `{ "error": { "code": "NOT_FOUND", "message": "Survey not available." } }`, optional `fields` only for safe validation paths. Never expose SQL, stack, connection strings, feedback, tokens or account values. Logs identify operation/correlation ID and safe error class, not request/response bodies, cookies or comments. Use the existing shared transport protections; this GET adds no request JSON parser or larger body allowance.

All protected success/error responses send `Cache-Control: private, no-store`; do not emit result ETags or 304 cached-result responses. Ignore conditional validators and perform normal authorization/read, or let a shared no-store policy do so consistently. Client requests/results stay out of persistent browser storage, service-worker caches and analytics payloads. Clear in-memory results on logout/session expiry, role/account/route changes and denial; never flash the previous survey's results while loading another.

5. Statistics and exact rounding

Let R be the number of committed Participation rows for this Survey. Unique (surveyId,studentId) makes `responseCount = R = COUNT(*)` equivalent to distinct submitted respondents. It is not eligibility size, bundle/answer count or current Section membership. No student IDs need be selected to compute it.

For each RATING question q, let c1…c5 count valid persisted rating answers of scores 1…5 belonging to q and this Survey's committed ResponseBundles. Then `N = answeredCount = c1+c2+c3+c4+c5`, `S = c1+2c2+3c3+4c4+5c5`, and the unrounded arithmetic mean is S/N when N>0. Missing optional answers contribute neither a row, a zero nor a denominator

increment. One response can answer multiple questions; it still contributes once to R. Do not join multiple question/comment rows into Participation before counting, which multiplies respondents.

When N=0: all five bins are zero and mean is null. Display “No responses yet” if R=0; otherwise “No answers to this question”. There is no minimum-count suppression for Closed identified results: N=1 is visible and uses its actual rating. RATING means never become 0, NaN or a dash pretending to be a number.

Proposed decimal half-up to two places, applied **once** to exact S/N: for N>0 compute integer hundredths `H = floor((200*S + N) / (2*N))`; format H/100 with exactly two fractional digits, without binary floating-point conversion before rounding. Use exact integer/BigInt or PostgreSQL numeric arithmetic through formatting; integer division of positive BigInts gives the specified floor. Do not use JavaScript `toFixed()` on an already approximated AVG or average separately rounded values. If counts cannot be represented safely in the JSON integer representation, fail safely rather than silently lose precision; this is not a new product capacity guarantee.

Scores 1,2,3,4,5,5

R / N / S: 6 / 6 / 20

Required mean: "3.33"

Purpose: Five bins 1,1,1,1,2

Optional scores 2,4,5; three omissions among those six participants

R / N / S: 6 / 3 / 11

Required mean: "3.67"

Purpose: Denominator is 3, not 6

Seven 1s and one 2

R / N / S: 8 / 8 / 9

Required mean: "1.13"

Purpose: Exact tie 1.125 rounds up

Thirteen 2s and twenty-seven 3s

R / N / S: 40 / 40 / 107

Required mean: "2.68"

Purpose: Exact tie 2.675; binary-float trap

219 ones, 31 twos (unit histogram fixture)

R / N / S: 250 / 250 / 281

Required mean: "1.12"

Purpose: 1.124 below tie

437 ones, 63 twos (unit histogram fixture)

R / N / S: 500 / 500 / 563

Required mean: "1.13"

Purpose: 1.126 above tie

One score 1 / one score 5

R / N / S: 1 / 1 / 1 or 5

Required mean: "1.00" / "5.00"

Purpose: Endpoints and trailing zeros

One participant answers TEXT only, optional rating omitted

R / N / S: 1 / 0 / 0

Required mean: null

Purpose: Valid response, no rating answers

No submissions

R / N / S: 0 / 0 / 0

Required mean: null

Purpose: Real empty Closed result

Results use each question's frozen meaning. A slow→fast pacing scale does not measure suitable→unsuitable pacing or overall teaching quality. Do not combine questions or surveys into an overall average, rank instructors, or infer comparability from the numeric 1-5 range.

6. Data, query and consistency responsibilities

Issue #16/SYS-01 owns schema, migration, indexes and fixtures. **No F-05-specific migration or persistent summary table is required by this design.** Implementation #21 owns read queries/serializers/UI. Schema prerequisites must be reviewed in #16 before code; do not create a competing Answer/Results model.

Survey.lectureId unique ☐ Lecture.sectionId ☐ Section.ownerId; Section ☐ Course

F-05 use / owner of writes: Scope selected Survey through canonical Section ownership; read safe context only; F-02/#16 seed contexts, F-03 owns lifecycle

Survey status/mode, frozen Question definitions

F-05 use / owner of writes: State/mode release decision, exact question ID/position/prompt/type/required/scale readback; F-03 freezes before publication

Unique Question(surveyId,position), Question.id PK

F-05 use / owner of writes: Deterministic complete question ordering; no joins by text, category or mutable template

Unique SurveyEligibility(surveyId,studentId), FKs to Survey/User

F-05 use / owner of writes: Frozen permission basis for F-04 participation; F-05 does not expose this roster or recalculate from Membership

Unique Participation(surveyId,studentId), FK to eligibility

F-05 use / owner of writes: Count committed rows for R separately from answers; F-04 owns atomic insertion

ResponseBundle(id,surveyId,identifiedStudentId)

F-05 use / owner of writes: Internal survey-scoped answer join using bundleId/surveyId only; identified link stays in storage, not owner projection

Unique identified bundle per (surveyId,identifiedStudentId); unique Answer(bundleId,questionId); same-survey composite FKs

F-05 use / owner of writes: Prevent duplicate counted answers/cross-survey associations; #16 constraints and F-04 atomic validation supply these guarantees

Answer typed values; integer rating CHECK 1-5; correct question type/required flags

F-05 use / owner of writes: Aggregate persisted valid answers, not live request input; F-04 owns completeness, optional blank normalization and one complete response per participation

Use parameterized, scoped SQL/Prisma with explicit columns. A read-only REPEATABLE READ transaction covers ownership, Survey state, count, definitions, rating groups and comments. One SQL statement producing the entire correctly scoped representation is equivalent. Multiple independent READ COMMITTED statements are insufficient: a concurrent submission/Close could mix Published state or R with later answer data.

Algorithm: (1) authenticate/validate request; (2) obtain scoped Survey and safe context within the snapshot; (3) enforce state/mode; (4) count Participation for this Survey; (5) Published: return immediately with count-only serializer, **without querying answer/comment content**; (6) Closed: fetch frozen ordered definitions, group ratings by

survey/question/score, read only question ID and text for TEXT comments, construct every question including unanswered ones; (7) validate/serialize the complete projection and return after successful read completion. No broad User joins, no response-level object spanning questions, no session/identity lookup for display. Do not join multiple one-to-many sets and count the resulting fanout.

Check consumed Closed data for invalid score/type representations and derived invariants `0 ≤ N ≤ R`, nonnegative integer bins, sum of bins=N, and correct frozen rating range. Persisted validity is primarily enforced by #16/F-04; do not silently coerce/filter detected corrupt values into plausible means. A detected inconsistency returns 500 RESULTS_INCONSISTENT without partial data and safe diagnostic context. This is not a separate database repair/audit feature. F-05 never repairs, deletes or rewrites stored responses.

A snapshot before Close commits may return Published count-only, even if Close commits before HTTP delivery. A snapshot observing Closed includes every complete F-04 submission committed before the closing transaction under BR-11. It cannot include a response whose submit lost to Close. GET takes no exclusive Survey lock, makes no lifecycle change and must not block normal submission by adopting a write lock. F-03/F-04 must share their existing Survey-lock protocol; F-05 does not invent another close rule.

On any read/query/serialization failure, discard the entire projection and return a safe failure; never fall back to zeros or an earlier successful response. GET retry is safe and may observe a newer committed snapshot. Repeated Closed reads/restart against unchanged stored data give the same aggregates, metadata and comment multiset/order; authentication/session handling may require a fresh login after restart. Do not regenerate demonstration data on API startup.

Existing index requirements: Section.ownerId, Lecture.sectionId, Survey.lectureId/status, Question survey/order, Eligibility/Participation composite keys, Answer bundle/question. #16 reviews survey/question-leading aggregation paths (e.g. Answer(surveyId,questionId)) using the agreed schema/query plan before adding indexes. F-05 does not prescribe an unrelated schema expansion or claim measured performance. NFR-04's load target remains a later verification responsibility.

7. Privacy, disclosure and text safety

Sprint 1 is **identified in storage**. Safe Owner text: “This survey is identified. Answers remain linked to accounts in storage. This view omits account identifiers, but written content and small-group results may still identify people.” F-04 must give the truthful pre-answer disclosure under BR-14; this view cannot substitute for it. Never label unlabelled comments “anonymous”, promise anonymity, or offer per-student participation lists.

Render titles, context, prompts, anchors, interpretations and comments as plain text through React text nodes/DOM textContent (equivalent output encoding allowed), never dangerouslySetInnerHTML, executable HTML, interpreted Markdown or automatic embedded content. Preserve comment line breaks with CSS and wrap long strings. Text such as `<script>` or an image onerror attribute must remain visible literal text and never execute or trigger injected network activity. Do not deduplicate comments or redact their content automatically; the guarantee is exclusion of metadata links, not removal of all possible self-identification.

S1 exposes Closed identified text regardless of small counts. It does not implement anonymous thresholds or raw-text retention policy. Unexpected anonymous mode is rejected server-side before reading answers; future F-06 must replace this fail-closed branch only through its accepted privacy design and tests. Future F-08 must reuse policy while providing aggregate-only export, not serialize this comments-bearing JSON into CSV. No export endpoint/button is delivered here.

8. UI contract

Proposed Owner route `/surveys/:id/results`, reached from F-02's own-survey navigation and F-03's management view; confirm names with those contracts. F-05 calls only its results GET for analytics. F-03 owns closing; after confirmed Close the view refetches results, rather than manufacture Closed data from an old Published response. F-02 continues to own discovery; a direct URL still requires the backend checks.

Published

Observable UI behavior: Context, persisted PUBLISHED badge, “Submitted responses” R, and “Question results and written feedback become available after closing.” No score chart, means, comments or hidden payload/DOM values. A real zero count is allowed here.

Closed header

Observable UI behavior: Persisted CLOSED badge, context/title and “Submitted responses” R; truthful identified notice (§7), no participant list or overall instructor score.

RATING question

Observable UI behavior: Frozen position/prompt/required flag, 1/5 endpoint labels and interpretation; “Answered this question” N and “Average rating” exact two-decimal mean or no-data text. Explain optional missing answers are excluded; never use R as this mean's denominator.

Distribution

Observable UI behavior: Five horizontal blue bars using SDS §6.1 tokens, score labels and exact counts outside fills. A labelled HTML table exposes the same score/count values, with a visible question heading and text description; color/tooltips are supplementary. No unlabeled percentages or invented quality direction.

TEXT question

Observable UI behavior: Neutral white cards under frozen prompt, one per comment, preserved line breaks, safe literal text and no names/avatars/IDs/times. Empty array displays “No written feedback for this question.”

Empty Closed

Observable UI behavior: R=0: “No responses yet”; keep actual frozen questions, zero bins/null means, no sample data. R>0 and N=0: “No answers to this question”, not 0.00. N=1 is shown without suppression.

Loading / refresh

Observable UI behavior: Static busy indicator, no invented result numbers. Clear old survey/account data before navigation/loading; render a coherent new snapshot only after a successful response. Manual retry/refresh is a safe GET.

Draft / unsupported mode

Observable UI behavior: Safe unavailable message from 409, no zero analytics or anonymous preview. Do not offer a results-dependent action as if results existed.

Error / denial

Observable UI behavior: 401 clears private data and routes to F-01 login; 403/404 clears results and shows generic denied/unavailable state. Network/500/503 shows an error and Retry without fake count/mean or claiming data loss. Hide prior result content on failure until a successful retry.

Keyboard / screen readers

Observable UI behavior: Logical headings/landmarks, native links/buttons, labelled table/columns, visible focus, polite busy/error updates and keyboard-operable navigation/Retry. Charts are not required keyboard stops when the table conveys their values.

360px / 1280px

Observable UI behavior: Single-column cards on narrow screens, labelled values/table kept readable, long Thai/English text wraps; desktop can place table beside chart. No horizontal page overflow or tiny clipped count labels. Inspect zoom/reflow per SDS visual checks.

No localStorage/IndexedDB persistence of results or raw feedback; no analytics/error-report payload containing comments. Browser Back after logout or switching users must not recover an earlier Owner's result view without reauthorization.

9. Acceptance criteria and forward traceability

Every row is an acceptance target, not a satisfied result. TEST-F05 suffixes below expand to complete case IDs in the STS (f-05-results-sts.md).

AC-F05-01

Required observable outcome: Own Draft results GET is 409 RESULTS_NOT_AVAILABLE with no statistics; UI shows unavailable, never invented zeros.

Planned TEST-F05 cases: U04,I02,E02

AC-F05-02

Required observable outcome: Own identified Published GET returns exactly survey metadata and committed responseCount, including real zero; no answer/comment query or quantitative payload/DOM.

Planned TEST-F05 cases: U04,I02,I10,E02

AC-F05-03

Required observable outcome: Own identified Closed GET returns full ordered frozen question results and identified comments; low counts are not suppressed and stored data is unchanged.

Planned TEST-F05 cases: U04,I02,I11,E01

AC-F05-04

Required observable outcome: Unauthenticated 401, Respondent 403, foreign/missing Survey 404, including same Course/different Owner; direct calls and guessed IDs cannot bypass it.

Planned TEST-F05 cases: U04,I01,I09,H02

AC-F05-05

Required observable outcome: UUID/body/query/method/Origin and error precedence follow §4.3; safe messages do not reveal private records or echo inputs.

Planned TEST-F05 cases: I01,I08,I09

AC-F05-06

Required observable outcome: responseCount equals committed distinct participating respondents, not eligibility, bundles/answers or current membership; joins cannot multiply it.

Planned TEST-F05 cases: U01,I03,I10,I14

AC-F05-07

Required observable outcome: Each rating answeredCount includes only its own persisted valid answers; optional omissions add neither zero nor denominator weight.

Planned TEST-F05 cases: U01,I03,I14

AC-F05-08

Required observable outcome: Each rating has five ordered integer bins for scores 1-5, zeros included, summing exactly to answeredCount.

Planned TEST-F05 cases: U01,I03,I14

AC-F05-09

Required observable outcome: Exact S/N is rounded once with proposed decimal half-up; §5's endpoint/tie/below/above fixtures and two-decimal strings match, without binary-float ambiguity.

Planned TEST-F05 cases: U02,I04,E01

AC-F05-10

Required observable outcome: R=0 and R>0/N=0 produce null means and all-zero bins with distinct no-data messages; never 0.00/NaN or fabricated observations.

Planned TEST-F05 cases: U03,U06,I05,E02

AC-F05-11

Required observable outcome: Frozen IDs/prompts/order/types/required flags/scales/anchors/interpretation are preserved; no live template/current-membership substitution or cross-question comparability claim.

Planned TEST-F05 cases: U05,I06,E01

AC-F05-12

Required observable outcome: Closed TEXT comments preserve literal strings, duplicates and line breaks, use deterministic per-question ordering, and carry no identity/bundle/timing or cross-question response linkage.

Planned TEST-F05 cases: U05,I07,E03

AC-F05-13

Required observable outcome: Unsafe comments and all user-authored metadata render as literal text; scripts/event handlers/embedded content do not execute.

Planned TEST-F05 cases: U06,E03

AC-F05-14

Required observable outcome: JSON, DOM, cache/storage, logs and analytics exclude forbidden identity/participation/bundle/timing/auth fields and raw feedback in logs; notice makes no anonymity promise.

Planned TEST-F05 cases: U05,I07,I09,E03,H02

AC-F05-15

Required observable outcome: Each result response is one committed snapshot across state/count/definitions/answers, including submit and Close races; no mixed Published/Closed projections.

Planned TEST-F05 cases: I10,I11,H01

AC-F05-16

Required observable outcome: Known storage outage 503 and unexpected/inconsistent data 500 return safe failures, not partial/zero results; Retry performs a safe new read.

Planned TEST-F05 cases: I12,I14,E04

AC-F05-17

Required observable outcome: Repeated reads and restart against unchanged PostgreSQL preserve results/metadata/comment order and all stored rows; GET has no domain writes.

Planned TEST-F05 cases: I13,H01

AC-F05-18

Required observable outcome: Owner sees correct Published/Closed view, per-question denominator/mean/table, frozen meaning, comments and truthful identified notice at the proposed navigation handoff.

Planned TEST-F05 cases: U06,E01,E02,H01

AC-F05-19

Required observable outcome: Loading, network/database errors, session expiry and denials show §8 states; old/private content is cleared and no premature/fabricated numbers displayed.

Planned TEST-F05 cases: E04,H02

AC-F05-20

Required observable outcome: Results navigation/Retry and equivalent numerical table work by keyboard with labels/focus/readable layout at 360px and 1280px.

Planned TEST-F05 cases: E04,M01

AC-F05-21

Required observable outcome: Own unsupported/anonymous mode is safely rejected with no text/count fallback; no S2 thresholds, export, history or overall instructor score are added.

Planned TEST-F05 cases: U04,I02

AC-F05-22

Required observable outcome: Reviewed/versioned precode interfaces/schema/rounding and mapped STS exist before dependent implementation; later acceptance records actual results, meaningful TDD and human review, leaving release/PDF gates separate.

Planned TEST-F05 cases: M02,H01,H02

10. Planned verification and evidence boundaries

The STS specifies **28 cases: 6 unit, 14 API/real PostgreSQL, 4 selected UI/E2E, 2 supplementary/process and 2 cross-feature handoffs**. All 22 AC map forward and every test maps back. Every application case is **Planned / Not run**. No schema, query, UI, executed test, TDD run, measured performance, student contribution or teammate approval is supplied by these documents.

Meaningful TDD candidates: known-answer optional denominator/bin/rounding assertions; Published projection containing no question data; same-Course foreign-owner rejection. Capture real intended-behavior RED before implementation and GREEN afterward with actual test names/versions/output. Import crashes or invented retrospective history are not rule failures. Unit results alone cannot prove real PostgreSQL authorization/snapshot behavior or browser escaping.

The staging Product DoD (product-dod.md) 01-10 require implemented AC/layers, recorded preimplementation design, meaningful unit tests, real API/database tests, selected E2E/accessibility, genuine RED/GREEN, security/disclosure, actual tested SHA/commands/counts, substantive teammate review/integration, and reproducible setup/docs. Record the shared version applied under #5. Release DoD 11-12 (accepted reviewed main release and A-F PDF) remain #25/#26 responsibilities, not satisfied by this feature package.

Record actual test file/name, AC/STS ID, command, environment/DB version, tested commit, observed result, pass/fail/skip counts, safe artifacts and real reviewer feedback when available. Do not include raw feedback/tokens in public run logs. A documentation-only link/formula/traceability check is not application execution.

11. Delivery responsibilities and exclusions

Tracker snapshot assigns Issue #14 and implementation #21 to R1NNE0, with the other member Maibokdaimhai as planned reviewer; no review occurrence/availability is claimed. #10/#17 supply trusted identity, #11/#18 owned context/discovery, #12/#19 lifecycle/frozen definitions, #13/#20 atomic responses and BR-11, #15 tooling, #16 migrations/seeds, #22/#23 integrated API/E2E, #24 reproducible instructions, #25 release and #26 evidence/PDF. Current tracker gates remain authoritative until a coordinated revision; this contract does not authorize Git/GitHub actions or mark any gate Done.

Follow the Tracker's phased Issue #16 policy: the initial User/session foundation requires working #15 setup, reviewed #10 and accepted shared conventions/DoD, not unrelated #11-#14 contracts or full #16 completion. Subsequent domain migrations require their respective reviewed feature contracts and verification within one additive migration history. Full #16 completion requires the complete Sprint 1 schema, migrations, seed, constraints and verification. F-05 implementation #21 still requires its own reviewed #14 contract, applicable verified schema dependencies and actual persisted F-03/F-04 lifecycle/answer behavior from #19/#20; the initial auth foundation alone cannot satisfy these prerequisites.

BR-14 pre-answer disclosure is a joint F-03/F-04 obligation; F-05 consumes mode and gives the Owner's truthful notice. BR-16 future aggregate CSV must omit these text comments. F-06 will add accepted anonymous safeguards; F-07 adds choices/metric provenance; F-09 adds compatible history analysis and F-10 private notes. None is implemented or made a prerequisite for this identified S1 results view.

12. Open agreements and recommended shared updates

Shared version/conventions

Required resolution before dependent code: Record the staging shared/F-01/DoD versions used; follow their authentication errors, UUID and Origin/no-store conventions. Resolve F-05-specific mean-as-string and exact half-up agreements without treating the merged PR #29 as a provisional dependency

Coordination: #5/#10/#14 and teammate

Owned navigation/context

Required resolution before dependent code: Reconcile actual accepted F-02/F-03 routes and §4 context/date/scale serialization; preserve separate discovery/definition/results responsibilities

Coordination: #11/#12/#14

Schema/query subset

Required resolution before dependent code: Confirm composite FKs, participation/bundle uniqueness, typed answers, exact numeric conversion, UTF-8 C collation and query indexes; no competing summary schema

Coordination: #16/#13/#14

Submission/Close/read snapshot

Required resolution before dependent code: Verify real F-03/F-04 Survey-lock ordering and committed-only F-05 reads; handoff H01 must use actual routes, not a mock lock harness

Coordination: #12/#13/#14

Comment/privacy interface

Required resolution before dependent code: Confirm unlabelled per-question string arrays/order, no participant/bundle/time projection, safe rendering/log policy; full S1 comment read without silent truncation

Coordination: #14 reviewer; future #6 evidence uses safe artifacts

Dependency gate

Required resolution before dependent code: Follow Tracker §3 and §11 above: initial #16 User/session work needs working #15, reviewed #10 and accepted shared conventions; later domain increments need their respective reviewed contracts. Full #16 closes only after all S1 schema/migrations/seed/constraints/verification are complete. #21 needs reviewed #14, applicable verified schema and actual #19/#20 persisted behavior, not merely the initial auth subset

Coordination: #5/#16/#14; tracker maintainers

Recommended later edits, **not performed**: add links to both F-05 documents under F-05 in `docs/README.md` and `docs/features.md`; add AC-F05-01-22/planned STS references to F-05 mappings in `docs/traceability.md`; after acceptance, reference exact rounding/projection/query agreements from `docs/system-sds.md` §§6.2,11,13; add reviewed #14 version/#21 evidence links in `tracker.md` without prematurely changing completion claims. Add the adopted rounding/wire rule to shared conventions only through coordinated review; do not silently treat this proposal as an existing shared decision.

This package is prepared for independent specification and teammate review. Implementation, executed verification, shared-agreement acceptance and delivery closure remain pending.

docs/sprints/sprint-1/f-05-results-sts.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

F-05 - Software Test Specification

Version 0.2 · 2026-11-07 · Issue #14 · **Every application case: Planned / Not run.**

1. Scope, traceability and execution boundary

Planned verification of the F-05 contract (f-05-results.md) §§3-9: Owner access, state-specific release, exact aggregate arithmetic, frozen meaning, identified text/privacy, consistent durable reads and usable UI. There are **22 AC and 28 planned cases**: 6 U, 14 I, 4 E, 2 M, 2 H. U = unit; I = API/real PostgreSQL; E = selected UI/E2E; M = supplementary/process; H = cross-feature handoff. No application tests, schema or implementation are created here.

The contract §9 table is the complete forward AC→case index; each linked-AC column below is the reverse index. Preserve IDs when refining wording. Subscenarios should be independently asserted/parameterized during implementation; 28 specification cases are not a claim of runner test/assertion counts. Every row below is **Planned / Not run**, including human/process/handoff checks; there is no PASS evidence.

2. Deterministic fixtures and execution setup

Use synthetic Owner A/B with separate Sections of the same Course, owned Lectures and unique Survey-per-Lecture fixtures in each state. Respondents have one role, and F-01 supplies real sessions. Seed an extra eligible but unsubmitted respondent to distinguish participation from enrollment. Published/Closed fixtures have the frozen definition and SurveyEligibility; membership changes afterward must not change result inputs. #16 owns schema/migrations/seed; test setup is isolated from another developer's DB and never a public endpoint.

Fixture A (Closed IDENTIFIED): seven eligible respondents, six committed Participation/identified bundles (R1-R6); R7 does not submit. Questions in order: Q1 required RATING clarity with explicit frozen anchors/interpretation; Q2 optional RATING pacing slow→fast (not “better”); Q3 optional TEXT suggestions. Q1 scores by R1…R6 are `[1,2,3,4,5,5]`: R=6, N=6, S=20, bins `[1,1,1,1,2]`, mean `"3.33"`. Q2 scores are `[2,omitted,omitted,4,omitted,5]`: N=3, S=11, bins `[0,1,0,1,1]`, mean `"3.67"`. Every response remains valid via Q1; omitted optional answers have no Answer row. A second Owner's survey has different counts and sentinel feedback `OTHER_OWNER_SECRET` to detect cross-survey reads.

Q3 comments: R1 = `<img src=x onerror="window.__f05Executed=true"><script>window.__f05Executed=true</script>`; R2 omitted; R3/R4 both `Same feedback`; R5 = `Line one\nLine two` (actual newline in persisted fixture); R6 = ■■■■■■■■■■. Expected five strings in UTF-8 byte/C-collation order: the `<img...` string, multiline `Line one...`, two separate `Same feedback` strings, then Thai text. Preserve the malicious-looking literal text but never execute it. Add a second TEXT question in the privacy subfixture with different per-respondent order to prove the API has no bundle-aligned/correlated response object. No identity/timestamp is attached to strings.

Fixture Z0: valid Closed survey, nonempty eligibility, no submissions. All rating bins zero, means null, comments empty. **Fixture Z1:** valid Closed survey with required TEXT answered once and optional RATING omitted; R=1, rating N=0, mean null. Text-only response is valid because the published definition includes that optional RATING and the response contains nonempty TEXT. A Closed one-rating-response fixture proves no identified minimum-count suppression.

Rounding fixtures: T1 seven 1s and one 2 (N=8,S=9,1.125→`"1.13"`); T2 thirteen 2s and twenty-seven 3s (N=40,S=107,2.675→`"2.68"`); endpoints one score 1/5→`"1.00"`/`"5.00"`. Unit-only histograms below/above the tie use 219 ones/31 twos (281/250=1.124→`"1.12"`) and 437 ones/63 twos (563/500=1.126→`"1.13"`); no need to create hundreds of DB accounts for those unit assertions.

Run future integration against real migrated PostgreSQL, HTTP middleware and F-01 sessions; never substitute SQLite/in-memory mocks for SQL grouping/access/snapshot evidence. Use separate connections and explicit transaction barriers, not sleeps or request-start order, for race tests. Real browser/API/DB E2E proves persistence/rendering; mocked success alone cannot. Test-only instrumentation can observe statement classes/transaction points without logging query parameter values or raw comments. Failure injection is a private harness seam/controlled DB outage, not an application

feature.

When executed, record actual file/test name, command, environment/database version, tested SHA, observed result, pass/fail/skip counts and safe artifact/reviewer links. Actual errors/skips remain visible. Documentation validation is separate from application results.

3. Unit cases - 6 planned

TEST-F05-U01

Linked AC: AC-F05-06, AC-F05-07, AC-F05-08

Level: Unit

Preconditions / fixtures: Fixture A domain-level rating/participation inputs, not an ORM mock proving SQL

Input: Six distinct participants, seven eligible, Q1/Q2 scores and optional omissions

Action: Evaluate aggregate domain calculation/representation against independent known-answer expectations

Expected observable result: R=6; Q1 N=6/bins 1,1,1,1,2; Q2 N=3/bins 0,1,0,1,1; sum bins=N; no zero imputation or answer-count inflation of R.

TEST-F05-U02

Linked AC: AC-F05-09

Level: Unit

Preconditions / fixtures: Exact integer/rational formatting policy

Input: Contract §5 fixtures: 20/6,11/3,9/8,107/40,281/250,563/500 and endpoints

Action: Compute exact hundredths and format without pre-rounding binary floats

Expected observable result: Exactly 3.33,3.67,1.13,2.68,1.12,1.13,1.00,5.00 as two-decimal strings; tie rounds up once; raw denominator not total eligibility.

TEST-F05-U03

Linked AC: AC-F05-10

Level: Unit

Preconditions / fixtures: Z0/Z1 and single-answer fixtures

Input: R=0/N=0; R=1/N=0; N=1 scores 1/5

Action: Build no-data/small-data rating result

Expected observable result: N=0 gives null and five zero bins; distinct survey/question no-data states; N=1 mean 1.00/5.00, never suppressed or zero mean.

TEST-F05-U04

Linked AC: AC-F05-01, AC-F05-02, AC-F05-03, AC-F05-04, AC-F05-21

Level: Unit

Preconditions / fixtures: Isolated role/state/mode release policy

Input: OWNER/RESPONDENT; DRAFT/PUBLISHED/CLOSED; IDENTIFIED/ANONYMOUS; foreign-owner predicate

Action: Evaluate policy and projection selection

Expected observable result: Only own identified Published count and Closed results released; assert status and error.code: Draft 409 RESULTS_NOT_AVAILABLE, unsupported mode 409 MODE_NOT_SUPPORTED, wrong role 403 FORBIDDEN_ROLE and foreign resource 404 NOT_FOUND under contract precedence; no S2 fallback. Does not prove database scoping.

TEST-F05-U05

Linked AC: AC-F05-11, AC-F05-12, AC-F05-14

Level: Unit

Preconditions / fixtures: Raw objects deliberately include forbidden identity/bundle/time/auth fields, unordered questions/comments

Input: Frozen Q metadata, distinct/duplicate/Thai/multiline comments; Published and Closed serializers

Action: Serialize explicit allowlists and deterministic order

Expected observable result: Question IDs/order/required/meaning unchanged; Published has no question data; Closed per-question strings preserve duplicates/order, no response correlation or forbidden fields; truthful mode notice.

TEST-F05-U06

Linked AC: AC-F05-10, AC-F05-13, AC-F05-18

Level: Unit / UI component

Preconditions / fixtures: Result presenter/component with real encoding behavior

Input: Mean string/null; zero bins, slow→fast labels; unsafe title/prompt/comment text

Action: Render/query visible text and markup

Expected observable result: Correct two-decimal/no-data labels and denominators; frozen meaning, no automatic “better”; untrusted content encoded as literal text, never interpreted HTML; no fabricated 0.00. Actual browser nonexecution still requires E03.

4. API / real PostgreSQL cases - 14 planned

TEST-F05-I01

Linked AC: AC-F05-04, AC-F05-05

Level: API + PostgreSQL

Preconditions / fixtures: A/B Sections same Course; eligible Respondent, missing session and controlled-clock loaded authenticated session at/past its deadline

Input: Valid owned/foreign/missing Survey UUIDs in all states; malformed UUID as wrong role versus Owner

Action: Direct GET results using actual trusted sessions and valid earlier perimeter checks

Expected observable result: Own allowed states work; assert status and error.code: no session 401 AUTH_REQUIRED, loaded expired authenticated session 401 SESSION_EXPIRED, Respondent 403 FORBIDDEN_ROLE before lookup, Owner foreign/missing identical 404 NOT_FOUND irrespective of state; Owner malformed UUID 422 INVALID_REQUEST; no counts/private data on denial.

TEST-F05-I02

Linked AC: AC-F05-01, AC-F05-02, AC-F05-03, AC-F05-21

Level: API + PostgreSQL

Preconditions / fixtures: Owned Draft, zero/nonzero Published, zero/one/nonzero Closed, unsupported-mode fixture

Input: GET each state/mode; otherwise valid requests

Action: Compare exact JSON key allowlists; observe query classes without values

Expected observable result: Draft 409/no statistics; Published 200 only survey/R and no answer/comment query; Closed complete ordered results even at N=1; unsupported mode 409/no data. No hidden preview, threshold or unrelated endpoint introduced.

TEST-F05-I03

Linked AC: AC-F05-06, AC-F05-07, AC-F05-08

Level: API + PostgreSQL

Preconditions / fixtures: Fixture A and B's sentinel survey; extra TEXT/optional questions up to ten in subfixture

Input: Owner A GET; later remove Membership/add a new unsubmitted current Section member in isolated setup, leaving frozen Eligibility unchanged

Action: Read JSON and independently inspect committed counts; repeat with multi-question/comment fanout fixture

Expected observable result: R stays six, independent of question/eligibility/current membership counts; Q1/Q2 N/bins exact, ordered scores1-5, bin sums correct; no rows from B's survey. Omitted optional answers never count as zero.

TEST-F05-I04

Linked AC: AC-F05-09

Level: API + PostgreSQL

Preconditions / fixtures: Real persisted T1/T2, endpoint and Fixture A datasets

Input: GET results on each Closed survey

Action: Compare service JSON with exact rational known answers, including underlying SQL numeric conversion

Expected observable result: T1 1.13, T2 2.68, endpoints 1.00/5.00, A 3.33/3.67; values are two-decimal strings, not approximated numbers; counts/bins agree.

TEST-F05-I05

Linked AC: AC-F05-10

Level: API + PostgreSQL

Preconditions / fixtures: Z0/Z1, valid frozen questionnaire and eligibility

Input: GET both Closed surveys

Action: Inspect every rating/comment entry and responseCount

Expected observable result: Z0 R=0, rating N=0/null/zero bins, empty comments; Z1 R=1 with optional N=0/null/zero bins and its valid TEXT; unanswered questions not omitted.

TEST-F05-I06

Linked AC: AC-F05-11

Level: API + PostgreSQL

Preconditions / fixtures: Closed Survey with explicit clarity/pacing meaning; nontrivial stored question order; changed current membership and unrelated mutable Draft

Input: GET Closed results

Action: Compare result metadata to frozen stored Question fields; modify unrelated Draft/setup then reread

Expected observable result: Exact question IDs/prompts/types/positions/required/scales/anchors/interpretation retained; no template/live Draft substitution or membership-driven redefinition; speed not relabelled quality.

TEST-F05-I07

Linked AC: AC-F05-12, AC-F05-14

Level: API + PostgreSQL

Preconditions / fixtures: Fixture A comments plus second TEXT privacy subfixture; underlying bundles have identified links

Input: GET as authorized Owner; inspect full recursive response and safe logs

Action: Verify content multiset/order and allowed keys; repeat read

Expected observable result: Five Q3 strings in specified byte order with duplicate Same feedback twice, line breaks/Thai intact; no student/name/avatar/participant/bundle/Answer/time/session fields, no cross-question response object; raw

feedback absent from logs. Literal HTML in JSON is data, not a demand to mutate stored text.

TEST-F05-I08

Linked AC: AC-F05-05

Level: API + PostgreSQL

Preconditions / fixtures: Authenticated Owner, valid Survey; shared perimeter active

Input: Bad UUID, body, any query including spoofed actor/filter/sort/page/format; unsupported methods with valid applicable CSRF/Origin

Action: Call route and examine status/error/Allow/header, using valid bodies where required by perimeter

Expected observable result: 422 INVALID_REQUEST for body/query/UUID, 405 Allow GET for unsupported method, safe shared 400 for malformed transport; no input echo/SQL/private data or mutation. No duplicate discovery/export handler.

TEST-F05-I09

Linked AC: AC-F05-04, AC-F05-05, AC-F05-14

Level: API + PostgreSQL + F-01

Preconditions / fixtures: Actual login/logout sessions and shared Origin middleware; controlled-clock loaded authenticated session at/past deadline; separate missing/pruned/forged/revoked/invalid-state session and missing/invalid User fixtures

Input: Explicit foreign/null Origin, valid/omitted Origin GET, missing CSRF GET, loaded expired session versus missing/pruned expired row and replayed cookie

Action: GET results; include otherwise valid requests and valid earlier perimeter checks to isolate each auth error; inspect headers/logs

Expected observable result: Assert status and error.code: foreign/null Origin 403 ORIGIN_FORBIDDEN; loaded expired authenticated session 401 SESSION_EXPIRED; missing/pruned expiry or other unusable session/User 401 AUTH_REQUIRED. Same-origin GET may omit Origin/CSRF; all protected success/error responses private/no-store, no ETag/304 reuse; safe logs contain no bodies/tokens/comments.

TEST-F05-I10

Linked AC: AC-F05-02, AC-F05-06, AC-F05-15

Level: API + PostgreSQL concurrency

Preconditions / fixtures: Published survey, one committed response; separate connection preparing atomic second F-04-like response

Input: GET paused after scoped state read; second response commits before later read-query phase

Action: Use explicit snapshot/commit barriers; run fresh GET after commit

Expected observable result: First snapshot returns R=1 count-only; next R=2 count-only. No mixed state/data or answer fetch; never counts uncommitted/partial participation. Harness proves read snapshot, actual F-04 handoff remains H01.

TEST-F05-I11

Linked AC: AC-F05-03, AC-F05-15

Level: API + PostgreSQL concurrency

Preconditions / fixtures: Published fixture; F-03/F-04-compatible private DB transactions using shared Survey lock; real results endpoint

Input: Results snapshot before versus after Close commit; valid submit commits first/Close commits first

Action: Barrier lock/commit/read order and inspect persisted rows/projection

Expected observable result: Pre-Close snapshot only Published/R; Closed snapshot includes complete submit-first answer set; close-first losing submit adds none. No Closed state paired with earlier partial R/answers. Actual route-level integration still H01.

TEST-F05-I12

Linked AC: AC-F05-16

Level: API + PostgreSQL failure

Preconditions / fixtures: Owned Closed fixture and pre-read row snapshot; private fault seam/controlled database unavailability

Input: Outage during scoped lookup/count/aggregation/comment read; unexpected serialization fault

Action: Inject failure at each stage, retry after recovery; inspect response/logs and unchanged DB

Expected observable result: Known outage503/unexpected500, safe no-data error envelope, no partial 200/zeros/SQL/feedback; successful retry reads actual committed data; no domain writes.

TEST-F05-I13

Linked AC: AC-F05-17

Level: API + PostgreSQL + process

Preconditions / fixtures: Stable Closed known-answer dataset and saved complete domain-row snapshot

Input: Repeated GET; actual stop/start API with same PostgreSQL database; new login if needed

Action: Compare JSON metadata/statistics/comment order and rows before/after

Expected observable result: Identical results for unchanged data, zero domain changes to Survey/Questions/Eligibility/Participation/Bundles/Answers; startup never resets fixtures or relies on process-local results.

TEST-F05-I14

Linked AC: AC-F05-06, AC-F05-07, AC-F05-08, AC-F05-16

Level: API + PostgreSQL integrity negative

Preconditions / fixtures: Isolated test-only invalid service-state fixture that still satisfies local DB constraints, e.g. eligible bundle/answer without Participation; separate wrong-question-type value fixture where cross-table validation is service-owned

Input: Closed results with N>R or consumed answer type inconsistent with frozen Question

Action: Read through real aggregation/serializer, without disabling production constraints

Expected observable result: 500 RESULTS_INCONSISTENT/no partial statistics; never plausible zero/mean via silently dropping/coercing detected corruption. Valid datasets still satisfy nonnegative bins, sum=N, N≤R. No repair writes or new integrity-admin route.

5. Selected browser/E2E cases - 4 planned

TEST-F05-E01

Linked AC: AC-F05-03, AC-F05-09, AC-F05-11, AC-F05-18

Level: UI/E2E

Preconditions / fixtures: Real Owner session/API/PostgreSQL; Closed Fixture A and T1/T2; no mocked result success

Input: Open owned results from proposed navigation and direct URL; refresh

Action: Inspect visible counts/means/blue bars/table and frozen scale meaning; compare API

Expected observable result: R=6; Q1 6/3.33, Q2 3/3.67; exact bin/table parity, endpoint labels/interpretation and notice, T1/T2 1.13/2.68, no overall score or “higher=better” invention; real readback preserved.

TEST-F05-E02

Linked AC: AC-F05-01, AC-F05-02, AC-F05-10, AC-F05-18

Level: UI/E2E

Preconditions / fixtures: Real Draft, zero/nonzero Published, Closed Z0/Z1 and one-answer fixtures

Input: Navigate among states, including direct Draft results URL

Action: Inspect content and complete network JSON/DOM

Expected observable result: Draft unavailable/no fake zeros; Published only actual count/message; Closed no-response vs no-rating-answer messages distinct, no 0.00/NaN/sample chart; one answer visible without suppression.

TEST-F05-E03

Linked AC: AC-F05-12, AC-F05-13, AC-F05-14

Level: UI/E2E security

Preconditions / fixtures: Real Closed comments/privacy fixture; unsafe markup in title/prompt/anchors/interpretation too

Input: Render literal HTML/script/event-handler strings, duplicates, Thai, newline/long text

Action: Observe DOM/text, execution marker and injected-request events; inspect storage/analytics payloads

Expected observable result: Literal content preserved and safely encoded; marker never set, injected script/image requests absent; duplicate cards retained, newline readable; no identities/times/hidden linkage or raw feedback in analytics/persistent storage; truthful identified notice.

TEST-F05-E04

Linked AC: AC-F05-16, AC-F05-19, AC-F05-20

Level: UI/E2E

Preconditions / fixtures: Real session/API; 360px/1280px; controllable slow read/outage/denial

Input: Keyboard navigation/Retry, delayed response, offline/503/500, 401/403/404; route change during pending read

Action: Move between surveys, recover/retry and inspect responsive chart/table/labels/focus

Expected observable result: Busy/error states have no fabricated/stale numbers; prior account/survey content cleared, late old-route response cannot replace current view; denied data hidden, safe retry succeeds; all values/table and controls keyboard usable/readable without color-only meaning or page overflow.

6. Supplementary/process cases - 2 planned

TEST-F05-M01

Linked AC: AC-F05-20

Level: Manual accessibility supplement

Preconditions / fixtures: Implemented results UI; 360px/1280px; Thai/long text and no-data fixtures

Input: Keyboard, chart/table, focus, 200% zoom/reflow, announcements

Action: Human checks associated labels/headings, contrast against SDS tokens, count readability and navigation/Retry

Expected observable result: Required widths usable with equivalent numerical values and visible focus/errors; findings/results recorded honestly, no full WCAG claim from this plan. Supplements E04 rather than replacing it.

TEST-F05-M02

Linked AC: AC-F05-22

Level: Process/evidence audit

Preconditions / fixtures: Proposed contract/STS now; staging shared/F-01/Tracker sources and later reviewed F-05/schema/adjacent versions and actual implementation

Input: AC mapping, phased #16 prerequisites, exact rounding/wire agreement, precode history, genuine RED/GREEN, actual run records/human review/setup

Action: Review preimplementation gate, then reconcile implemented AC/tests and feature DoD

Expected observable result: Initial auth foundation depends on working #15, reviewed #10 and accepted shared conventions, not all later contracts; full #16 still needs its complete verified S1 scope. F-05 waits for reviewed #14, applicable verified schema and actual #19/#20 persisted behavior. Required decisions recorded before dependent code; all actual failures/skips/run SHA/counts/reviews traceable; pending remains pending; no invented approval/test execution or feature claim of release/PDF completion.

7. Cross-feature handoffs - 2 planned

TEST-F05-H01

Linked AC: AC-F05-15, AC-F05-17, AC-F05-18, AC-F05-22

Level: Integrated F-02/F-03/F-04/F-05 API + UI

Preconditions / fixtures: Accepted real adjacent routes and #16 schema; owned Lecture; eligible Respondents; shared Survey lock; versions recorded

Input: Discover/create/publish, submit known scores with optional omission, inspect count, close, inspect results; two controlled submit/close orders; restart

Action: Follow actual owner/student journeys and navigation with real APIs/DB; tie to adjacent handoff cases to avoid double-counting one run as multiple independent passes

Expected observable result: F-02/F-03 links/context/scale agree; Published count only; submit-first answers appear in Closed, close-first submit rejected without rows; durable correct Closed aggregates/text/frozen meaning; no harness-only evidence substituted for actual routes.

TEST-F05-H02

Linked AC: AC-F05-04, AC-F05-14, AC-F05-19, AC-F05-22

Level: Integrated F-01/F-05 API + browser

Preconditions / fixtures: Real A and B accounts, controlled-clock loaded expired session and separate revoked/missing/pruned session fixtures; A's private results loaded

Input: Logout then Browser Back/direct API; switch to B same Course/different Section; expire session during retry

Action: Reenter results through actual auth/navigation; inspect network, DOM and persistent storage

Expected observable result: No A data recovered from cache/late responses; assert status and error.code: revoked cookie 401 AUTH_REQUIRED, loaded expired authenticated session 401 SESSION_EXPIRED (missing/pruned expiry 401 AUTH_REQUIRED), B's request for A results 404 NOT_FOUND. Session loss/denial clears private content; fresh correct identity required for own data; human review/version/result evidence recorded only when executed.

8. Meaningful TDD targets and evidence gate

U01/U02 then I03/I04: denominator, bins and exact rounding

Intended RED assertion: Optional rating incorrectly divided by six, missing bin or 2.675 tie incorrectly formatted

Intended GREEN evidence: Known-answer domain assertions plus real SQL-derived API values agree with independent expected constants

U04/U05 then I02: Published projection

Intended RED assertion: Question/comment data or answer query occurs before closing

Intended GREEN evidence: Only metadata/R returned, no answer/comment query; real state-specific API test

I01: same-Course Owner isolation

Intended RED assertion: Owner B obtains any A count/result for guessed Survey ID

Intended GREEN evidence: Canonically scoped query and generic404 with no private data

These are planned meaningful slices, not retrospective RED/GREEN claims or a requirement to manufacture a failure for every parameter. Preserve actual intended-behavior failure before its implementation and passing output after, with file/test

names and real versions. Import/syntax/setup failure is not rule RED; disabled/weakened assertions are not GREEN. Keep all remaining planned coverage even when another legitimate TDD slice is chosen.

Before code, resolve contract §12 and record reviewed contract/STS/schema/interface versions. Before feature acceptance, implement/run mapped cases, retain actual outputs/counts/SHA, record real teammate review and reproduce setup. Integrated runs #22/#23, reviewed main release #25 and actual evidence/PDF #26 remain separate gates. Writing this specification satisfies none of those execution gates.

Part F - Actual candidate evidence and remaining gates

Actual verification on 1f7ae02083438fba066185e3823a68f77bde3aa0

75 selected automated tests passed: 37 unit, 2 API liveness, 17 real API/PostgreSQL feature scenarios, 9 foundation, 2 PostgreSQL tooling, 4 product browser and 4 inherited browser smoke. Final listed suites reported no failures/skips. Prisma compatibility and actual built-process restart also passed. These counts do not certify every planned STS case or human acceptance.

npm run typecheck

Exit: 0; Command completed successfully.

npm run build

Exit: 0; Command completed successfully.

npm run test:unit

Exit: 0; Test Files 6 passed (6); Tests 37 passed (37)

npm run test:api

Exit: 0; Test Files 1 passed (1); Tests 2 passed (2)

node --env-file=.local/sprint1-tests.env node_modules/vitest/vitest.mjs run --config vitest.features.config.ts

Exit: 0; Test Files 1 passed (1); Tests 17 passed (17)

node --env-file=.local/sprint1-foundation.env node_modules/vitest/vitest.mjs run --config vitest.foundation.config.ts

Exit: 0; Test Files 1 passed (1); Tests 9 passed (9)

node --env-file=.local/sprint1-tests.env node_modules/vitest/vitest.mjs run --config vitest.db.config.ts

Exit: 0; Test Files 1 passed (1); Tests 2 passed (2)

node --env-file=.local/sprint1-tests.env --import tsx scripts/orm-smoke.ts

Exit: 0; Prisma 7.10.1 generated-client / PostgreSQL adapter compatibility passed; no domain migration applied.

node --env-file=.local/sprint1-browser.env scripts/playwright.mjs test --config playwright.features.config.ts

Exit: 0; 4 passed (5.1s)

npm run test:e2e

Exit: 0; 4 passed (957ms)

node --env-file=.local/sprint1-tests.env --import tsx scripts/verify-restart.ts

Exit: 0; Built API process restart: same persisted sessions, absolute deadline, survey, own answers and results verified; no migration or reseed between starts.

These are candidate checks, not post-merge assessed-main checks. Installation succeeded with the unchanged lockfile; actual earlier failures/corrections are disclosed in the embedded implementation record.

docs/sprints/sprint-1/implementation-evidence.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

Sprint 1 working increment and evidence

Prepared 2026-11-09. This is a review candidate for #17-#24, based on the verified database source in PR #35 (`6e80fa0828c8e6e00d604a7cf257cd6e11888da9`). PR #35 is not merged at the recorded check; no teammate implementation approval, integrated staging acceptance, main release, tag or completed PDF submission is claimed. Instructor requirements remain the supplied PDFs; exact session/limit/UI choices come from the accepted LECTRA contracts.

Implemented candidate

- F-01: actual Argon2id login, server-derived current identity/role, PostgreSQL opaque sessions, SID/CSRF regeneration, absolute guest/auth deadlines, revocation, Origin/CSRF/transport/schema guards and process-local login throttling. Cookie expiry is capped on serialization; the store corrects the upstream whole-second ceiling before acknowledging a save. No automatic session table creation or memory session fallback.

- F-02: scoped Course/Section/Lecture selectors and paginated survey discovery. Canonical Section ownership and frozen eligibility control queries; allowlisted projections exclude other accounts/answers. Pagination uses repeatable-read snapshots and fixed C-collation ordering.

- F-03: Draft creation, revisioned whole-definition save/reorder/delete, publication snapshot and close. Published definitions are immutable. All transitions share a Survey row lock; unique lecture IDs arbitrate concurrent creates.

- F-04: strict rating/text validation, Unicode code-point bounds, no empty submission, one atomic participation/bundle/answer transaction, no automatic POST retry, and persisted own-answer readback. Submit/close share the same Survey lock and bounded native database waits (5-second lock / 10-second statement timeout).

- F-05: owner-only count while Published; Closed exact half-up means, five score bins, actual answered denominators and unlabelled C-ordered plain-text comments. Invalid persisted type/count/range invariants fail closed. No anonymous mode/export/history/notes.

- Web: labelled native controls, memory-only private state, safe React text rendering, cool light theme, explicit loading/empty/error states, save-before-publish, no default rating, retained inputs after validation rejection, unknown-outcome status recovery, private-state clearing and truthful sign-out failure handling. Bootstrap callers are coalesced to prevent StrictMode cookie/token races.

The runtime uses parameterized `pg` SQL for scoped queries and explicit row-lock transactions, alongside the accepted Prisma migration/schema/generated-client foundation. It does not create a competing schema or replace persistent storage with a mock. Additional declaration packages are pinned `@types/express-session@1.19.0` and `@types/connect-pg-simple@7.0.3`; no new runtime service or UI library is added.

Actual test sources and selected contract coverage

These rows describe selected evidence, not a claim that every planned STS case was executed. Test names in the source are the authoritative executed scenario boundaries. One combined scenario can contain many assertions but is counted once by its runner.

F-01 AC-01-14/17-19 (partial STS coverage)

Actual source: `apps/api/tests/unit/auth-rules.test.ts`; `apps/api/tests/features/workflows.test.ts`

Selected observations: Absolute boundary/future timestamps; CSRF format/equality; real bootstrap/login/trusted identity/role refresh; generic credential errors; strict schema/transport; regeneration; expiry/logout/replay; already-authenticated conflict; old token; 10th/11th attempt; store failure; exact persisted deadline; overlapping read/logout; independent session; forged cookie/foreign origin/method checks.

F-01 AC-15/16, F-02 selection, F-03 editing, F-04 confirmation, F-05 display (selected journeys)

Actual source: `tests/browser/feedback.spec.ts`

Selected observations: Actual browser-to-PostgreSQL normal workflow, keyboard login, required rejection retaining feedback, immutable own readback after browser reload, Closed mean/comments, script-looking text not executed, no page overflow at 360px/1280px.

F-02 ownership/discovery/pagination AC

Actual source: `apps/api/tests/features/workflows.test.ts`

Selected observations: Same-Course foreign Section rejection; respondent role rejection; hidden Drafts; strict duplicate/leading-zero query rejection; real authorized selectors.

F-03 lifecycle/revision/freeze/concurrency AC

Actual source: `apps/api/tests/unit/feedback-rules.test.ts`; feature suite

Selected observations: Draft blanks versus publication validation; scalar bounds; unique survey; stale/no-op revisions; stable IDs; foreign-owner rejection; eligibility snapshot; published edit refusal; actual edit/publish race.

F-04 validation/atomicity/readback/concurrency AC

Actual source: unit/feature suites

Selected observations: 2,000/2,001 non-BMP code-point boundary; malformed Unicode/NUL/required/duplicate/wrong-survey/type/range/empty rejection; no partial writes; actual SQL fault rollback; concurrent duplicate; both actual API submit/close lock orders; own-only readback.

F-05 statistics/state/privacy/integrity AC

Actual source: unit/feature/browser suites

Selected observations: Exact half-up/null means; Published count-only; Closed distribution/comment projection; respondent/foreign-owner rejection; invalid persisted type causes RESULTS_INCONSISTENT; escaped UI text.

Cross-feature persistence

Actual source: `scripts/verify-restart.ts`

Selected observations: Starts/stops/restarts the built API process with the same database and secret, then compares identity/deadline, survey, own answers and results. No migration/reseed between starts. Run after the feature suite with its private RESTART_PASSWORD.

Inherited foundation/tooling

Actual source: existing unit/API/foundation/DB/ORM suites and `tests/e2e/workspace.spec.ts`

Selected observations: Retain prior migration/seed/constraint checks and configuration/driver/liveness checks, distinctly from product scenarios.

Genuine RED/GREEN history

`b63e613`

Observed failure and correction boundary: Three intended-rule tests failed for stubbed absolute expiry/future timestamp/CSRF predicates. `fa944d9` implements the predicates; later full unit runs pass them. This is genuine new history, not a reconstruction of earlier #15 work.

`fa944d9`

Observed failure and correction boundary: Feature suite had 4 failed / 5 passed before feedback routes existed. The context/create assertions received 404; dependent response/result scenarios also failed. Treat dependent scenario failures as missing-route observations, not independent proof of every business-rule RED.

`4f9e593`

Observed failure and correction boundary: Exact persisted deadline regression failed: upstream connect-pg-simple rounded expiry up to a second. Targeted run: 1 failed / 13 not selected. The correction updates expire to the exact absolute millisecond deadline before save acknowledgment; the final full suite checks it. The test later selects its exact SID so earlier sessions in a full run cannot contaminate the fixture.

`f0ccc3c`

Observed failure and correction boundary: Deterministic browser bootstrap regression expected one request and observed two, failing in both viewport projects. The correction coalesces in-flight session bootstrap requests; selected and full final browser runs record the actual result.

Initial browser runs also failed on exact text-label matching for select/textarea labels; accessible combobox/textbox role locators corrected those test targeting problems without weakening the behavior assertions. One subsequent browser login exposed the real bootstrap race above. These failures remain disclosed; no retry or automatic POST replay is used to mask them.

Completion boundaries and remaining verification

Actual final commands/counts/tested commit are recorded in the PR and generated review report snapshot after execution. Working-tree observations must not be relabelled as release SHA evidence. No coverage percentage is claimed.

- Human teammate review/integration is pending for this increment. #35 must integrate first; review the feature-only range against its source. No merge is performed by this work.

- Selected automated checks do not certify all 47 F-01, F-02/F-03/F-04/F-05 STS cases, every AC subcondition, accessibility compliance, deployment/proxy behavior, network-loss/failure UI permutations or P15 human usability sessions. Keep non-executed planned cases Not run and close remaining gaps under #22/#23 before declaring full Product DoD.

- #24 setup commands and private synthetic handoff are supplied; actual teammate clean-checkout reproduction remains unobserved. Record their real outcome rather than AI impersonation.

- #25 requires reviewed/integrated staging and a separately reviewed staging-to-main release. No immutable assessed release exists for this candidate; no tag/merge is created here.

- #26 may assemble a clearly marked review draft with full source Parts A-E and selected observed evidence. Final release-linked output, contributions and review/integration evidence remain incomplete until they occur. Do not submit the draft as an accepted final report.

README.md

Embedded source snapshot. Historical draft/pending statements retain their original planning meaning; current execution and acceptance limits are in Part F.

LECTRA

Lecture Evaluation, Classroom Thoughts, Reviews & Analytics - CPE334 lecture feedback.

This branch supplies a review candidate for identified lecture feedback: real login, scoped classroom/survey discovery, Draft/publish/close, one-time student answers, own readback and owner summaries. It builds on database PR #35. It is not an accepted main release. See engineering docs (docs/README.md), contracts (docs/sprints/sprint-1/README.md), implementation/evidence boundaries (docs/sprints/sprint-1/implementation-evidence.md).

Prerequisites

Node **24.22.1**, npm **10.9.2**, PostgreSQL **17** (verified patch 17.11), one root lockfile. Install the pinned runtime first; the runtime guard intentionally refuses another version. No CI/cloud deployment or application Docker image is required for this local increment.

```
npm ci
npm run setup:local
```

`setup:local` creates ignored `.env`, `.env.test.local`, `.local/postgres.env` with random synthetic secrets and mode 0600; it refuses existing files. Examples contain placeholders only. Keep actual URLs/passwords/session secrets out of Git/PDF. Build/typecheck generate the Prisma client; generated files stay ignored.

Disposable database and private demo

Configure `.env.test.local` with a dedicated `lectra_test` or `lectra_test_*` target, a distinct actual development `DATABASE_URL`, and matching `ALLOW_TEST_DATABASE`. Host/port query overrides are rejected in both URLs. Optional local Docker example uses only a new disposable container (do not replace an existing one):

```
docker run --name lectra-demo-postgres --env-file .local/postgres.env --publish 127.0.0.1:55432:5432 --tmpfs
/var/lib/postgresql/data -d postgres:17-alpine
npm run demo:config
npm run demo:migrate
npm run demo:seed
npm run demo
```

The example creates `lectra_test` from `POSTGRES_DB` in the local setup file; keep URL/name/port aligned. `demo:config` first validates test/development separation, then creates `.local/demo-setup.env` and `.local/demo.env` without overwriting existing files. All secrets are private local random values (0600). Runtime points at the explicitly opted-in synthetic database; the distinct development reference is retained in setup configuration. No development/deployed database is seeded.

Open **http://127.0.0.1:5173**. API runs on loopback 3001; Vite forwards same-origin `/api`. Synthetic accounts are `owner.1@example.test`, `owner.2@example.test`, `owner.3@example.test` and `respondent.11@example.test` through `respondent.14@example.test`. Retrieve the two privately generated passwords locally from `.local/demo-setup.env`; share through an agreed private channel, never repository/PR/report/screenshots. No default password, role selector or signup exists.

Repeat seed verifies matching fixtures and retains hashes/sessions/submissions. An edited/published seeded Draft deliberately causes refusal rather than overwriting it. Do not reset or rerun seed to erase demo evidence. Use a new disposable target for a fresh demonstration.

Normal workflow: Owner 1 selects SYN-CPE334 → Section A → Lecture 2, creates a Draft, adds a required 1-5 RATING with explicit endpoint labels/interpretation and optional TEXT, saves, then publishes. Respondent 11 opens the eligible survey, tries submitting without the required score (rejected), then submits valid feedback and reopens saved immutable answers. Owner 1 sees only count before closing, then closes and sees means/distribution/unlabelled comments. Owner 2 cannot access the survey; Respondent 13 is ineligible. Published/Closed definitions cannot be edited, responses cannot be

resubmitted, and student access never reveals another student's answers.

S1 is identified: answers remain account-linked in storage. Owner projections omit account identifiers, but text/small groups can still identify a person. Anonymous mode/export/history/notes remain later work.

Ctrl+C closes both services and the API/session pool. Restart `npm run demo` against the same database/configuration to retain unexpired sessions/feedback. The optional tmpfs container is **disposable storage**, not evidence of durable storage after container removal. Remove only your own instance when finished:

```
docker stop lectra-demo-postgres
docker rm -v lectra-demo-postgres
```

Build and verification

```
npm run typecheck
npm run build
npm test
npm run test:db
npm run check:orm
npm run browsers:install
npm run test:e2e
```

`npm test` runs units and API liveness checks. `test:db` and `check:orm` use the opted-in test configuration. `test:e2e` is the inherited web/proxy/auth-required tooling smoke at 360px/1280px, not the complete product journey. Browser binaries stay under ignored `.local/playwright-browsers`.

For real feature integration, supply a **new empty** dedicated database in `.env.test.local` and set `ALLOW_FEATURE_TESTS` to that database name, then `npm run test:features`. The suite migrates/seeds itself and refuses existing tables; there is no reset command. For another run, create another new empty database. It verifies actual auth, role/ownership, lifecycle/revision, validation/rollback, duplicate/close/edit races, own readback, result projections/integrity and precise session expiry. `ALLOW_FOUNDATION_TESTS` and `npm run test:db:foundation` separately exercise the inherited nine migration/seed/constraint cases on their own new database. See database setup (docs/sprints/sprint-1/database-foundation.md).

For selected product browser tests, create private ignored `.local/browser.env` containing NODE_ENV=test, APP_ORIGIN=http://127.0.0.1:4174, a random SESSION_SECRET, DATABASE_URL and TEST_DATABASE_URL pointing to the same **new empty synthetic test database**, DEVELOPMENT_DATABASE_URL pointing to the distinct actual development target, matching ALLOW_TEST_DATABASE/ALLOW_BROWSER_TESTS, and private SEED_OWNER_PASSWORD/SEED_RESPONDENT_PASSWORD. Then run `npm run test:e2e:features`. Preparation validates isolation, migrates and seeds; tests run real web/API on 4174/3102 and do not reuse another server. Use a new database per run. Screenshots contain only synthetic UI; traces are off to avoid recording credentials/tokens.

An actual built-process restart check is available as `node --env-file=<private-feature-env> --import tsx scripts/verify-restart.ts` after a feature run whose private RESTART_PASSWORD was supplied. It compares persisted identity/deadline/survey/own answers/results across stop/start without migration or reseed. This script never prints credential values.

For ordinary forward development migrations only, explicitly configure `.env` with NODE_ENV=development and ALLOW_DATABASE_MIGRATIONS matching the intended database, then `npm run db:migrate:dev`. It does not seed/reset. Production/proxy/HTTPS deployment remains unverified Lab 5 work. To start the built API use `npm start` with the appropriate private `.env`; serve the built web behind the same reviewed origin before any deployment.

Actual teammate fresh-checkout reproduction, full contract-case completion, reviewed staging/main integration and assessed release/PDF evidence remain pending. Report real failures/skips and test the final release commit rather than treating a feature-branch pass as release acceptance.

Selected real test excerpts

F-02: owner context

```
it('F-02: owner context is scoped even within a shared Course, and query pagination is strict', async () => {
```

```
    const owner = await login();
    const courses = await owner.agent.get('/api/courses').expect(200);
    expect(courses.body.data.items).toHaveLength(2);
    const sections = await owner.agent.get(`/api/sections?courseId=${fixtureId(101)}`).expect(200);
    expect(sections.body.data.items.map((s: {
        id: string;
    }) => s.id)).toEqual([fixtureId(201)]);
    await owner.agent.get(`/api/sections/${fixtureId(202)}/lectures`).expect(404);
    await owner.agent.get('/api/courses?limit=01').expect(422);
    await owner.agent.get('/api/courses?limit=1&limit=2').expect(422);
    const student = await login('respondent.11@example.test');
    await student.agent.get('/api/courses').expect(403);
    expect((await student.agent.get('/api/surveys').expect(200)).body.data.items).toEqual([]);
    await request(app).get('/api/courses').expect(401);
});
```

F-04: an actual SQL fault

```
it('F-04: an actual SQL fault after participation/bundle insertion rolls the entire submission back', async () => {
    const owner = await login();
    await mutation(owner, 'post', `/api/surveys/${fixtureId(401)}/publish`, { expectedRevision: 1 }).expect(200);
    const student = await login('respondent.12@example.test');
    await pool.query(`CREATE FUNCTION fail_answer_test() RETURNS trigger LANGUAGE plpgsql AS $$ BEGIN RAISE
EXCEPTION 'Injected storage failure'; END $$; CREATE TRIGGER fail_answer_test BEFORE INSERT ON "Answer" FOR EACH ROW
EXECUTE FUNCTION fail_answer_test()`);
    try {
        await mutation(student, 'post', `/api/surveys/${fixtureId(401)}/responses`, { answers: [{ questionId:
fixtureId(501), value: 4 }] }).expect(500);
    }
    finally {
        await pool.query('DROP TRIGGER fail_answer_test ON "Answer"; DROP FUNCTION fail_answer_test()');
    }
    expect((await pool.query('SELECT count(*)::int AS n FROM "Participation" WHERE "surveyId"=$1',
[fixtureId(401)])).rows[0].n).toBe(0);
    expect((await pool.query('SELECT count(*)::int AS n FROM "ResponseBundle" WHERE "surveyId"=$1',
[fixtureId(401)])).rows[0].n).toBe(0);
    expect((await student.agent.get(`/api/surveys/${fixtureId(401)}/my-submission`).expect(200)).body.data.submitted).
toBe(false);
});
async function publishedFixture(owner: Awaited<ReturnType<typeof login>>, sequence: number) {
    const lecture = (await pool.query('INSERT INTO "Lecture" ("sectionId",title,"lectureDate",sequence) VALUES
($1,$2,\'2026-11-09\',$3) RETURNING id', [fixtureId(201), 'Race fixture', sequence])).rows[0].id;
    const created = await mutation(owner, 'post', '/api/surveys', { lectureId: lecture }).expect(201);
    const id = created.body.data.id;
    const saved = await mutation(owner, 'patch', `/api/surveys/${id}`, { expectedRevision: 1, title: 'Race fixture',
questions: [{ id: null, type: 'RATING', prompt: 'Understanding', required: true, ratingScale: { min: 1, max: 5,
minLabel: 'Low', maxLabel: 'High', interpretation: 'Higher means clearer' } }] }).expect(200);
    await mutation(owner, 'post', `/api/surveys/${id}/publish`, { expectedRevision: 2 }).expect(200);
    return { id, question: saved.body.data.questions[0].id };
}
async function waitingConnections(count: number) {
    const end = Date.now() + 4000;
    while (Date.now() < end) {
        const n = Number((await pool.query("SELECT count(*) AS n FROM pg_stat_activity WHERE
datname=current_database() AND wait_event_type='Lock' AND pid<>pg_backend_pid()")).rows[0].n);
        if (n >= count)
            return;
        await new Promise(r => setTimeout(r, 10));
    }
    throw new Error('Expected overlapping API transactions to wait on the held Survey lock');
}
```

Selected actual browser evidence

Figure source commit: a501b278940a215344951e32177d1e5607a7ae9a. These actual synthetic UI captures are candidate evidence, not assessed-release figures.

submission-chromium-wide.png

Submission received

Your saved answers are read-only.

Understanding

5

Next time

<script>window.feedbackExecuted=true</script> More examples.

submission-chromium-narrow.png

Submission received

Your saved answers are read-only.

Understanding

5

Next time

<script>window.feedbackExecuted=true</script> More examples.

results-chromium-wide.png

Feedback summary

Refresh results

Responses: **1**

Understanding

Mean: **5.00** · Answered: 1

1: Low · 5: High

Higher means clearer

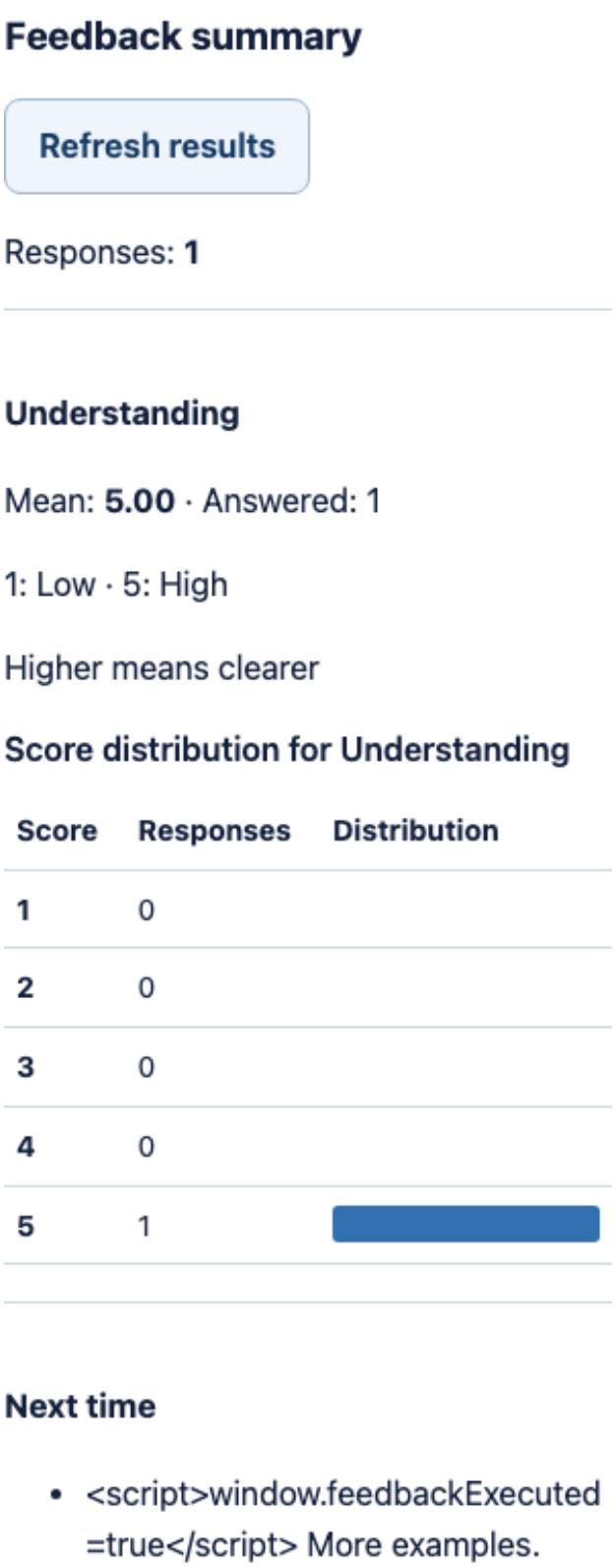
Score distribution for Understanding

Score	Responses	Distribution
1	0	
2	0	
3	0	
4	0	
5	1	

Next time

- <script>window.feedbackExecuted=true</script> More examples.

results-chromium-narrow.png



Review, integration and contribution status

Completed history: baseline PR #7, tracker #27, workflow #28, shared/F-01 #29, evidence plan #30, F-02 #31, F-03 #32, F-05 #33 and tooling/F-04 #34 merged. Actual approval is recorded on GitHub; no review is invented. PR #31 has the owner-accepted Good to go approval. Database PR #35 is approved but not merged at the captured audit.

Maibokdaimhai: project-owner-authorized AI-assisted candidate implementation/publication and actual review of database PR #35. R1NNE0: database PR #35 author and actual reviewer of PR #34. No hours, unsupported pairing history, individual comprehension or later acceptance is inferred. The team must confirm the final contribution account/name mapping and actual personal contribution description.

AI use: Codex assisted planning, implementation, test execution and this draft assembly. AI output is not teammate approval or proof that either student can explain the work. Both students remain responsible for understanding, reviewing and validating the submitted result.

Final release/report gate: retain an immutable accepted main SHA/tag; run required checks on it; update AC-to-actual-test dispositions and final board/review evidence; confirm contributions; regenerate and visually check the final PDF. This draft is intentionally not presented as completion of #25/#26 or a timely submission.